

Комплексна система захисту інформації

Профіль базових заходів із захисту інформації

Зміст

Зміст

1	АС	13
1.1	ПОЛІТИКА ТА ПРОЦЕДУРИ УПРАВЛІННЯ ДОСТУПОМ (АС-1)	13
1.2	УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ (АС-2)	14
1.2.1	АВТОМАТИЗОВАНЕ УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ СИСТЕМИ (АС-2(1))	15
1.2.2	ДЕАКТИВАЦІЯ ОБЛІКОВИХ ЗАПИСІВ (АС-2(3))	15
1.2.3	ДІЇ ПРИ АВТОМАТИЗОВАНОМУ АУДИТІ (АС-2(4))	16
1.2.4	ВИХІД ІЗ СИСТЕМИ ЗА ВІДСУТНОСТІ АКТИВНОСТІ (АС-2(5))	17
1.2.5	ДИНАМІЧНЕ УПРАВЛІННЯ ПРИВІЛЕЯМИ (АС-2(6))	17
1.2.6	СХЕМИ, ЗАСНОВАНІ НА РОЛЯХ (АС-2(7))	17
1.2.7	ДИНАМІЧНЕ УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ (АС-2(8))	18
1.2.8	ОБМЕЖЕННЯ НА ВИКОРИСТАННЯ СПІЛЬНИХ ТА ГРУПОВИХ ОБЛІКОВИХ ЗАПИСІВ (АС-2(9))	19
1.2.9	ЗМІНА ДАНИХ СПІЛЬНИХ І ГРУПОВИХ ОБЛІКОВИХ ЗАПИСІВ (АС-2(10))	19
1.2.10	УМОВИ ВИКОРИСТАННЯ (АС-2(11))	19
1.2.11	МОНІТОРИНГ НЕТИПОВОГО ВИКОРИСТАННЯ ОБЛІКОВИХ ЗАПИСІВ (АС-2(12))	20
1.2.12	ДЕАКТИВАЦІЯ ОБЛІКОВИХ ЗАПИСІВ ОСІБ З ВИСОКИМ РІВНЕМ РИЗИКУ (АС-2(13))	20
1.3	ЗАБЕЗПЕЧЕННЯ ДОСТУПУ (АС-3)	21
1.3.1	ОБМЕЖЕНИЙ ДОСТУП ДО ПРИВІЛЕЙОВАНИХ ФУНКЦІЙ (АС-3(1))	21
1.3.2	ПОДВІЙНА АВТОРИЗАЦІЯ (АС-3(2))	21
1.3.3	МАНДАТНЕ УПРАВЛІННЯ ДОСТУПОМ (АС-3(3))	21
1.3.4	ДИСКРЕЦІЙНЕ УПРАВЛІННЯ ДОСТУПОМ (АС-3(4))	23
1.3.5	ІНФОРМАЦІЯ ЩОДО БЕЗПЕКИ (АС-3(5))	24
1.3.6	ЗАХИСТ ІНФОРМАЦІЇ КОРИСТУВАЧА ТА СИСТЕМИ (АС-3(6))	25
1.3.7	УПРАВЛІННЯ ДОСТУПОМ НА ОСНОВІ РОЛЕЙ (АС-3(7))	25
1.3.8	АНУЛЮВАННЯ ПРАВ ДОСТУПУ (АС-3(8))	25
1.3.9	КЕРОВАНА ПЕРЕДАЧА (ПУБЛІКАЦІЯ) ІНФОРМАЦІЇ (АС-3(9))	26
1.3.10	ПЕРЕГЛЯД АУДИТОМ МЕХАНІЗМІВ КОНТРОЛЮ ДОСТУПУ (АС-3(10))	26
1.3.11	ОБМЕЖЕННЯ ДОСТУПУ ДО СПЕЦІАЛЬНОЇ ІНФОРМАЦІЇ (АС-3(11))	27
1.3.12	ВСТАНОВЛЕННЯ ТА ЗАБЕЗПЕЧЕННЯ ДОСТУПУ ДО ЗАСТОСУНКІВ (АС-3(12))	27
1.3.13	УПРАВЛІННЯ ДОСТУПОМ НА ОСНОВІ АТРИБУТІВ (АС-3(13))	28
1.3.14	ІНДИВІДУАЛЬНИЙ ДОСТУП (АС-3(14))	28
1.3.15	ДИСКРЕЦІЙНИЙ ТА ОБОВ'ЯЗКОВИЙ ДОСТУП (АС-3(15))	29
1.4	УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ (АС-4)	30
1.4.1	АТРИБУТИ БЕЗПЕКИ ОБ'ЄКТУ (АС-4(1))	30
1.4.2	ДОМЕНИ ОБРОБ- (АС-4(2))	32
1.4.3	УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ УПРАВЛІННЯ ІНФОРМАЦІЙНИМ ПОТОКОМ (АС-4(3))	32
1.4.4	УПРАВЛІННЯ ПОТОКОМ ЗАШИФРОВАНОЇ ІНФОРМАЦІЇ (АС-4(4))	32
1.4.5	ВБУДОВУВАННЯ ТИПІВ ДАНИХ (АС-4(5))	33
1.4.6	МЕТАДАНИ (АС-4(6))	33
1.4.7	МЕХАНІЗМИ ОДНОСТОРОННЬОГО ПОТОКУ (АС-4(7))	33
1.4.8	УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОЛІТИКИ БЕЗПЕКИ (АС-4(8))	34
1.4.9	ПЕРЕВІРКИ, ЩО ПРОВОДИТЬ ПЕРСОНАЛ (АС-4(9))	34
1.4.10	АКТИВАЦІЯ ТА ДЕАКТИВАЦІЯ ФІЛЬТРІВ ПОЛІТИКИ БЕЗПЕКИ (АС-4(10))	35
1.4.11	КОНФІГУРАЦІЯ ФІЛЬТРІВ ПОЛІТИКИ БЕЗПЕКИ (АС-4(11))	35
1.4.12	ІДЕНТИФІКАТОРИ ТИПУ ДАНИХ (АС-4(12))	36
1.4.13	ДЕКОМПОЗИЦІЯ НА ВІДПОВІДНІ ПОЛІТИЦІ СУБКОМПОНЕНТИ (АС-4(13))	36
1.4.14	ОБМЕЖЕННЯ ФІЛЬТРА ПОЛІТИКИ БЕЗПЕКИ (АС-4(14))	36

1.4.15	ВІЯВЛЕННЯ НЕСАНКЦІОНОВАНОЇ ІНФОРМАЦІЇ (АС-4(15))	37
1.4.16	ПЕРЕДАЧА ІНФОРМАЦІЇ ПРО ВЗАЄМОПОВ'ЯЗАНІ СИСТЕМИ (АС-4(16))	38
1.4.17	ПРИВ'ЯЗКА АТРИБУТУ БЕЗПЕКИ (АС-4(18))	38
1.4.18	ПЕРЕВІРКА МЕТАДАНИХ (АС-4(19))	38
1.4.19	ЗАТВЕРДЖЕНІ РІШЕННЯ (АС-4(20))	39
1.4.20	ФІЗИЧНЕ ТА ЛОГІЧНЕ ВІДДІЛЕННЯ ІНФОРМАЦІЙНИХ ПОТОКІВ (АС-4(21))	39
1.4.21	ЄДИНИЙ ДОСТУП (АС-4(22))	40
1.4.22	МОДИФІКОВАНА ІНФОРМАЦІЯ, ЯКА НЕ ПІДЛЯГАЄ ОПРИЛЮДНЕННЮ (АС-4(23))	40
1.4.23	УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ НОРМАЛІЗОВАНИЙ ФОРМАТ (АС-4(24))	40
1.4.24	ОЧИЩЕННЯ ДАНИХ (АС-4(25))	41
1.4.25	ДІЇ З ФІЛЬТРАЦІЇ АУДИТУ (АС-4(26))	41
1.4.26	УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ КОВІ/НЕЗАЛЕЖНІ ФІЛЬТРУЮЧІ МЕХАНІЗМИ (АС-4(27))	41
1.4.27	ЛІНІЙНІ ФІЛЬТРУВАЛЬНІ КАНАЛИ (АС-4(28))	42
1.4.28	УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ХАНІЗМІВ ОРКЕСТРОВКИ (АС-4(29))	42
1.4.29	МЕХАНІЗМИ ФІЛЬТРАЦІЇ З ВИКОРИСТАННЯМ КІЛЬКОХ ПРОЦЕСІВ (АС-4(30))	43
1.4.30	ЗАПОБІГАННЯ СПРОБАМ ПЕРЕДАЧІ ВМІСТУ, ЯКИЙ НЕ ПРОЙШОВ ПЕРЕВІРКУ ФІЛЬТРАЦІЇ (АС-4(31))	43
1.4.31	ВИМОГИ ДО ПРОЦЕСУ ПЕРЕДАЧІ ІНФОРМАЦІЇ (АС-4(32))	43
1.5	РОЗМЕЖУВАННЯ ОBOB'ЯЗКІВ (АС-5)	43
1.6	МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ (АС-6)	44
1.6.1	АВТОРИЗОВАНИЙ ДОСТУП ДО ФУНКЦІЙ БЕЗПЕКИ (АС-6(1))	44
1.6.2	НЕПРИВІЛЕЙОВАНИЙ ДОСТУП ДО НЕЗАХИЩЕНИХ ФУНКЦІЙ (АС-6(2))	45
1.6.3	РОЗДІЛЬНІ ДОМЕНИ ОБРОВКИ (АС-6(4))	45
1.6.4	ПРИВІЛЕЙОВАНІ ОБЛІКОВІ ЗАПИСИ (АС-6(5))	46
1.6.5	ПРИВІЛЕЙОВАНИЙ ДОСТУП КОРИСТУВАЧАМИ, ЩО НЕ НАЛЕЖАТЬ ДО ОРГАНІЗАЦІЇ (АС-6(6))	46
1.6.6	ПЕРЕГЛЯД ПОВНОВАЖЕНЬ КОРИСТУВАЧА (АС-6(7))	46
1.6.7	РІВНІ ПРИВІЛЕЇВ ДЛЯ ВИКОНАННЯ КОДУ (АС-6(8))	47
1.6.8	АУДИТ ВИКОРИСТАННЯ ПРИВІЛЕЙОВАНИХ ФУНКЦІЙ (АС-6(9))	47
1.6.9	ЗАБОРОНА НЕПРИВІЛЕЙОВАНИМ КОРИСТУВАЧАМ ВИКОНУВАТИ ПРИВІЛЕЙОВАНІ ФУНКЦІЇ (АС-6(10))	47
1.7	НЕВДАЛІ СПРОБИ ВХОДУ В СИСТЕМУ (АС-7)	47
1.7.1	АВТОМАТИЧНЕ БЛОКУВАННЯ ОБЛІКОВОГО ЗАПИСУ (АС-7(1))	49
1.7.2	ОЧИЩЕННЯ АБО СТИРАННЯ МОБІЛЬНОГО ПРИСТРОЮ (АС-7(2))	49
1.7.3	ОБМЕЖЕННЯ НА СПРОБИ БІОМЕТРИЧНОГО ВХОДУ (АС-7(3))	49
1.7.4	ВИКОРИСТАННЯ АЛЬТЕРНАТИВНОГО ФАКТОРА (АС-7(4))	50
1.8	ПОПЕРЕДЖЕННЯ ПРО ВИКОРИСТАННЯ СИСТЕМИ (АС-8)	50
1.9	БЛОКУВАННЯ ПРИСТРОЮ (АС-11)	51
1.9.1	ПРИХОВАНІ ДИСПЛЕЇ (АС-11(1))	52
1.10	Припинення сеансу (АС-12)	52
1.10.1	ІНІЦІЙОВАНЕ КОРИСТУВАЧЕМ БЛОКУВАННЯ (АС-12(1))	52
1.10.2	ПОВІДОМЛЕННЯ ПРО ПРИПИНЕННЯ СЕАНСУ (АС-12(2))	53
1.10.3	ЗАСТЕРЕЖНЕ ПОВІДОМЛЕННЯ ПРО ТЕ, ЩО ЧАС СЕСІЇ ДОБИГАЄ КІНЦЯ (АС-12(3))	53
1.11	ВІДДАЛЕНИЙ ДОСТУП (АС-17)	53
1.11.1	АВТОМАТИЗОВАНИЙ МОНІТОРИНГ ТА УПРАВЛІННЯ (АС-17(1))	54
1.11.2	ЗАХИСТ КОНФІДЕНЦІЙНОСТІ ТА ЦІЛІСНОСТІ ЗА ДОПОМОГОЮ ШИФРУВАННЯ (АС-17(2))	54
1.11.3	КЕРОВАНІ ТОЧКИ КОНТРОЛЮ ДОСТУПУ (АС-17(3))	54
1.11.4	ПРИВІЛЕЙОВАНІ КОМАНДИ ТА ДОСТУП (АС-17(4))	54
1.11.5	МОНІТОРИНГ ДЛЯ НЕАВТОРИЗОВАНИХ ПІДКЛЮЧЕНЬ (АС-17(5))	55
1.11.6	ЗАХИСТ ІНФОРМАЦІЇ (АС-17(6))	55
1.11.7	ДОДАТКОВИЙ ЗАХИСТ ДЛЯ ДОСТУПУ ДО ФУНКЦІЙ БЕЗПЕКИ (АС-17(7))	55
1.11.8	ДЕАКТИВАЦІЯ НЕЗАХИЩЕНИХ ПРОТОКОЛІВ МЕРЕЖІ (АС-17(8))	55
1.11.9	ВІДКЛЮЧЕННЯ АБО ДЕАКТИВАЦІЯ ДОСТУПУ (АС-17(9))	56
1.11.10	(10) АВТЕНТИФІКАЦІЯ ВІДДАЛЕНИХ КОМАНД (АС-17(10))	56

1.12	БЕЗДРОТОВИЙ ДОСТУП (АС-18)	56
1.12.1	АВТЕНТИФІКАЦІЯ ТА ШИФРУВАННЯ (АС-18(1))	57
1.12.2	БЕЗДРОТОВИЙ ПІДКЛЮЧЕНЬ (АС-18(2))	57
1.12.3	ВІДКЛЮЧЕННЯ БЕЗДРОТОВОЇ МЕРЕЖІ (АС-18(3))	57
1.12.4	БЕЗДРОТОВИЙ ДОСТУП СТУВАЧАМИ (АС-18(4))	57
1.12.5	АНТЕНИ ТА РІВЕНЬ ПОТУЖНОСТІ ПЕРЕДАЧІ (АС-18(5))	58
1.13	КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ (АС-19)	58
1.13.1	ВИКОРИСТАННЯ ПИСЬМОВИХ ТА ПОРТАТИВНИЙ ПРИСТРОЇВ ДЛЯ ЗБЕРІГАННЯ ДАНИХ (АС-19(1))	59
1.13.2	ВИКОРИСТАННЯ ПЕРСОНАЛЬНИХ ПОРТАТИВНИХ ПРИСТРОЇВ ЗБЕРІГАННЯ ДАНИХ (АС-19(2))	59
1.13.3	ВИКОРИСТАННЯ ПОРТАТИВНИХ ПРИСТРОЇВ ЗБЕРІГАННЯ ДАНИХ З НЕІДЕНТИФІКОВАНИМ ВЛАСНИКОМ (АС-19(3))	59
1.13.4	ОБМЕЖЕННЯ ДЛЯ ЗАСЕКРЕЧЕНОЇ ІНФОРМАЦІЇ (АС-19(4))	59
1.13.5	ПОВНЕ ШИФРУВАННЯ ПРИСТРОЇВ ТА СХОВИЩ ІНФОРМАЦІЇ (АС-19(5))	60
1.14	ВИКОРИСТАННЯ ЗОВНІШНІХ СИСТЕМ (АС-20)	60
1.14.1	ОБМЕЖЕННЯ НА АВТОРИЗОВАНЕ ВИКОРИСТАННЯ (АС-20(1))	61
1.14.2	ПЕРЕНОСНІ ПРИСТРОЇ ЗБЕРІГАННЯ ДАНИХ (АС-20(2))	61
1.14.3	СИСТЕМИ ТА КОМПОНЕНТИ, ЩО НЕ ЗНАХОДЯТЬСЯ У ВЛАСНОСТІ ОРГАНІЗАЦІЇ (АС-20(3))	62
1.14.4	ПРИСТРОЇ ДЛЯ ЗБЕРІГАННЯ ДАНИХ, ЯКІ МОЖУТЬ МАТИ ДОСТУП ДО МЕРЕЖІ (АС-20(4))	62
1.14.5	ПОРТАТИВНІ ПРИСТРОЇ ДЛЯ ЗБЕРІГАННЯ ДАНИХ – ЗАБОРОНА ВИКОРИСТАННЯ (АС-20(5))	62
1.15	ПУБЛІЧНО ДОСТУПНИЙ КОНТЕНТ (АС-22)	62
2	АТ	63
2.1	ПОЛІТИКА ТА ПРОЦЕДУРИ ПІДВИЩЕННЯ ОБІЗНАНОСТІ ТА НАВЧАННЯ (АТ-1)	63
2.2	НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ (АТ-2)	64
2.2.1	НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ НАВЧАННЯ ЩОДО РОЗПІЗНАВАННЯ ВНУТРІШНЬОЇ ЗАГРОЗИ	66
2.2.2	НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ НАВЧАННЯ З ПИТАНЬ СОЦІАЛЬНОЇ ІНЖЕНЕРІЇ	66
2.3	РОЛЬОВЕ НАВЧАННЯ (АТ-3)	67
2.3.1	ЗАБЕЗПЕЧУЄТЬСЯ ПІДВИЩЕННЯМ КВАЛІФІКАЦІЇ В ГАЛУЗІ ЗАЙНЯТОСТІ ТА ФУНКЦІОНУВАННЯ ЗАХОДІВ ЗАХИСТУ РОБОЧОГО СЕРЕДОВИЩА З (АТ-3(1))	68
2.3.2	ЗАБЕЗПЕЧУЮТЬСЯ ПІДГОТОВКОЮ З ПИТАНЬ ЗАСТОСУВАННЯ ТА ЕКСПЛУАТАЦІЇ ЗАХОДІВ (АТ-3(2))	68
3	AU	69
3.1	Політика та процедури аудиту та підзвітності (AU-1)	69
3.2	ПОДІЇ АУДИТУ (AU-2)	71
3.2.1	УЗАГАЛЬНЕННЯ ЗАПИСІВ ПРО АУДИТ З ДЕКІЛЬКОХ ДЖЕРЕЛ (AU-2(1))	72
3.2.2	ВИБІР ПОДІЇ АУДИТУ ЗА КОМПОНЕНТАМИ (AU-2(2))	72
3.2.3	ПЕРЕГЛЯД ТА ОНОВЛЕННЯ (AU-2(3))	72
3.2.4	ПРИВІЛЕЙОВАНІ ФУНКЦІЇ (AU-2(4))	73
3.3	ЗМІСТ ЗАПИСІВ АУДИТУ (AU-3)	73
3.3.1	ДОДАТКОВА ІНФОРМАЦІЯ ПРО АУДИТ (AU-3(1))	74
3.3.2	ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ ПЛАНОВАНИМ ЗМІСТОМ ЗАПИСІВ АУДИТУ (AU-3(2))	74
3.3.3	ОБМЕЖЕННЯ ЕЛЕМЕНТІВ ПЕРСОНАЛЬНИХ ДАНИХ (AU-3(3))	74
3.4	РЕАГУВАННЯ НА ВІДМОВИ ОБРОБКИ ДАНИХ АУДИТУ (AU-5)	74
3.4.1	МІСТКІСТЬ СХОВИЩА ЗАПИСІВ АУДИТУ (AU-5(1))	75
3.4.2	ТРИВОЖНЕ СПОВІЩЕННЯ В РЕАЛЬНОМУ ЧАСІ (AU-5(2))	76
3.4.3	НАЛАШТУВАННЯ ПОРОГОВОГО ОБСЯГУ ТРАФІКУ (AU-5(3))	76
3.4.4	ВИМКНЕННЯ У РАЗІ ВІДМОВИ (AU-5(4))	77

3.4.5	МОЖЛИВІСТЬ АЛЬТЕРНАТИВНОГО ЖУРНАЛЮВАННЯ АУДИТУ (AU-5(5))	77
3.5	ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ (AU-6)	77
3.5.1	АВТОМАТИЗОВАНА ІНТЕГРАЦІЯ ПРОЦЕСІВ (AU-6(1))	78
3.5.2	ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ СПОВЩЕННЯ ПРО ПОРУШЕННЯ БЕЗПЕКУ (AU-6(2))	78
3.5.3	ЗІСТАВЛЯННЯ СХОВИЩ АУДИТУ (AU-6(3))	79
3.5.4	ЦЕНТРАЛІЗОВАНИЙ ПЕРЕГЛЯД ТА АНАЛІЗ (AU-6(4))	79
3.5.5	ІНТЕГРОВАНІЙ АНАЛІЗ ЗАПИСІВ АУДИТУ (AU-6(5))	79
3.5.6	КОРЕЛЯЦІЯ З ФІЗИЧНИМ МОНІТОРИНГОМ (AU-6(6))	79
3.5.7	ДОЗВОЛЕНІ ДІЇ (AU-6(7))	80
3.5.8	АНАЛІЗ ПОВНОГО ТЕКСТУ ПРИВІЛЕЙОВАНИХ КОМАНД (AU-6(8))	80
3.5.9	РЕГУЛЮВАННЯ РІВНЯ АУДИТУ (AU-6(10))	80
3.6	СКОРОЧЕННЯ ЗАПИСІВ АУДИТУ ТА ФОРМУВАННЯ ЗВІТУ (AU-7)	80
3.6.1	АВТОМАТИЧНА ОБРОБКА (AU-7(1))	81
3.6.2	АВТОМАТИЧНЕ СОРТУВАННЯ ТА ПОШУК (AU-7(2))	81
3.7	ПОЗНАЧКА ЧАСУ (AU-8)	82
3.7.1	СИНХРОНІЗАЦІЯ З АВТОРИТЕТНИМ ДЖЕРЕЛОМ ЧАСУ (AU-8(1))	82
3.7.2	ВТОРИННЕ АВТОРИТЕТНЕ ДЖЕРЕЛО ЧАСУ (AU-8(2))	82
3.8	ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ (AU-9)	82
3.8.1	АПАРАТНІ НОСІЇ ІНФОРМАЦІЇ ОДНОРАЗОВОГО ЗАПИСУ (AU-9(1))	83
3.8.2	ЗБЕРІГАННЯ НА ОКРЕМИХ ФІЗИЧНИХ СИСТЕМАХ АБО КОМПОНЕНТАХ (AU-9(2))	83
3.8.3	КРИПТОГРАФІЧНИЙ ЗАХИСТ (AU-9(3))	84
3.8.4	ДОСТУП, ЯКИЙ НАДАЄТЬСЯ ЧЕРЕЗ ЧЛЕНСТВО В ПІДМНОЖИНИ ПРИВІЛЕЙОВАНИХ КОРИСТУВАЧІВ (AU-9(4))	84
3.8.5	ПОДВІЙНА АВТОРИЗАЦІЯ (AU-9(5))	84
3.8.6	ДОСТУП ТІЛЬКИ ДЛЯ ЧИТАННЯ (AU-9(6))	85
3.8.7	ЗБЕРІГАННЯ НА КОМПОНЕНТІ ІНШОЇ ОПЕРАЦІЙНОЇ СИСТЕМИ (AU-9(7))	85
3.9	ЗБЕРЕЖЕННЯ ЗАПИСІВ АУДИТУ (AU-11)	85
3.9.1	ДОВГОСТРОКОВА МОЖЛИВІСТЬ ОТРИМАННЯ (AU-11(1))	86
3.10	ГЕНЕРАЦІЯ ДАНИХ АУДИТУ (AU-12)	86
3.10.1	ЗАГАЛЬНОСИСТЕМНИЙ ТА СИНХРОНІЗОВАНИЙ ЗА ЧАСОМ ЖУРНАЛУ АУДИТУ (AU-12(1))	87
3.10.2	СТАНДАРТИЗОВАНІ ФОРМАТИ (AU-12(2))	87
3.10.3	ЗМІНИ, ЩО ВНОСЯТЬ АВТОРИЗОВАНІ ОСОБИ (AU-12(3))	87
3.10.4	АУДИТ ЗАПИТІВ ПЕРСОНАЛЬНИХ ДАНИХ (AU-12(4))	88
4	СА	88
4.1	ПОЛІТИКА І ПРОЦЕДУРИ ОЦІНЮВАННЯ, АКРЕДИТАЦІЯ ТА МОНІТОРИНГ БЕЗПЕКИ (СА-1)	89
4.2	ОЦІНЮВАННЯ (СА-2)	90
4.2.1	НЕЗАЛЕЖНІ ЕКСПЕРТИ (СА-2(1))	92
4.2.2	ВКЛЮЧАЮТЬСЯ ЯК ЧАСТИНА ОЦІНЮВАННЯ ЗАХОДІВ БЕЗПЕКИ ТА КОНФІДЕНЦІЙНОСТІ; (СА-2(2))	92
4.2.3	ЗОВНІШНІ ОРГАНІЗАЦІЇ (СА-2(3))	93
4.3	ВЗАЄМОДІЯ СИСТЕМ (СА-3)	93
4.3.1	ВЗАЄМОДІЯ СИСТЕМ- НЕЗАХИЩЕНІ З'ЄДНАННЯ СИСТЕМИ (СА-3(1))	94
4.3.2	ЗАХИЩЕНІ З'ЄДНАННЯ СИСТЕМИ (СА-3(2))	95
4.3.3	НЕСЕКРЕТНІ З'ЄДНАННЯ СИСТЕМИ БЕЗПЕКИ, ЩО НЕ Є НАЦІОНАЛЬНИМИ (СА-3(3))	95
4.3.4	ПІДКЛЮЧЕННЯ ДО ЗАГАЛЬНОДОСТУПНИХ МЕРЕЖ (СА-3(4))	95
4.3.5	ОБМЕЖЕННЯ ЗВ'ЯЗКУ ІЗ ЗОВНІШНІМИ СИСТЕМАМИ (СА-3(5))	95
4.3.6	ПЕРЕДАЧА ДОЗВОЛІВ (СА-3(6))	95
4.3.7	ТРАНЗИТИВНИЙ ОБМІН ІНФОРМАЦІЄЮ (СА-3(7))	96
4.4	ПЛАН УСУНЕННЯ НЕДОЛІКІВ ТА КОНТРОЛЬНІ ПОКАЗНИКИ (СА-5)	96
4.4.1	АВТОМАТИЗАЦІЯ ПІДТРИМКИ ЗАДЛЯ ТОЧНОСТІ ТА ВЖИВАНOSTІ (СА-5(1))	96
4.5	БЕЗПЕРЕРВНИЙ МОНІТОРИНГ (СА-7)	97
4.5.1	НЕЗАЛЕЖНЕ ОЦІНЮВАННЯ (СА-7(1))	99

4.5.2	ВИДИ ОЦІНОК (СА-7(2))	99
4.5.3	АНАЛІЗ ТЕНДЕНЦІЇ (СА-7(3))	99
4.5.4	МОНІТОРИНГ РИЗИКУ (СА-7(4))	100
4.5.5	УЗГОДЖЕНИЙ АНАЛІЗ (СА-7(5))	100
4.5.6	БЕЗПЕРЕРВНИЙ МОНІТОРИНГУ (СА-7(6))	101
5	СМ	101
5.1	Політика та процедури управління конфігурацією (СМ-1)	101
5.2	БАЗОВА КОНФІГУРАЦІЯ (СМ-2)	103
5.2.1	ПЕРЕГЛЯД ТА ОНОВЛЕННЯ (СМ-2(1))	104
5.2.2	АВТОМАТИЗАЦІЯ ПІДТРИМКИ ЗАДЛЯ ТОЧНОСТІ ТА ВЖИВАНOSTІ (СМ-2(2))	104
5.2.3	ЗБЕРІГАННЯ ПОПЕРЕДНІХ ВЕРСІЙ КОНФІГУРАЦІЙ (СМ-2(3))	105
5.2.4	НЕАВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ (СМ-2(4))	105
5.2.5	АВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ (СМ-2(5))	105
5.2.6	РОЗРОБКА ТА СЕРЕДОВИЩЕ ТЕСТУВАННЯ (СМ-2(6))	106
5.2.7	КОНФІГУРАЦІЯ СИСТЕМ ТА КОМПОНЕНТІВ ДЛЯ СФЕР З ВИСОКИМ РИЗИКОМ (СМ-2(7))	106
5.3	УПРАВЛІННЯ ЗМІНАМИ КОНФІГУРАЦІЇ (СМ-3)	106
5.3.1	АВТОМАТИЗОВАНЕ ДОКУМЕНТУВАННЯ, ПОВІДОМЛЕННЯ ТА ЗАБОРОНА ВНЕСЕННЯ ЗМІН (СМ-3(1))	108
5.3.2	ТЕСТУВАННЯ, ВАЛІДАЦІЯ ТА ДОКУМЕНТУВАННЯ ЗМІН (СМ-3(2))	109
5.3.3	АВТОМАТИЗОВАНА РЕАЛІЗАЦІЯ ЗМІН (СМ-3(3))	110
5.3.4	ПРЕДСТАВНИК БЕЗПЕКИ (СМ-3(4))	110
5.3.5	АВТОМАТИЧНЕ РЕАГУВАННЯ БЕЗПЕКИ (СМ-3(5))	111
5.3.6	УПРАВЛІННЯ ЗАСОБАМИ КРИПТОГРАФІЧНОГО ЗАХИСТУ (СМ-3(6))	111
5.3.7	ПЕРЕГЛЯД ЗМІН У СИСТЕМІ (СМ-3(7))	112
5.3.8	ЗАПОБІГАННЯ ЧИ ОБМЕЖЕННЯ ЗМІН КОНФІГУРАЦІЇ (СМ-3(8))	112
5.4	АНАЛІЗ ВПЛИВУ НА БЕЗПЕКУ ТА ПРИВАТНІСТЬ (СМ-4)	113
5.4.1	ВІДОКРЕМЛЕНІ ВИПРОБУВАЛЬНІ СЕРЕДОВИЩА (СМ-4(1))	113
5.4.2	ВЕРИФІКАЦІЯ ФУНКЦІЙ БЕЗПЕКИ ТА ПРИВАТНОСТІ (СМ-4(2))	114
5.5	ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ (СМ-5)	115
5.5.1	АУДИТ І ЗДІЙСНЕННЯ АВТОМАТИЧНОГО ДОСТУПУ (СМ-5(1))	116
5.5.2	ПЕРЕГЛЯД ЗМІН У СИСТЕМІ (СМ-5(2))	116
5.5.3	ПІДПИСАНІ КОМПОНЕНТИ (СМ-5(3))	116
5.5.4	ПОДВІЙНА АВТОРИЗАЦІЯ (СМ-5(4))	116
5.5.5	ОБМЕЖЕННЯ ПОВНОВАЖЕНЬ ДЛЯ ВИРОБНИЦТВА ТА ЕКСПЛУАТАЦІЇ (СМ-5(5))	117
5.5.6	ОБМЕЖЕННЯ ПОВНОВАЖЕНЬ ДЛЯ БІБЛІОТЕК (СМ-5(6))	118
5.5.7	ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ ВАДЖЕННЯ ЗАХОДІВ ЗАХИСТУ (СМ-5(7))	118
5.6	НАЛАШТУВАННЯ КОНФІГУРАЦІЇ (СМ-6)	118
5.6.1	АВТОМАТИЗОВАНЕ УПРАВЛІННЯ, ЗАСТОСУВАННЯ ТА ВЕРИФІКАЦІЯ (СМ-6(1))	119
5.6.2	НАЛАШТУВАННЯ КОНФІГУРАЦІЇ САНКЦІОНОВАНІ ЗМІНИ (СМ-6(2))	120
5.6.3	ДЕМОНСТРАЦІЯ ВІДПОВІДНОСТІ (СМ-6(4))	120
5.7	МІНІМАЛЬНО НЕОБХІДНА ФУНКЦІОНАЛЬНІСТЬ (СМ-7)	121
5.7.1	ПЕРІОДИЧНИЙ ПЕРЕГЛЯД (СМ-7(1))	122
5.7.2	ЗАБОРОНА ВИКОНАННЯ ПРОГРАМИ (СМ-7(2))	123
5.7.3	ВІДПОВІДНІСТЬ РЕЄСТРАЦІЇ (СМ-7(3))	123
5.7.4	НЕАВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ - ЧОРНИЙ СПИСОК (СМ-7(4))	124
5.7.5	АВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ – БІЛИЙ СПИСОК (СМ-7(5))	125
5.7.6	ЗАМКНУТІ СЕРЕДОВИЩА З ОБМЕЖЕНИМИ ПРИВІЛЕЯМИ (СМ-7(6))	125
5.7.7	ВИКОНУВАНИЙ КОД У ЗАХИЩЕНОМУ СЕРЕДОВИЩІ (СМ-7(7))	126
5.7.8	БІНАРНИЙ АБО МАШИНИЙ ВИКОНУВАНИЙ КОД (СМ-7(8))	126
5.7.9	ЗАБОРОНА ВИКОРИСТАННЯ НЕАВТОРИЗОВАНОГО ОБЛАДНАННЯ (СМ-7(9))	127
5.8	ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ (СМ-8)	128
5.8.1	ОНОВЛЕННЯ ПІД ЧАС ВСТАНОВЛЕННЯ ТА ВИДАЛЕННЯ (СМ-8(1))	129
5.8.2	АВТОМАТИЗОВАНА ПІДТРИМКА (СМ-8(2))	129
5.8.3	АВТОМАТИЗОВАНЕ ВИЯВЛЕННЯ НЕАВТОРИЗОВАНИХ КОМПОНЕНТІВ (СМ-8(3))	130

5.8.4	ІНФОРМАЦІЯ ПРО ПІДЗВІТНІСТЬ (СМ-8(4))	131
5.8.5	ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ ДУБЛЮВАННЯ КОМПОНЕНТІВ ОБЛІКУ (СМ-8(5))	131
5.8.6	ПЕРЕВІРЕНІ НАЛАШТУВАННЯ ТА ЗАТВЕРДЖЕНІ ВІДХИЛЕННЯ (СМ-8(6))	132
5.8.7	ЦЕНТРАЛІЗОВАНЕ СХОВИЩЕ (СМ-8(7))	132
5.8.8	АВТОМАТИЗОВАНЕ ВІДСТЕЖЕННЯ МІСЦЯ РОЗТАШУВАННЯ (СМ-8(8))	132
5.8.9	ПРИЗНАЧЕННЯ КОМПОНЕНТІВ СИСТЕМАМ (СМ-8(9))	132
5.9	РОЗТАШУВАННЯ ІНФОРМАЦІЇ (СМ-12)	133
5.9.1	АВТОМАТИЗОВАНІ ІНСТРУМЕНТИ ПІДТРИМКИ РОЗТАШУВАННЯ ІНФОРМАЦІЇ (СМ-12(1))	134
6	СР	134
6.1	РЕЗЕРВНЕ КОПЮВАННЯ (СР-9)	134
6.1.1	ВИПРОБУВАННЯ НА НАДІЙНІСТЬ ТА ЦІЛІСНІСТЬ (СР-9(1))	135
6.1.2	ТЕСТУВАННЯ ВІДНОВЛЕННЯ З ВИКОРИСТАННЯМ ЗРАЗКІВ (СР-9(2))	136
6.1.3	ВІДОКРЕМЛЕНЕ СХОВИЩЕ КРИТИЧНОЇ ІНФОРМАЦІЇ (СР-9(3))	136
6.1.4	ПЕРЕДАЧА НА АЛЬТЕРНАТИВНЕ СХОВИЩЕ ЗБЕРІГАННЯ (СР-9(5))	137
6.1.5	НАДЛИШКОВА ВТОРИННА СИСТЕМА (СР-9(6))	137
6.1.6	ПОДВІЙНА АВТОРИЗАЦІЯ (СР-9(7))	137
6.1.7	КРИПТОГРАФІЧНИЙ ЗАХИСТ (СР-9(8))	138
7	ІА	138
7.1	Політика та процедури ідентифікації та автентифікації (ІА-1)	138
7.2	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ КОРИСТУВАЧІВ (ІА-2)	140
7.2.1	БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ ПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (ІА-2(1))	140
7.2.2	БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ НЕПРИВІЛЕЙОВАНИХ (ІА-2(2))	140
7.2.3	ЛОКАЛЬНИЙ ДОСТУП ДО ПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (ІА-2(3))	140
7.2.4	ЛОКАЛЬНИЙ ДОСТУП ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (ІА-2(4))	141
7.2.5	ІНДИВІДУАЛЬНА АВТЕНТИФІКАЦІЯ З ГРУПОВОЮ АВТЕНТИФІКАЦІЄЮ (ІА-2(5))	141
7.2.6	МЕРЕЖЕВИЙ ДОСТУП ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ – ОКРЕМИЙ ПРИСТРІЙ (ІА-2(7))	141
7.2.7	Доступ до облікових записів — стійкість до відтворення (ІА-2(8))	141
7.2.8	ДОСТУП ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ – СТІЙКІСТЬ ДО ВІДТВОРЕННЯ (ІА-2(9))	141
7.2.9	ЄДИНА ТОЧКА ВХОДУ (ІА-2(10))	142
7.2.10	ВІДДАЛЕНИЙ ДОСТУП - ОКРЕМИЙ ПРИСТРІЙ (ІА-2(11))	142
7.2.11	ПРИЙНЯТТЯ ПОВНОВАЖЕНЬ ДЛЯ ВЕРИФІКАЦІЇ ОСОБИСТОЇ ІНФОРМАЦІЇ (PIV CREDENTIALS) (ІА-2(12))	142
7.2.12	АВТЕНТИФІКАЦІЯ ПО ЗОВНІШНЬОМУ КАНАЛУ (ІА-2(13))	142
7.3	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ ПРИСТРОЇВ (ІА-3)	143
7.3.1	КРИПТОГРАФІЧНА ДВОБІЧНА АВТЕНТИФІКАЦІЯ (ІА-3(1))	143
7.3.2	КРИПТОГРАФІЧНИЙ ДВОБІЧНА МЕРЕЖА АВТЕНТИФІКАЦІЯ [Виключено: включено до ІА-03(01)]. (ІА-3(2))	143
7.3.3	ДИНАМІЧНИЙ РОЗПОДІЛ АДРЕСИ (ІА-3(3))	143
7.3.4	ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ ПРИСТРОЮ ВИКОНУЄТЬСЯ НА ОСНОВІ АТЕСТАЦІЇ ЗА ДОПОМОГОЮ (ІА-3(4))	144
7.4	УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ (ІА-4)	144
7.4.1	ЗАБОРОНА ВИКОРИСТАННЯ ІДЕНТИФІКАТОРІВ ОБЛІКОВИХ ЗАПИСІВ ТАКИ САМИХ, ЯК Й ПУБЛІЧНІ ІДЕНТИФІКАТОРИ (ІА-4(1))	145
7.4.2	АВТОРИЗАЦІЯ СУПЕРВАЙЗЕРА [Виключено: Включено до ІА-12(01)]. (ІА-4(2))	145
7.4.3	МНОЖИННІ ФОРМИ СЕРТИФІКАЦІЇ (ІА-4(3))	146
7.4.4	ІДЕНТИФІКАЦІЯ СТАТУСУ КОРИСТУВАЧА (ІА-4(4))	146
7.4.5	ДИНАМІЧНЕ УПРАВЛІННЯ (ІА-4(5))	146
7.4.6	КРОС-ОРГАНІЗАЦІЙНЕ УПРАВЛІННЯ (ІА-4(6))	146
7.4.7	ОСОБИСТА РЕЄСТРАЦІЯ [Виключено: Включено до ІА-12(04)]. (ІА-4(7))	147

7.4.8	ПОПАРНІ ПСЕВДОНІМНІ ІДЕНТИФІКАТОРИ (IA-4(8))	147
7.4.9	ПОПАРНІ ПСЕВДОНІМНІ ІДЕНТИФІКАТОРИ (IA-4(9))	147
7.5	АВТЕНТИФІКАТОР УПРАВЛІННЯ	147
7.5.1	АВТЕНТИФІКАЦІЯ НА ОСНОВІ ПАРОЛЯ (IA-5(1))	148
7.5.2	АВТЕНТИФІКАЦІЯ НА ОСНОВІ ВІДКРИТОГО КЛЮЧА (IA-5(2))	150
7.5.3	ОСОБИСТА АБО ДОВІРЧА АВТЕНТИФІКАЦІЯ ЗОВНІШНЬОЇ СТОРОНИ [Виключено: Включено до IA-12(04)]. (IA-5(3))	150
7.5.4	АВТОМАТИЗОВАНА ПІДТРИМКА ДЛЯ ВИЗНАЧЕННЯ МІЦНОСТІ ПАРОЛЯ [Виключено: Включено до IA-05(01)]. (IA-5(4))	150
7.5.5	ЗМІНА АВТЕНТИФІКАТОРІВ ДО ДОСТАВКИ (IA-5(5))	150
7.5.6	ЗАХИСТ АВТЕНТИФІКАТОРІВ (IA-5(6))	150
7.5.7	ВІДСУТНІСТЬ ВБУДОВАНИХ НЕЗАШИФРОВАНІХ СТАТИЧНИХ АВТЕНТИФІКАТОРІВ (IA-5(7))	151
7.5.8	БАГАТОСИСТЕМНІ ОБЛІКОВІ ЗАПИСИ (IA-5(8))	151
7.5.9	УПРАВЛІННЯ ОБ'ЄДНАННЯМ АВТЕНТИФІКАТОРІВ (IA-5(9))	151
7.5.10	ДИНАМІЧНЕ ЗВ'ЯЗУВАННЯ МАНДАТІВ (IA-5(10))	151
7.5.11	АВТЕНТИФІКАЦІЯ НА ОСНОВІ АПАРАТНИХ ТОКЕНІВ (IA-5(11))	152
7.5.12	ЕФЕКТИВНІСТЬ БІОМЕТРИЧНОЇ АВТЕНТИФІКАЦІЇ (IA-5(12))	152
7.5.13	ЗАКІНЧЕННЯ ТЕРМІНУ ШУВАННЯ АВТЕНТИФІКАТОРІВ (IA-5(13))	152
7.5.14	УПРАВЛІННЯ ЗМІСТОМ ДОВІРЧИХ СХОВИЩ ІНФРАСТРУКТУРИ ВІДКРИТИХ КЛЮЧІВ (IA-5(14))	152
7.5.15	ПРОДУКТИ ТА ПОСЛУГИ, ЗАТВЕРДЖЕНІ УПОВНОВАЖЕНИМ ОРГАНОМ (IA-5(15))	153
7.5.16	ПЕРЕДАЧА ОСОБИСТОЇ АБО ДОВІРЧОЇ АВТЕНТИФІКАЦІЇ ЗОВНІШНЬОЇ СТОРОНИ (IA-5(16))	153
7.5.17	АВТОМАТИЗОВАНІ ЗАСОБИ ВИЯВЛЕННЯ АТАК ІЗ ВИКОРИСТАННЯМ БІОМЕТРИЧНИХ АВТЕНТИФІКАТОРІВ (IA-5(17))	153
7.5.18	МЕНЕДЖЕР ПАРОЛІВ (IA-5(18))	154
7.6	ПРИХОВУВАННЯ ЗВОРОТНОГО ЗВ'ЯЗКУ АВТЕНТИФІКАТОРА	154
7.7	ПОВТОРНА АВТЕНТИФІКАЦІЯ (IA-11)	154
8	IR	155
8.1	Політика та процедури реагування на інциденти (IR-1)	155
8.2	НАВЧАННЯ З РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-2)	156
8.2.1	МОДЕЛЮВАННЯ ПОДІЙ (IR-2(1))	157
8.2.2	ЗЛАМ (IR-2(3))	157
8.3	ПЕРЕВІРКА РЕАГУВАНЬ НА ІНЦИДЕНТИ (IR-3)	158
8.3.1	КООРДИНАЦІЯ З ПОВ'ЯЗАНИМИ ПЛАНАМИ (IR-3(2))	158
8.3.2	ПОСТІЙНЕ ПОКРАЩЕННЯ (IR-3(3))	158
8.4	Обробка інциденту (IR-4)	159
8.4.1	ДИНАМІЧНА РЕКОНФІГУРАЦІЯ (IR-4(2))	161
8.4.2	БЕЗПЕРЕРВНІСТЬ ОПЕРАЦІЙ (IR-4(3))	161
8.4.3	ІНФОРМАЦІЙНА КОРЕЛЯЦІЯ (IR-4(4))	162
8.4.4	ВНУТРІШНІ ЗАГРОЗИ - ОСОБЛИВІ МОЖЛИВОСТІ (IR-4(6))	162
8.4.5	КООРДИНАЦІЯ З ЗОВНІШНІМИ ОРГАНІЗАЦІЯМИ (IR-4(8))	162
8.4.6	ЗДАТНІСТЬ ДИНАМІЧНОГО РЕАГУВАННЯ (IR-4(9))	163
8.4.7	КООРДИНАЦІЯ ЛАНЦЮГА ПОСТАЧАННЯ (IR-4(10))	163
8.4.8	ІНТЕГРОВАНА ГРУПА РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-4(11))	163
8.4.9	ЗЛОВМИСНИЙ КОД ТА КРИМІНАЛІСТИЧНИЙ АНАЛІЗ (IR-4(12))	163
8.4.10	АНАЛІЗ ПОВЕДІНКИ (IR-4(13))	164
8.4.11	ЦЕНТР БЕЗПЕКИ (IR-4(14))	164
8.4.12	ЗВ'ЯЗКИ З ГРОМАДКІСТЮ ТА ВІДНОВЛЕННЯ РЕПУТАЦІЇ (IR-4(15))	164
8.5	Моніторинг інциденту (IR-5)	164
8.5.1	АВТОМАТИЗОВАНЕ ВІДСТЕЖЕННЯ, ЗБІР ДАНИХ І АНАЛІЗ (IR-5(1))	165
8.6	ЗВІТНІСТЬ ПРО ІНЦИДЕНТИ (IR-6)	165
8.6.1	АВТОМАТИЧНЕ ЗВІТУВАННЯ (IR-6(1))	166
8.6.2	КООРДИНАЦІЯ ЛАНЦЮЖКА ПОСТАЧАННЯ (IR-6(3))	166

8.7	ПІДТРИМКА РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-7)	166
8.7.1	АВТОМАТИЗАЦІЯ ПІДТРИМКИ ДЛЯ ЗАБЕЗПЕЧЕННЯ ДОСТУПНОСТІ ІНФОРМАЦІЇ ТА ПІДТРИМКИ (IR-7(1))	167
8.7.2	КООРДИНАЦІЯ З ЗОВНІШНІМИ ПОСТАЧАЛЬНИКАМИ (IR-7(2))	167
8.8	План реагування на інциденти (IR-8)	167
8.8.1	ОБРОБКА ПЕРСОНАЛЬНИХ ДАНИХ (IR-8(1))	170
9	МА	171
9.1	ПОЛІТИКА ТА ПРОЦЕДУРИ ТЕХНІЧНОГО ОБСЛУГОВУВАННЯ (МА-1)	171
9.2	ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ (МА-3)	172
9.2.1	ПЕРЕВІРКА ІНСТРУМЕНТІВ (МА-3(1))	173
9.2.2	ПЕРЕВІРКА НОСІВ ІНФОРМАЦІЇ (МА-3(2))	173
9.2.3	ЗАПОБІГАННЯ НЕСАНКЦІОНОВАНОМУ ПЕРЕМІЩЕННЮ (МА-3(3))	174
9.2.4	ОБМЕЖЕННЯ ВИКОРИСТАННЯ ІНСТРУМЕНТА (МА-3(4))	174
9.2.5	ПРИВІЛЕЙОВАНЕ ВИКОНАННЯ (МА-3(5))	175
9.2.6	ОНОВЛЕННЯ ПРОГРАМ- (МА-3(6))	175
9.3	ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ (МА-4)	175
9.3.1	АУДИТ ТА ОГЛЯД (МА-4(1))	176
9.3.2	ДОКУМЕНТУВАННЯ ВІДДАЛЕНОГО ОБСЛУГОВУВАННЯ (МА-4(2))	177
9.3.3	ПОРІВНЯЛЬНА БЕЗПЕКА І ОЧИЩЕННЯ (МА-4(3))	177
9.3.4	СХВАЛЕННЯ ТА ПОВІДОМЛЕННЯ (МА-4(5))	178
9.3.5	ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ РОЗ'ЄДНАННЯ (МА-4(7))	178
9.4	ТЕХНІЧНИЙ ПЕРСОНАЛ (МА-5)	178
9.4.1	ОСОБИ БЕЗ НАЛЕЖНОГО ДОСТУПУ (МА-5(1))	179
9.4.2	ОФОРМЛЕННЯ ДОПУСКУ ДЛЯ СИСТЕМ, ЩО ОБРОБЛЯЮТЬ ІНФОРМАЦІЮ З ОБМЕЖЕНИМ ДОСТУПОМ (МА-5(2))	180
9.4.3	ВИМОГИ ДО ГРОМАДЯНСТВА (МА-5(3))	180
9.4.4	ІНОЗЕМНІ ГРОМАДЯНИ (МА-5(4))	180
9.4.5	НЕСИСТЕМНЕ ОБСЛУГОВУВАННЯ (МА-5(5))	181
10	МР	181
10.1	ПОЛІТИКА ТА ПРОЦЕДУРИ ЩОДО ЗАХИСТУ НОСІВ ІНФОРМАЦІЇ (МР-1)	182
10.2	ДОСТУП ДО НОСІВ ІНФОРМАЦІЇ (МР-2)	183
10.2.1	АВТОМАТИЗОВАНИЙ ОБМЕЖЕНИЙ ДОСТУП (МР-2(1))	184
10.2.2	КРИПТОГРАФІЧНИЙ ЗАХИСТ (МР-2(2))	184
10.3	МАРКУВАННЯ НОСІВ ІНФОРМАЦІЇ (МР-3)	184
10.4	ЗБЕРІГАННЯ НОСІВ ІНФОРМАЦІЇ (МР-4)	185
10.4.1	КРИПТОГРАФІЧНИЙ ЗАХИСТ (МР-4(1))	186
10.4.2	АВТОМАТИЗОВАНИЙ ОБМЕЖЕНИЙ ДОСТУП (МР-4(2))	187
10.5	Транспортування носіїв інформації (МР-5)	187
10.5.1	ЗАХИСТ ПОЗА КОНТРОЛЬОВАНИМИ ЗОНАМИ (МР-5(1))	189
10.5.2	ДОКУМЕНТУВАННЯ ДІЙ (МР-5(2))	189
10.5.3	ЗБЕРІГАЧІ (МР-5(3))	189
10.5.4	КРИПТОГРАФІЧНИЙ ЗАХИСТ (МР-5(4))	189
10.6	ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ (МР-6)	189
10.6.1	ПЕРЕГЛЯДАТИ, ЗАТВЕРДЖЕННЯ, ВІДСТЕЖЕННЯ, ДОКУМЕНТУВАННЯ ТА ПЕРЕ- ВІРКА (МР-6(1))	191
10.6.2	ПЕРЕВІРКА ОБЛАДНАННЯ (МР-6(2))	191
10.6.3	НЕРУЙНІВНІ МЕТОДИ (МР-6(3))	192
10.6.4	КЕРОВАНА НЕСЕКРЕТНА ІНФОРМАЦІЯ (МР-6(4))	192
10.6.5	СЕКРЕТНА ІНФОРМАЦІЯ (МР-6(5))	192
10.6.6	ЗНИЩЕННЯ НОСІВ ІНФОРМАЦІЇ (МР-6(6))	193
10.6.7	ПОДВІЙНА АВТОРИЗАЦІЯ (МР-6(7))	193
10.6.8	ВІДДАЛЕНЕ ОЧИЩЕННЯ АБО СТИРАННЯ ІНФОРМАЦІЇ (МР-6(8))	193
10.7	ВИКОРИСТАННЯ НОСІВ ІНФОРМАЦІЇ (МР-7)	193
10.7.1	ЗАБОРОНА ВИКОРИСТАННЯ БЕЗ ВИЗНАЧЕНОГО ВЛАСНИКА (МР-7(1))	194

10.7.2	ЗАБОРОНА ВИКОРИСТАННЯ (MP-7(2))	195
11	PE	195
11.1	PE-1 фізичного захисту та захисту робочого середовища Авторизація фізичного (PE-1)	195
11.2	PE-2 доступу (PE-2)	196
11.3	ФІЗИЧНИЙ ДОСТУП ДО СИСТЕМИ	197
11.3.1	Керування фізичним доступом — Захист від злому (PE-3(5))	200
11.4	PE-4 ліній електроживлення (PE-4)	200
11.5	КОНТРОЛЬ ДОСТУПУ В ПРИМІЩЕННЯ ДЛЯ ВІДОБРАЖЕННЯ ІНФОРМАЦІЇ	200
11.6	МОНІТОРИНГ ФІЗИЧНОГО ДОСТУПУ	201
11.6.1	Моніторинг фізичного доступу — Автоматичні розпізнавання вторгнень і відповідна реакція (PE-6(2))	202
11.7	АЛЬТЕРНАТИВНЕ РОБОЧЕ МІСЦЕ (PE-17)	202
12	PL	203
12.1	ПОЛІТИКИ ТА ПРОЦЕДУРИ ПЛАНУВАННЯ БЕЗПЕКИ (PL-1)	203
12.2	ПЛАНИ ЗАХИСТУ ІНФОРМАЦІЇ ТА ПЕРСОНАЛЬНИХ ДАНИХ (PL-2)	204
12.2.1	КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ДИВЕРСИФІКАЦІЯ ПОСТАЧАЛЬНИКІВ (PL-2(1))	206
12.2.2	ПЛАНИ ЗАХИСТУ ІНФОРМАЦІЇ ФУНКЦІОНАЛЬНА АРХІТЕКТУРА (PL-2(2))	206
12.3	ПРАВИЛА ПОВЕДІНКИ (PL-4)	206
12.3.1	ОБМЕЖЕННЯ НА СОЦІАЛЬНІ МЕДІА ТА МЕРЕЖУ (PL-4(1))	207
13	PS	207
13.1	Політика та процедури кадрової безпеки (PS-1)	207
13.2	Перевірка персоналу (PS-3)	208
13.3	Звільнення персоналу (PS-4)	209
13.4	Переведення персоналу (PS-5)	209
14	RA	210
14.1	ПОЛІТИКА ТА ПРОЦЕДУРИ ОЦІНЮВАННЯ РИЗИКУ (RA-1)	210
14.2	ОЦІНЮВАННЯ РИЗИКУ (RA-3)	211
14.2.1	ОЦІНЮВАННЯ ПОСТАЧАННЯ (RA-3(1))	212
14.2.2	ВИКОРИСТАННЯ ІНФОРМАЦІЇ З УСІХ ДОСТУПНИХ ДЖЕРЕЛ (RA-3(2))	212
14.2.3	УСВІДОМЛЕННЯ ДИНАМІЧНИХ ЗАГРОЗ (RA-3(3))	212
14.2.4	ПРОГНОСТИЧНА КІБЕРАНАЛІТИКА (RA-3(4))	212
14.3	СКАНУВАННЯ ВРАЗЛИВОСТЕЙ (RA-5)	213
14.3.1	СКАНУВАННЯ ВРАЗЛИВОСТЕЙ ІНСТРУМЕНТІВ (RA-5(1))	214
14.3.2	ОНОВЛЕННЯ ЗА ЧАСТОТОЮ, ПЕРЕД НОВИМ СКАНУВАННЯМ АБО ПРИ ІДЕНТИФІКАЦІЇ (RA-5(2))	214
14.3.3	ШИРОТА ТА ГЛИБИНА ПОКРИТТЯ (RA-5(3))	214
14.3.4	ВИЯВНА ІНФОРМАЦІЯ (RA-5(4))	214
14.3.5	ПРИВІЛЕЙОВАНИЙ ДОСТУП (RA-5(5))	215
14.3.6	СКАНУВАННЯ ТЕНДЕНЦІЙ (RA-5(6))	215
14.3.7	АВТОМАТИЗОВАНЕ ВИЯВЛЕННЯ ТА СПОВІЩЕННЯ ПРО НЕАВТОРИЗОВАНІ КОМПОНЕНТИ (RA-5(7))	215
14.3.8	ОГЛЯД ЖУРНАЛІВ АУДИТУ ЗА МИНУЛІ ПЕРІОДИ (RA-5(8))	215
14.3.9	СКАНУВАННЯ ВРАЗЛИВОСТЕЙ ПРОНИКНЕННЯ (RA-5(9))	215
14.4	РЕАГУВАННЯ НА РИЗИК (RA-7)	216
15	SA	216
15.1	ПОЛІТИКИ ТА ПРОЦЕДУРИ ПРИДБАННЯ СИСТЕМ ТА ПОСЛУГ (SA-1)	216
15.2	БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ІНЖИНІРИНГУ (SA-8)	217
15.2.1	ЧІТКА АБСТРАКЦІЯ (SA-8(1))	219
15.2.2	БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ НАЙМЕНШ ПОШИРЕНИЙ МЕХАНІЗМ (SA-8(2))	219
15.2.3	БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ МОДУЛЬНІСТЬ І БАГАТОРІВНЕВІСТЬ (SA-8(3))	219

15.2.4	БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ЧАСТКОВО ВПОРЯДКОВАНІ ЗАЛЕЖНОСТІ (SA-8(4))	220
15.2.5	БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ЕФЕКТИВНИЙ ОПОСЕРЕДКОВАНИЙ ДОСТУП (SA-8(5))	220
15.2.6	БЕЗПЕКА ТА ПРИВАТНІСТЬ МІНІМІЗОВАНИЙ ОБМІН (SA-8(6))	220
15.2.7	ЗНИЖЕНА СКЛАДНІСТЬ (SA-8(7))	221
15.2.8	БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ЕВОЛЮЦІЯ БЕЗПЕКИ В СИСТЕМІ (SA-8(8))	221
15.2.9	ДОВІРЕНІ КОМПОНЕНТИ СИСТЕМИ (SA-8(9))	221
15.2.10	РЕАЛІЗУЮТЬ ПРИНЦИП ІЄРАРХІЧНОЇ ДОВІРИ В ДИЗАЙНІ БЕЗПЕКИ (SA-8(10)) .	222
15.2.11	РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ ЗВОРОТНОГО ПОРОГУ МОДИФІКАЦІЇ (SA-8(11))	222
15.2.12	РЕАЛІЗУЮТЬ ПРИНЦИП ПОБУДОВИ ІЄРАРХІЧНОГО ЗАХИСТУ (SA-8(12))	222
15.2.13	РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ З МІНІМІЗАЦІЄЮ ЕЛЕМЕНТІВ БЕЗПЕКИ (SA-8(13))	223
15.2.14	РЕАЛІЗУЮТЬ ПРИНЦИП ПОБУДОВИ БЕЗПЕКИ ЗА ПРИНЦИПОМ НАЙМЕНШИХ ПРИВІЛЕЇВ (SA-8(14))	223
15.2.15	РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ ПОПЕРЕДНЬОГО ДОЗВОЛУ (SA-8(15))	223
15.2.16	РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ САМОДОСТАТНЬОЇ НАДІЙНОСТІ (SA-8(16))	224
15.2.17	РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ ЗАХИЩЕНОГО РОЗПОДІЛЕНОГО ВМІСТУ (SA-8(17))	224
15.2.18	РЕАЛІЗУЮТЬ ПРИНЦИП ПОБУДОВИ БЕЗПЕКИ ДОВІРЕНИХ КАНАЛІВ ЗВ'ЯЗКУ (SA-8(18))	224
15.2.19	РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ ДОВГОТРИВАЛОГО (SA-8(19))	225
15.2.20	РЕАЛІЗУЮТЬ ПРИНЦИП БЕЗПЕЧНОГО УПРАВЛІННЯ МЕТАДАНИМИ (SA-8(20)) .	225
15.2.21	РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ НА ОСНОВІ САМОАНАЛІЗУ (SA-8(21))	225
15.2.22	РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕЧНИХ НАЛАШТУВАНЬ ЗА ЗАМОВЧУВАННЯМ (SA-8(23))	226
15.2.23	<SA-08(25)_ODP системи або компоненти реалізують принцип безпеки економіки. (SA-8(25))	226
15.2.24	<SA-08(26)_ODP системи або компоненти реалізують принцип безпеки продуктивності. (SA-8(26))	226
15.2.25	РЕАЛІЗУЮТЬ ПРИНЦИП БЕЗПЕКИ З УРАХУВАННЯМ ЛЮДСЬКОГО ФАКТОРУ (SA-8(27))	226
15.2.26	<SA-08(28)_ODP системи або компоненти реалізують принцип прийнятного рівня безпеки. (SA-8(28))	227
15.2.27	РЕАЛІЗУЮТЬ ПРИНЦИП БЕЗПЕЧНОЇ МОДИФІКАЦІЇ СИСТЕМ (SA-8(31))	227
15.2.28	РЕАЛІЗУЮТЬ ПРИНЦИП ДОСТАТНЬОЇ ДОПУСКНОЇ ДОКУМЕНТАЦІЇ (SA-8(32)) .	227
15.2.29	<SA-08(33)_ODP системи або компоненти реалізують принцип мінімізації конфіденційності. (SA-8(33))	228
15.3	ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ (SA-9)	228
15.3.1	ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- ОЦІНЮВАННЯ РИЗИКІВ ТА ОРГАНІЗАЦІЙНІ ПОГОДЖЕННЯ (SA-9(1))	228
15.3.2	ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- ВИЗНАЧЕННЯ ФУНКЦІЙ, ПОРТІВ, ПРОТОКОЛІВ ТА СЛУЖБ (SA-9(2))	229
15.3.3	СТВОРЕННЯ ТА ПІДТРИМКА ДОВІРЧИХ ВІДНОСИН З ПОСТАЧАЛЬНИКАМИ (SA-9(3))	229
15.3.4	ЗОВНІШНІ СИСТЕМНІ СЛУЖБИ СПОЖИВАЧІВ І ПОСТАЧАЛЬНИКІВ (SA-9(4)) . .	230
15.3.5	ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- МІСЦЕ ОБРОБКИ, ЗБЕРІГАННЯ ТА ОБСЛУГОВУВАННЯ (SA-9(5))	230
15.3.6	ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- КРИПТОГРАФІЧНІ КЛЮЧІ, КЕРОВАНІ ОРГАНІЗАЦІЄЮ (SA-9(6))	230
15.3.7	ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- ПЕРЕВІРКА ЦІЛІСНОСТІ, ЩО КОНТРОЛЮЄТЬСЯ ОРГАНІЗАЦІЄЮ (SA-9(7))	231
15.3.8	ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИЗБЕРІГАННЯ – ЮРИСДИКЦІЯ УКРАЇНИ (SA-9(8))	231
15.4	КОМПОНЕНТИ СИСТЕМИ, ЩО НЕ ПІДТРИМУЮТЬСЯ (SA-22)	231

16	SC	232
16.1	ПОЛІТИКА ТА ПРОЦЕДУРИ ЗАХИСТУ СИСТЕМИ ТА КОМУНІКАЦІЙ (SC-1)	232
16.2	ІНФОРМАЦІЯ В ЗАГАЛЬНИХ СИСТЕМНИХ РЕСУРСАХ (SC-4)	233
16.2.1	РІВНІ БЕЗПЕКИ (SC-4(1))	233
16.2.2	ІНФОРМАЦІЯ В ЗАГАЛЬНИХ СИСТЕМНИХ БАГАТОРІВНЕВА АБО ПЕРІОДИЧНА ОБРІВКА (SC-4(2))	233
16.3	ДОСТУПНІСТЬ РЕСУРСІВ (SC-7)	234
16.3.1	ФІЗИЧНО ВІДДІЛЕНІ ПІДМЕРЕЖІ (SC-7(1))	234
16.3.2	ПУБЛІЧНИЙ ДОСТУП (SC-7(2))	234
16.3.3	ТОЧКИ ДОСТУПУ (SC-7(3))	234
16.3.4	ЗОВНІШНІ КОМУНІКАЦІЙНІ СЛУЖБИ (SC-7(4))	234
16.3.5	ВІДМОВА ЗА ЗАМОВЧУВАННЯМ - ДОЗВІЛ ЗА ВИНЯТКОМ (SC-7(5))	236
16.3.6	ВІДПОВІДЬ НА РОЗПІЗНАНІ ПОМИЛКИ (SC-7(6))	236
16.3.7	ЗАПОБІГАННЯ ПОДІЛУ ТУНЕЛЮВАННЯ ДЛЯ ВІДДАЛЕНИХ ПРИСТРОЇВ (SC-7(7))	236
16.3.8	ЗАХИСТ ПЕРИМЕТРА -МАРШРУТИЗАЦІЯ АВТЕНТИФІКОВАНИХ ПРОКСІ-СЕРВЕРІВ (SC-7(8))	236
16.3.9	ЗАХИСТ (SC-7(9))	236
16.3.10	ІЗОЛЬОВАНИ ВІД ІНШИХ ВНУТРІШНІХ КОМПОНЕНТІВ СИСТЕМИ ШЛЯХОМ ВПРОВАДЖЕННЯ ФІЗИЧНО ВІДОКРЕМЛЕНИХ ПІДМЕРЕЖ З КЕРОВАНИМИ ІНТЕРФЕЙСАМИ ДО ІНШИХ КОМПОНЕНТІВ СИСТЕМИ (SC-7(13))	237
16.4	КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ ПЕРЕДАЧІ (SC-8)	237
16.4.1	КОНФІДЕНЦІЙНІСТЬ ТА КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-8(1))	237
16.4.2	ПОПЕРЕДНЯ І ПОСТОБРІВКА (SC-8(2))	238
16.4.3	КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ КРИПТОГРАФІЧНИЙ ЗАХИСТ ПОВІДОМЛЕНЬ (SC-8(3))	238
16.4.4	ПРИХОВУВАННЯ АБО РАНДОМІЗАЦІЯ КОМУНІКАЦІЙ (SC-8(4))	238
16.4.5	КОНФІДЕНЦІЙНІСТЬ ТА СИСТЕМА РОЗПОДІЛУ (SC-8(5))	239
16.5	ВІДКЛЮЧЕННЯ МЕРЕЖІ (SC-10)	239
16.6	ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)	239
16.7	КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-13)	239
16.8	СПІЛЬНІ ОБЧИСЛЮВАЛЬНІ ПРИСТРОЇ ТА ЗАСТОСУНКИ (SC-15)	240
16.9	МОБІЛЬНИЙ КОД (SC-18)	240
16.10	АВТЕНТИФІКАЦІЯ СЕСІЙ (SC-23)	240
16.11	ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ (SC-28)	241
16.11.1	ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ КРИПТОГРАФІЧНИЙ ЗАХИСТ	241
17	SI	241
17.1	ПОЛІТИКА І ПРОЦЕДУРИ ЦІЛІСНОСТІ ІНФОРМАЦІЇ (SI-1)	241
17.2	ВИПРАВЛЕННЯ ДЕФЕКТІВ (SI-2)	242
17.2.1	ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ (SI-2(1))	243
17.2.2	АВТОМАТИЗОВАНЕ ВИПРАВЛЕННЯ ДЕФЕКТІВ (SI-2(2))	243
17.2.3	ЧАС ДЛЯ УСУНЕННЯ ДЕФЕКТІВ ТА ОРІЄНТИРИ ДЛЯ КОРИГУВАЛЬНИХ ДІЙ (SI-2(3))	243
17.2.4	АВТОМАТИЧНІ ЗАСОБИ УПРАВЛІННЯ ВИПРАВЛЕННЯМИ (SI-2(4))	243
17.2.5	ВИПРАВЛЕННЯ ДЕФЕКТІВ АВТОМАТИЧНЕ ОНОВЛЕННЯ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ВВУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ (SI-2(5))	244
17.2.6	ВИДАЛЕННЯ ПОПЕРЕДНІХ ВЕРСІЙ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ВВУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ (SI-2(6))	244
17.3	ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ (SI-3)	244
17.3.1	ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ (SI-3(1))	245
17.3.2	АВТОМАТИЧНІ ОНОВЛЕННЯ (SI-3(2))	245
17.3.3	ЗАХИСТ ВІД ШКІДЛИВОГО КОРИСТУВАЧІ (SI-3(3))	245
17.3.4	ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ ПРИВІЛЕЙОВАНИМИ КОРИСТУВАЧАМИ (SI-3(4))	245
17.3.5	ЗАХИСТ ВІД ШКІДЛИВОГО ЗБЕРІГАННЯ ДАНИХ (SI-3(5))	246
17.3.6	ТЕСТУВАННЯ ТА ВЕРИФІКАЦІЯ (SI-3(6))	246
17.3.7	ВИЯВЛЕННЯ БЕЗ ПІДПISУ (SI-3(7))	246
17.3.8	ВИЯВЛЕННЯ НЕАВТОРИЗОВАНИХ КОМАНД (SI-3(8))	246

17.3.9	АВТЕНТИФІКАЦІЯ ВІДДАЛЕНИХ КОМАНД (SI-3(9))	247
17.3.10	АНАЛІЗ ШКІДЛИВОГО КОДУ (SI-3(10))	247
17.4	МОНІТОРИНГ СИСТЕМИ (SI-4)	247
17.4.1	МОНІТОРИНГ СИСТЕМИ ВИЯВЛЕННЯ ВТОРГНЕНЬ (IDS) (SI-4(1))	248
17.4.2	АВТОМАТИЗОВАНІ МЕХАНІЗМИ АНАЛІЗУ В РЕАЛЬНОМУ ЧАСІ (SI-4(2))	248
17.4.3	МОНІТОРИНГ СИСТЕМИ МЕХАНІЗМИ ІНТЕГРАЦІЇ (SI-4(3))	248
17.4.4	МОНІТОРИНГ СИСТЕМИ КОМУНІКАЦІЙ (SI-4(4))	249
17.4.5	СИСТЕМНІ СПОВІЩЕННЯ (SI-4(5))	249
17.4.6	ЗАБОРОНА ДЛЯ НЕПРИВІЛЕЙОВАНИХ КОРИСТУВАЧІВ (SI-4(6))	249
17.4.7	МОНІТОРИНГ СИСТЕМИ ПІДОЗРІЛІ ПОДІЇ (SI-4(7))	249
17.4.8	ЗАХИСТ ІНФОРМАЦІЇ МОНІТОРИНГУ (SI-4(8))	250
17.4.9	ТЕСТУВАННЯ ЗАСОБІВ І МЕХАНІЗМІВ МОНІТОРИНГУ (SI-4(9))	250
17.4.10	МОНІТОРИНГ КОМУНІКАЦІЙ (SI-4(10))	250
17.4.11	МОНІТОРИНГ СИСТЕМИ КОМУНІКАЦІЙ (SI-4(11))	250
17.4.12	МОНІТОРИНГ СИСТЕМИ АВТОМАТИЗОВАНІ СПОВІЩЕННЯ (SI-4(12))	251
17.4.13	АНАЛІЗ ТРАФІКУ ТА ШАБЛОНІВ ПОДІЙ (SI-4(13))	251
17.4.14	МОНІТОРИНГ ВТОРГНЕННЯ (SI-4(14))	252
17.4.15	ПЕРЕХІД ВІД БЕЗДРОТОВОГО ЗВ'ЯЗКУ ДО ПРОВІДНИХ МЕРЕЖ (SI-4(15))	252
17.4.16	МОНІТОРИНГ МОНІТОРИНГУ (SI-4(16))	252
17.4.17	МОНІТОРИНГ ОБІЗНАНІСТЬ (SI-4(17))	252
17.4.18	АНАЛІЗ ТРАФІКУ ТА ПРИХОВАНОЇ ЕКСФІЛЬТРАЦІЇ (SI-4(18))	253
17.4.19	ОСОБИ, ЯКІ ПРЕДСТАВЛЯЮТЬ БІЛЬШИЙ РИЗИК (SI-4(19))	253
17.4.20	ПРИВІЛЕЙОВАНІ КОРИСТУВАЧІ (SI-4(20))	253
17.4.21	ВИПРОБУВАЛЬНІ ТЕРМІНИ (SI-4(21))	254
17.4.22	НЕСАНКЦІОНОВАНІ ПОСЛУГИ МЕРЕЖІ (SI-4(22))	254
17.4.23	ПРИСТРОЇ НА ОСНОВІ ХОСТА (SI-4(23))	254
17.4.24	ІНДИКАТОРИ КОМПРОМЕТАЦІЇ (SI-4(24))	254
17.4.25	АНАЛІЗ МЕРЕЖЕВОГО ТРАФІКУ (SI-4(25))	255
17.5	ПОПЕРЕДЖЕННЯ, РЕКОМЕНДАЦІЇ ТА ДИРЕКТИВИ З БЕЗПЕКИ (SI-5)	255
17.5.1	ПОПЕРЕДЖЕННЯ, РЕКОМЕНДАЦІЇ ТА ДИРЕКТИВИ З БЕЗПЕКИ АВТОМАТИЧНІ ПОПЕРЕДЖЕННЯ ТА РЕКОМЕНДАЦІЇ (SI-5(1))	256
17.6	УПРАВЛІННЯ ТА ЗБЕРЕЖЕННЯ ІНФОРМАЦІЇ (SI-12)	256
17.6.1	УПРАВЛІННЯ ТА ЗБЕРЕЖЕННЯ ІНФОРМАЦІЇ ЕЛЕМЕНТІВ ПЕРСОНАЛЬНИХ ДА- НИХ (SI-12(1))	257
17.6.2	МІНІМІЗАЦІЯ ВИКОРИСТАННЯ ПЕРСОНАЛЬНИХ ДАНИХ ПІД ЧАС ТЕСТУВАННЯ, НАВЧАННЯ ТА ДОСЛІДЖЕННЯ (SI-12(2))	257
17.6.3	УПРАВЛІННЯ ІНФОРМАЦІЇ (SI-12(3))	257
18	SR	258
18.1	ПОЛІТИКА ТА ПРОЦЕДУРИ УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-1)	258
18.2	ПЛАН УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-2)	259
18.2.1	СТВОРЕННЯ КОМАНДИ ПОСТАЧАННЯ (SR-2(1))	259
18.3	КОНТРОЛЬ ЛАНЦЮГА ПОСТАЧАННЯ І ПРОЦЕСІВ (SR-3)	260
18.3.1	РІЗНІ БАЗИ ПОСТАЧАННЯ (SR-3(1))	261
18.3.2	ОБМЕЖЕННЯ ШКОДИ (SR-3(2))	261
18.3.3	ПЕРЕНЕСЕННЯ ЗАХОДІВ ЗАХИСТУ УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТА- ЧАННЯ ДО СУБПІДРЯДНИКІВ (SR-3(3))	261
18.4	СТРАТЕГІЇ ПРИДБАННЯ, ІНСТРУМЕНТИ І МЕТОДИ (SR-5)	261
18.4.1	НАЛЕЖНЕ ПОСТАЧАННЯ (SR-5(1))	262
18.4.2	ОЦІНКА ПЕРЕД ВІДБОРОМ, ПРИЙНЯТТЯ, МОДИФІКАЦІЯ ЧИ ОНОВЛЕННЯ (SR-5(2))	262
18.5	ОЦІНКА ПОСТАЧАЛЬНИКІВ (SR-6)	263
18.5.1	ТЕСТУВАННЯ ТА АНАЛІЗ (SR-6(1))	263

Анотація

Базовий профіль — затверджується Адміністрацією Держспецзв'язку (наказом).

1. АС

1.1. ПОЛІТИКА ТА ПРОЦЕДУРИ УПРАВЛІННЯ ДОСТУПОМ (АС-1)

а. Розробити, задокументувати та поширити [Призначення: серед визначеного організацією персоналу або ролей]: 1. 2. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політики контролю доступу, яка: (а) містить мету, сферу застосування, ролі, відповідальність, зобов'язання керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliances); (b) відповідає чинному законодавству, нормативним документам, директивам, нормам, політикам, стандартам і керівним документам. Процедури, що сприяють реалізації політики управління доступом і відповідних заходів управління доступом. б. Призначити на посаду [Призначення: визначену організацією посадову особу] для управління, документування і розповсюдження політики та процедур контролю доступу. с. Переглянути та оновити: 1. поточну політику управління доступом [Призначення: з визначеною організацією частотою] та [Призначення: події, визначені організацією]; 2. поточні процедури управління доступом [Призначення: з визначеною організацією частотою] та [Завдання: події, визначені організацією].

No: 1

Name: ac_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюється політика контролю доступу

No: 2

Name: ac_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури контролю доступу

No: 3

Name: ac_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 4

Name: ac_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами контролю доступу

No: 5

Name: ac_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика контролю доступу

No: 6

Name: ac_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, які вимагають перегляду та оновлення поточної політики контролю доступу

No: 7

Name: ac_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури контролю доступу

1.2. УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ (АС-2)

а. Визначити та задокументувати типи облікових записів системи, дозволених для використання в ІС для підтримки цілей, завдань, функцій і процесів організації. б. Призначити менеджерів облікових записів для управління системними обліковими записами. с. Створити умови для групового та рольового членства. d. Визначити авторизованих користувачів інформаційної системи, членство в групі та ролі, а також дозволи доступу (наприклад, привілеї) та інші атрибути (за потреби) для кожного облікового запису. е. Вимагати схвалення [Призначення: визначеною організацією відповідальною особою або роллю] запитів на створення облікових записів системи. f. Створювати, активувати, змінювати, деактивувати та видаляти системні облікові записи відповідно до [Призначення: визначених організацією політики, процедур та умов]. g. Впровадити моніторинг використання облікових записів системи. h. Повідомляти адміністраторів облікових записів у межах [Призначення: визначеною організацією часового періоду для кожної ситуації]: 1. коли облікові записи більше не потрібні; 2. коли користувачі звільнені чи переведені; 3. коли використовуються індивідуальні системи або наявні зміни, які потребують нових знань. і. Авторизувати доступ до системи на основі: 1. Дійсної авторизації доступу. 2. Передбачуваного використання системи. 3. Інших атрибутів, що вимагаються організацією. j. Проводити перегляд облікових записів на відповідність вимогам управління обліковими записами з [Призначення: визначеною організацією частотою]. к. Впровадити процес повторного випуску облікових даних спільного/групового облікового запису (якщо він буде розгорнутий), коли особи виходять з групи. l. Узгодити процеси управління обліковими записами з процесами звільнення та перевodu (передачі повноважень) персоналу.

No: 1

Name: ac_2_odp_09

Type: integer

Default: 24

Визначено передумови та критерії членства в групах і ролях; визначено атрибути (за необхідності) для кожного облікового запису; визначено персонал або ролі, необхідні для затвердження запитів на створення облікових записів; визначено політику, процедури, передумови та критерії створення, активації, зміни, деактивації та видалення облікових записів; визначено персонал або ролі, які мають бути повідомлені; визначено період часу, протягом якого адміністратори облікових записів повинні бути повідомлені про те, що облікові записи більше не потрібні; визначено термін, протягом якого необхідно повідомляти адміністраторів облікових записів про звільнення або переведення користувачів; визначено період часу, протягом якого необхідно повідомляти адміністраторів облікових записів про зміни у використанні системи або необхідність знати про зміни для окремої особи; визначено атрибути, необхідні для авторизації доступу до системи (за потреби); AC-02_ODP[10] AC-02a.[01] AC-02a.[02] AC-02b AC-02c AC-02d.01 AC-02d.02 AC-02d.03[01] AC-02d.03[02] AC-02e AC-02f.[01] AC-02f.[02] AC-02f.[03] AC-02f.[04] AC-02f.[05] AC-02g AC-02h.01 AC-02h.02 AC-02h.03 AC-02i.01 AC-02i.02 AC-02i.03 визначено періодичність перегляду облікових записів; визначено та задокументовано типи облікових записів, дозволених для використання в системі; визначено та задокументовано типи облікових записів, які заборонено використовувати в системі; призначені менеджери облікових записів; необхідні умови та критерії

для членства в групах та ролях; визначено авторизованих користувачів системи; вказано приналежність до групи або ролі; для кожного облікового запису вказуються повноваження доступу (тобто привілеї); атрибути (за необхідності) вказуються для кожного облікового запису; для запитів на створення облікових записів потрібні схвалення від персоналу або ролей; облікові записи створюються відповідно до політики, процедур, передумов та критеріїв; облікові записи активуються відповідно до політики, процедур, передумов та критеріїв; облікові записи змінюються відповідно до політики, процедур, передумов та критеріїв; облікові записи деактивуються відповідно до політики, процедур, передумов та критеріїв; облікові записи видаляються відповідно до політики, процедур, передумов та критеріїв; контролюється використання облікових записів; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли облікові записи більше не потрібні; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли користувачі звільнені чи переведені; адміністратори облікових записів та персонал або ролі отримують повідомлення протягом періоду часу, коли використовуються індивідуальні системи або наявні зміни, які потребують нових знань. Доступ до системи здійснюється на підставі дійсної авторизації доступу; доступ до системи авторизується на основі передбачуваного використання системи; доступ до системи авторизовано на основі атрибутів (за необхідності); AC-02j AC-02k.[01] AC-02k.[02] AC-02l.[01] AC-02l.[02] облікові записи переглядаються на відповідність вимогам управління обліковими записами частота; створено процес повторного випуску облікових даних спільного доступу або групових облікових записів (якщо вони розгорнуті), коли користувачів вилучено з групи; впроваджено процес повторного випуску облікових даних спільного доступу або групових облікових записів (якщо вони розгорнуті), коли користувачів вилучено з групи; процеси управління обліковими записами узгоджуються з процесами звільнення персоналу; процеси управління обліковими записами узгоджуються з процесами переведення персоналу

1.2.1. АВТОМАТИЗОВАНЕ УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ СИСТЕМИ (AC-2(1))

Використовувати автоматизовані системними обліковими записами. механізми для підтримки управління

No: 1

Name: ac_2_1_01

Type: string

Default: "автоматизований засіб моніторингу"

Управління обліковими записами системи підтримується за допомогою автоматизовані механізми

No: 2

Name: ac_2_1_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для підтримки управління обліковими записами системи

1.2.2. ДЕАКТИВАЦІЯ ОБЛІКОВИХ ЗАПИСІВ (AC-2(3))

Автоматично деактивувати облікові записи коли: a) їх строк дії минув; b) вони більше не пов'язані з користувачем; c) вони порушують організаційну політику; d) вони були неактивними впродовж [Призначення: визначеного організацією періоду часу].

No: 1

Name: ac_2_3_b

Type: list

Default: ["admin", "security_officer"]

Облікові записи деактивуються протягом часового періоду, коли облікові записи більше не пов'язані з користувачем або фізичною особою

No: 2

Name: ac_2_3_d

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Облікові записи відключено протягом часового періоду, коли облікові записи порушують політику організації; облікові записи деактивуються протягом , якщо вони були неактивними протягом

No: 3

Name: ac_2_3_odp_01

Type: integer

Default: 30

Визначено період часу, протягом якого необхідно деактивувати облікові записи

No: 4

Name: ac_2_3_odp_02

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено період часу неактивності, після закінчення якого облікові записи будуть деактивовані; АС-02(03)(а) облікові записи деактивуються протягом часового періоду, коли термін дії облікових записів минув

1.2.3. ДІЇ ПРИ АВТОМАТИЗОВАНОМУ АУДИТІ (АС-2(4))

Проводити автоматизований аудит створення, модифікації, деактивації та видалення облікових записів і сповіщення про дії. ПРИ активації,

No: 1

Name: ac_2_4_01

Type: string

Default: nil

Створення облікового запису автоматично аудитується

No: 2

Name: ac_2_4_02

Type: string

Default: nil

Модифікація облікового запису автоматично аудитується

No: 3

Name: ac_2_4_03

Type: string

Default: nil

Активація облікового запису автоматично аудитується

No: 4

Name: ac_2_4_04

Type: string

Default: nil

Деактивація облікового запису автоматично аудитується

No: 5

Name: ac_2_4_05

Type: string

Default: nil

Видалення облікового запису автоматично аудитується

1.2.4. ВИХІД ІЗ СИСТЕМИ ЗА ВІДСУТНОСТІ АКТИВНОСТІ (АС-2(5))

Вимагати від користувачів виходити із системи, коли [Призначення: вичерпано визначений організацією періоду часу очікування або опис того, коли необхідно вийти із системи].

No: 1

Name: ac_2_5_01

Type: integer

Default: 30

Користувачі повинні виходити з системи, коли період очікуваної бездіяльності або опис часу, коли потрібно вийти з системи

No: 2

Name: ac_2_5_odp

Type: integer

Default: 30

Визначено часовий період очікуваної бездіяльності або опис, коли потрібно вийти з системи

1.2.5. ДИНАМІЧНЕ УПРАВЛІННЯ ПРИВІЛЕЯМИ (АС-2(6))

Реалізувати такі можливості динамічного управління привілеями: [Призначення: визначений організацією перелік можливостей динамічного управління привілеями].

No: 1

Name: ac_2_6_01

Type: string

Default: nil

Реалізовано можливості динамічного управління привілеями

No: 2

Name: ac_2_6_odp

Type: string

Default: nil

Визначено можливості динамічного управління привілеями

1.2.6. СХЕМИ, ЗАСНОВАНІ НА РОЛЯХ (АС-2(7))

а) Створювати й адмініструвати привілейовані облікові записи користувачів відповідно до схеми доступу на основі ролей (role-based), яка реалізує дозволений доступ до системи та призначення привілеїв для ролей. б) Проводити моніторинг призначення привілейованих ролей. в) Відстежувати зміни ролей або атрибутів. г) Скасовувати доступ, коли призначені привілейовані ролі більше не потрібні.

No: 1

Name: ac_2_7_b

Type: string

Default: nil

Проводиться моніторинг призначення привілейованих ролей або атрибутів

No: 2

Name: ac_2_7_c

Type: string

Default: nil

Відстежуються зміни ролей або атрибутів

No: 3

Name: ac_2_7_d

Type: list

Default: ["admin", "security_officer"]

Доступ скасовується, коли призначені привілейовані ролі більше не потрібні.0

No: 4

Name: ac_2_7_odp

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {схема доступу на основі ролей; схема доступу на основі атрибутів}

1.2.7. ДИНАМІЧНЕ УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ (АС-2(8))

Створювати, активувати, управляти та деактивувати [Призначення: системні облікові записи, визначені організацією] динамічно.

No: 1

Name: ac_2_8_01

Type: string

Default: nil

УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ - ДИНАМІЧНЕ УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ
МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: ac_2_8_02

Type: string

Default: nil

Облікові записи системи активуються динамічно

No: 3

Name: ac_2_8_03

Type: string

Default: nil

Облікові записи системи активуються динамічно

No: 4

Name: ac_2_8_04

Type: string

Default: nil

Облікові записи системи деактивуються динамічно

No: 5

Name: ac_2_8_odp

Type: string

Default: nil

Визначено облікові записи системи, які динамічно створюються, активуються, управляються та деактивуються

1.2.8. ОБМЕЖЕННЯ НА ВИКОРИСТАННЯ СПІЛЬНИХ ТА ГРУПОВИХ ОБЛІКОВИХ ЗАПИСІВ (АС-2(9))

Використовувати лише ті спільні та групові облікові записи, які відповідають [Призначення: визначеним організацією умовам для створення спільних та групових облікових записів].

No: 1

Name: ac_2_9_01

Type: list

Default: []

Використання спільних та групових облікових записів дозволено лише за умови дотримання умов

No: 2

Name: ac_2_9_odp

Type: list

Default: []

Визначено умови створення спільних та групових облікових записів

1.2.9. ЗМІНА ДАНИХ СПІЛЬНИХ І ГРУПОВИХ ОБЛІКОВИХ ЗАПИСІВ (АС-2(10))

No: 1

Name: ac_2_10_01

Type: string

Default: nil

УПРАВЛІННЯ ОБЛІКОВИМИ ЗАПИСАМИ - ЗМІНА ДАНИХ СПІЛЬНИХ І ГРУПОВИХ ОБЛІКОВИХ ЗАПИСІВ [Вилучено: включено до АС-02(k)]

1.2.10. УМОВИ ВИКОРИСТАННЯ (АС-2(11))

Забезпечити дотримання [Призначення: обставин та/або умов використання, визначених організацією] для [Призначення: визначених організацією облікових записів системи].

No: 1

Name: ac_2_11_01

Type: list

Default: []

Обставини та/або умови використання для облікових записів системи застосовуються

No: 2

Name: ac_2_11_odp_01

Type: list

Default: []

Визначено обставини та/або умови використання визначених облікових записів системи

No: 3

Name: ac_2_11_odp_02

Type: string

Default: nil

Визначені облікові записи системи, що підлягають виконанню обставин та/або умов використання

1.2.11. МОНІТОРИНГ НЕТИПОВОГО ВИКОРИСТАННЯ ОБЛІКОВИХ ЗАПИСІВ (АС-2(12))

а) Проводити моніторинг облікових записів системи на [Призначення: визначене організацією нетипове використання]. б) Повідомляти про нетипове використання облікових записів системи [Призначення: визначеного організацією персоналу або ролей].

No: 1

Name: ac_2_12_a

Type: list

Default: []

Облікові записи системи відстежуються на предмет обставини та/або умови використання

No: 2

Name: ac_2_12_b

Type: list

Default: ["admin", "security_officer"]

Про визначені обставини та/або умови використання системних облікових записів повідомляється персонал або ролі

No: 3

Name: ac_2_12_odp_01

Type: list

Default: []

Визначено обставини та/або умови використання, для яких необхідно здійснювати моніторинг облікових записів системи

No: 4

Name: ac_2_12_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, яким належить повідомляти про визначені обставини та/або умови використання

1.2.12. ДЕАКТИВАЦІЯ ОБЛІКОВИХ ЗАПИСІВ ОСІБ З ВИСОКИМ РІВНЕМ РИЗИКУ (АС-2(13))

Деактивувати облікові записи користувачів, які становлять значний ризик, у межах [Призначення: визначеного організацією періоду часу] після виявлення ризику.

No: 1

Name: ac_2_13_01

Type: integer

Default: 30

Облікові записи користувачів деактивуються протягом періоду часу з моменту виявлення значних ризиків

No: 2

Name: ac_2_13_odp_01

Type: integer

Default: 30

Визначено період часу, протягом якого необхідно деактивувати облікові записи фізичних осіб, які становлять значний ризик

No: 3

Name: ac_2_13_odp_02

Type: string

Default: nil

Визначено значні ризики, що призводять до деактивації облікових записів

1.3. ЗАБЕЗПЕЧЕННЯ ДОСТУПУ (АС-3)

Застосовувати затверджені повноваження для логічного доступу до інформації та ресурсів системи відповідно до чинної політики (правил) управління доступом.

No: 1

Name: ac_3_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Затверджені повноваження на логічний доступ до інформації та ресурсів системи виконуються відповідно до чинних політик(правил) управління доступом

1.3.1. ОБМЕЖЕНИЙ ДОСТУП ДО ПРИВІЛЕЙОВАНИХ ФУНКЦІЙ (АС-3(1))

No: 1

Name: ac_3_1_01

Type: string

Default: nil

ЗАБЕЗПЕЧЕННЯ ДОСТУПУ - ОБМЕЖЕНИЙ ДОСТУП ДО ПРИВІЛЕЙОВАНИХ ФУНКЦІЙ [Вилучено: включено до складу АС-06]

1.3.2. ПОДВІЙНА АВТОРИЗАЦІЯ (АС-3(2))

Забезпечити подвійну авторизацію для [Призначення: визначених організацією привілейованих команд та/або інших дій, визначених організацією].

No: 1

Name: ac_3_2_01

Type: string

Default: nil

Подвійна авторизація застосовується для привілейованих команд та/або інших дій

No: 2

Name: ac_3_2_odp

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено привілейовані команди та/або інші дії, що потребують подвійної авторизації

1.3.3. МАНДАТНЕ УПРАВЛІННЯ ДОСТУПОМ (АС-3(3))

Застосовувати [Призначення: визначену організацією мандатну (mandatory) політику управління доступом] щодо всіх суб'єктів і об'єктів доступу, у яких політика: (а) одноманітно застосовується для всіх суб'єктів і об'єктів у межах системи; (b) вказує, що суб'єкт, якому було надано доступ до інформації, обмежений у виконанні будь-якої з таких дій: (с) (1) передача інформації неавторизованим суб'єктам або об'єктам; (2) надання іншим суб'єктам привілеїв; (3) зміна одного чи декількох атрибутів безпеки суб'єкта, об'єкта, системи або компонентів

системи; (4) вибір атрибутів безпеки та значень атрибутів, які повинні бути пов'язані з новоствореними або зміненими об'єктами; (5) зміна правил, що регулюють управління доступом; має бути вказано, що [Призначення: визначеним організацією суб'єктам] можуть бути явно надані [Призначення: визначені організацією привілеї], так що вони не обмежуються будь-яким з перелічених вище обмежень.

No: 1

Name: ac_3_3_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Мандатна політика контролю доступу застосовується до набору охоплених суб'єктів, зазначених у політиці

No: 2

Name: ac_3_3_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Мандатна політика контролю доступу застосовується до набору охоплених об'єктів, зазначених у політиці

No: 3

Name: ac_3_3_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Мандатна політика контролю доступу застосовується одноманітно до всіх суб'єктів системи

No: 4

Name: ac_3_3_a_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Мандатна політика контролю доступу застосовується одноманітно до всіх об'єктів системи; AC-03(03)(b)(01) мандатна політика контролю доступу та мандатна політика контролю доступу, які визначають, що суб'єкт, якому надано доступ до інформації, зобов'язаний не передавати інформацію неавторизованим суб'єктам або об'єктам; AC-03(03)(b)(02) мандатна політика контролю доступу та мандатна політика контролю доступу, які визначають, що суб'єкт, якому надано доступ до інформації, обмежений у наданні своїх привілеїв іншим суб'єктам; AC-03(03)(b)(03) мандатна політика контролю доступу та мандатна політика контролю доступу, які визначають, що суб'єкт, якому надано доступ до інформації, не може змінювати один або декілька атрибутів безпеки (визначених політикою) суб'єктів, об'єктів, системи або компонентів системи; AC-03(03)(b)(04) мандатна політика контролю доступу та мандатна політика контролю доступу, які визначають, що суб'єкт, якому надано доступ до інформації, обмежений у виборі атрибутів безпеки та значень атрибутів (визначених політикою), що повинні бути пов'язані з новостворюваними або зміненими об'єктами; AC-03(03)(b)(05) мандатна політика контролю доступу та мандатна політика контролю доступу, які визначають, що суб'єкт, якому надано доступ до інформації, не має права змінювати правила, що регулюють управління доступом

No: 5

Name: ac_3_3_c

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Мандатна політика контролю доступу та мандатна політика контролю доступу, які визначають, що суб'єктам можуть бути явно надані привілеї таким чином, щоб вони не були обмежені будь-якою визначеною підмножиною (або всіма) з наведених вище обмежень

No: 6

Name: ac_3_3_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено мандатну політику контролю доступу, що застосовується до набору охоплених суб'єктів

No: 7

Name: ac_3_3_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено мандатну політику контролю доступу, що застосовується до набору охоплених об'єктів

No: 8

Name: ac_3_3_odp_03

Type: string

Default: nil

Визначені суб'єкти, яким явно надаються привілеї

No: 9

Name: ac_3_3_odp_04

Type: string

Default: nil

Визначено привілеї, які мають бути прямо надані суб'єктам

1.3.4. ДИСКРЕЦІЙНЕ УПРАВЛІННЯ ДОСТУПОМ (АС-3(4))

Застосовувати [Призначення: визначену організацією дискреційну політику управління доступом] щодо визначених суб'єктів і об'єктів доступу, для яких політика визначає, що суб'єкт, якому було надано доступ до інформації, може виконати одну чи більше з таких дій: (a) передача інформацію будь-яким іншим суб'єктам чи об'єктам; (b) призначення своїх привілеїв іншим суб'єктам; (c) зміна атрибутів безпеки суб'єктів, об'єктів, систем або компонентів системи; (d) вибір атрибутів безпеки, які будуть пов'язані з новоствореними або переглянутими об'єктами; (e) зміна правил, що регулюють управління доступом.

No: 1

Name: ac_3_4_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика управління доступом застосовується до набору охоплених суб'єктів, зазначених у політиці

No: 2

Name: ac_3_4_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика управління доступом застосовується до набору охоплених об'єктів, зазначених у політиці

No: 3

Name: ac_3_4_a

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика управління доступом та дискреційна політика управління доступом застосовуються, коли політика визначає, що суб'єкт, якому надано доступ до інформації, може передавати інформацію будь-яким іншим суб'єктам або об'єктам

No: 4

Name: ac_3_4_b

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика управління доступом та дискреційна політика управління доступом застосовуються, коли політика визначає, що суб'єкт, якому надано доступ до інформації, може надавати свої привілеї іншим суб'єктам

No: 5

Name: ac_3_4_c

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика управління доступом та дискреційна політика управління доступом застосовуються, коли політика визначає, що суб'єкт, якому надано доступ до інформації, може змінювати атрибути безпеки суб'єктів, об'єктів, системи або компонентів системи

No: 6

Name: ac_3_4_d

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика управління доступом та дискреційна політика управління доступом застосовуються там, де політика визначає, що суб'єкт, якому надано доступ до інформації, може вибирати атрибути безпеки, які будуть пов'язані з новоствореними або переглянутими об'єктами

No: 7

Name: ac_3_4_e

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика управління доступом та дискреційна політика управління доступом застосовуються, коли політика визначає, що суб'єкт, якому надано доступ до інформації, може змінювати правила управління доступом

No: 8

Name: ac_3_4_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено дискреційну політику управління доступом, яка застосовується до набору охоплених суб'єктів

No: 9

Name: ac_3_4_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено дискреційну політику управління доступом, яка застосовується до набору охоплених об'єктів

1.3.5. ІНФОРМАЦІЯ ЩОДО БЕЗПЕКИ (АС-3(5))

Запобігати доступу до [Призначення: інформації щодо безпеки, яка визначена організацією], за винятком випадків, коли наявні безпечні неробочі стани системи.

No: 1

Name: ac_3_5_01

Type: string

Default: nil

Доступ до інформації щодо безпеки заборонено, за винятком випадків, коли наявні безпечні неробочі стани системи

No: 2

Name: ac_3_5_odp

Type: string

Default: nil

Визначено інформацію щодо безпеки, доступ до якої заборонено, за винятком випадків, коли наявні безпечні неробочі стани системи

1.3.6. ЗАХИСТ ІНФОРМАЦІЇ КОРИСТУВАЧА ТА СИСТЕМИ (АС-3(6))

No: 1
 Name: ac_3_6_01
 Type: string
 Default: nil

ЗАБЕЗПЕЧЕННЯ ДОСТУПУ - ЗАХИСТ ІНФОРМАЦІЇ КОРИСТУВАЧА ТА СИСТЕМИ [Вилучено: Включено в МР-04 та SC-28]. АС-03(07) ЗАБЕЗПЕЧЕННЯ ДОСТУПУ - УПРАВЛІННЯ ДОСТУПОМ НА ОСНОВІ РОЛЕЙ

1.3.7. УПРАВЛІННЯ ДОСТУПОМ НА ОСНОВІ РОЛЕЙ (АС-3(7))

Застосовувати політику управління доступом на основі ролей щодо визначених суб'єктів і об'єктів та управління доступом на основі [Призначення: визначених організацією ролей та користувачів, уповноважених приймати такі ролі].

No: 1
 Name: ac_3_7_01
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Політика управління доступом на основі ролей застосовується до визначених суб'єктів

No: 2
 Name: ac_3_7_02
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Політика управління доступом на основі ролей застосовується до визначених об'єктів

No: 3
 Name: ac_3_7_03
 Type: list
 Default: ["admin", "security_officer"]

Доступ контролюється на основі ролей та користувачів, яким дозволено приймати такі ролі

No: 4
 Name: ac_3_7_odp_01
 Type: list
 Default: ["admin", "security_officer"]

Визначено ролі, на яких базується управління доступом

No: 5
 Name: ac_3_7_odp_02
 Type: string
 Default: nil

Визначено користувачів, уповноважених на прийняття ролей (визначених у АС-03(07)_ODP[01])

1.3.8. АНУЛЮВАННЯ ПРАВ ДОСТУПУ (АС-3(8))

Здійснювати анулювання прав доступу в результаті змін атрибутів безпеки суб'єктів і об'єктів на основі [Призначення: визначених організацією правил, що регулюють терміни скасування прав доступу].

No: 1

Name: ac_3_8_01

Type: string

Default: nil

Здійснюється анулювання прав доступу в результаті зміни атрибутів безпеки суб'єктів на основі правил

No: 2

Name: ac_3_8_02

Type: string

Default: nil

Здійснюється анулювання прав доступу в результаті зміни атрибутів безпеки об'єктів на основі правил

No: 3

Name: ac_3_8_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено правила, що регулюють терміни скасування дозволів на доступ

1.3.9. КЕРОВАНА ПЕРЕДАЧА (ПУБЛІКАЦІЯ) ІНФОРМАЦІЇ (АС-3(9))

Передавати (публікувати) інформацію за межами встановленої межі системи можливо, якщо: а) Приймальна [Призначення: визначена організацією система або компонент системи] забезпечує [Призначення: визначені організацією заходи безпеки]; б) [Призначення: визначені організацією заходи безпеки] використовуються для підтвердження відповідності інформації, призначеної для керованих передач (публікації).

No: 1

Name: ac_3_9_a

Type: string

Default: nil

Інформація випускається за межі системи, тільки якщо отримуюча система або компонент системи забезпечує заходи захисту

No: 2

Name: ac_3_9_b

Type: string

Default: nil

Інформація публікується за межами системи, тільки якщо заходи захисту використовуються для перевірки відповідності інформації, призначеної для публікації

1.3.10. ПЕРЕГЛЯД АУДИТОМ МЕХАНІЗМІВ КОНТРОЛЮ ДОСТУПУ (АС-3(10))

Застосувати перегляд аудитом механізмів автоматизованого управління доступу при [Призначення: визначених організацією умовах] [Призначення: визначеними організацією ролями].

No: 1

Name: ac_3_10_01

Type: string

Default: nil

За умов застосовується перегляд аудитом механізмів автоматизованого контролю доступу за допомогою ролей

No: 2

Name: ac_3_10_odp_01

Type: list

Default: []

Визначено умови, за яких можна застосовувати перегляд аудитом механізмів автоматизованого управління доступом

No: 3

Name: ac_3_10_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено ролі, яким дозволено використовувати перегляд аутот механізмів автоматизованого управління доступом

1.3.11. ОБМЕЖЕННЯ ДОСТУПУ ДО СПЕЦІАЛЬНОЇ ІНФОРМАЦІЇ (АС-3(11))

Обмежити прямий доступ до сховищ даних, що містять [Призначення: визначені організацією типи інформації].

No: 1

Name: ac_3_11_01

Type: string

Default: nil

Обмежено доступ до сховищ даних, що містять типи інформації

1.3.12. ВСТАНОВЛЕННЯ ТА ЗАБЕЗПЕЧЕННЯ ДОСТУПУ ДО ЗАСТОСУНКІВ (АС-3(12))

- a) Вимагати від застосунків встановити в процесі інсталяції доступ до таких застосунків системи і функцій: [Призначення: визначених організацією програм та функцій системи];
- b) Впровадити механізм примусового застосування, щоб запобігти доступу, відмінному від заявленого. c) Схвалити зміни доступу після початкового встановлення застосунків.

No: 1

Name: ac_3_12_a

Type: string

Default: nil

У процесі інсталяції програми повинні встановити доступ до таких системних застосунків і функцій системи: програм та функцій системи

No: 2

Name: ac_3_12_b

Type: string

Default: nil

Передбачено механізм примусового застосування запобігання несанкціонованому доступу

No: 3

Name: ac_3_12_c

Type: string

Default: nil

Зміни доступу після первинної інсталяції програми схвалено

No: 4
 Name: ac_3_12_odp
 Type: string
 Default: nil

Визначено програми та функції системи, яким необхідно встановити права доступу

1.3.13. УПРАВЛІННЯ ДОСТУПОМ НА ОСНОВІ АТРИБУТІВ (АС-3(13))

Здійснювати політику управління доступу на основі атрибутів (attribute-based) для визначених суб'єктів і об'єктів доступу й управляти доступом на основі [Призначення: визначених організацією атрибутів для ухвалення рішень про доступ].

No: 1
 Name: ac_3_13_1
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Політика управління доступом на здійснюється до визначених суб'єктів; основі атрибутів АС-03(13)[2] політика управління доступом на здійснюється до визначених об'єктів; основі атрибутів

No: 2
 Name: ac_3_13_3
 Type: string
 Default: nil

Доступ контролюється на основі атрибутів

No: 3
 Name: ac_3_13_odp
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Визначено атрибути для визначення прав доступу

1.3.14. ІНДИВІДУАЛЬНИЙ ДОСТУП (АС-3(14))

Надайте [Призначення: механізми, визначені організацією], щоб дозволити особам мати доступ до певних елементів їх особистої інформації: [Призначення: елементи, визначені організацією]

No: 1
 Name: ac_3_14_01
 Type: list
 Default: ["admin", "security_officer"]

Механізми надаються для того, щоб дозволити особам мати доступ до елементів їхньої персональної інформації

No: 2
 Name: ac_3_14_odp_01
 Type: list
 Default: ["admin", "security_officer"]

Визначено механізми, що дозволяють фізичним особам мати доступ до елементів їхньої персональної інформації

No: 3
 Name: ac_3_14_odp_02
 Type: list
 Default: ["admin", "security_officer"]

Визначено елементи інформації, що ідентифікує особу, до якої мають доступ фізичні особи

1.3.15. ДИСКРЕЦІЙНИЙ ТА ОБОВ'ЯЗКОВИЙ ДОСТУП (АС-3(15))

(а) Застосовувати [Призначення: визначену організацією політику обов'язкового контролю доступу] до набору охоплених суб'єктів і об'єктів, указаних у політиці; (б) Застосування [Призначення: визначена організацією дискреційна політика контролю доступу] до набору охоплених суб'єктів і об'єктів, указаних у політиці.

No: 1

Name: ac_3_15_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Політика обов'язкового контролю доступу застосовується до набору охоплених суб'єктів, зазначених у політиці

No: 2

Name: ac_3_15_a_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Політика обов'язкового контролю доступу застосовується до набору охоплених об'єктів, зазначених у політиці

No: 3

Name: ac_3_15_b_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика контролю доступу застосовується до набору суб'єктів, зазначених у політиці

No: 4

Name: ac_3_15_b_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дискреційна політика контролю доступу застосовується до набору об'єктів, зазначених у політиці

No: 5

Name: ac_3_15_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено обов'язкову політику контролю доступу, яка застосовується до набору суб'єктів, зазначених у політиці

No: 6

Name: ac_3_15_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено обов'язкову політику контролю доступу, яка застосовується до набору об'єктів, зазначених у політиці

No: 7

Name: ac_3_15_odp_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено дискреційну політику контролю доступу, яка застосовується до набору суб'єктів, зазначених у політиці

No: 8

Name: ac_3_15_odp_04

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено дискреційну політику контролю доступу, яка застосовується до набору об'єктів, зазначених у політиці

1.4. УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ (АС-4)

Застосувати затверджені повноваження для управління потоком інформації всередині системи та між пов'язаними системами на основі [Призначення: визначеними організацією політиками управління інформаційним потоком].

No: 1

Name: ac_4_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Затверджені повноваження застосовуються для контролю потоку інформації всередині системи та між підключеними системами на основі політики управління інформаційними потоками

No: 2

Name: ac_4_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політики управління інформаційними потоками всередині системи та між підключеними системами

1.4.1. АТРИБУТИ БЕЗПЕКИ ОБ'ЄКТУ (АС-4(1))

Використовувати [Призначення: визначені організацією атрибути безпеки], пов'язані з [Призначення: визначеними організацією інформацією, джерелами та об'єктами призначення], щоб запровадити [Призначення: визначену організацією політику управління потоками інформації] як основу для ухвалення рішень щодо управління потоками.

No: 1

Name: ac_4_1_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Атрибути безпеки, пов'язані з об'єктами інформації, джерела об'єктів та об'єктами призначення, використовуються для забезпечення виконання політик управління інформаційними потоками як основи для прийняття рішень щодо управління потоками

No: 2

Name: ac_4_1_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Атрибути конфіденційності, пов'язані з об'єктами інформації, джерела об'єктів та об'єктами призначення, використовуються для забезпечення виконання політик управління інформаційними потоками як основи для прийняття рішень щодо управління потоками

No: 3

Name: ac_4_1_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено атрибути безпеки, які будуть пов'язані з інформацією, джерелом та об'єктами призначення

No: 4

Name: ac_4_1_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено атрибути конфіденційності, які будуть пов'язані з інформацією, джерелом та об'єктами призначення

No: 5

Name: ac_4_1_odp_03

Type: string

Default: nil

Визначено об'єкти інформації, які будуть пов'язані з атрибутами безпеки

No: 6

Name: ac_4_1_odp_04

Type: string

Default: nil

Визначено об'єкти інформації, які будуть пов'язані з атрибутами конфіденційності

No: 7

Name: ac_4_1_odp_05

Type: string

Default: nil

Визначено джерела об'єктів, які будуть пов'язані з атрибутами безпеки

No: 8

Name: ac_4_1_odp_06

Type: string

Default: nil

Визначено джерела об'єктів, які будуть пов'язані з атрибутами конфіденційності

No: 9

Name: ac_4_1_odp_07

Type: string

Default: nil

Визначено об'єкти призначення, які будуть пов'язані з атрибутами безпеки

No: 10

Name: ac_4_1_odp_08

Type: string

Default: nil

Визначено об'єкти призначення, які будуть пов'язані з атрибутами конфіденційності

No: 11

Name: ac_4_1_odp_09

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політику управління інформаційними потоками як основу для ухвалення рішень щодо управління потоками

1.4.2. ДОМЕНИ ОБРОБ- (АС-4(2))

Використовувати захищені домени обробки даних для забезпечення [Призначення: визначеної організацією політики управління потоками інформації] як основу для ухвалення рішень щодо управління потоками.

No: 1

Name: ac_4_2_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Захищені домени обробки використовуються для забезпечення дотримання політики управління інформаційними потоками як основи для ухвалення рішень щодо управління потоками

No: 2

Name: ac_4_2_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політики управління інформаційними потоками, які будуть застосовуватися з використанням захищених доменів обробки

1.4.3. УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ УПРАВЛІННЯ ІНФОРМАЦІЙНИМ ПОТОКОМ (АС-4(3))

Здійснювати динамічне управління потоком інформації на основі [Призначення: визначених організацією політик (правил)].

No: 1

Name: ac_4_3_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Здійснюється динамічне управління потоком інформації на основі політики управління інформаційними потоками

No: 2

Name: ac_4_3_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначені політики контролю інформаційних потоків, які необхідно впроваджувати

1.4.4. УПРАВЛІННЯ ПОТОКОМ ЗАШИФРОВАНОЇ ІНФОРМАЦІЇ (АС-4(4))

Запобігати обходу [Призначення: механізмів управління потоками, визначених організацією] зашифрованої інформації шляхом [Вибір (один або декілька): дешифрування інформації; блокування потоку зашифрованої інформації; завершення сеансів зв'язку, що намагаються передавати зашифровану інформацію; [Призначення: визначеними організацією процедурою або методом]].

No: 1

Name: ac_4_4_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено механізми контролю інформаційних потоків, які унеможливають обхід зашифрованої інформації

No: 2

Name: ac_4_4_odp_02

Type: string

Default: "AES-256-GCM"

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {дешифрування інформації; блокування потоку зашифрованої інформації; завершення сеансів зв'язку що намагаються передавати зашифровану інформацію; визначена організацією процедура або метод}

No: 3

Name: ac_4_4_odp_03

Type: string

Default: "автоматизований засіб моніторингу"

Визначено організацією процедуру або метод, що використовується для запобігання обходу зашифрованої інформації через механізми контролю інформаційних потоків (якщо вибрано)

1.4.5. ВБУДОВУВАННЯ ТИПІВ ДАНИХ (АС-4(5))

Впровадити [Призначення: визначені організацією обмеження] для вбудовування типів даних в інші типи даних.

No: 1

Name: ac_4_5_odp

Type: string

Default: nil

Визначеного обмеження, які слід застосовувати щодо вбудовування типів даних в інші типи даних; обмеження накладаються на вбудовування типів даних у інші типи даних

1.4.6. МЕТАДАНИ (АС-4(6))

Здійснювати управління інформаційним потоком на основі [Призначення: визначених організацією метаданих].

No: 1

Name: ac_4_6_01

Type: string

Default: nil

Інформаційна система здійснює управління інформаційним потоком на основі метадани

No: 2

Name: ac_4_6_odp

Type: string

Default: nil

Визначено метадани, які слід використовувати як засіб управління інформаційним потоком

1.4.7. МЕХАНІЗМИ ОДНОСТОРОННЬОГО ПОТОКУ (АС-4(7))

Впровадити [Призначення: визначені організацією односторонні інформаційні потоки] за допомогою апаратних механізмів.

No: 1

Name: ac_4_7_01

Type: string

Default: nil

Односторонні інформаційні потоки забезпечуються за допомогою апаратних механізмів управління потоками.
ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

1.4.8. УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОЛІТИКИ БЕЗПЕКИ (АС-4(8))

а) Забезпечити контроль над потоком інформації, використовуючи [Призначення: визначені організацією фільтри безпеки або політики конфіденційності] як основу для рішень щодо керування потоком для [Призначення: визначені організацією потоки інформації]; б) [Вибір (один або кілька): Блокування; Зміна; Карантин] даних після помилки обробки фільтра відповідно до [Призначення: політика безпеки або конфіденційності, визначена організацією].

No: 1

Name: ac_4_8_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

ODP[02] визначено фільтри політики конфіденційності, які будуть використовуватися як основа для забезпечення керування інформаційними потоками

No: 2

Name: ac_4_8_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Управління інформаційними потоками здійснюється за допомогою <АС-04(08) _ODP[01] фільтр політики безпеки> як основи для прийняття рішень щодо управління потоками для <АС-04(08) _ODP[03] інформаційних потоків>; АС-04(08)(а)[01] контроль інформаційних потоків здійснюється за допомогою <АС-04(08) _ODP[02] фільтр політики конфіденційності> як основи для прийняття рішень щодо контролю потоків для <АС-04(08) _ODP[04] інформаційних потоків>

1.4.9. ПЕРЕВІРКИ, ЩО ПРОВОДИТЬ ПЕРСОНАЛ (АС-4(9))

Примусово використовувати перевірку персоналом [Призначення: потоки інформації, визначені організацією] за таких умов: [Призначення: умови, визначені організацією].

No: 1

Name: ac_4_9_01

Type: list

Default: ["admin", "security_officer"]

Перевірка персоналом використовуються для інформаційних потоків за умов

No: 2

Name: ac_4_9_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено інформаційні потоки, які потребують використання перевірку персоналом

No: 3

Name: ac_4_9_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено умови, за яких використання перевірки персоналом на інформаційні потоки має бути обов'язковим

1.4.10. АКТИВАЦІЯ ТА ДЕАКТИВАЦІЯ ФІЛЬТРІВ ПОЛІТИКИ БЕЗПЕКИ (АС-4(10))

Впровадити можливість для привілейованих адміністраторів активувати та деактивувати [Призначення: фільтри політики безпеки, що визначаються організацією] за таких умов: [Призначення: визначені організацією умови].

No: 1

Name: ac_4_10_01

Type: string

Default: nil

Привілейованим адміністраторам надано можливість активувати та деактивувати <АС-04(10) _ODP[01] фільтри безпеки> за <АС-04(10) _ODP[03] умов>

No: 2

Name: ac_4_10_02

Type: string

Default: nil

Привілейованим адміністраторам надано можливість активувати та деактивувати <АС-04(10) _ODP[02] фільтри конфіденційності> за <АС-04(10) _ODP[04] умов>

1.4.11. КОНФІГУРАЦІЯ ФІЛЬТРІВ ПОЛІТИКИ БЕЗПЕКИ (АС-4(11))

Впровадити можливість для привілейованих адміністраторів налаштувати [Призначення: визначені організацією фільтри політики безпеки] для підтримки різних політик безпеки.

No: 1

Name: ac_4_11_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Привілейованим адміністраторам надано можливість налаштовувати фільтри політики безпеки для підтримки різних політик безпеки або конфіденційності

No: 2

Name: ac_4_11_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Привілейованим адміністраторам надано можливість налаштовувати фільтри політики конфіденційності для підтримки різних політик безпеки або конфіденційності

No: 3

Name: ac_4_11_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено фільтри політики безпеки, які привілейовані адміністратори можуть налаштовувати для підтримки різних політик безпеки та конфіденційності

No: 4

Name: ac_4_11_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено фільтри політики конфіденційності, які привілейовані адміністратори можуть налаштовувати для підтримки різних політик безпеки та конфіденційності

1.4.12. ІДЕНТИФІКАТОРИ ТИПУ ДАНИХ (АС-4(12))

При передачі інформації між різними захищеними доменами використовувати [Призначення: визначені організацією ідентифікатори типів даних] для перевірки даних, необхідних для ухвалення рішень щодо інформаційного потоку.

No: 1

Name: ac_4_12_odp

Type: string

Default: nil

Визначено ідентифікатори типів даних, які будуть використовуватися для перевірки даних, необхідних для ухвалення рішень щодо інформаційних потоків; АС-04(12) при передачі інформації між різними доменами безпеки, ідентифікатори типів даних використовуються для перевірки даних, необхідних для ухвалення рішень щодо інформаційних потоків

1.4.13. ДЕКОМПОЗИЦІЯ НА ВІДПОВІДНІ ПОЛІТИЦІ СУБКОМПОНЕНТИ (АС-4(13))

При передачі інформації між різними захищеними доменами здійснювати декомпозицію інформації на [Призначення: визначені організацією субкомпоненти, що відповідають політиці] для представлення в механізмах реалізації політики.

No: 1

Name: ac_4_13_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

При передачі інформації між різними доменами безпеки інформація розкладається на субкомпоненти політики для подання механізмам забезпечення дотримання політики

No: 2

Name: ac_4_13_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено субкомпоненти політики, на які слід розкласти інформацію для подання до механізмів реалізації політики

1.4.14. ОБМЕЖЕННЯ ФІЛЬТРА ПОЛІТИКИ БЕЗПЕКИ (АС-4(14))

При передачі інформації між різними захищеними доменами реалізувати [Призначення: визначені організацією фільтри політики безпеки], що вимагають повного переліку форматів, які обмежують структуру та зміст даних.

No: 1

Name: ac_4_14_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

При передачі інформації між різними захищеними доменами, реалізовані фільтри політики безпеки вимагають повністю перелічених форматів, які обмежують структуру та зміст даних

No: 2

Name: ac_4_14_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

При передачі інформації між різними захищеними доменами, реалізовані фільтри політики конфіденційності вимагають повністю перелічених форматів, які обмежують структуру та вміст даних

No: 3

Name: ac_4_14_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено фільтри політики конфіденційності, які вимагають повного переліку форматів, що обмежують структуру та зміст даних

1.4.15. ВИЯВЛЕННЯ НЕСАНКЦІОНОВАНОЇ ІНФОРМАЦІЇ (АС-4(15))

При передачі інформації між різними захищеними доменами перевіряти інформацію на наявність [Призначення: визначеної організацією несанкціонованої інформації] та забороняти передачу такої інформації відповідно до [Призначення: визначеної організацією політики безпеки].

No: 1

Name: ac_4_15_01

Type: string

Default: nil

При передачі інформації між різними доменами безпеки інформація перевіряється на наявність <АС- 04(15)_ODP[01] несанкціонованої інформації>

No: 2

Name: ac_4_15_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

При передачі інформації між різними доменами безпеки забороняється передача несанкціонованої інформації відповідно до політики безпеки

No: 3

Name: ac_4_15_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

При передачі інформації між різними доменами безпеки забороняється передача несанкціонованої інформації відповідно до політики конфіденційності

No: 4

Name: ac_4_15_odp_01

Type: string

Default: nil

Визначено несанкціоновану інформацію, яку потрібно виявляти

No: 5

Name: ac_4_15_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політику безпеки, яка вимагає заборонити передачу несанкціонованої інформації між різними доменами безпеки (якщо вибрано)

No: 6

Name: ac_4_15_odp_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політику конфіденційності, яка вимагає заборонити передачу визначеної організацією несанкціонованої інформації між різними доменами безпеки (якщо вибрано)

1.4.16. ПЕРЕДАЧА ІНФОРМАЦІЇ ПРО ВЗАЄМОПОВ'ЯЗАНІ СИСТЕМИ (АС-4(16))

No: 1

Name: ac_4_16_01

Type: string

Default: nil

УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ - ПЕРЕДАЧА ІНФОРМАЦІЇ ПРО ВЗАЄМОПОВ'ЯЗАНІ СИСТЕМИ [Вилучено: Включено в АС-04]

1.4.17. ПРИВ'ЯЗКА АТРИБУТУ БЕЗПЕКИ (АС-4(18))

No: 1

Name: ac_4_18_01

Type: string

Default: nil

УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ - ПРИВ'ЯЗКА АТРИБУТУ БЕЗПЕКИ [Вилучено: Включено в АС-16]

1.4.18. ПЕРЕВІРКА МЕТАДАНИХ (АС-4(19))

Під час передачі інформації між різними захищеними доменами застосовувати до метаданих ту ж політику безпеки фільтрації, що й для корисних даних.

No: 1

Name: ac_4_19_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

При передачі інформації між різними доменами безпеки, фільтри політики безпеки реалізовано на метаданих

No: 2

Name: ac_4_19_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

При передачі інформації між різними доменами безпеки, фільтри політики конфіденційності реалізовано на метаданих

No: 3

Name: ac_4_19_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено фільтри політики безпеки, які буде застосовано до метаданих (якщо вибрано)

No: 4

Name: ac_4_19_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено фільтри політики конфіденційності, які буде застосовано до метаданих (якщо вибрано)

1.4.19. ЗАТВЕРДЖЕНІ РІШЕННЯ (АС-4(20))

Впровадити [Призначення: визначені організацією рішення про схвалені конфігурації] для керування потоком [Призначення: інформації, визначеної організацією] через захищені домени.

No: 1

Name: ac_4_20_01

Type: string

Default: nil

УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ - ЗАТВЕРДЖЕНІ РІШЕННЯ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: ac_4_20_odp_01

Type: string

Default: nil

Визначені рішення про схвалені конфігурації для керування потоками інформації через захищені домени

No: 3

Name: ac_4_20_odp_02

Type: string

Default: nil

Визначено інформацію, якою потрібно керувати, коли вона проходить через захищені домени

1.4.20. ФІЗИЧНЕ ТА ЛОГІЧНЕ ВІДДІЛЕННЯ ІНФОРМАЦІЙНИХ ПОТОКІВ (АС-4(21))

Відокремлювати потоки інформації логічно або фізично, використовуючи [Призначення: визначені організацією механізми та/або методи] для досягнення [Призначення: визначеного організацією необхідного поділу за типами інформації].

No: 1

Name: ac_4_21_02

Type: string

Default: nil

Інформаційні потоки логічно розділені за допомогою механізмів та/або методів для виконання необхідних розділень; інформаційні потоки фізично розділені за допомогою механізмів та/або методів для виконання розділень>; <АС-04(21)_ODP[03] необхідних

No: 2

Name: ac_4_21_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено механізми та/або методи, що використовуються для логічного розділення інформаційних потоків (якщо вибрано)

No: 3

Name: ac_4_21_odp_02

Type: string

Default: "автоматизований засіб моніторингу"

Визначено механізми та/або методи, що використовуються для фізичного розділення інформаційних потоків (якщо вибрано)

No: 4

Name: ac_4_21_odp_03

Type: string

Default: nil

Визначено необхідні поділи за типами інформації

1.4.21. ЄДИНИЙ ДОСТУП (АС-4(22))

Забезпечити доступ з одного пристрою до обчислювальних платформ, застосунків або даних, що розташовуються в декількох різних захищених доменах, одночасно запобігаючи передачі будь-якого потоку інформації між різними захищеними доменами.

No: 1

Name: ac_4_22_01

Type: integer

Default: 30

Доступ забезпечується з одного пристрою до обчислювальних платформ, застосунків або даних, що розташовуються в декількох різних захищених доменах, одночасно запобігаючи передачі інформації між різними захищеними доменами

1.4.22. МОДИФІКОВАНА ІНФОРМАЦІЯ, ЯКА НЕ ПІДЛЯГАЄ ОПРИЛЮДНЕННЮ (АС-4(23))

Під час передачі інформації між різними доменами безпеки змінюйте інформацію, яка не підлягає оприлюдненню, реалізувавши [Призначення: визначена організацією дія модифікації]

No: 1

Name: ac_4_23_odp

Type: string

Default: nil

Визначено дію модифікації, що застосовується до інформації, яка не підлягає оприлюдненню; АС-04(23) при передачі інформації між доменами безпеки інформація, що не підлягає оприлюдненню, модифікується шляхом реалізації дія модифікації

1.4.23. УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ НОРМАЛІЗОВАНИЙ ФОРМАТ (АС-4(24))

Під час передачі інформації між різними доменами безпеки аналізуйте вхідні дані у внутрішньому нормалізованому форматі та повторно генеруйте дані, щоб вони відповідали призначеній специфікації.

No: 1

Name: ac_4_24_1

Type: string

Default: nil

При передачі інформації між різними доменами безпеки вхідні дані розбираються у внутрішній, нормалізований формат

No: 2
 Name: ac_4_24_2
 Type: string
 Default: nil

При передачі інформації між різними доменами безпеки дані регенеруються, щоб відповідати їхній специфікації

1.4.24. ОЧИЩЕННЯ ДАНИХ (АС-4(25))

Під час передачі інформації між різними доменами безпеки очищуйте дані, щоб мінімізувати [Вибір (один або кілька): доставка зловмисного вмісту, керування та керування зловмисним кодом, доповнення зловмисного коду та стеганографічно закодовані дані; витік конфіденційної інформації] відповідно до [Призначення: політика, визначена організацією].

No: 1
 Name: ac_4_25_odp_01
 Type: string
 Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {доставка шкідливого коду, керування та контроль шкідливого коду, доповнення шкідливого коду та даних, закодованих стеганографією; витік конфіденційної інформації}

No: 2
 Name: ac_4_25_odp_02
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Визначено політику очищення даних

1.4.25. ДІЇ З ФІЛЬТРАЦІЇ АУДИТУ (АС-4(26))

Під час передачі інформації між різними доменами безпеки записуйте та перевіряйте дії фільтрації вмісту та результати для інформації, що фільтрується.

No: 1
 Name: ac_4_26_01
 Type: list
 Default: ["login", "logout", "failed_attempt"]

При передачі інформації між різними доменами безпеки дії з фільтрації вмісту фіксуються і перевіряються

No: 2
 Name: ac_4_26_02
 Type: string
 Default: nil

При передачі інформації між різними доменами безпеки, результати для інформації, що фільтрується, записуються і перевіряються

1.4.26. УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ПОТОКАМИ КО-ВІ/НЕЗАЛЕЖНІ ФІЛЬТРУЮЧІ МЕХАНІЗМИ (АС-4(27))

НАДЛИШКОВІ/НЕЗАЛЕЖНІ ФІЛЬТРУЮЧІ МЕХАНІЗМИ - Під час передачі інформації між різними доменами безпеки впроваджуйте рішення фільтрації вмісту, які забезпечують надлишкові та незалежні механізми фільтрації для кожного типу даних.

No: 1
 Name: ac_4_27_01
 Type: integer
 Default: 30

Під час передачі інформації між системами безпеки впроваджені рішення для фільтрації контенту забезпечують надлишкові та незалежні механізми фільтрації для кожного типу даних

1.4.27. ЛІНІЙНІ ФІЛЬТРУВАЛЬНІ КАНАЛИ (АС-4(28))

Під час передачі інформації між різними доменами безпеки запровадьте конвеєр лінійного фільтрування вмісту, який забезпечується дискреційним і обов'язковим контролем доступу.

No: 1
 Name: ac_4_28_01
 Type: string
 Default: nil

При передачі інформації між доменами безпеки реалізовано лінійний конвеєр фільтрації контенту, який забезпечується дискретними та обов'язковими засобами контролю доступу

1.4.28. УПРАВЛІННЯ ІНФОРМАЦІЙНИМИ ХАНІЗМІВ ОРКЕСТРОВКИ (АС-4(29))

Під час передачі інформації між різними доменами безпеки використовуйте механізми оркестровки фільтрів вмісту, щоб забезпечити: а. Механізми фільтрації вмісту успішно завершують виконання без помилок; б. Дії фільтрації вмісту виконуються в правильному порядку та відповідають [Призначення: політика, визначена організацією]

No: 1
 Name: ac_4_29_a
 Type: string
 Default: "автоматизований засіб моніторингу"

При передачі інформації між доменами безпеки використовуються механізми оркестрування фільтрації контенту, які гарантують, що механізми фільтрації контенту успішно завершать виконання без помилок

No: 2
 Name: ac_4_29_b_01
 Type: list
 Default: ["login", "logout", "failed_attempt"]

При передачі інформації між доменами безпеки використовуються механізми оркестрування фільтрації контенту, які гарантують, що дії з фільтрації контенту відбуваються в правильному порядку

No: 3
 Name: ac_4_29_b_02
 Type: list
 Default: ["login", "logout", "failed_attempt"]

При передачі інформації між доменами безпеки використовуються механізми оркестрування фільтрації контенту, які гарантують, що дії з фільтрації контенту відповідають політиці.

No: 4
 Name: ac_4_29_odp
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Визначено політику щодо дій з фільтрації контенту

1.4.29. МЕХАНІЗМИ ФІЛЬТРАЦІЇ З ВИКОРИСТАННЯМ КІЛЬКОХ ПРОЦЕСІВ (АС-4(30))

Під час передачі інформації між різними доменами безпеки реалізуйте механізми фільтрації вмісту за допомогою кількох процесів.

No: 1

Name: ac_4_30_01

Type: string

Default: "автоматизований засіб моніторингу"

При передачі інформації між доменами безпеки реалізовані механізми контент-фільтрації з використанням декількох процесів. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

1.4.30. ЗАПОБІГАННЯ СПРОБАМ ПЕРЕДАЧІ ВМІСТУ, ЯКИЙ НЕ ПРОЙШОВ ПЕРЕВІРКУ ФІЛЬТРАЦІЇ (АС-4(31))

Під час передачі інформації між різними доменами безпеки запобігайте передачі вмісту, який не пройшов перевірку фільтрації до домену-одержувача.

No: 1

Name: ac_4_31_01

Type: string

Default: nil

При передачі інформації між різними доменами безпеки запобігається передача вмісту який не пройшов фільтрацію

1.4.31. ВИМОГИ ДО ПРОЦЕСУ ПЕРЕДАЧІ ІНФОРМАЦІЇ (АС-4(32))

Під час передачі інформації між різними доменами безпеки, процес, який передає інформацію між конвеєрами фільтрації: а. не фільтрує вміст повідомлення; б. перевіряє метадані фільтрації; с. забезпечує успішне завершення фільтрації вмісту, пов'язаного з метаданими фільтрації; і d. передає вміст до цільового фільтруючого конвеєра.

Немає параметрів для цього контролю.

1.5. РОЗМЕЖУВАННЯ ОBOB'ЯЗКІВ (АС-5)

а. Розмежувати і документувати [Призначення: визначені організацією обов'язки окремих осіб]. б. Установити правила авторизації доступу для підтримки розмежування обов'язків.

No: 1

Name: ac_5_odp

Type: string

Default: nil

Визначено обов'язки осіб, які потребують розмежування; АС-05[a] обов'язки осіб визначені та задокументовані; АС-05[b] визначено права авторизації доступу до системи для підтримки розмежування обов'язків

1.6. МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ (АС-6)

Впровадити принцип мінімізації повноважень, який дозволяє користувачам (або процесам, що діють від імені користувачів) здійснювати лише такі авторизовані звернення, які необхідні для виконання визначених завдань відповідно до цілей (призначення, місії) організації та функцій.

No: 1
Name: ac_6_01
Type: string
Default: nil

Застосовується принцип мінімізації повноважень, який дозволяє користувачам (або процесам, що діють від імені користувачів) здійснювати лише такі авторизовані звернення, які необхідні для виконання поставлених завдань організації

1.6.1. АВТОРИЗОВАНИЙ ДОСТУП ДО ФУНКЦІЙ БЕЗПЕКИ (АС-6(1))

No: 1
Name: ac_6_1_a_01
Type: string
Default: nil

Авторизовано доступ для осіб та ролей до функцій безпеки (розгорнуті на апаратному забезпеченні)

No: 2
Name: ac_6_1_a_02
Type: string
Default: nil

Авторизовано доступ для осіб та ролей до функцій безпеки (розгорнуті на програмному забезпеченні)

No: 3
Name: ac_6_1_a_03
Type: string
Default: nil

Авторизовано доступ для осіб та ролей до функцій безпеки (розгорнуті на мікропрограмному забезпеченні)

No: 4
Name: ac_6_1_b
Type: string
Default: nil

Авторизовано доступ для осіб та ролей до інформації

No: 5
Name: ac_6_1_odp_01
Type: list
Default: ["admin", "security_officer"]

Визначені особи або ролі з авторизованим доступом до функцій безпеки та інформації, що має відношення до безпеки

No: 6
Name: ac_6_1_odp_02
Type: string
Default: nil

Визначені функції безпеки (розгорнуті в апаратному забезпеченні) для авторизованого доступу

No: 7

Name: ac_6_1_odp_03

Type: string

Default: nil

Визначені функції безпеки (розгорнуті в програмному забезпеченні) для авторизованого доступу

No: 8

Name: ac_6_1_odp_04

Type: string

Default: nil

Визначені функції безпеки (розгорнуті в мікропрограмному забезпеченні) для авторизованого доступу

No: 9

Name: ac_6_1_odp_05

Type: string

Default: nil

Визначено інформацію, важливу для забезпечення безпеки, для авторизованого доступу

1.6.2. НЕПРИВІЛЕЙОВАНИЙ ДОСТУП ДО НЕЗАХИЩЕНИХ ФУНКЦІЙ (АС-6(2))

Вимагати від користувачів облікових записів системи або ролей, які мають доступ до [Призначення: визначених організацією функцій безпеки або інформації, що стосується безпеки], використовувати непривілейовані облікові записи чи ролі під час доступу до незахищених функцій.

No: 1

Name: ac_6_2_01

Type: list

Default: ["admin", "security_officer"]

Користувачі облікових записів (або ролей) системи з доступом до функцій безпеки або інформації, що стосується безпеки, повинні використовувати непривілейовані облікові записи або ролі під час доступу до незахищених функцій

No: 2

Name: ac_6_2_odp

Type: string

Default: nil

Визначені функції безпеки або інформація, що стосується безпеки

1.6.3. РОЗДІЛЬНІ ДОМЕНИ ОБРОБКИ (АС-6(4))

Надати окремі домени обробки даних для забезпечення більш точного розподілу повноважень користувача.

No: 1

Name: ac_6_4_01

Type: string

Default: nil

Надаються окремі домени обробки для більш тонкого розподілу повноважень користувачів

1.6.4. ПРИВІЛЕЙОВАНІ ОБЛІКОВІ ЗАПИСИ (АС-6(5))

Обмежити привілейовані облікові записи в системі згідно з [Призначення: визначеним організацією персоналом або ролями].

No: 1

Name: ac_6_5_01

Type: list

Default: ["admin", "security_officer"]

Привілейовані облікові записи в системі обмежено персонал або ролі

No: 2

Name: ac_6_5_odp

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, яким мають бути обмежені привілейовані облікові записи в системі

1.6.5. ПРИВІЛЕЙОВАНИЙ ДОСТУП КОРИСТУВАЧАМИ, ЩО НЕ НАЛЕЖАТЬ ДО ОРГАНІЗАЦІЇ (АС-6(6))

Заборонити привілейований доступ до системи користувачам, які не належать до організації.

No: 1

Name: ac_6_6_01

Type: string

Default: nil

Привілейований доступ до системи для користувачів, які не є членами організації, заборонено

1.6.6. ПЕРЕГЛЯД ПОВНОВАЖЕНЬ КОРИСТУВАЧА (АС-6(7))

а) Переглядати [Призначення: з визначеною організацією частотою] повноваження призначених для [Призначення: визначених організацією посад або класів користувачів] для перевірки необхідності таких повноважень; б) За необхідності перепризначити або зняти повноваження, правильного відображення цілей (місії) організації та потреб організації. для

No: 1

Name: ac_6_7_a

Type: integer

Default: 30

Повноваження, призначені ролям і класам, переглядаються з частотою для перевірки необхідності таких повноважень

No: 2

Name: ac_6_7_b

Type: string

Default: nil

Привілеї перепризначаються або знімаються, якщо це необхідно, для правильного відображення місії організації та потреб

No: 3

Name: ac_6_7_odp_01

Type: integer

Default: 30

Визначено частоту перегляду повноважень, призначених ролям або класам користувачів

No: 4

Name: ac_6_7_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено ролі або класи користувачів, яким призначено повноваження

1.6.7. РІВНІ ПРИВІЛЕЇВ ДЛЯ ВИКОНАННЯ КОДУ (АС-6(8))

Запобігати виконанню програмного забезпечення на рівні привілеїв вищому, ніж доступний користувачеві, який використовує програмне забезпечення [Призначення: визначене організацією програмне забезпечення].

No: 1

Name: ac_6_8_01

Type: string

Default: nil

Програмне забезпечення заборонено виконувати з вищими рівнями привілеїв, ніж у користувачів, які виконують це програмне забезпечення

1.6.8. АУДИТ ВИКОРИСТАННЯ ПРИВІЛЕЙОВАНИХ ФУНКЦІЙ (АС-6(9))

Реєструвати виконання привілейованих функцій.

No: 1

Name: ac_6_9_01

Type: string

Default: nil

Проводиться аудит виконання привілейованих функцій

1.6.9. ЗАБОРОНА НЕПРИВІЛЕЙОВАНИМ КОРИСТУВАЧАМ ВИКОНУВАТИ ПРИВІЛЕЙОВАНІ ФУНКЦІЇ (АС-6(10))

Вжити заходи для запобігання можливості виконувати привілейовані функції непривілейованими користувачами.

No: 1

Name: ac_6_10_01

Type: string

Default: nil

МІНІМІЗАЦІЯ ПОВНОВАЖЕНЬ - ЗАБОРОНА НЕПРИВІЛЕЙОВАНИМ КОРИСТУВАЧАМ ВИКОНУВАТИ ПРИВІЛЕЙОВАНІ ФУНКЦІЇ МЕТА ОЦІНКИ: Визначити, чи:

1.7. НЕВДАЛІ СПРОБИ ВХОДУ В СИСТЕМУ (АС-7)

а. Встановити обмеження на [Призначення: визначену організацією кількість] послідовних неуспішних спроб входу користувача в систему впродовж [Призначення: визначеного організацією часового періоду]. б. Автоматично виконати [Вибір (один або декілька): блокування облікового запису/вузла на [Призначення: визначений організацією часовий період]; блокуван-

ня облікового запису/вузла, доки він не буде розблокований адміністратором; затримання наступної команди входу в систему за [Надання: визначеним організацією алгоритмом затримки]; виконати [Призначення: визначені організацією дії]], коли перевищено максимальну кількість невдалих спроб входу в систему.

No: 1

Name: ac_7_a

Type: integer

Default: 30

Застосовано обмеження на кількість послідовних неуспішних спроб входу користувача протягом періоду часу

No: 2

Name: ac_7_odp_01

Type: integer

Default: 30

Визначається кількість послідовних неуспішних спроб входу користувача, дозволених протягом певного періоду часу

No: 3

Name: ac_7_odp_02

Type: integer

Default: 30

Визначено період часу, яким обмежується кількість послідовних неуспішних спроб входу користувача

No: 4

Name: ac_7_odp_03

Type: string

Default: "AES-256-GCM"

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {заблокувати обліковий запис або вузол на період часу; заблокувати обліковий запис або вузол до зняття адміністратором; затримати наступний запит на вхід за алгоритмом затримки; повідомити системного адміністратора; виконати іншу дію}

No: 5

Name: ac_7_odp_04

Type: integer

Default: 30

Період часу, на який буде заблоковано обліковий запис або вузол (якщо вибрано)

No: 6

Name: ac_7_odp_05

Type: string

Default: "AES-256-GCM"

Визначено алгоритм затримки наступного запиту на вхід (якщо вибрано)

No: 7

Name: ac_7_odp_06

Type: integer

Default: 3

Інша дія, яка буде виконана після перевищення максимальної кількості невдалих спроб (якщо вибрано)

1.7.1. АВТОМАТИЧНЕ БЛОКУВАННЯ ОБЛІКОВОГО ЗАПИСУ (АС-7(1))

No: 1
Name: ac_7_1_01
Type: integer
Default: 3

НЕВДАЛІ СПРОБИ ВХОДУ В СИСТЕМУ - АВТОМАТИЧНЕ БЛОКУВАННЯ ОБЛІКОВОГО ЗАПИСУ
[Вилучено: Включено в АС-07]

1.7.2. ОЧИЩЕННЯ АБО СТИРАННЯ МОБІЛЬНОГО ПРИСТРОЮ (АС-7(2))

Очистити або стерти інформацію з [Призначення: визначених організацією мобільних пристроїв] на основі [Призначення: визначених організацією вимог та методик очищення чи стирання] після [Призначення: визначеної організацією кількості] послідовних невдалих спроб входу в систему з пристрою.

No: 1
Name: ac_7_2_01
Type: integer
Default: 3

Інформація очищується або стирається з мобільних пристроїв на основі вимог або методів очищення або стирання після <АС-07(02)_ODP[03 кількість]> послідовних, невдалих спроб входу на пристрій

No: 2
Name: ac_7_2_odp_01
Type: string
Default: nil

Визначено мобільні пристрої, які підлягають очищенню або стиранню інформації

No: 3
Name: ac_7_2_odp_02
Type: string
Default: nil

Визначено вимоги та методи очищення чи стирання інформації з мобільних пристроїв

No: 4
Name: ac_7_2_odp_03
Type: integer
Default: 3

Визначається кількість послідовних невдалих спроб входу в систему до того, як інформація буде очищена або стерта з мобільних пристроїв

1.7.3. ОБМЕЖЕННЯ НА СПРОБИ БІОМЕТРИЧНОГО ВХОДУ (АС-7(3))

Обмежити кількість невдалих спроб входу за допомогою біометрики [Призначення: визначена організацією кількість].

No: 1
Name: ac_7_3_01

Type: integer

Default: 3

Визначено кількість невдалих спроб входу за допомогою біометрики обмежно кількість невдалих спроб входу за допомогою біометрики

1.7.4. ВИКОРИСТАННЯ АЛЬТЕРНАТИВНОГО ФАКТОРА (АС-7(4))

а) Дозволити використання [Призначення: визначені організацією фактори автентифікації], які відрізняються від основних факторів автентифікації після перевищення визначеної організацією кількості послідовних невдалих спроб входу в систему; б) Обмежити [Призначення: визначена організацією кількість] послідовних невдалих спроб входу за допомогою використання альтернативних факторів користувачем протягом [Призначення: визначеного організацією періоду часу].

No: 1

Name: ac_7_4_a

Type: integer

Default: 30

Фактори автентифікації, які відрізняються від основних факторів автентифікації, дозволяється використовувати після перевищення кількості визначених організацією послідовних невдалих спроб входу; АС-07(04)(b) введено обмеження на послідовних невдалих спроб входу через використання користувачем альтернативних факторів протягом періоду часу

No: 2

Name: ac_7_4_odp_01

Type: string

Default: nil

Визначено фактори автентифікації, які дозволено використовувати, але які відрізняються від основних факторів автентифікації

No: 3

Name: ac_7_4_odp_02

Type: integer

Default: 3

Визначено кількість послідовних, недійсних спроб входу через використання альтернативних факторів

No: 4

Name: ac_7_4_odp_03

Type: integer

Default: 30

Визначено період часу, протягом якого користувач може спробувати увійти через альтернативні фактори

1.8. ПОПЕРЕДЖЕННЯ ПРО ВИКОРИСТАННЯ СИСТЕМИ (АС-8)

а. б. Демонструвати користувачам [Призначення: визначене організацією сповіщення або банер про використання системи] перед тим, як надавати доступ до системи, що забезпечує безпеку та приватність відповідно до чинних законів, нормативних документів, наказів, директив, політик, правил, стандартів і керівних принципів, які зазначають, що: 1. користувачі здійснюють доступ до урядової системи; 2. використання системи може контролюватися, реєструватися та підлягати аудиту; 3. несанкціоноване використання системи забороняється та приводить

до кримінальної та цивільної відповідальності; 4. використання системи означає згоду на моніторинг і запис дій користувача. Зберігати сповіщення або банер на екрані, доки користувачі не визнають умови використання та не приймуть явних дій для входу в систему або подальшого доступу до системи. с. Для загальнодоступних систем: 1. демонструвати інформацію про умови використання системи [Призначення: визначені організацією умови], перш ніж надавати подальший доступ до загальнодоступної системи; 2. демонструвати посилання, якщо такі є, на моніторинг, запис або аудит, які узгоджуються з акомодациєю приватності для таких систем, які зазвичай забороняють такі дії; 3. мати опис авторизованого використання системи.

No: 1

Name: ac_8_c_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначається сповіщення або банер про використання системи, який система буде показувати користувачам перед наданням доступу до системи; визначено умови використання системи, які система відображатиме перед наданням подальшого доступу; повідомлення про використання системи відображається користувачам перед наданням доступу до системи, яке містить повідомлення про конфіденційність і безпеку, що відповідають чинним законам, нормативним документам, наказам, директивам, політикам, правилам, стандартам і керівним принципам; у повідомленні про використання системи зазначено, що користувачі отримують доступ до урядової системи; у повідомленні про використання системи зазначено, що використання системи може контролюватися, реєструватися та підлягати аудиту; у повідомленні про використання системи зазначено, що несанкціоноване використання системи заборонено і тягне за собою кримінальну та цивільну відповідальність; у повідомленні про використання системи зазначено, що використання системи означає згоду на моніторинг і запис дій; сповіщення або банер залишається на екрані до тих пір, поки користувачі не визнають умови використання та не приймуть явні дії для входу в систему або подальшого доступу до неї; для загальнодоступних систем інформація про використання системи умови відображається перед наданням подальшого доступу до загальнодоступної системи; для загальнодоступних систем відображаються будь-які посилання на моніторинг, запис або аудит, які узгоджуються з положеннями про конфіденційність таких систем, що зазвичай забороняють ці види діяльності; для загальнодоступних систем додається опис авторизованого використання системи

1.9. БЛОКУВАННЯ ПРИСТРОЮ (АС-11)

а. Заборонити подальший доступ до системи шляхом ініціювання блокування пристрою після [Призначення: визначеного організацією періоду] бездіяльності або після отримання запиту від користувача. б. Зберігати блокування пристрою, поки користувач не відновить доступ, використовуючи встановлені процедури ідентифікації та автентифікації.

No: 1

Name: ac_11_b

Type: string

Default: nil

Блокування пристрою зберігається доти, доки користувач не відновить доступ за допомогою встановлених процедур ідентифікації та автентифікації

No: 2

Name: ac_11_odp_01

Type: integer

Default: 30

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {ініціювання блокування пристрою після періоду неактивності; вимога до користувача ініціювати блокування пристрою перед тим, як залишити систему без нагляду}

No: 3
Name: ac_11_odp_02
Type: integer
Default: 30

Часовий проміжок бездіяльності, після якого ініціюється блокування пристрою (якщо вибрано)

1.9.1. ПРИХОВАНІ ДИСПЛЕЇ (АС-11(1))

No: 1
Name: ac_11_1_01
Type: string
Default: nil

Система приховує (через блокування сеансу) інформацію, попередньо видиму на дисплеї, загальнодоступним зображенням

1.10. Припинення сеансу (АС-12)

Сеанс користувача має завершуватися автоматично після [Призначення: визначених організацією умов або тригерних подій, що вимагають припинення сеансу].

No: 1
Name: ac_12_01
Type: string
Default: nil

Сеанс користувача автоматично завершується після виконання умов або подій

No: 2
Name: ac_12_odp
Type: list
Default: ["login", "logout", "failed_attempt"]

Визначено умови або події, що вимагають припинення сеансу

1.10.1. ІНІЦІЙОВАНЕ КОРИСТУВАЧЕМ БЛОКУВАННЯ (АС-12(1))

Забезпечити можливість припинення сеансів зв'язку з ініціативи користувача, коли автентифікація використовується для отримання доступу до [Призначення: визначених організацією інформаційних ресурсів].

No: 1
Name: ac_12_1_01
Type: string
Default: nil

Для сеансів зв'язку, ініційованих користувачем, передбачено можливість виходу з системи щоразу, коли автентифікація використовується для отримання доступу до інформаційних ресурсів

1.10.2. ПОВІДОМЛЕННЯ ПРО ПРИПИНЕННЯ СЕАНСУ (АС-12(2))

Відобразити виразне повідомлення для користувача, що вказує на достовірне припинення автентифікованих сеансів зв'язку.

No: 1
Name: ac_12_2_01
Type: string
Default: nil

Користувачам буде показано явне повідомлення про завершення сеансу автентифікованого зв'язку

1.10.3. ЗАСТЕРЕЖНЕ ПОВІДОМЛЕННЯ ПРО ТЕ, ЩО ЧАС СЕСІЇ ДОБІГАЄ КІНЦЯ (АС-12(3))

Відобразити виразне повідомлення користувачам, що вказує, що сесія добігає кінця [Завдання: визначений організацією час до кінця сесії].

No: 1
Name: ac_12_3_01
Type: integer
Default: 30

Визначено час до кінця сесії для відображення користувачам; виводиться явне повідомлення користувачам про те, що сеанс завершиться у час

1.11. ВІДДАЛЕНИЙ ДОСТУП (АС-17)

а. Встановити та задокументувати обмеження на використання, вимоги до конфігурації/підключення та рекомендації щодо здійснення кожного типу віддаленого доступу. б. Авторизувати віддалений доступ до системи, перш ніж будуть дозволені такі підключення.

No: 1
Name: ac_17_a_02
Type: string
Default: nil

Для кожного типу дозволеного віддаленого доступу встановлені та задокументовані вимоги до конфігурації/підключення

No: 2
Name: ac_17_a_03
Type: string
Default: nil

Для кожного типу дозволеного віддаленого доступу встановлені та задокументовані рекомендації

No: 3
Name: ac_17_b
Type: string
Default: nil

Кожен тип віддаленого доступу до системи авторизується перед тим, як дозволити такі підключення

1.11.1. АВТОМАТИЗОВАНИЙ МОНІТОРИНГ ТА УПРАВЛІННЯ (АС-17(1))

No: 1

Name: ac_17_1_01

Type: string

Default: nil

Проводиться моніторинг методами віддаленого доступу

No: 2

Name: ac_17_1_02

Type: string

Default: nil

Проводиться управління методами віддаленого доступу

1.11.2. ЗАХИСТ КОНФІДЕНЦІЙНОСТІ ТА ЦІЛІСНОСТІ ЗА ДОПОМОГОЮ ШИФРУВАННЯ (АС-17(2))

No: 1

Name: ac_17_2_01

Type: string

Default: "AES-256-GCM"

ВІДДАЛЕНИЙ ДОСТУП - ЗАХИСТ КОНФІДЕНЦІЙНОСТІ ТА ЦІЛІСНОСТІ ЗА ДОПОМОГОЮ ШИФРУВАННЯ МЕТА ОЦІНКИ: Визначте, чи інформаційна система криптографічні механізми

1.11.3. КЕРОВАНІ ТОЧКИ КОНТРОЛЮ ДОСТУПУ (АС-17(3))

No: 1

Name: ac_17_3_01

Type: string

Default: nil

Віддалений доступ маршрутизується через авторизовані та керовані точки контролю доступу до мережі

1.11.4. ПРИВІЛЕЙОВАНІ КОМАНДИ ТА ДОСТУП (АС-17(4))

No: 1

Name: ac_17_4_a_01

Type: string

Default: nil

Виконання привілейованих команд за допомогою віддаленого доступу дозволено лише для наступних потреб: потреби

No: 2

Name: ac_17_4_a_02

Type: string

Default: nil

Доступ до інформації, важливої для безпеки, за допомогою віддаленого доступу дозволяється лише для наступних потреб: потреби

No: 3

Name: ac_17_4_b

Type: string

Default: nil

Обґрунтування віддаленого доступу задокументовано в плані захисту інформації

No: 4

Name: ac_17_4_odp_01

Type: string

Default: nil

Визначено потреби, що потребують виконання привілейованих команд за допомогою віддаленого доступу; АС-17(04)_ODP[02] визначено потреби, що вимагають доступу до інформації, що стосується безпеки, за допомогою віддаленого доступу

1.11.5. МОНІТОРИНГ ДЛЯ НЕАВТОРИЗОВАНИХ ПІДКЛЮЧЕНЬ (АС-17(5))

No: 1

Name: ac_17_5_01

Type: string

Default: nil

ВІДДАЛЕНИЙ ДОСТУП - МОНІТОРИНГ ДЛЯ НЕАВТОРИЗОВАНИХ ПІДКЛЮЧЕНЬ [Вилучено: Включено в CI-04]

1.11.6. ЗАХИСТ ІНФОРМАЦІЇ (АС-17(6))

No: 1

Name: ac_17_6_01

Type: string

Default: "автоматизований засіб моніторингу"

Інформація про механізми віддаленого доступу захищена від неавторизованого використання та розкриття

1.11.7. ДОДАТКОВИЙ ЗАХИСТ ДЛЯ ДОСТУПУ ДО ФУНКЦІЙ БЕЗПЕКИ (АС-17(7))

Немає параметрів для цього контролю.

1.11.8. ДЕАКТИВАЦІЯ НЕЗАХИЩЕНИХ ПРОТОКОЛІВ МЕРЕЖІ (АС-17(8))

No: 1

Name: ac_17_8_01

Type: string

Default: "TLS 1.3"

ВІДДАЛЕНИЙ ДОСТУП - ДЕАКТИВАЦІЯ НЕЗАХИЩЕНИХ ПРОТОКОЛІВ МЕРЕЖІ [Вилучено: Включено в CM-07]

1.11.9. ВІДКЛЮЧЕННЯ АБО ДЕАКТИВАЦІЯ ДОСТУПУ (АС-17(9))

No: 1

Name: ac_17_9_01

Type: integer

Default: 30

Передбачена можливість відключення або деактивації віддаленого доступу до системи протягом періоду часу

No: 2

Name: ac_17_9_odp

Type: integer

Default: 30

Визначено період часу, протягом якого потрібно відключити або деактивувати віддалений доступ до системи

1.11.10. (10) АВТЕНТИФІКАЦІЯ ВІДДАЛЕНИХ КОМАНД (АС-17(10))

No: 1

Name: ac_17_10_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначені механізми аутентифікації- ють визначені віддалені команди

No: 2

Name: ac_17_10_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено механізми, реалізовані для автентифікації віддалених команд

No: 3

Name: ac_17_10_odp_02

Type: string

Default: nil

Визначено віддалені команди, які мають бути автентифіковані механізмами

1.12. БЕЗДРОТОВИЙ ДОСТУП (АС-18)

а. Установити обмеження на використання, вимоги до конфігурації/підключення та рекомендації щодо здійснення бездротового доступу. б. Авторизувати бездротовий доступ до системи, перш ніж будуть дозволені такі підключення.

No: 1

Name: ac_18_a_01

Type: string

Default: nil

Встановлено обмеження на використання щодо здійснення бездротового доступу

No: 2

Name: ac_18_a_02

Type: string

Default: nil

Встановлено вимоги до конфігурації або підключення щодо здійснення бездротового доступу

No: 3

Name: ac_18_a_03

Type: string

Default: nil

Встановлено доступу

No: 4

Name: ac_18_b

Type: string

Default: nil

Авторизується бездротовий доступ до системи перед тим, як дозволяти такі з'єднання. рекомендації щодо здійснення бездротового

1.12.1. АВТЕНТИФІКАЦІЯ ТА ШИФРУВАННЯ (АС-18(1))

No: 1

Name: ac_18_1_02

Type: string

Default: "AES-256-GCM"

Бездротовий доступ до системи захищений за допомогою шифрування

1.12.2. БЕЗДРОТОВИЙ ПІДКЛЮЧЕНЬ (АС-18(2))

No: 1

Name: ac_18_2_01

Type: string

Default: nil

БЕЗДРОТОВИЙ ПІДКЛЮЧЕНЬ ДОСТУП - МОНІТОРИНГ НЕАВТОРИЗОВАНИХ [Вилучено: Включено в SI-04]

1.12.3. ВІДКЛЮЧЕННЯ БЕЗДРОТОВОЇ МЕРЕЖІ (АС-18(3))

No: 1

Name: ac_18_3_01

Type: string

Default: nil

Відключено, у разі відсутності необхідності у використанні, вбудовані в компоненти системи можливості бездротових мереж до їх виклику та розгортання

1.12.4. БЕЗДРОТОВИЙ ДОСТУП СТУВАЧАМИ (АС-18(4))

No: 1

Name: ac_18_4_01

Type: string

Default: nil

Встановлено користувачів, яким дозволено самостійно налаштовувати можливості бездротової мережі

No: 2
 Name: ac_18_4_02
 Type: string
 Default: nil

Явно авторизуються визначені користувачі, яким дозволено самостійно налаштовувати можливості бездротової мережі

1.12.5. АНТЕНИ ТА РІВЕНЬ ПОТУЖНОСТІ ПЕРЕДАЧІ (АС-18(5))

No: 1
 Name: ac_18_5_01
 Type: string
 Default: nil

Вибрано такі радіо антени, які зменшують ймовірність того, що корисні сигнали можуть прийматися за межами контрольованих організацією меж

No: 2
 Name: ac_18_5_02
 Type: string
 Default: nil

Калібруються рівні потужності передачі, щоб зменшити ймовірність того, що корисні сигнали можуть прийматися за контрольованими організацією межами

1.13. КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ (АС-19)

а. Встановити обмеження на використання, вимоги до конфігурації, вимоги до підключення і рекомендації щодо впровадження мобільних пристроїв, контрольованих організацією. б. Авторизувати підключення мобільних пристроїв до систем, які експлуатуються організацією.

No: 1
 Name: ac_19_a_01
 Type: string
 Default: nil

Встановлено вимоги до конфігурації мобільних пристроїв, що контролюються організацією, в тому числі, коли такі пристрої перебувають за межами контрольованої території

No: 2
 Name: ac_19_a_02
 Type: string
 Default: nil

Встановлюються вимоги до підключення для мобільних пристроїв, що контролюються організацією, в тому числі, коли такі пристрої знаходяться за межами контрольованої території

No: 3
 Name: ac_19_a_03
 Type: string
 Default: nil

Розроблено рекомендації щодо впровадження для мобільних пристроїв, які контролюються організацією, в тому числі, коли такі пристрої перебувають за межами контрольованої території

No: 4
Name: ac_19_b
Type: string
Default: nil

Авторизовано підключення мобільних пристроїв до систем організації

1.13.1. ВИКОРИСТАННЯ ПИСЬМОВИХ ТА ПОРТАТИВНИЙ ПРИСТРОЇВ ДЛЯ ЗБЕРІГАННЯ ДАНИХ (АС-19(1))

No: 1
Name: ac_19_1_01
Type: string
Default: nil

КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПИСЬМОВИХ ТА ПОРТАТИВНИЙ ПРИСТРОЇВ ДЛЯ ЗБЕРІГАННЯ ДАНИХ [Вилучено: Включено в МР-07]

1.13.2. ВИКОРИСТАННЯ ПЕРСОНАЛЬНИХ ПОРТАТИВНИХ ПРИСТРОЇВ ЗБЕРІГАННЯ ДАНИХ (АС-19(2))

No: 1
Name: ac_19_2_01
Type: list
Default: ["admin", "security_officer"]

КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПЕРСОНАЛЬНИХ ПОРТАТИВНИХ ПРИСТРОЇВ ЗБЕРІГАННЯ ДАНИХ [Вилучено: Включено в МР-07]. АС-19(03) КОНТРОЛЬ ДОСТУПУ ДЛЯ МОБІЛЬНИХ ПРИСТРОЇВ - ВИКОРИСТАННЯ ПОРТАТИВНИХ ПРИСТРОЇВ ЗБЕРІГАННЯ ДАНИХ З НЕІДЕНТИФІКОВАНИМ ВЛАСНИКОМ [Вилучено: Включено в МР-07]

1.13.3. ВИКОРИСТАННЯ ПОРТАТИВНИХ ПРИСТРОЇВ ЗБЕРІГАННЯ ДАНИХ З НЕІДЕНТИФІКОВАНИМ ВЛАСНИКОМ (АС-19(3))

Немає параметрів для цього контролю.

1.13.4. ОБМЕЖЕННЯ ДЛЯ ЗАСЕКРЕЧЕНОЇ ІНФОРМАЦІЇ (АС-19(4))

No: 1
Name: ac_19_4_a
Type: list
Default: ["admin", "security_officer"]

Використання незахищених мобільних пристроїв на об'єктах, що містять системи, які обробляють, зберігають або передають секретну інформацію, заборонено, за винятком випадків, коли на це є спеціальний дозвіл уповноваженої посадової особи; АС-19(04)(b)(01) заборона підключення незахищених мобільних пристроїв до систем з обмеженим доступом застосовується до осіб, яким уповноважена посадова особа дозволила використовувати незахищені мобільні пристрої на об'єктах, що містять системи, які обробляють, зберігають або передають інформацію з обмеженим доступом; АС-19(04)(b)(02) дозвіл уповноваженої посадової особи на підключення незахищених мобільних пристроїв до незахищених систем вимагається від осіб, яким дозволено

використовувати незахищені мобільні пристрої на об'єктах, що містять системи, які обробляють, зберігають або передають інформацію з обмеженим доступом; АС-19(04)(b)(03) заборона використання внутрішніх або зовнішніх модемів чи бездротових інтерфейсів у складі незахищених мобільних пристроїв поширюється на осіб, яким уповноваженою посадовою особою дозволено використовувати незахищені мобільні пристрої під час виконання службових обов'язків, а також на осіб, які не мають права на використання таких пристроїв АС-19(04)(b)(04)[01] вибірковий огляд та перевірка незахищених мобільних пристроїв та інформації, що зберігається на них, посадовими особами є обов'язковими; АС-19(04)(b)(04)[02] дотримання політики обробки інцидентів застосовується у разі виявлення секретної інформації під час випадкового огляду та перевірки незахищених мобільних пристроїв

No: 2

Name: ac_19_4_c

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Підключення захищених мобільних пристроїв до засекречених систем обмежено відповідно до політики безпеки

No: 3

Name: ac_19_4_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено посадових осіб із захисту інформації, відповідальних за огляд та перевірку захищених мобільних пристроїв та інформації, що зберігається на цих пристроях

No: 4

Name: ac_19_4_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено політики безпеки, що обмежують підключення захищених мобільних пристроїв до засекречених систем

1.13.5. ПОВНЕ ШИФРУВАННЯ ПРИСТРОЇВ ТА СХОВИЩ ІНФОРМАЦІЇ (АС-19(5))

Немає параметрів для цього контролю.

1.14. ВИКОРИСТАННЯ ЗОВНІШНІХ СИСТЕМ (АС-20)

а. [Вибір (один або кілька): Встановіть [Призначення: умови, визначені організацією]; Визначте [Призначення: визначені організацією засоби контролю, які, як стверджується, будуть реалізовані на зовнішніх системах]], узгоджені з довірчими відносинами, встановленими з іншими організаціями, які володіють, експлуатують та/або обслуговують зовнішні системи, дозволяючи уповноваженим особам: 1. доступ до системи із зовнішніх систем; 2. обробляти, зберігати або передавати керовану організацією інформацію за допомогою зовнішніх систем; б. Заборонити використання [Призначення: організаційно-визначені типи зовнішніх систем].

No: 1

Name: ac_20_odp_01

Type: list

Default: []

Вибрано одне або більше з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {встановити умови та положення; визначити заходи захисту}

No: 2

Name: ac_20_odp_02

Type: list

Default: []

Визначено умови та положення, що відповідають довірчим відносинам, встановленим з іншими організаціями, які володіють, експлуатують та/або обслуговують зовнішні системи (якщо вибрано)

No: 3

Name: ac_20_odp_03

Type: string

Default: nil

Визначено заходи захисту, які мають бути застосовані до зовнішніх систем відповідно до довірчих відносин, встановлених з іншими організаціями, що володіють, експлуатують та/або обслуговують зовнішні системи (якщо обрано)

No: 4

Name: ac_20_odp_04

Type: string

Default: nil

Визначено типи зовнішніх систем, заборонених до використання

1.14.1. ОБМЕЖЕННЯ НА АВТОРИЗОВАНЕ ВИКОРИСТАННЯ (АС-20(1))

No: 1

Name: ac_20_1_a

Type: list

Default: ["admin", "security_officer"]

Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після перевірки виконання заходів безпеки та конфіденційності, зазначених у політиці безпеки та конфіденційності організації, а також планів безпеки та конфіденційності (якщо такі застосовуються)

No: 2

Name: ac_20_1_b

Type: list

Default: ["admin", "security_officer"]

Авторизовані особи мають право використовувати зовнішню систему для доступу до системи або для обробки, зберігання чи передачі інформації, що контролюється організацією, лише після збереження погоджених угод про підключення або обробку системи з структурою організації, на якій розміщена зовнішня система

1.14.2. ПЕРЕНОСНІ ПРИСТРОЇ ЗБЕРІГАННЯ ДАНИХ (АС-20(2))

No: 1

Name: ac_20_2_01

Type: list

Default: ["admin", "security_officer"]

Використання портативних пристроїв носіїв інформації уповноваженими особами обмежено у зовнішніх системах за допомогою обмеження

No: 2

Name: ac_20_2_odp

Type: list

Default: ["admin", "security_officer"]

Визначено обмеження на використання авторизованими особами портативних носіїв інформації у зовнішніх системах

1.14.3. СИСТЕМИ ТА КОМПОНЕНТИ, ЩО НЕ ЗНАХОДЯТЬСЯ У ВЛАСНОСТІ ОРГАНІЗАЦІЇ (АС-20(3))

No: 1

Name: ac_20_3_01

Type: string

Default: nil

Використання систем або компонентів систем, що не належать організації, для обробки, зберігання або передачі інформації, що належить організації, обмежується за допомогою обмеження

No: 2

Name: ac_20_3_odp

Type: string

Default: nil

Визначено обмеження на використання систем або компонентів систем, що не належать організації, для обробки, зберігання або передачі інформації організації

1.14.4. ПРИСТРОЇ ДЛЯ ЗБЕРІГАННЯ ДАНИХ, ЯКІ МОЖУТЬ МАТИ ДОСТУП ДО МЕРЕЖІ (АС-20(4))

No: 1

Name: ac_20_4_b

Type: string

Default: nil

Заборонено використання заборонені типи зовнішніх систем (якщо застосовно)

1.14.5. ПОРТАТИВНІ ПРИСТРОЇ ДЛЯ ЗБЕРІГАННЯ ДАНИХ – ЗАБОРОНА ВИКОРИСТАННЯ (АС-20(5))

No: 1

Name: ac_20_5_01

Type: list

Default: ["admin", "security_officer"]

Використання уповноваженими особами зовнішніх носіїв інформації, підконтрольних організації, на зовнішніх системах заборонено

1.15. ПУБЛІЧНО ДОСТУПНИЙ КОНТЕНТ (АС-22)

а. Призначити осіб, що уповноважені на розміщення інформації в загальнодоступній системі. б. Навчати уповноважених осіб тому, щоб загальнодоступна інформація не містила інформацію з обмеженим доступом. с. Переглядати запропонований зміст інформації до публікації в загальнодоступній системі, щоб гарантувати, що там не міститься інформація з обмеженим до-

ступом. d. Переглядати вміст загальнодоступної системи на предмет наявності там інформації з обмеженим доступом з [Призначення: визначеною організацією частотою]; така інформація має бути видалена в разі її виявлення.

No: 1

Name: ac_22_a

Type: list

Default: ["admin", "security_officer"]

Визначені особи уповноважені на розміщення інформації в загальнодоступній системі

No: 2

Name: ac_22_b

Type: list

Default: ["admin", "security_officer"]

Уповноважені особи проходять навчання, щоб гарантувати, що загальнодоступна інформація не містить інформацію з обмеженим доступом

No: 3

Name: ac_22_c

Type: string

Default: nil

Запропонований зміст інформації перевіряється до публікації в загальнодоступній системі, щоб гарантувати, що там не міститься інформація з обмеженим доступом

No: 4

Name: ac_22_d_01

Type: integer

Default: 30

Зміст у загальнодоступній системі перевіряється на наявність інформації з обмеженим доступом з частотою

No: 5

Name: ac_22_d_02

Type: string

Default: nil

Інформація з обмеженим доступом видаляється з загальнодоступної системи, якщо її виявлено

No: 6

Name: ac_22_odp

Type: integer

Default: 30

Визначено частоту, з якою слід переглядати вміст загальнодоступної системи на предмет наявності там інформації з обмеженим доступом

2. АТ

2.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ПІДВИЩЕННЯ ОБІЗНАНОСТІ ТА НАВЧАННЯ (АТ-1)

а. Розробити, задокументувати та поширити [Призначення: серед визначеного організацією персоналу або ролей]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-

процесу; рівень системи] політики обізнаності та навчання у сфері забезпечення безпеки та приватності, яка: (a) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинним законам, нормативним документам, директивам, нормам, політикам, стандартам та керівним документам. 2. Процедури, що сприяють реалізації політики підвищення обізнаності та професійної підготовки в галузі безпеки, приватності, а також пов'язаних з ними заходів захисту інформації та персональних даних. b. Призначити [Призначення: визначену організацією посадову особу] для управління політикою та процедурами підвищення обізнаності та навчання у сфері забезпечення безпеки та приватності. c. Переглядати та оновлювати: 1. Поточну політику [Призначення: частота, визначена організацією] і наступне [Призначення: події, визначені організацією]; 2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].

Немає параметрів для цього контролю.

2.2. НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ (АТ-2)

Впровадити базові тренінги з підвищення обізнаності у сфері безпеки та приватності для користувачів системи (включно з менеджерами, керівниками компаній і підрядниками): a. Забезпечити навчання грамотності з питань безпеки та конфіденційності для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників): 1. як частину початкового навчання для нових користувачів і [Призначення: частота, визначена організацією] після цього; 2. якщо цього потребують системні зміни або наступні [Призначення: події, визначені організацією]. b. Використовувати наведені нижче методи, щоб підвищити рівень безпеки та конфіденційності користувачів системи [Завдання: визначені організацією методи поінформованості]; c. Оновлювати навчання грамотності та зміст обізнаності [Завдання: частота, визначена організацією] і наступні [Завдання: події, визначені організацією]; d. Включити уроки, отримані з внутрішніх або зовнішніх інцидентів безпеки або порушень, у навчання грамотності та методи підвищення обізнаності.

No: 1

Name: at_2_b

Type: string

Default: nil

Методи застосовуються для підвищення обізнаності користувачів системи щодо безпеки та конфіденційності

No: 2

Name: at_2_c_01

Type: integer

Default: 30

Оновлюється зміст навчання грамотності та підвищення обізнаності з частотою

No: 3

Name: at_2_c_02

Type: string

Default: nil

Оновлюється зміст навчання грамотності та підвищення обізнаності після подій

No: 4

Name: at_2_d

Type: string

Default: nil

Уроки, отримані в результаті внутрішніх або зовнішніх інцидентів або порушень безпеки, включені в методи навчання та підвищення обізнаності

No: 5

Name: at_2_odp_01

Type: string

Default: "щорічно"

Визначено періодичність проведення навчання грамотності з питань безпеки для користувачів системи (в тому числі менеджерів, вищого керівництва та підрядників) після початкового тренінгу

No: 6

Name: at_2_odp_02

Type: string

Default: "щорічно"

Визначено періодичність проведення навчання грамотності з питань конфіденційності для користувачів системи (в тому числі менеджерів, вищого керівництва та підрядників) після початкового тренінгу

No: 7

Name: at_2_odp_03

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують навчання користувачів системи грамотності з питань безпеки

No: 8

Name: at_2_odp_05

Type: string

Default: nil

Визначено методи, які слід застосовувати для підвищення обізнаності користувачів системи щодо безпеки та конфіденційності

No: 9

Name: at_2_odp_06

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено частоту оновлення навчання грамотності та змісту обізнаності; АТ-02_ОДР[07] визначено події після яких необхідне оновлення навчання грамотності та змісту обізнаності; АТ-02(а)[01][01] навчання з грамотності з питань безпеки надається користувачам системи (включаючи менеджерів, керівників вищої ланки та підрядників) як частина початкового навчання для нових користувачів; АТ-02(а)[01][02] навчання з грамотності з питань конфіденційності надається користувачам системи (включаючи менеджерів, керівників вищої ланки та підрядників) як частина початкового навчання для нових користувачів; АТ-02(а)[01][03] для користувачів системи (включно з менеджерами, вищим керівництвом та підрядниками) проводиться навчання з безпеки з періодичністю після цього; АТ-02(а)[01][04] для користувачів системи (включно з менеджерами, вищим керівництвом та підрядниками) проводиться навчання з конфіденційності з періодичністю після цього; АТ-02(а)[02][01] тренінги з грамотності з питань безпеки проводяться для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників), коли цього вимагають зміни в системі або після подій; АТ-02(а)[02][02] тренінги з грамотності з питань конфіденційності проводяться для користувачів системи (включаючи менеджерів, керівників вищої ланки та підрядників), коли цього вимагають зміни в системі або після подій

No: 10

Name: at_2_odp_4

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують навчання користувачів системи грамотності з питань конфіденційності

2.2.1. НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ | НАВЧАННЯ ЩОДО РОЗПІЗНАВАННЯ ВНУТРІШНЬОЇ ЗАГРОЗИ

Ввести до програми навчання вправи з розпізнавання та виявлення потенційних індикаторів внутрішніх загроз.

No: 1
Name: at_2_2_01
Type: string
Default: nil

Введено до програми навчання вправи з розпізнавання потенційних індикаторів внутрішніх загроз

No: 2
Name: at_2_2_02
Type: string
Default: nil

Введено до програми навчання вправи з виявлення потенційних індикаторів внутрішніх загроз

2.2.2. НАВЧАННЯ З ПІДВИЩЕННЯ ОБІЗНАНОСТІ | НАВЧАННЯ З ПИТАНЬ СОЦІАЛЬНОЇ ІНЖЕНЕРІЇ

Ввести до програми навчання вправи з підвищення обізнаності щодо розпізнавання та повідомлення про потенційні та фактичні атаки, з використанням методів соціальної інженерії та інтелектуального аналізу соціальних даних.

No: 1
Name: at_2_3_01
Type: string
Default: nil

До програми навчання введено вправи з розпізнавання потенційних та фактичних випадків соціального інжинірингу

No: 2
Name: at_2_3_02
Type: string
Default: nil

До програми навчання введено вправи з повідомлення про потенційні та фактичні випадки соціального інжинірингу

No: 3
Name: at_2_3_03
Type: string
Default: nil

До програми навчання введено вправи з розпізнавання потенційних та фактичних випадків інтелектуального аналізу соціальних даних

No: 4
Name: at_2_3_04
Type: string
Default: nil

До програми навчання введено вправи з повідомлення про потенційні та фактичні випадки інтелектуального аналізу соціальних даних

2.3. РОЛЬОВЕ НАВЧАННЯ (АТ-3)

а. Забезпечити проведення навчання з питань безпеки та приватності на основі ролей для працівників з ролями та обов'язками: [Призначення: визначені організацією ролі та обов'язки]: 1. перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків і [Призначення: частота, визначена організацією] після цього; 2. коли цього потребують системні зміни. б. Оновити навчальний контент на основі ролей [Призначення: частота, визначена організацією] і наступні [Призначення: події, визначені організацією]; с. Включить у рольове навчання, інформацію, отриману з внутрішніх або зовнішніх інцидентів та порушень безпеки.

No: 1

Name: at_3_b_01

Type: integer

Default: 30

Оновлюється вміст навчання на основі ролей з частотою

No: 2

Name: at_3_b_02

Type: string

Default: nil

Оновлюється вміст навчання на основі ролей після подій

No: 3

Name: at_3_c

Type: string

Default: nil

Інформація отримана з внутрішніх чи зовнішніх інцидентів або порушень безпеки, включається в навчання на основі ролей

No: 4

Name: at_3_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено ролі та обов'язки для тренінгів з безпеки на основі ролей

No: 5

Name: at_3_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено ролі та обов'язки для тренінгів з конфіденційності на основі ролей

No: 6

Name: at_3_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначено частоту проведення тренінгів на основі ролей з безпеки та конфіденційності для призначеного персоналу після початкової підготовки

No: 7

Name: at_3_odp_04

Type: integer

Default: 30

Визначено частоту оновлення змісту навчання на основі ролей

No: 8

Name: at_3_odp_05

Type: list

Default: ["admin", "security_officer"]

Визначено події, які потребують оновлення змісту навчання на основі ролей; AT-03(a)[01][01] навчання з безпеки на основі ролей проводиться для ролей та обов'язків перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків; AT-03(a)[01][02] навчання з конфіденційності на основі ролей проводиться для ролей та обов'язків перед авторизацією доступу до системи, інформації або виконанням призначених обов'язків; AT-03(a)[01][03] навчання з безпеки на основі ролей проводиться для ролей та обов'язків з частотою після цього; AT-03(a)[01][04] навчання з конфіденційності на основі ролей проводиться для ролей та обов'язків з частотою після цього; AT-03(a)[02][01] навчання з питань безпеки на основі ролей проводиться для персоналу, який виконує певні ролі та обов'язки у сфері безпеки, коли цього вимагають зміни в системі; AT-03(a)[02][02] навчання з питань конфіденційності на основі ролей проводиться для персоналу, який виконує певні ролі та обов'язки у сфері безпеки, коли цього вимагають зміни в системі

2.3.1. ЗАБЕЗПЕЧУЄТЬСЯ ПІДВИЩЕННЯМ КВАЛІФІКАЦІЇ В ГАЛУЗІ ЗАЙНЯТОСТІ ТА ФУНКЦІОНУВАННЯ ЗАХОДІВ ЗАХИСТУ РОБОЧОГО СЕРЕДОВИЩА З (АТ-3(1))

No: 1

Name: at_3_1_01

Type: list

Default: ["admin", "security_officer"]

Персонал або ролі забезпечується підвищенням кваліфікації в галузі зайнятості та функціонування заходів захисту робочого середовища з частотою

No: 2

Name: at_3_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути забезпечені початковим навчанням та підвищенням кваліфікації з питань застосування та експлуатації заходів захисту робочого середовища

No: 3

Name: at_3_1_odp_02

Type: integer

Default: 30

Визначено частоту проведення підвищення кваліфікації в галузі операцій та функціонування заходів захисту робочого середовища

2.3.2. ЗАБЕЗПЕЧУЮТЬСЯ ПІДГОТОВКОЮ З ПИТАНЬ ЗАСТОСУВАННЯ ТА ЕКСПЛУАТАЦІЇ ЗАХОДІВ (АТ-3(2))

Надати [Призначення: визначеним організацією персоналу чи ролям] з початку роботи та з [Призначення: визначеною організацією частотою] підготовку з питань застосування та експлуатації заходів фізичної безпеки.

No: 1

Name: at_3_2_01

Type: list

Default: ["admin", "security_officer"]

Персонал або ролі забезпечуються підготовкою з питань застосування та експлуатації заходів фізичної безпеки з частотою

No: 2

Name: at_3_2_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути забезпечені підготовкою з питань застосування та експлуатації заходів фізичної безпеки

No: 3

Name: at_3_2_odp_02

Type: integer

Default: 30

Визначено частоту проведення підготовки з питань застосування та експлуатації заходів фізичної безпеки

3. AU

3.1. Політика та процедури аудиту та підзвітності (AU-1)

а. Розробити, задокументувати та поширити [Призначення: серед персоналу або ролей, що їх визначила організація]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політика аудиту та підзвітності, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинним законам, нормативним документам, директивам, нормам, політикам, стандартам та керівним документам. 2. Процедури, що сприяють здійсненню політики аудиту та підзвітності, а також пов'язані з ними заходи аудиту та підзвітності. б. Призначити [Призначення: визначену організацією старшу посадову особу] для управління політикою та процедурами аудиту та підзвітності. с. Переглядати та оновлювати поточний аудит та підзвітність: 1. політику [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією]; 2. процедури аудиту [Призначення: визначеною організацією частотою] та [Завдання: події, визначені організацією].

No: 1

Name: au_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику аудиту та підзвітності

No: 2

Name: au_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика аудиту та підзвітності доведена до персонал або ролі

No: 3

Name: au_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблені та задокументовані процедури аудиту та підзвітності, що сприяють впровадженню політики аудиту та підзвітності, а також відповідні заходи контролю аудиту та підзвітності

No: 4

Name: au_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління політикою та процедурами аудиту та підзвітності AU-01(c)[01][01] переглядається та оновлюється поточна політика аудиту та підзвітності з частота; AU-01(c)[01][02] переглядається та оновлюється поточна політика аудиту та підзвітності після подій; AU-01(c)[02][01] переглядається та оновлюється поточні процедури аудиту та підзвітності з частота; AU-01(c)[02][02] переглядається та оновлюється поточні процедури аудиту та підзвітності після подій

No: 5

Name: au_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких має бути доведена політика аудиту та підзвітності

No: 6

Name: au_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури аудиту та підзвітності

No: 7

Name: au_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: au_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка управлятиме політикою та процедурами аудиту та підзвітності

No: 9

Name: au_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика аудиту та підзвітності

No: 10

Name: au_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, які потребують перегляду та оновлення поточної політики аудиту та підзвітності

No: 11

Name: au_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури аудиту та підзвітності

No: 12

Name: au_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення поточної процедури аудиту та підзвітності

3.2. ПОДІЇ АУДИТУ (AU-2)

a. Визначити типи подій, які система може реєструвати для підтримки функції аудиту: [Призначення: типи подій, визначені організацією, які система здатна реєструвати]; b. Координувати функції аудиту безпеки з іншими організаційними підрозділами, які вимагають інформації, пов'язаної з аудитом, для посилення взаємної підтримки та допомоги у виборі типів подій, що перевіряються; c. Визначити, які типи подій підлягають аудиту: [Призначення: визначені організацією події, що підлягають аудиту (підмножина подій, що підлягають аудиту, визначених в AU-2 а.), а також частота (або ситуація, що вимагає) проведення аудиту для кожної ідентифікованої події] d. Обґрунтувати, чому типи подій, що перевіряються, вважаються достатніми для підтримки розслідувань інцидентів (постфактум), пов'язаних з безпекою та приватністю; e. Перегляньте й оновіть типи подій, вибрані для журналювання [Призначення: частота, визначена організацією].

No: 1

Name: au_2_a

Type: string

Default: nil

Типи подій, які система здатна реєструвати, визначено для підтримки функції аудиту

No: 2

Name: au_2_b

Type: string

Default: nil

Функція аудиту безпеки координується з іншими підрозділами організації, які вимагають інформації, пов'язаної з аудитом, для посилення взаємної підтримки та допомоги у виборі типів подій, що перевіряються

No: 3

Name: au_2_c_01

Type: string

Default: nil

Типи подій (підмножина 02_ODP[01]) визначаються для реєстрації у системі; AU-

No: 4

Name: au_2_c_02

Type: string

Default: "щорічно"

Зазначені типи подій реєструються 02_ODP[03] частота або ситуація>; <AU-

No: 5

Name: au_2_d

Type: string

Default: nil

Надається обґрунтування, чому типи подій, що перевіряються, вважаються достатніми для підтримки розслідувань інцидентів (постфактум), пов'язаних з безпекою та конфіденційністю

No: 6

Name: au_2_e

Type: string
Default: "щорічно"

Переглядаються та оновлюються типи подій, вибрані для реєстрації, частота, у системі

No: 7
Name: au_2_odp_01
Type: string
Default: nil

Визначено типи подій, які система може реєструвати для підтримки функції аудиту

No: 8
Name: au_2_odp_02
Type: string
Default: nil

Визначено типи подій (підмножина AU-02_ODP[01]) що підлягають аудиту у системі

No: 9
Name: au_2_odp_03
Type: list
Default: ["login", "logout", "failed_attempt"]

Визначено частоту або ситуацію, що вимагає проведення аудиту для кожної ідентифікованої події

No: 10
Name: au_2_odp_04
Type: string
Default: "щорічно"

Частота перегляду та оновлення типів подій, обраних для журналювання

3.2.1. УЗАГАЛЬНЕННЯ ЗАПИСІВ ПРО АУДИТ З ДЕКІЛЬКОХ ДЖЕРЕЛ (AU-2(1))

No: 1
Name: au_2_1_01
Type: list
Default: ["login", "logout", "failed_attempt"]

ПОДІЇ АУДИТУ - УЗАГАЛЬНЕННЯ ЗАПИСІВ ПРО АУДИТ З ДЕКІЛЬКОХ ДЖЕРЕЛ [Вилучено: Включено в AU-12]. AU-02(02) ПОДІЇ АУДИТУ - ВИБІР ПОДІЇ АУДИТУ ЗА КОМПОНЕНТАМИ [Вилучено: Включено в AU-12]

3.2.2. ВИБІР ПОДІЇ АУДИТУ ЗА КОМПОНЕНТАМИ (AU-2(2))

Немає параметрів для цього контролю.

3.2.3. ПЕРЕГЛЯД ТА ОНОВЛЕННЯ (AU-2(3))

No: 1
Name: au_2_3_01
Type: list
Default: ["login", "logout", "failed_attempt"]

ПОДІЇ АУДИТУ - ПЕРЕГЛЯД ТА ОНОВЛЕННЯ [Вилучено: Включено в AU-02]

3.2.4. ПРИВІЛЕЙОВАНІ ФУНКЦІЇ (AU-2(4))

No: 1

Name: au_2_4_01

Type: list

Default: ["login", "logout", "failed_attempt"]

ПОДІЇ АУДИТУ - ПРИВІЛЕЙОВАНІ ФУНКЦІЇ [Вилучено: Включено в AC-06(09)]

3.3. ЗМІСТ ЗАПИСІВ АУДИТУ (AU-3)

Переконалися, що записи аудиту містять інформацію, яка встановлює наступне: а. який тип події стався; b. коли відбулася подія; c. де відбулася подія; d. джерело події; e. наслідки події; f. результат події та ідентифікатор будь-яких осіб або суб'єктів, пов'язаних з подією.

No: 1

Name: au_3_a

Type: list

Default: ["login", "logout", "failed_attempt"]

Записи аудиту містять інформацію, яка встановлює який тип події стався

No: 2

Name: au_3_b

Type: string

Default: nil

Записи аудиту містять інформацію, яка встановлює коли подія сталася

No: 3

Name: au_3_c

Type: string

Default: nil

Записи аудиту містять інформацію, яка встановлює де відбулася подія

No: 4

Name: au_3_d

Type: list

Default: ["login", "logout", "failed_attempt"]

Записи аудиту містять інформацію, яка встановлює джерело події

No: 5

Name: au_3_e

Type: list

Default: ["login", "logout", "failed_attempt"]

Записи аудиту містять інформацію, яка встановлює наслідки події

No: 6

Name: au_3_f

Type: list

Default: ["login", "logout", "failed_attempt"]

Записи аудиту містять інформацію, яка встановлює результат події та ідентифікатор будь-яких осіб або суб'єктів, пов'язаних з подією

3.3.1. ДОДАТКОВА ІНФОРМАЦІЯ ПРО АУДИТ (AU-3(1))

No: 1
 Name: au_3_1_01
 Type: string
 Default: nil

ЗМІСТ ЗАПИСІВ АУДИТУ - ДОДАТКОВА ІНФОРМАЦІЯ ПРО АУДИТ МЕТА ОЦІНКИ: Визначити, чи:

No: 2
 Name: au_3_1_odp
 Type: string
 Default: nil

Визначено додаткову інформацію, яка має бути включена до записів аудиту

3.3.2. ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ ПЛАНОВАНИМ ЗМІСТОМ ЗАПИСІВ АУДИТУ (AU-3(2))

No: 1
 Name: au_3_2_01
 Type: string
 Default: nil

ЗМІСТ ЗАПИСІВ АУДИТУ - ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ ПЛАНОВАНИМ ЗМІСТОМ ЗАПИСІВ АУДИТУ [Вилучено: Включено до PL-09]

3.3.3. ОБМЕЖЕННЯ ЕЛЕМЕНТІВ ПЕРСОНАЛЬНИХ ДАНИХ (AU-3(3))

Обмежити персональні дані, що міститься в записах аудиту, до таких елементів, які визначені в оцінці ризику приватності: [Призначення: визначені організацією елементи].

No: 1
 Name: au_3_3_01
 Type: list
 Default: ["admin", "security_officer"]

Інформація, що ідентифікує особу, яка міститься в записах аудиту, обмежується елементами, визначеними в оцінці ризиків конфіденційності

No: 2
 Name: au_3_3_odp
 Type: string
 Default: nil

Визначаються елементи, визначені конфіденційності; в оцінці ризику

3.4. РЕАГУВАННЯ НА ВІДМОВИ ОБРОБКИ ДАНИХ АУДИТУ (AU-5)

а. Сповіщати [Призначення: визначені організацією персонал або посади] у разі збою обробки даних аудиту в [Призначення: визначений організацією період часу]. б. Виконати наступні додаткові дії: [Призначення: визначені організацією дії, які необхідно зробити].

No: 1

Name: au_5_a

Type: list

Default: ["admin", "security_officer"]

Персонал або ролі отримують сповіщення у разі збою процесу обробки даних аудиту періоду часу

No: 2

Name: au_5_b

Type: list

Default: ["login", "logout", "failed_attempt"]

Додаткові дії виконуються у разі збою процесу обробки даних аудиту

No: 3

Name: au_5_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які отримують сповіщення про збої в процесі обробки даних аудиту

No: 4

Name: au_5_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено період часу, протягом якого персонал або ролі отримують сповіщення про збої в процесі обробки даних аудиту

No: 5

Name: au_5_odp_03

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено додаткові дії, яких слід вжити у випадку збою в процесі обробки даних аудиту

3.4.1. МІСТКІСТЬ СХОВИЩА ЗАПИСІВ АУДИТУ (AU-5(1))

No: 1

Name: au_5_1_01

Type: list

Default: ["admin", "security_officer"]

Попередження надається персоналу або ролям протягом періоду часу, коли виділений обсяг сховища журналів аудиту досягає відсотків від максимального обсягу сховища журналів аудиту

No: 2

Name: au_5_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути попереджені, коли обсяг записів аудиту, що зберігаються, досягає максимуму місткості сховища. AU-05(01)_ODP[02] визначено період часу, протягом якого визначений персонал або ролі будуть попереджені

No: 3

Name: au_5_1_odp_03

Type: string

Default: nil

Визначено відсоток максимальної ємності сховища для зберігання журналів аудиту

3.4.2. ТРИВОЖНЕ СПОВІЩЕННЯ В РЕАЛЬНОМУ ЧАСІ (AU-5(2))

Забезпечити сповіщення в [Призначення: визначений організацією період реального часу] [Призначення: визначених організацією персоналу, ролей та/або місць], коли відбуваються такі події збою аудиту: [Призначення: визначені організацією події, пов'язані зі збоями та помилками аудиту, які вимагають тривоги в реальному часі].

No: 1

Name: au_5_2_01

Type: list

Default: ["admin", "security_officer"]

Протягом періоду реального часу надається сповіщення персоналу або ролям, коли виникають події

No: 2

Name: au_5_2_odp_01

Type: integer

Default: 30

Визначено період реального часу, за який потрібно надсилати сповіщення при виникненні подій збою аудиту (визначених у AU-05(02)_ODP[03])

No: 3

Name: au_5_2_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути сповіщені при виникненні подій збоїв в аудиті (визначених в AU05(02)_ODP[03])

No: 4

Name: au_5_2_odp_03

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, пов'язані зі збоями та помилками аудиту

3.4.3. НАЛАШТУВАННЯ ПОРОГОВОГО ОБСЯГУ ТРАФІКУ (AU-5(3))

Здійснювати налаштування порогових значень обсягу трафіку комунікаційних мереж, що відображають обмеження на можливості аудиту та [Вибір: відхиляти; затримувати] мережевий трафік, якщо він перевищує цей поріг.

No: 1

Name: au_5_3_01

Type: string

Default: nil

Застосовуються налаштовані порогові значення обсягу трафіку комунікаційних мереж, що відображають обмеження на можливості аудиту

No: 2

Name: au_5_3_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {відхиляти; затримати}

3.4.4. ВИМКНЕННЯ У РАЗІ ВІДМОВИ (AU-5(4))

Застосовувати [Вибір: повне вимикання системи; часткове вимикання системи; знижений режим роботи з обмеженням доступної/цільової функціональності] у разі [Призначення: визначених організацією збоїв аудиту], якщо немає альтернативної можливості аудиту.

Немає параметрів для цього контролю.

3.4.5. МОЖЛИВІСТЬ АЛЬТЕРНАТИВНОГО ЖУРНАЛЮВАННЯ АУДИТУ (AU-5(5))

Надання альтернативної можливості журналювання аудиту в разі збою основної можливості журналювання аудиту, яка реалізується [Призначення: визначена організацією функція альтернативного журналювання аудиту]

No: 1

Name: au_5_5_01

Type: string

Default: nil

Альтернативна можливість ведення журналу аудиту надається на випадок відмови основної можливості ведення журналу аудиту, який реалізує визначений альтернативний функціонал ведення журналу аудиту

No: 2

Name: au_5_5_odp

Type: string

Default: nil

Визначено альтернативний функціонал ведення журналу аудиту на випадок збою в роботі основної функції ведення журналу аудиту

3.5. ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ (AU-6)

а. Переглядати та аналізувати записи системного аудиту [Призначення: з визначеною організацією частотою] для виявлення [Призначення: визначеної організацією неналежної або незвичайної діяльності]. б. Відправляти звіт про аудит [Призначення: визначеним організацією персоналу або посадам]. с. Налаштувати рівні огляду аудиту, аналізу та звітності в рамках системи, коли змінюється рівень ризику на основі інформації від правоохоронних органів, розвідувальної інформації або від інших достовірних джерел інформації.

No: 1

Name: au_6_01

Type: string

Default: nil

ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: au_6_a

Type: string

Default: "щотижня"

Записи аудиту системи переглядаються та аналізуються частота для виявлення ознак неналежної або незвичної діяльності та потенційного впливу неналежної або незвичної діяльності

No: 3
 Name: au_6_b
 Type: list
 Default: ["admin", "security_officer"]

Звіт аудиту відправляється персоналу або ролям

No: 4
 Name: au_6_c
 Type: string
 Default: nil

Рівень перевірки, аналізу та звітування записів аудиту в системі коригується у разі зміни ризиків на основі інформації правоохоронних органів, розвідувальної інформації або інших достовірних джерел інформації

No: 5
 Name: au_6_odp_01
 Type: integer
 Default: 30

Визначено частоту, з якою переглядаються та аналізуються записи аудиту системи

No: 6
 Name: au_6_odp_02
 Type: string
 Default: nil

Визначена неналежна або незвична діяльність

No: 7
 Name: au_6_odp_03
 Type: list
 Default: ["admin", "security_officer"]

Визначено персонал або ролі які отримують результати оглядів та аналізів системних записів

3.5.1. АВТОМАТИЗОВАНА ІНТЕГРАЦІЯ ПРОЦЕСІВ (AU-6(1))

No: 1
 Name: au_6_1_01
 Type: string
 Default: nil

Процеси перегляду, аналізу та звітності інтегровані з використанням автоматизованих механізмів

No: 2
 Name: au_6_1_odp
 Type: string
 Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для інтеграції процесів перегляду, аналізу та звітності записів аудиту

3.5.2. ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ СПОВІЩЕННЯ ПРО ПОРУШЕННЯ БЕЗПЕКУ (AU-6(2))

No: 1
 Name: au_6_2_01
 Type: string
 Default: nil

ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ СПОВІЩЕННЯ ПРО ПОРУШЕННЯ БЕЗПЕКУ - АВТОМАТИЗОВАНІ [Вилучено: Включено до SI-4]

3.5.3. ЗІСТАВЛЯННЯ СХОВИЩ АУДИТУ (AU-6(3))

Аналізувати та зіставляти записи аудиту в різних сховищах задля забезпечення ситуативної обізнаності в масштабах організації.

No: 1

Name: au_6_3_01

Type: string

Default: nil

Аналізуються та зіставляються записи аудиту в різних сховищах, задля забезпечення ситуативної обізнаності в масштабах організації

3.5.4. ЦЕНТРАЛІЗОВАНИЙ ПЕРЕГЛЯД ТА АНАЛІЗ (AU-6(4))

Забезпечити та впровадити можливість централізованого перегляду та аналізу записів аудиту з декількох компонентів у системі.

No: 1

Name: au_6_4_01

Type: string

Default: nil

Забезпечено можливість централізованого перегляду та аналізу записів аудиту з декількох компонентів у системі

No: 2

Name: au_6_4_02

Type: string

Default: nil

Впроваджено можливість централізованого перегляду та аналізу записів аудиту з декількох компонентів у системі

3.5.5. ІНТЕГРОВАНІЙ АНАЛІЗ ЗАПИСІВ АУДИТУ (AU-6(5))

Інтегрувати аналіз записів аудиту з аналізом [Вибір (один або більше): інформації про сканування уразливостей; даних про продуктивність; інформації про моніторинг системи; [Призначення: визначених організацією даних/інформації, зібраних з інших джерел]] для подальшого підвищення здатності виявляти неприйнятну або незвичайну діяльність.

No: 1

Name: au_6_5_odp_01

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {інформація про сканування вразливостей; дані про продуктивність; інформація про моніторинг системи; дані/інформація, зібрана з інших джерел}

3.5.6. КОРЕЛЯЦІЯ З ФІЗИЧНИМ МОНІТОРИНГОМ (AU-6(6))

Зіставляти інформацію із записів аудиту з інформацією, отриманою від моніторингу фізичного доступу, для подальшого підвищення здатності ідентифікувати підозрілу, неприйнятну, незвичайну або зловмисну діяльність.

No: 1
 Name: au_6_6_01
 Type: string
 Default: nil

Інформація з записів аудиту співвідноситься з інформацією, отриманою в результаті моніторингу фізичного доступу, для подальшого посилення здатності виявляти підозрілу, невідповідну, незвичну або зловмисну діяльність

3.5.7. ДОЗВОЛЕНІ ДІЇ (AU-6(7))

Визначити дозволені дії для кожного [Вибір (один або кілька): системного процесу; ролі; користувача], пов'язаного з переглядом, аналізом та поданням інформації про аудит.

No: 1
 Name: au_6_7_odp
 Type: string
 Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {процес системи; роль; користувач}

3.5.8. АНАЛІЗ ПОВНОГО ТЕКСТУ ПРИВІЛЕЙОВАНИХ КОМАНД (AU-6(8))

Виконувати повний аналіз тексту привілейованих команд аудиту у фізично окремому компоненті чи підсистемі або іншій системі, яка може виконувати такий аналіз.

No: 1
 Name: au_6_8_01
 Type: string
 Default: nil

У фізично окремому компоненті чи підсистемі або іншій системі, яка може виконувати такий аналіз. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

3.5.9. РЕГУЛЮВАННЯ РІВНЯ АУДИТУ (AU-6(10))

No: 1
 Name: au_6_10_01
 Type: string
 Default: nil

ОГЛЯД, АНАЛІЗ І ЗВІТНІСТЬ АУДИТУ - РЕГУЛЮВАННЯ РІВНЯ АУДИТУ [Вилучено: Включено до AU-06]

3.6. СКОРОЧЕННЯ ЗАПИСІВ АУДИТУ ТА ФОРМУВАННЯ ЗВІТУ (AU-7)

Забезпечити та реалізувати можливості скорочення записів перевірок аудитом і звітів, до рівня, який: а. підтримує перевірку, аналіз і звітність аудиту на вимогу та розслідування (постфактум) інцидентів безпеки; б. не змінює оригінальний вміст або час упорядкування записів аудиту.

No: 1

Name: au_7_a_02

Type: string

Default: nil

Реалізовано можливість скорочення записів перевірок аудитом та звітів, до рівня що підтримує перевірку, аналіз і звітність аудиту на вимогу та розслідування (постфактум) інцидентів безпеки

No: 2

Name: au_7_b_01

Type: integer

Default: 30

Забезпечено можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний зміст або час упорядкування записів аудиту

No: 3

Name: au_7_b_02

Type: integer

Default: 30

Реалізовано можливість скорочення записів перевірок аудитом та звітів, які не змінюють оригінальний зміст або час упорядкування записів аудиту

3.6.1. АВТОМАТИЧНА ОБРОБКА (AU-7(1))

No: 1

Name: au_7_1_01

Type: string

Default: nil

Забезпечити можливість обробки записів аудиту для подій, що представляють інтерес, на основі полів в записах аудиту

No: 2

Name: au_7_1_02

Type: string

Default: nil

Реалізувати можливість обробки записів аудиту для подій, що представляють інтерес, на основі полів в записах аудиту

No: 3

Name: au_7_1_odp

Type: string

Default: nil

Визначено поля в записах аудиту, які можна обробляти, сортувати або шукати

3.6.2. АВТОМАТИЧНЕ СОРТУВАННЯ ТА ПОШУК (AU-7(2))

No: 1

Name: au_7_2_01

Type: string

Default: nil

СКОРОЧЕННЯ АУДИТУ ТА ФОРМУВАННЯ ЗВІТУ - АВТОМАТИЧНЕ СОРТУВАННЯ ТА ПОШУК
[Вилучено: Включено до AU-07(01)]

3.7. ПОЗНАЧКА ЧАСУ (AU-8)

а. Використовувати внутрішньосистемний годинник для створення позначок часу для записів аудиту. б. Застосовувати позначки часу, які відповідають [Призначення: деталізація вимірювання часу, визначена організацією] і використовують всесвітній координований час, мають фіксоване зміщення місцевого часу відносно всесвітнього координованого часу або включають зміщення місцевого часу як частину позначки часу.

No: 1

Name: au_8_a

Type: integer

Default: 30

Внутрішній системний годинник використовується для створення позначок часу для записів аудиту

No: 2

Name: au_8_b

Type: integer

Default: 30

Позначки часу застосовуються для записів аудиту, які відповідають деталізації вимірювання часу і які використовують всесвітній координований час, мають фіксоване місцеове зміщення місцевого часу від всесвітнього координованого часу або включають зміщення місцевого часу як частину позначки часу

No: 3

Name: au_8_odp

Type: integer

Default: 30

Визначено деталізацію вимірювання часу для часових позначок записів аудиту

3.7.1. СИНХРОНІЗАЦІЯ З АВТОРИТЕТНИМ ДЖЕРЕЛОМ ЧАСУ (AU-8(1))

No: 1

Name: au_8_1_01

Type: integer

Default: 30

ПОЗНАЧКА ЧАСУ - СИНХРОНІЗАЦІЯ З АВТОРИТЕТНИМ ДЖЕРЕЛОМ ЧАСУ [Вилучено: Включено до SC-45(01)]

3.7.2. ВТОРИННЕ АВТОРИТЕТНЕ ДЖЕРЕЛО ЧАСУ (AU-8(2))

No: 1

Name: au_8_2_01

Type: integer

Default: 30

ПОЗНАЧКА ЧАСУ - ВТОРИННЕ АВТОРИТЕТНЕ ДЖЕРЕЛО ЧАСУ [Вилучено: Включено до SC-45(02)]

3.8. ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ (AU-9)

а. Захист інформації аудиту та інструментів несанкціонованого доступу, зміни та видалення; журналювання аудиту від б. Сповідання [Призначення: персонал або ролі, визначені

організацією] у разі виявлення несанкціонованого доступу, зміни або видалення інформації аудиту.

No: 1
Name: au_9_01
Type: string
Default: nil

ЗАХИСТ ІНФОРМАЦІЇ АУДИТУ МЕТА ОЦІНКИ: Визначити, чи:

No: 2
Name: au_9_a
Type: string
Default: nil

Інформація про аудит та інструменти журналювання аудиту захищені від несанкціонованого доступу, зміни та видалення

No: 3
Name: au_9_b
Type: list
Default: ["admin", "security_officer"]

Персонал або ролі отримують сповіщення при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту

No: 4
Name: au_9_odp
Type: list
Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути сповіщені при виявленні несанкціонованого доступу, зміни або видалення інформації аудиту

3.8.1. АПАРАТНІ НОСІЇ ІНФОРМАЦІЇ ОДНОРАЗОВОГО ЗАПИСУ (AU-9(1))

No: 1
Name: au_9_1_01
Type: string
Default: nil

Журнали аудиту записані на апаратні носії інформації з одноразовим записом

3.8.2. ЗБЕРІГАННЯ НА ОКРЕМИХ ФІЗИЧНИХ СИСТЕМАХ АБО КОМПОНЕНТАХ (AU-9(2))

Зберігати записи аудиту з [Призначення: визначеною організацією з частотою] у репозиторії, який є частиною фізично іншої системи або компонента системи, ніж система або компонент, який перевіряється.

No: 1
Name: au_9_2_01
Type: integer
Default: 30

Зберігати записи аудиту з частотою у репозиторії, який є частиною іншої системи або компонента системи, не частиною системи або компонента системи, який перевіряється

No: 2
 Name: au_9_2_odp
 Type: integer
 Default: 30

Визначено частоту з якою необхідно зберігати записи аудиту

3.8.3. КРИПТОГРАФІЧНИЙ ЗАХИСТ (AU-9(3))

Запровадити криптографічні механізми для захисту цілісності інформації аудиту та інструментів аудиту.

No: 1
 Name: au_9_3_01
 Type: string
 Default: "AES-256-GCM"

Впроваджено криптографічні механізми для захисту цілісності інформації аудиту

3.8.4. ДОСТУП, ЯКИЙ НАДАЄТЬСЯ ЧЕРЕЗ ЧЛЕНСТВО В ПІДМНОЖИНИ ПРИВІЛЕЙОВАНИХ КОРИСТУВАЧІВ (AU-9(4))

Авторизувати доступ до управління функціональністю аудиту тільки для [Призначення: визначеної організацією підмножини привілейованих користувачів].

No: 1
 Name: au_9_4_01
 Type: string
 Default: nil

Авторизувати доступ до управління функціональністю аудиту тільки для підмножини привілейованих користувачів

No: 2
 Name: au_9_4_odp
 Type: string
 Default: nil

Визначено підмножину привілейованих користувачів

3.8.5. ПОДВІЙНА АВТОРИЗАЦІЯ (AU-9(5))

Здійснювати подвійну авторизацію для [Вибір (один або кілька): переміщення; видалення] [Призначення: визначеної організацією інформації аудиту].

No: 1
 Name: au_9_5_odp_01
 Type: string
 Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {переміщення; видалення}

No: 2
 Name: au_9_5_odp_02
 Type: string
 Default: nil

Визначено інформацію аудиту, для якої має бути застосована подвійна авторизація

3.8.6. ДОСТУП ТІЛЬКИ ДЛЯ ЧИТАННЯ (AU-9(6))

Авторизувати доступ лише для читання інформації аудиту для [Призначення: визначеної організацією підмножини привілейованих користувачів].

No: 1

Name: au_9_6_01

Type: string

Default: nil

Авторизувати доступ лише для читання інформації аудиту для підмножини привілейованих користувачів

No: 2

Name: au_9_6_odp

Type: string

Default: nil

Визначено підмножину привілейованих користувачів для яких доступ авторизовано тільки для читання

3.8.7. ЗБЕРІГАННЯ НА КОМПОНЕНТІ ІНШОЇ ОПЕРАЦІЙНОЇ СИСТЕМИ (AU-9(7))

Зберігати інформацію про аудит на компоненті, що працює з іншою операційною системою, ніж система або компонент, який проходить аудит.

No: 1

Name: au_9_7_01

Type: string

Default: nil

Інформація про аудит зберігається на компоненті, що працює з іншою операційною системою, ніж система або компонент, який проходить аудит

3.9. ЗБЕРЕЖЕННЯ ЗАПИСІВ АУДИТУ (AU-11)

Зберігати записи аудиту впродовж [Призначення: визначеного організацією періоду часу, відповідно політиці зберігання записів], щоб забезпечити підтримку розслідувань (постфактум) інцидентів безпеки та приватності, а також для задоволення вимог нормативних і документів організації щодо збереження даних аудиту.

No: 1

Name: au_11_01

Type: integer

Default: 30

Записи аудиту зберігаються впродовж періоду часу, щоб забезпечити підтримку розслідування (постфактум) інцидентів безпеки та конфіденційності, а також відповідати нормативним та вимогам організації щодо збереження даних аудиту

No: 2

Name: au_11_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено період часу для зберігання записів аудиту, який узгоджується з політикою зберігання записів

3.9.1. ДОВГОСТРОКОВА МОЖЛИВІСТЬ ОТРИМАННЯ (AU-11(1))

No: 1

Name: au_11_1_01

Type: string

Default: nil

Впровадити заходи, щоб гарантувати, що довгострокові записи аудиту, можуть бути отримані

No: 2

Name: au_11_1_odp

Type: string

Default: nil

Визначено заходи, необхідні для реалізації довгострокової можливості отримання записів аудиту

3.10. ГЕНЕРАЦІЯ ДАНИХ АУДИТУ (AU-12)

а. Забезпечити генерацію даних аудиту для типів подій, що перевіряються в AU-2а в [Призначення: визначених організацією компонентах системи]. б. Дозволити [Призначення: визначеному організацією персоналу або посадам] вибирати, які типи подій, що перевіряються, повинні перевірятися окремими компонентами системи; с. Генерувати записи аудиту для типів подій, визначених в AU-2с. з вмістом згідно з AU-3.

No: 1

Name: au_12_a

Type: string

Default: nil

Можливість генерації записів аудиту для типів подій, які система здатна перевіряти (визначених у AU-02_ODP[01]), забезпечується компонентами системи

No: 2

Name: au_12_b

Type: list

Default: ["admin", "security_officer"]

Персонал або ролі може/можуть вибирати типи подій, які будуть реєструватися певними компонентами системи; AU-12(с) згенеровано записи аудиту для типів подій, визначених у AU02_ODP[02], які включають вміст записів аудиту, визначений у AU03

No: 3

Name: au_12_odp_01

Type: string

Default: nil

Визначено компоненти системи, які забезпечують можливість генерації записів аудиту для типів подій (визначених у AU02_ODP[02])

No: 4

Name: au_12_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, яким дозволено обирати типи подій, що мають реєструватися певними компонентами системи

3.10.1. ЗАГАЛЬНОСИСТЕМНИЙ ТА СИНХРОНІЗОВАНИЙ ЗА ЧАСОМ ЖУРНАЛУ АУДИТУ (AU-12(1))

No: 1

Name: au_12_1_01

Type: integer

Default: 30

Записи аудиту з компонентів системи збираються у загальносистемний (логічний або фізичний) журнал аудиту, який синхронізується у часі в межах рівня взаємозв'язку

No: 2

Name: au_12_1_odp_01

Type: string

Default: nil

Визначено компоненти системи, з яких записи аудиту мають бути зібрані в загальносистемний (логічний або фізичний) журнал аудиту

3.10.2. СТАНДАРТИЗОВАНІ ФОРМАТИ (AU-12(2))

Створити загальносистемний (логічний або фізичний) журнал аудиту, що складається із записів аудиту в стандартизованому форматі.

No: 1

Name: au_12_2_01

Type: string

Default: nil

Створюється загальносистемний (логічний) журнал аудиту, що складається з записів аудиту в стандартизованому форматі

3.10.3. ЗМІНИ, ЩО ВНОСЯТЬ АВТОРИЗОВАНІ ОСОБИ (AU-12(3))

Забезпечити та реалізувати можливість для [Призначення: визначених організацією окремих осіб або ролей] змінити аудит, який виконуватиметься на [Призначення: визначених організацією компонентах системи] на основі [Призначення: визначених організацією критеріїв вибору подій] у межах [Призначення: визначених організацією часових порогів].

No: 1

Name: au_12_3_01

Type: list

Default: ["admin", "security_officer"]

Забезпечено можливість особам або ролям змінювати аудит на компонентах системи на основі обраних критеріїв події у межах часових порогів

No: 2

Name: au_12_3_02

Type: list

Default: ["admin", "security_officer"]

Реалізовано можливість особам або ролям змінювати аудит на компонентах системи на основі обраних критеріїв події у межах часових порогів

No: 3

Name: au_12_3_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено осіб або ролі, яким дозволено змінювати аудит компонентів системи

No: 4

Name: au_12_3_odp_02

Type: string

Default: nil

Визначено компоненти системи, на яких має виконуватися аудит

No: 5

Name: au_12_3_odp_03

Type: list

Default: []

Визначено критерії вибору подій

No: 6

Name: au_12_3_odp_04

Type: integer

Default: 30

Визначено часові пороги, в яких мають змінюватися аудит

3.10.4. АУДИТ ЗАПИТІВ ПЕРСОНАЛЬНИХ ДАНИХ (AU-12(4))

Забезпечити та реалізувати можливості аудиту параметрів подій запитів користувачів для наборів даних, що містять персональні дані.

No: 1

Name: au_12_4_01

Type: list

Default: ["admin", "security_officer"]

Забезпечена можливості аудиту параметрів подій запитів користувачів для наборів даних, що містять персональну ідентифікаційну інформацію

No: 2

Name: au_12_4_02

Type: list

Default: ["admin", "security_officer"]

Реалізована можливості аудиту параметрів подій запитів користувачів для наборів даних, що містять персональну ідентифікаційну інформацію

4. СА

Клас заходів захисту СА — ОЦІНЮВАННЯ,

4.1. ПОЛІТИКА І ПРОЦЕДУРИ ОЦІНЮВАННЯ, АКРЕДИТАЦІЯ ТА МОНІТОРИНГ БЕЗПЕКИ (СА-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посад]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політика оцінювання, авторизації та моніторингу, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинним законам, нормативним документам, наказам, положенням, політиці, стандартам і керівним принципам. 2. Процедури, що сприяють реалізації політики оцінювання, авторизації та моніторингу безпеки та приватності, а також пов'язаних з ними заходів оцінювання, авторизації та моніторингу безпеки та приватності. b. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур оцінювання, авторизації та моніторингу; c. Переглядати та оновлювати поточне оцінювання, авторизацію та моніторинг: 1. Політику [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією]; 2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].

No: 1

Name: ca_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику оцінювання, авторизації та моніторингу

No: 2

Name: ca_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика оцінювання, авторизації та моніторингу поширюється серед персоналу або ролей

No: 3

Name: ca_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблені та задокументовані процедури оцінювання, авторизації та моніторингу, що сприяють впровадженню політики оцінювання, авторизації та моніторингу, а також пов'язані з ними засоби контролю оцінювання, авторизації та моніторингу

No: 4

Name: ca_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур оцінювання, авторизації та моніторингу; СА-01(с)[01][01] переглядається та оновлюється поточна політика оцінки, авторизації та моніторингу з частотою; СА-01(с)[01][02] переглядається та оновлюється поточна політика оцінки, авторизації та моніторингу після подій; СА-01(с)[02][01] переглядаються та оновлюються поточні процедури оцінки, авторизації та моніторингу з частотою; СА-01(с)[02][02] переглядаються та оновлюються поточні процедури оцінки, авторизації та моніторингу після подій; ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

No: 5

Name: ca_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, серед яких має бути поширена політика оцінювання, авторизації та моніторингу

No: 6

Name: ca_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, серед яких мають бути поширені процедури оцінювання, авторизації та моніторингу

No: 7

Name: ca_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: ca_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка управлятиме розробкою, документуванням і розповсюдженням політики та процедур оцінювання, авторизації та моніторингу

No: 9

Name: ca_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика оцінювання, авторизації та моніторингу

No: 10

Name: ca_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, які потребують перегляду та оновлення поточної політики оцінки, авторизації та моніторингу

No: 11

Name: ca_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядається та оновлюється поточні процедури оцінювання, авторизації та моніторингу

No: 12

Name: ca_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення поточні процедури оцінки, авторизації та моніторингу

4.2. ОЦІНЮВАННЯ (CA-2)

а. Виберіть відповідного оцінювача або команду з оцінки для типу оцінювання, яке буде проводитися; б. Розробіть план контрольної оцінки, який описує обсяг оцінки, в тому числі:

1. заходи захисту та посилені заходи, що підлягають оцінюванню; 2. процедури оцінювання, ефективності заходів; які використовуватимуться для визначення 3. середовище оцінювання, групу оцінювання, ролі й обов'язки з оцінювання. с. Забезпечити розгляд і затвердження плану оцінювання уповноваженою офіційною особою або призначеним для проведення оцінювання представником; d. Оцінити заходи захисту в системі та в її середовищі функціонування з [Призначення: визначеною організацією частотою] для визначення, наскільки коректно реалізовані заходи безпеки і чи працюють вони за призначенням і дають бажаний результат щодо дотримання встановлених вимог безпеки та приватності; e. Підготувати звіт оцінювання безпеки, який документує результати оцінювання; f. Надати результати оцінювання з безпеки [Призначення: особам або ролям, визначеним організацією].

No: 1

Name: ca_2_a

Type: string

Default: nil

Обрано відповідного оцінювача або команду оцінювачів для проведення оцінювання

No: 2

Name: ca_2_b_01

Type: list

Default: ["admin", "security_officer"]

Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи заходи захисту та посилені заходи, що підлягають оцінюванню. CA-02(b)[02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. CA-02(b)[03][01] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. CA-02(b)[03][02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. CA-02(b)[03][03] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання

No: 3

Name: ca_2_b_02

Type: list

Default: ["admin", "security_officer"]

Розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи процедури оцінювання, які використовуватимуться для визначення ефективності заходів. CA-02(b)[03][01] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи середовище оцінювання. CA-02(b)[03][02] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи групу оцінювання. CA-02(b)[03][03] розроблено план контрольної оцінки, який описує обсяг оцінки, включаючи ролі й обов'язки з оцінювання

No: 4

Name: ca_2_c

Type: list

Default: ["admin", "security_officer"]

План оцінки заходів захисту розглядається та затверджується уповноваженою посадовою особою або призначеним представником перед проведенням оцінки

No: 5

Name: ca_2_d_01

Type: string

Default: "щорічно"

Заходи захисту оцінюються в системі та середовищі її функціонування частота оцінки, щоб визначити, наскільки коректно реалізовані заходи захисту, чи працюють вони за призначенням і чи дають бажаний результат щодо дотримання встановлених вимог до безпеки

No: 6

Name: ca_2_d_02

Type: string
Default: "щорічно"

Заходи захисту оцінюються в системі та середовищі її функціонування частота оцінки, щоб визначити, наскільки коректно реалізовані заходи захисту, чи працюють вони за призначенням і чи дають бажаний результат щодо дотримання встановлених вимог до конфіденційності; СА-02(е) готується звіт оцінювання

No: 7
Name: ca_2_f
Type: list
Default: ["admin", "security_officer"]

Результати оцінювання з безпеки надаються особам або ролям. оцінювання, який документує результати

No: 8
Name: ca_2_odp_01
Type: integer
Default: 30

Визначено частоту, з якою слід оцінювати засоби контролю в системі та середовищі її функціонування

No: 9
Name: ca_2_odp_02
Type: list
Default: ["admin", "security_officer"]

Визначені особи або ролі, яким мають бути надані результати оцінювання з безпеки

4.2.1. НЕЗАЛЕЖНІ ЕКСПЕРТИ (СА-2(1))

No: 1
Name: ca_2_1_01
Type: string
Default: nil

Для проведення контрольних оцінок залучаються незалежні експерти або групи експертів

4.2.2. ВКЛЮЧАЮТЬСЯ ЯК ЧАСТИНА ОЦІНЮВАННЯ ЗАХОДІВ БЕЗПЕКИ ТА КОНФІДЕНЦІЙНОСТІ; (СА-2(2))

Ввести як частину оцінювання заходів безпеки та приватності, [Призначення: з визначеною організацією частотою], [Вибір: з попередженням; без попередження], [Вибір (один або кілька): поглиблений моніторинг; сканування уразливостей; тестування на шкідливих користувачів; оцінювання внутрішньої загрози; тестування продуктивності та навантаження; [Призначення: організаційно визначені інші форми оцінювання]].

No: 1
Name: ca_2_2_odp_01
Type: integer
Default: 30

Визначено частоту, з якою слід включати спеціалізовані оцінки як частину оцінювання безпеки та конфіденційності

No: 2
Name: ca_2_2_odp_02
Type: string
Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {з попередженням; без попередження}

No: 3

Name: ca_2_2_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {поглиблений моніторинг; сканування уразливостей; тестування на шкідливих користувачів; оцінювання внутрішньої загрози; тестування продуктивності та навантаження; }

4.2.3. ЗОВНІШНІ ОРГАНІЗАЦІЇ (CA-2(3))

Використовуйте результати контрольного оцінювання, які виконує [Призначення: зовнішня організація, визначена організацією] на [Призначення: система, визначена організацією], коли оцінювання відповідає [Завдання: вимоги, визначені організацією].

No: 1

Name: ca_2_3_01

Type: list

Default: ["admin", "security_officer"]

Визначено організацію, яка надає результати оцінок заходів захисту інформації та персональних даних визначено систему, яка приймає результати оцінок заходів захисту інформації та персональних даних визначено вимоги до результатів оцінок заходів захисту інформації та персональних даних прийняти результати оцінок заходів захисту інформації та персональних даних організаціями., що надані, на систему, коли оцінювання відповідає вимогам

4.3. ВЗАЄМОДІЯ СИСТЕМ (CA-3)

а. схвалити та керувати обміном інформацією між системою та іншими системами за допомогою [Вибір (один або кілька): угоди безпеки взаємозв'язку; договори безпеки обміну інформацією; меморандуми про взаєморозуміння; угоди про рівень обслуговування; угоди користувача; угоди про нерозголошення; [Доручення: тип договору, визначений організацією]]; б. документувати, як частину угоди про обмін, характеристики інтерфейсу, вимоги до безпеки та приватності, засоби контролю та відповідальність для кожної системи, а також характер переданої інформації; с. здійснювати перегляд та оновлення угод з [Призначення: визначеною організацією частотою].

No: 1

Name: ca_3_b_01

Type: integer

Default: 30

Характеристики інтерфейсу задокументовані як частина кожної угоди про обмін

No: 2

Name: ca_3_b_02

Type: integer

Default: 30

Вимоги до безпеки задокументовані як частина кожної угоди про обмін

No: 3

Name: ca_3_b_03

Type: integer

Default: 30

Вимоги щодо конфіденційності задокументовані як частина кожної угоди про обмін

No: 4

Name: ca_3_b_04

Type: integer

Default: 30

Заходи захисту задокументовані як частина кожної угоди про обмін

No: 5

Name: ca_3_b_05

Type: integer

Default: 30

Відповідальність за кожну систему задокументована як частина кожної угоди про обмін

No: 6

Name: ca_3_b_06

Type: integer

Default: 30

Характер переданої інформації документується як частина кожної угоди про обмін

No: 7

Name: ca_3_c

Type: string

Default: "щорічно"

Угоди переглядаються та оновлюються частота

No: 8

Name: ca_3_odp_01

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {}): угоди безпеки взаємозв'язку; договори безпеки обміну інформацією; меморандуми про взаєморозуміння; угоди про рівень обслуговування; угоди користувача; угоди про нерозголошення; тип угоди}

No: 9

Name: ca_3_odp_02

Type: string

Default: nil

Визначено тип угоди, який використовується для схвалення та керування обміном інформацією (якщо вибрано)

No: 10

Name: ca_3_odp_03

Type: integer

Default: 30

Визначено частоту, з якою необхідно переглядати та оновлювати угоди

4.3.1. ВЗАЄМОДІЯ СИСТЕМ- НЕЗАХИЩЕНІ З'ЄДНАННЯ СИСТЕМИ (CA-3(1))

No: 1

Name: ca_3_1_01

Type: string

Default: nil

ВЗАЄМОДІЯ СИСТЕМ- НЕЗАХИЩЕНІ З'ЄДНАННЯ СИСТЕМИ [Вилучено: Включено до SC-07(25)]. CA-03(02) ВЗАЄМОДІЯ СИСТЕМ - ЗАХИЩЕНІ З'ЄДНАННЯ СИСТЕМИ [Вилучено: Включено до SC-07(26)]

4.3.2. ЗАХИЩЕНІ З'ЄДНАННЯ СИСТЕМИ (СА-3(2))

Немає параметрів для цього контролю.

4.3.3. НЕСЕКРЕТНІ З'ЄДНАННЯ СИСТЕМИ БЕЗПЕКИ, ЩО НЕ Є НАЦІОНАЛЬНИМИ (СА-3(3))

No: 1

Name: ca_3_3_01

Type: string

Default: nil

ВЗАЄМОДІЯ СИСТЕМ - НЕСЕКРЕТНІ З'ЄДНАННЯ СИСТЕМИ БЕЗПЕКИ, ЩО НЕ Є НАЦІОНАЛЬНИМИ
[Вилучено: Включено до SC-07(27)]

4.3.4. ПІДКЛЮЧЕННЯ ДО ЗАГАЛЬНОДОСТУПНИХ МЕРЕЖ (СА-3(4))

No: 1

Name: ca_3_4_01

Type: string

Default: nil

ВЗАЄМОДІЯ СИСТЕМ - ПІДКЛЮЧЕННЯ ДО ЗАГАЛЬНОДОСТУПНИХ МЕРЕЖ [Вилучено: Включено до SC-07(28)]

4.3.5. ОБМЕЖЕННЯ ЗВ'ЯЗКУ ІЗ ЗОВНІШНІМИ СИСТЕМАМИ (СА-3(5))

No: 1

Name: ca_3_5_01

Type: string

Default: nil

ВЗАЄМОДІЯ СИСТЕМ - ОБМЕЖЕННЯ ЗВ'ЯЗКУ ІЗ ЗОВНІШНІМИ СИСТЕМАМИ [Вилучено: Включено до SC-07(05)]

4.3.6. ПЕРЕДАЧА ДОЗВОЛІВ (СА-3(6))

Переконатися, що особи або системи, які передають дані між взаємопов'язаними системами, мають необхідні повноваження (тобто дозволи на запис або привілеї), до прийняття таких даних.

No: 1

Name: ca_3_6_01

Type: list

Default: ["admin", "security_officer"]

Особі або системи, які передають дані між системами, що з'єднуються, мають необхідні повноваження (тобто дозволи на запис або привілеї) перед тим, як приймати такі дані

4.3.7. ТРАНЗИТИВНИЙ ОБМІН ІНФОРМАЦІЄЮ (СА-3(7))

а) Визначити транзитивний (низхідний) обмін інформацією з іншими системами через системи, визначені в СА-3а; б) Вжити заходів для забезпечення припинення транзитивного (низхідного) обміну інформацією, коли засоби контролю ідентифікованих транзитивних (низхідних) систем не можуть бути перевірені або підтверджені.

No: 1

Name: ca_3_7_b

Type: string

Default: "автоматизований засіб моніторингу"

Вживаються заходи для забезпечення припинення транзитного обміну інформацією, коли засоби контролю над ідентифікованими транзитними системами не можуть бути перевірені або підтверджені

4.4. ПЛАН УСУНЕННЯ НЕДОЛІКІВ ТА КОНТРОЛЬНІ ПОКАЗНИКИ (СА-5)

а. Розробити для системи план усунення недоліків та контрольні показники з метою документування запланованих коригувальних дій організації для усунення недоліків і зауважень, які виявлені в ході оцінювання заходів захисту, а також для зменшення або усунення відомих вразливостей у системі. б. Оновлювати чинний план усунення недоліків та контрольні показники з [Призначення: визначеною організацією частотою] на основі результатів оцінювання заходів, незалежних аудитів та постійного моніторингу.

No: 1

Name: ca_5_a

Type: list

Default: ["login", "logout", "failed_attempt"]

Розроблено план усунення недоліків та контрольні показники для системи, та задокументовано заплановані дії організації з коригування, спрямовані на усунення недоліків та зауважень, виявлених під час оцінки заходів захисту, а також на зменшення або усунення відомих вразливостей в системі

No: 2

Name: ca_5_b

Type: string

Default: "щорічно"

Існуючий план оновлюється частота на основі результатів оцінювання заходів, незалежних аудитів та постійного моніторингу

No: 3

Name: ca_5_odp

Type: integer

Default: 30

Визначено частоту оновлення чинного плану усунення недоліків та контрольних показників на основі результатів оцінювання заходів захисту, незалежних аудитів та постійного моніторингу

4.4.1. АВТОМАТИЗАЦІЯ ПІДТРИМКИ ЗАДЛЯ ТОЧНОСТІ ТА ВЖИВАНOSTІ (СА-5(1))

No: 1

Name: ca_5_1_01

Type: string

Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для забезпечення точності, актуальності та доступності плану усунення недоліків і основних етапів для системи

No: 2

Name: ca_5_1_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, які використовуються для забезпечення точності, актуальності та доступності плану усунення недоліків і основних етапів для системи

4.5. БЕЗПЕРЕРВНИЙ МОНІТОРИНГ (СА-7)

Розробити стратегію безперервного моніторингу безпеки та приватності й упровадити програму безперервного моніторингу безпеки та приватності, яка охоплює: а. встановлення показників безпеки та приватності, які необхідно відстежувати: [Призначення: визначені організацією метрики]; б. встановлення [Призначення: визначена організацією частота] для моніторингу та [Призначення: визначена організацією частота] для безперервного оцінювання ефективності заходів захисту; с. поточні оцінювання заходів захисту відповідно до стратегії безперервного моніторингу організації; d. постійний моніторинг стану безпеки та приватності відповідно до встановлених організацією метрик і відповідно до стратегії безперервного моніторингу організації; e. зіставлення та аналіз інформації, отриманої в результаті оцінювання та моніторингу безпеки та приватності; f. дії реагування за результатами аналізу інформації, пов'язаної з безпекою та приватністю; g. повідомлення про статус безпеки та приватності системи [Призначення: визначені організацією персонал або ролі] з [Призначення: визначеною організацією частотою].

No: 1

Name: ca_7_01

Type: string

Default: nil

Розроблено стратегію безперервного моніторингу на системному рівні; СА-07[02] безперервний моніторинг на рівні системи здійснюється відповідно до стратегії безперервного моніторингу на рівні організації

No: 2

Name: ca_7_a

Type: string

Default: nil

Безперервний моніторинг на рівні системи включає встановлення наступних метрик на рівні системи, які підлягають моніторингу: метрики системного рівня

No: 3

Name: ca_7_b_01

Type: integer

Default: 30

Безперервний моніторинг на рівні системи включає встановлені частоти для моніторингу ефективності заходів захисту

No: 4

Name: ca_7_b_02

Type: integer

Default: 30

Безперервний моніторинг на рівні системи включає встановлені частоти для оцінки ефективності заходів захисту

No: 5
 Name: ca_7_c
 Type: string
 Default: nil

Безперервний моніторинг на рівні системи включає поточні контрольні оцінки відповідно до стратегії безперервного моніторингу

No: 6
 Name: ca_7_d
 Type: string
 Default: nil

Безперервний моніторинг на рівні системи включає постійний моніторинг визначених системою та організацією показників відповідно до стратегії безперервного моніторингу

No: 7
 Name: ca_7_e
 Type: string
 Default: nil

Безперервний моніторинг на рівні системи включає зіставлення та аналіз інформації, отриманої в результаті оцінювання та моніторингу

No: 8
 Name: ca_7_f
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Безперервний моніторинг на рівні системи включає в себе дії з реагування на результати аналізу інформації, пов'язаної з безпекою та приватністю

No: 9
 Name: ca_7_g_01
 Type: list
 Default: ["admin", "security_officer"]

Безперервний моніторинг на рівні системи включає повідомлення про статус безпеки системи для персоналу або ролей частота

No: 10
 Name: ca_7_g_02
 Type: list
 Default: ["admin", "security_officer"]

Безперервний моніторинг на рівні системи включає повідомлення про стан конфіденційності системи персоналу або ролям частота

No: 11
 Name: ca_7_odp_01
 Type: string
 Default: nil

Визначено метрики системного рівня, які підлягають моніторингу

No: 12
 Name: ca_7_odp_02
 Type: integer
 Default: 30

Визначено частоту, з якою слід моніторити ефективність заходів захисту

No: 13
 Name: ca_7_odp_03
 Type: integer
 Default: 30

Визначено частоту, з якою слід оцінювати ефективність заходів захисту

No: 14
 Name: ca_7_odp_04
 Type: list
 Default: ["admin", "security_officer"]

Визначено персонал або ролі, яким повідомляється про стан безпеки системи

No: 15
 Name: ca_7_odp_05
 Type: integer
 Default: 30

Визначено частоту, з якою повідомляється про стан безпеки системи

No: 16
 Name: ca_7_odp_06
 Type: list
 Default: ["admin", "security_officer"]

Визначено персонал або ролі, яким повідомляється про стан конфіденційності системи

No: 17
 Name: ca_7_odp_07
 Type: integer
 Default: 30

Визначено частоту, з якою повідомляється про стан конфіденційності системи

4.5.1. НЕЗАЛЕЖНЕ ОЦІНЮВАННЯ (CA-7(1))

No: 1
 Name: ca_7_1_01
 Type: string
 Default: nil

Для постійного моніторингу заходів захисту в системі залучаються незалежні експертів або групи з оцінювання

4.5.2. ВИДИ ОЦІНОК (CA-7(2))

No: 1
 Name: ca_7_2_01
 Type: string
 Default: nil

БЕЗПЕРЕРВНИЙ МОНІТОРИНГ - ВИДИ ОЦІНОК [Вилучено: Включено до CA-02]

4.5.3. АНАЛІЗ ТЕНДЕНЦІЇ (CA-7(3))

Впровадити аналіз тенденцій, щоб визначити, чи потрібно змінювати реалізацію заходу захисту, частоту постійних моніторингових заходів і види діяльності, що використовуються в процесі безперервного моніторингу, на основі емпіричних даних.

No: 1

Name: ca_7_3_01

Type: string

Default: nil

Аналіз тенденцій використовується для визначення того, чи потрібно змінювати реалізацію заходів захисту, які використовуються в процесі безперервного моніторингу, на основі емпіричних даних

No: 2

Name: ca_7_3_02

Type: integer

Default: 30

Аналіз тенденцій застосовується для того, щоб на основі емпіричних даних визначити, чи потрібно змінювати частоту постійного моніторингу

No: 3

Name: ca_7_3_03

Type: string

Default: nil

Аналіз тенденцій застосовується для того, щоб на основі емпіричних даних визначити, чи потрібно змінювати види діяльності, які використовуються в процесі безперервного моніторингу

4.5.4. МОНІТОРИНГ РИЗИКУ (CA-7(4))

Забезпечити моніторинг ризиків, що є невід'ємною частиною стратегії постійного моніторингу та включає: (a) моніторинг ефективності; (b) моніторинг відповідності; (c) моніторинг змін.

No: 1

Name: ca_7_4_01

Type: integer

Default: 30

Моніторинг ризиків є невід'ємною частиною стратегії безперервного моніторингу

No: 2

Name: ca_7_4_a

Type: string

Default: nil

Моніторинг ефективності включено до моніторингу ризиків

No: 3

Name: ca_7_4_b

Type: string

Default: nil

Моніторинг відповідності включено до моніторингу ризиків

No: 4

Name: ca_7_4_c

Type: string

Default: nil

Моніторинг змін включений до моніторингу ризиків

4.5.5. УЗГОДЖЕНИЙ АНАЛІЗ (CA-7(5))

Застосуйте наступні дії, щоб перевірити, що політики встановлені, а запроваджені заходи захисту працюють узгоджено: [Призначення: дії, визначені організацією].

No: 1

Name: ca_7_5_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Дії використовуються для перевірки того, що політики встановлено

No: 2

Name: ca_7_5_02

Type: list

Default: ["login", "logout", "failed_attempt"]

Дії використовуються для перевірки того, що впроваджені заходи захисту працюють узгоджено

No: 3

Name: ca_7_5_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначені дії для підтвердження того, що політики встановлені

No: 4

Name: ca_7_5_odp_02

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначені дії для підтвердження того, що впроваджені заходи захисту працюють узгоджено

4.5.6. БЕЗПЕРЕРВНИЙ МОНІТОРИНГУ (CA-7(6))

Забезпечити точність, актуальність і доступність результатів моніторингу для системи за допомогою [Завдання: автоматизовані механізми, визначені організацією]

No: 1

Name: ca_7_6_01

Type: string

Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для забезпечення точності, актуальності та доступності результатів моніторингу системи

No: 2

Name: ca_7_6_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми забезпечення точності, актуальності та доступності результатів моніторингу системи

5. СМ

Клас заходів захисту СМ — УПРАВЛІННЯ КОНФІГУРАЦІЄЮ

5.1. Політика та процедури управління конфігурацією (СМ-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначених організацією персоналу або ролей]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політики управління конфігурацією, яка: 2. (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинним законам, нормативним документам, наказам, положенням, політикам, стандартам і керівним принципам; процедури, що сприяють реалізації політики управління конфігурацією та пов'язаних з нею заходів управління конфігурацією. б. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією. с. Переглядати та оновлювати поточну політику управління конфігурацією: 1. Політика [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією]; 2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].

No: 1

Name: cm_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику управління конфігурацією

No: 2

Name: cm_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика управління конфігурацією поширюється на персонал або ролі

No: 3

Name: cm_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблені та задокументовані процедури управління, що сприяють реалізації політики управління конфігурацією та пов'язаних з нею заходів управління конфігурацією

No: 4

Name: cm_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією; СМ-01(с)[01][01] переглядається та оновлюється поточна політика управління конфігурацією частота; СМ-01(с)[01][02] переглядається та оновлюється поточна політика управління конфігурацією після події; СМ-01(с)[02][01] переглядаються та оновлюються поточні процедури управління конфігурацією частота; СМ-01(с)[02][02] переглядаються та оновлюються поточні процедури управління конфігурацією після події; ЗНАЧЕННЯ конфігурацією

No: 5

Name: cm_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на яких поширюється політика управління конфігурацією

No: 6

Name: cm_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на яких поширюється процедури управління конфігурацією

No: 7

Name: cm_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: cm_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка управляє розробкою, документуванням і розповсюдженням політики та процедур керування конфігурацією

No: 9

Name: cm_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика управління конфігурацією

No: 10

Name: cm_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, після яких переглядається та оновлюється поточна політика управління конфігурацією

No: 11

Name: cm_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури управління конфігурацією

No: 12

Name: cm_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, після яких переглядаються та оновлюються поточні процедури управління конфігурацією

5.2. БАЗОВА КОНФІГУРАЦІЯ (СМ-2)

а. Розробити, задокументувати та підтримувати за допомогою заходів конфігурації поточні базові налаштування системи. б. Переглядати та оновлювати базові налаштування системи: 1. з [Призначення: визначеною організацією частотою]; 2. за потреби внаслідок [Призначення: визначених організацією обставин]; 3. коли встановлені нові або оновлені компоненти системи.

No: 1

Name: cm_2_a_01

Type: string

Default: nil

Розроблено та задокументовано поточні базові налаштування системи

No: 2

Name: cm_2_a_02

Type: string

Default: nil

Поточні базові налаштування системи підтримуються за допомогою заходів конфігурації

No: 3

Name: cm_2_b_01

Type: string

Default: "щорічно"

Переглядаються та оновлюються базові налаштування системи частота

No: 4

Name: cm_2_b_02

Type: string

Default: nil

Переглядаються та оновлюються базові налаштування системи після подій

No: 5

Name: cm_2_b_03

Type: string

Default: nil

Переглядаються та оновлюються базові налаштування системи коли встановлюються або модернізуються компоненти системи

No: 6

Name: cm_2_odp_01

Type: integer

Default: 30

Визначено частоту налаштувань; перегляду та оновлення базових

No: 7

Name: cm_2_odp_02

Type: string

Default: nil

Визначено обставини, що вимагають перегляду та оновлення базових налаштувань

5.2.1. ПЕРЕГЛЯД ТА ОНОВЛЕННЯ (СМ-2(1))

No: 1

Name: cm_2_1_01

Type: string

Default: nil

БАЗОВА КОНФІГУРАЦІЯ - ПЕРЕГЛЯД ТА ОНОВЛЕННЯ [Вилучено: Включено до СМ-02]

5.2.2. АВТОМАТИЗАЦІЯ ПІДТРИМКИ ЗАДЛЯ ТОЧНОСТІ ТА ВЖИВАНOSTІ (СМ-2(2))

Підтримувати актуальність, повноту, точність і доступність базової конфігурації системи за допомогою [Призначення: автоматизовані механізми, визначені організацією].

No: 1

Name: cm_2_2_02

Type: string

Default: "автоматизований засіб моніторингу"

Повнота базової конфігурації системи підтримується за допомогою автоматизовані механізми

No: 2

Name: cm_2_2_03

Type: string

Default: "автоматизований засіб моніторингу"

Точність базової конфігурації системи підтримується за допомогою автоматизовані механізми

No: 3

Name: cm_2_2_04

Type: string

Default: "автоматизований засіб моніторингу"

Доступність базової конфігурації системи підтримується за допомогою автоматизовані механізми

No: 4

Name: cm_2_2_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми підтримки базової конфігурації системи; СМ-02(02)[01] актуальність базової конфігурації системи підтримується за допомогою автоматизовані механізми

5.2.3. ЗБЕРІГАННЯ ПОПЕРЕДНІХ ВЕРСІЙ КОНФІГУРАЦІЙ (СМ-2(3))

Зберігати [Призначення: кількість, визначена організацією] попередніх версій базових конфігурацій системи для підтримки відкату.

No: 1

Name: cm_2_3_01

Type: string

Default: nil

Визначено попередні версії базових конфігурацій системи необхідні для підтримки відкату зберігати попередні версії для підтримки відкату

5.2.4. НЕАВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ (СМ-2(4))

Немає параметрів для цього контролю.

5.2.5. АВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ (СМ-2(5))

No: 1

Name: cm_2_5_01

Type: string

Default: nil

БАЗОВА КОНФІГУРАЦІЯ - АВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ [Вилучено: Включено до СМ-07(05)]

5.2.6. РОЗРОБКА ТА СЕРЕДОВИЩЕ ТЕСТУВАННЯ (СМ-2(6))

Підтримувати базову конфігурацію для розробки системи та тестових середовищ, які керуються окремо від робочої базової конфігурації.

No: 1

Name: cm_2_6_01

Type: string

Default: nil

Підтримується базова конфігурація для розробки системи, які керуються окремо від робочої базової конфігурації

No: 2

Name: cm_2_6_02

Type: string

Default: nil

Підтримується базова конфігурація для розробки тестових середовищ, які керуються окремо від робочої базової конфігурації

5.2.7. КОНФІГУРАЦІЯ СИСТЕМ ТА КОМПОНЕНТІВ ДЛЯ СФЕР З ВИСОКИМ РИЗИКОМ (СМ-2(7))

(a) Видавати [Призначення: визначених організацією систем або компонентів систем] з [Призначенням: визначеними організацією конфігураціями] особам, що перебувають у місцях, які організація вважає місцями зі значним ризиком; (b) Застосувати [Призначення: визначені організацією запобіжні заходи безпеки] до компонентів, коли особи повертаються з поїздки.

No: 1

Name: cm_2_7_a

Type: list

Default: ["admin", "security_officer"]

Системи або компоненти системи з конфігураціями видаються особам, що перебувають у місцях, які організація вважає, становлять значний ризик

No: 2

Name: cm_2_7_b

Type: list

Default: ["admin", "security_officer"]

Заходи безпеки застосовуються до систем або компонентів системи, коли особи повертаються з поїздки

No: 3

Name: cm_2_7_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено системи або компоненти систем, які мають видаватися особам, що перебувають у місцях зі значним ризиком

5.3. УПРАВЛІННЯ ЗМІНАМИ КОНФІГУРАЦІЇ (СМ-3)

а. Визначити типи змін у системі, які контролюються конфігурацією. б. Переглядати запропоновані зміни в конфігурації, контрольовані системою, і схвалити або відхилити ці зміни з явним урахуванням аналізу наслідків безпеки. с. Документувати рішення зі зміни конфігурації системи. d. Впровадити схвалені зміни конфігурації в систему. е. Зберігати записи змін конфігурації системи впродовж [Призначення: певного періоду часу, визначеного організацією]. f. Здійснювати моніторинг і аналіз дій, пов'язаних зі змінами конфігурації системи. g. Координувати та впроваджувати нагляд за діяльністю з управління змінами конфігурації за допомогою [Призначення: елементу управління змінами конфігурації, визначеного організацією], який викликається [Вибір (один або кілька): [Призначення: з визначеною організацією частотою]; [Призначення: визначені організацією умови зміни конфігурації]].

No: 1

Name: cm_3_b_01

Type: string

Default: nil

Розглядаються запропоновані зміни в конфігурації, що контролюються системою

No: 2

Name: cm_3_b_02

Type: string

Default: nil

Запропоновані зміни в конфігурації, що контролюються системою, схвалюються або відхиляються з урахуванням аналізу наслідків безпеки

No: 3

Name: cm_3_c

Type: string

Default: nil

Рішення про зміну конфігурації системи документуються

No: 4

Name: cm_3_d

Type: string

Default: nil

Впроваджуються схвалені зміни до конфігурації в систему

No: 5

Name: cm_3_e

Type: integer

Default: 30

Записи про зміни конфігурації у системі зберігаються протягом <період часу CM-03_ODP[01]>

No: 6

Name: cm_3_f_01

Type: string

Default: nil

Здійснюється моніторинг конфігурації системи

No: 7

Name: cm_3_f_02

Type: string

Default: nil

Здійснюється аналіз дій, пов'язаних зі змінами конфігурації системи

No: 8

Name: cm_3_g_01

Type: string

Default: nil

Діяльність з управління змінами конфігурації координується та контролюється елемент управління

No: 9

Name: cm_3_odp_01

Type: integer

Default: 30

Визначено період часу, протягом якого зберігатимуться записи про зміни конфігурації

No: 10

Name: cm_3_odp_02

Type: string

Default: nil

Визначено елементи управління змінами конфігурації, відповідальні за координацію та нагляд за діяльністю з управління змінами

No: 11

Name: cm_3_odp_03

Type: list

Default: []

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {частота; коли умови}

No: 12

Name: cm_3_odp_04

Type: integer

Default: 30

Визначено частоту, з якою викликаються елементи управління змінами конфігурації (якщо вибрано)

No: 13

Name: cm_3_odp_05

Type: list

Default: []

Визначено умови, за яких викликаються елементи управління змінами конфігурації (якщо вибрано); CM-03(a) визначено та задокументовано типи змін до системи, які контролюються конфігурацією

5.3.1. АВТОМАТИЗОВАНЕ ДОКУМЕНТУВАННЯ, ПОВІДОМЛЕННЯ ТА ЗАБОРОНА ВНЕСЕННЯ ЗМІН (CM-3(1))

No: 1

Name: cm_3_1_a

Type: string

Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для документування запропонованих змін до системи

No: 2

Name: cm_3_1_b

Type: string

Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для повідомлення уповноважені органи про запропоновані зміни в системі та запиту на затвердження змін

No: 3
 Name: cm_3_1_c
 Type: integer
 Default: 30

Автоматизовані механізми використовуються для виділення запропонованих змін до системи, які не були схвалені або відхилені протягом період часу

No: 4
 Name: cm_3_1_d
 Type: string
 Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для заборони внесення змін до системи до отримання відповідних погоджень

No: 5
 Name: cm_3_1_e
 Type: string
 Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для документування всіх змін в системі

No: 6
 Name: cm_3_1_f
 Type: list
 Default: ["admin", "security_officer"]

Автоматизовані механізми використовуються для повідомлення персоналу про завершення погоджених змін у системі

No: 7
 Name: cm_3_1_odp_01
 Type: string
 Default: "автоматизований засіб моніторингу"

Визначено механізми, що використовуються для автоматизації управління змінами конфігурації

No: 8
 Name: cm_3_1_odp_02
 Type: string
 Default: nil

Визначені уповноважені органи, про які необхідно повідомляти та узгоджувати пропонувані зміни в системі

No: 9
 Name: cm_3_1_odp_03
 Type: integer
 Default: 30

Визначено період часу, після якого слід виділяти зміни, які не були схвалені або відхилені

No: 10
 Name: cm_3_1_odp_04
 Type: list
 Default: ["admin", "security_officer"]

Визначено персонал, який буде повідомлений про завершення затверджених змін

5.3.2. ТЕСТУВАННЯ, ВАЛІДАЦІЯ ТА ДОКУМЕНТУВАННЯ ЗМІН (СМ-3(2))

Тестувати, перевіряти та документувати зміни в системі до повної їх реалізації.

No: 1
 Name: cm_3_2_01
 Type: string
 Default: nil

Зміни в системі тестуються перед повним впровадженням змін

No: 2
 Name: cm_3_2_02
 Type: string
 Default: nil

Зміни в системі перевіряються перед повним впровадженням змін

No: 3
 Name: cm_3_2_03
 Type: string
 Default: nil

Зміни в системі документуються перед повним впровадженням змін

5.3.3. АВТОМАТИЗОВАНА РЕАЛІЗАЦІЯ ЗМІН (СМ-3(3))

Внести зміни в поточний базову план системи та розгорнути оновлений базовий план на встановленій базі за допомогою [Призначення: автоматизовані механізми, визначені організацією].

No: 1
 Name: cm_3_3_01
 Type: string
 Default: "автоматизований засіб моніторингу"

Зміни до поточного базового плану системи реалізуються за допомогою автоматизовані механізми

No: 2
 Name: cm_3_3_02
 Type: string
 Default: "автоматизований засіб моніторингу"

Оновлений базовий план розгортається по всій встановленій базі за допомогою автоматизовані механізми

No: 3
 Name: cm_3_3_odp
 Type: string
 Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми для внесення змін та розгортання оновленого базового плану по всій встановленій базі

5.3.4. ПРЕДСТАВНИК БЕЗПЕКИ (СМ-3(4))

Вимагати від [Призначення: визначеного організацією представника з інформаційної безпеки] бути членом [Призначення: визначеного організацією елементу керування зміною конфігурацій].

No: 1
 Name: cm_3_4_01
 Type: string
 Default: nil

Представники безпеки повинні бути членами елемента керування змінами конфігурації

No: 2
 Name: cm_3_4_02
 Type: string
 Default: nil

Представники конфіденційності повинні бути членами елемента керування змінами конфігурації

No: 3
 Name: cm_3_4_odp_01
 Type: string
 Default: nil

Визначено представника з безпеки, який має бути членом елемента керування змінами конфігурації

No: 4
 Name: cm_3_4_odp_02
 Type: string
 Default: nil

Визначено представника з конфіденційності, який має бути членом елемента керування змінами конфігурації

No: 5
 Name: cm_3_4_odp_03
 Type: string
 Default: nil

Визначено елемент керування змінами конфігурації, членами якого мають бути представники безпеки та конфіденційності

5.3.5. АВТОМАТИЧНЕ РЕАГУВАННЯ БЕЗПЕКИ (СМ-3(5))

Реалізувати автоматичне [Призначення: визначене організацією реагування безпеки], якщо базова конфігурація системи змінюється несанкціонованим чином.

No: 1
 Name: cm_3_5_01
 Type: string
 Default: nil

Реагування безпеки автоматично застосовуються, якщо базова конфігурація системи змінюється несанкціонованим чином

No: 2
 Name: cm_3_5_odp
 Type: string
 Default: nil

Визначено реагування безпеки, які мають бути застосовані автоматично

5.3.6. УПРАВЛІННЯ ЗАСОБАМИ КРИПТОГРАФІЧНОГО ЗАХИСТУ (СМ-3(6))

Забезпечити, щоб криптографічні механізми, які використовуються для забезпечення відповідних заходів захисту перебували під управлінням конфігурацією [Призначення: визначених організацією заходів безпеки].

No: 1
 Name: cm_3_6_01
 Type: string
 Default: "AES-256-GCM"

Криптографічні механізми, які використовуються для забезпечення відповідних заходів захисту перебувають під управлінням конфігурацією заходи захисту

No: 2

Name: cm_3_6_odp

Type: string

Default: nil

Визначено заходи захисту

5.3.7. ПЕРЕГЛЯД ЗМІН У СИСТЕМІ (СМ-3(7))

Перегляньте зміни в системі [Призначення: частота, визначена організацією] або коли [Призначення: обставини, визначені організацією], щоб визначити, чи відбулися неавторизовані зміни.

No: 1

Name: cm_3_7_01

Type: string

Default: "щорічно"

Зміни в системі переглядаються частота або за обставин, щоб визначити, чи відбулися неавторизовані зміни

No: 2

Name: cm_3_7_odp_01

Type: integer

Default: 30

Визначено частоту, з якою необхідно переглядати зміни

No: 3

Name: cm_3_7_odp_02

Type: string

Default: nil

Визначено обставини, за яких зміни мають бути переглянуті

5.3.8. ЗАПОБІГАННЯ ЧИ ОБМЕЖЕННЯ ЗМІН КОНФІГУРАЦІЇ (СМ-3(8))

Запобігати або обмежити зміни конфігурації системи за таких обставин: [Призначення: обставини, визначені організацією].

No: 1

Name: cm_3_8_01

Type: string

Default: nil

Зміни конфігурації системи запобігають або обмежують за обставин

No: 2

Name: cm_3_8_odp

Type: string

Default: nil

Визначено обставини, за яких зміни мають бути запобіжені або обмежені

5.4. АНАЛІЗ ВПЛИВУ НА БЕЗПЕКУ ТА ПРИВАТНІСТЬ (СМ-4)

Аналізувати зміни в системі, щоб визначити потенційну загрозу безпеці та приватності перед реалізацією змін.

No: 1
Name: cm_4_01
Type: string
Default: nil

Аналізуються зміни в системі, щоб визначити потенційну загрозу безпеці перед реалізацією змін

No: 2
Name: cm_4_02
Type: string
Default: nil

Аналізуються зміни в системі, щоб визначити потенційну загрозу конфіденційності перед реалізацією змін

5.4.1. ВІДОКРЕМЛЕНІ ВИПРОБУВАЛЬНІ СЕРЕДОВИЩА (СМ-4(1))

No: 1
Name: cm_4_1_01
Type: string
Default: nil

Зміни в системі аналізуються в окремому тестовому середовищі перед впровадженням в операційному середовищі

No: 2
Name: cm_4_1_02
Type: string
Default: nil

Зміни в системі аналізуються на предмет впливу на безпеку через недоліки

No: 3
Name: cm_4_1_03
Type: string
Default: nil

Зміни в системі аналізуються на предмет впливу на конфіденційність через недоліки

No: 4
Name: cm_4_1_04
Type: string
Default: nil

Зміни в системі аналізуються на предмет впливу на безпеку через слабкості

No: 5
Name: cm_4_1_05
Type: string
Default: nil

Зміни в системі аналізуються на предмет впливу на конфіденційність через слабкості

No: 6

Name: cm_4_1_06

Type: string

Default: nil

Зміни в системі аналізуються на предмет впливу на безпеку через несумісність

No: 7

Name: cm_4_1_07

Type: string

Default: nil

Зміни в системі аналізуються на предмет впливу на конфіденційність через несумісність

No: 8

Name: cm_4_1_08

Type: string

Default: nil

Зміни в системі аналізуються на предмет впливу на безпеку через навмисне спричинення шкоди

No: 9

Name: cm_4_1_09

Type: string

Default: nil

Зміни в системі аналізуються на предмет впливу на конфіденційність через навмисне спричинення шкоди

5.4.2. ВЕРИФІКАЦІЯ ФУНКЦІЙ БЕЗПЕКИ ТА ПРИВАТНОСТІ (СМ-4(2))

Після змін у системі переконайтеся, що відповідні заходи захисту реалізовано правильно і вони функціонують належним чином та дають бажаний результат щодо дотримання вимог безпеки та приватності для системи.

No: 1

Name: cm_4_2_01

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, реалізовані правильно з точки зору відповідності вимогам безпеки системи після внесення змін до системи

No: 2

Name: cm_4_2_02

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, реалізовані правильно з точки зору відповідності вимогам конфіденційності системи після внесення змін до системи

No: 3

Name: cm_4_2_03

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, функціонують належним чином з точки зору відповідності вимогам безпеки системи після внесення змін до системи

No: 4

Name: cm_4_2_04

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, функціонують належним чином з точки зору відповідності вимогам конфіденційності системи після внесення змін до системи

No: 5

Name: cm_4_2_05

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, дають бажаний результат з точки зору відповідності вимогам безпеки системи після внесення змін до системи

No: 6

Name: cm_4_2_06

Type: string

Default: nil

Заходи захисту, на які було здійснено вплив, дають бажаний результат з точки зору відповідності вимогам конфіденційності системи після внесення змін до системи; ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

5.5. ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ (СМ-5)

Визначити, задокументувати, затвердити та забезпечити застосування фізичних і логічних обмежень доступу, пов'язаних зі змінами в системі.

No: 1

Name: cm_5_01

Type: string

Default: nil

Визначені та задокументовані фізичні обмеження доступу, пов'язані зі змінами в системі

No: 2

Name: cm_5_02

Type: string

Default: nil

Затверджені фізичні обмеження доступу, пов'язані зі змінами в системі

No: 3

Name: cm_5_03

Type: string

Default: nil

Застосовуються фізичні обмеження доступу, пов'язані зі змінами в системі

No: 4

Name: cm_5_04

Type: string

Default: nil

Визначені та задокументовані логічні обмеження доступу, пов'язані зі змінами в системі

No: 5

Name: cm_5_05

Type: string

Default: nil

Затверджені логічні обмеження доступу, пов'язані зі змінами в системі

No: 6
Name: cm_5_06
Type: string
Default: nil

Застосовуються логічні обмеження доступу, пов'язані зі змінами в системі

5.5.1. АУДИТ І ЗДІЙСНЕННЯ АВТОМАТИЧНОГО ДОСТУПУ (СМ-5(1))

No: 1
Name: cm_5_1_a
Type: string
Default: nil

Обмеження доступу до змін застосовуються за допомогою автоматизованих механізмів

No: 2
Name: cm_5_1_b
Type: string
Default: nil

Автоматично формуються записи аудиту для виконаних дій

No: 3
Name: cm_5_1_odp
Type: string
Default: "автоматизований засіб моніторингу"

Визначено механізми, що використовуються для автоматизації застосування обмежень доступу

5.5.2. ПЕРЕГЛЯД ЗМІН У СИСТЕМІ (СМ-5(2))

No: 1
Name: cm_5_2_01
Type: string
Default: nil

ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ - ПЕРЕГЛЯД ЗМІН У СИСТЕМІ [Вилучено: перенесено до СМ-03(07)]

5.5.3. ПІДПИСАНІ КОМПОНЕНТИ (СМ-5(3))

No: 1
Name: cm_5_3_01
Type: string
Default: nil

ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ - ПІДПИСАНІ КОМПОНЕНТИ [Вилучено: перенесено до СМ-14]

5.5.4. ПОДВІЙНА АВТОРИЗАЦІЯ (СМ-5(4))

Здійснювати подвійну авторизацію для внесення змін до [Призначення: компонентів системи та інформації на рівні системи, визначених організацією].

No: 1
Name: cm_5_4_01

Type: string

Default: nil

Запроваджено подвійну авторизацію для внесення змін до компонентів системи

No: 2

Name: cm_5_4_02

Type: string

Default: nil

Запроваджено подвійну авторизацію для внесення змін до інформації

No: 3

Name: cm_5_4_odp_01

Type: string

Default: nil

Визначено компоненти системи, що потребують подвійної авторизації для внесення змін

No: 4

Name: cm_5_4_odp_02

Type: string

Default: nil

Визначено інформацію на рівні системи, що потребують подвійної авторизації для внесення змін

5.5.5. ОБМЕЖЕННЯ ПОВНОВАЖЕНЬ ДЛЯ ВИРОБНИЦТВА ТА ЕКСПЛУАТАЦІЇ (CM-5(5))

(a) обмежити повноваження для зміни компонентів системи та інформації, пов'язаної із системою, у виробничому або операційному середовищі; (b) переглядати та переоцінювати повноваження [Призначення: визначеною організацією з частотою].

No: 1

Name: cm_5_5_a_01

Type: string

Default: nil

Повноваження для зміни компонентів системи у виробничому або операційному середовищі обмежені

No: 2

Name: cm_5_5_a_02

Type: string

Default: nil

Повноваження для зміни інформації, пов'язаної із системою у виробничому або операційному середовищі обмежені

No: 3

Name: cm_5_5_b_01

Type: string

Default: "щорічно"

Переглядаються частота>

No: 4

Name: cm_5_5_b_02

Type: string

Default: "щорічно"

Переоцінюються повноваження частота; повноваження <CM-05(05)_ODP[01]

No: 5

Name: cm_5_5_odp_01

Type: integer

Default: 30

Визначено частоту перегляду повноважень

No: 6

Name: cm_5_5_odp_02

Type: integer

Default: 30

Визначено частоту переоцінювання повноважень

5.5.6. ОБМЕЖЕННЯ ПОВНОВАЖЕНЬ ДЛЯ БІБЛІОТЕК (СМ-5(6))

Обмежити повноваження для зміни програмного забезпечення, яке перебуває в бібліотеках програмного забезпечення.

No: 1

Name: cm_5_6_01

Type: string

Default: nil

Обмежено повноваження для зміни програмного забезпечення, яке перебуває в бібліотеках програмного забезпечення

5.5.7. ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ ВАДЖЕННЯ ЗАХОДІВ ЗАХИСТУ (СМ-5(7))

No: 1

Name: cm_5_7_01

Type: string

Default: nil

ОБМЕЖЕННЯ ДОСТУПУ ДО ЗМІНИ ВАДЖЕННЯ ЗАХОДІВ ЗАХИСТУ - АВТОМАТИЧНЕ ВПРО-
[Вилучено: включено до SI-07]

5.6. НАЛАШТУВАННЯ КОНФІГУРАЦІЇ (СМ-6)

а. Встановити та задокументувати параметри конфігурації компонентів, які застосовуються в системі, які відображають найбільш обмежений режим, що відповідає експлуатаційним вимогам, використовуючи [Призначення: визначені організацією загальні безпечні конфігурації]. б. Реалізувати конфігураційні установки. с. Визначити, задокументувати та затвердити будь-які відхилення від встановлених конфігураційних параметрів конфігурації для [Призначення: визначених організацією компонентів системи] на основі [Призначення: визначених організацією експлуатаційних вимог]. d. Відстежувати та керувати змінами конфігураційних параметрів відповідно до організаційної політики та процедур.

No: 1

Name: cm_6_a

Type: string

Default: nil

Налаштування конфігурації, які відображають найбільш обмежувальний режим, що відповідає експлуатаційним вимогам, встановлені та задокументовані для компонентів, що застосовуються в системі з використанням безпечні конфігурації

No: 2
Name: cm_6_b
Type: string
Default: nil

Реалізовано установки конфігурації, задокументовані в CM-06a

No: 3
Name: cm_6_c_01
Type: string
Default: nil

Будь-які відхилення від встановлених параметрів конфігурації для компонентів системи визначаються та документуються на основі експлуатаційних вимог

No: 4
Name: cm_6_c_02
Type: string
Default: nil

Будь-які відхилення від встановлених налаштувань конфігурації для компонентів системи затверджуються

No: 5
Name: cm_6_d_01
Type: list
Default: ["default_deny_rule", "abac_rule_1"]

Зміни в налаштуваннях конфігурації відстежуються відповідно до політики та процедур організації

No: 6
Name: cm_6_d_02
Type: list
Default: ["default_deny_rule", "abac_rule_1"]

Зміни налаштувань конфігурації керуються відповідно до політики та процедур організації

No: 7
Name: cm_6_odp_01
Type: string
Default: nil

Визначено загальні безпечні конфігурації для встановлення та документування параметрів конфігурації компонентів, які застосовуються в системі; CM-06_ODP[02] визначено компоненти системи, для яких необхідно затвердити відхилення

No: 8
Name: cm_6_odp_03
Type: string
Default: nil

Визначені експлуатаційні вимоги, що вимагають затвердження відхилень

5.6.1. АВТОМАТИЗОВАНЕ УПРАВЛІННЯ, ЗАСТОСУВАННЯ ТА ВЕРИФІКАЦІЯ (CM-6(1))

No: 1
Name: cm_6_1_01

Type: string

Default: nil

Налаштування конфігурації для компонентів системи керуються за допомогою автоматизованих механізмів

No: 2

Name: cm_6_1_02

Type: string

Default: nil

Налаштування конфігурації для компонентів системи застосовуються за допомогою автоматизованих механізмів

No: 3

Name: cm_6_1_03

Type: string

Default: "автоматизований засіб моніторингу"

Налаштування конфігурації для компонентів системи перевіряються за допомогою автоматизованих механізмів; механізми керування перевірки

No: 4

Name: cm_6_1_odp_02

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми налаштуваннями конфігурації

No: 5

Name: cm_6_1_odp_03

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми застосування налаштувань конфігурації

No: 6

Name: cm_6_1_odp_04

Type: string

Default: nil

Визначено автоматизовані налаштувань конфігурації

5.6.2. НАЛАШТУВАННЯ КОНФІГУРАЦІЇ САНКЦІОНОВАНІ ЗМІНИ (СМ-6(2))

Виконайте такі дії у відповідь на неавторизовані зміни в [Призначення: параметри конфігурації, визначені організацією]: [Призначення: дії, визначені організацією].

Немає параметрів для цього контролю.

5.6.3. ДЕМОНСТРАЦІЯ ВІДПОВІДНОСТІ (СМ-6(4))

No: 1

Name: cm_6_4_01

Type: string

Default: nil

НАЛАШТУВАННЯ КОНФІГУРАЦІЇ - ДЕМОНСТРАЦІЯ ВІДПОВІДНОСТІ [Вилучено: Включено до СМ-04]

5.7. МІНІМАЛЬНО НЕОБХІДНА ФУНКЦІОНАЛЬНІСТЬ (СМ-7)

а. Налаштуйте систему для забезпечення лише [Призначення: основні функції, визначені організацією для місії]; б. Заборонити або обмежити використання таких функцій, портів, протоколів, програмного забезпечення та/або служб: [Призначення: визначені організацією заборонені або обмежені функції, системні порти, протоколи, програмне забезпечення та/або служби].

No: 1

Name: cm_7_a

Type: string

Default: nil

Система налаштована на забезпечення лише основні функції системи

No: 2

Name: cm_7_b_01

Type: string

Default: nil

Використання функцій заборонено або обмежено

No: 3

Name: cm_7_b_02

Type: string

Default: nil

Використання порти заборонено або обмежено

No: 4

Name: cm_7_b_03

Type: string

Default: "TLS 1.3"

Використання протоколи заборонено або обмежено

No: 5

Name: cm_7_b_04

Type: string

Default: nil

Використання програмне забезпечення заборонено або обмежено

No: 6

Name: cm_7_b_05

Type: string

Default: nil

Використання служби заборонено або обмежено

No: 7

Name: cm_7_odp_01

Type: string

Default: nil

Визначено основні функції системи, необхідні для виконання місії

No: 8

Name: cm_7_odp_02

Type: string

Default: nil

Визначено функції, які необхідно заборонити або обмежити

No: 9

Name: cm_7_odp_03

Type: string

Default: nil

Визначено системні порти, які необхідно заборонити або обмежити

No: 10

Name: cm_7_odp_04

Type: string

Default: "TLS 1.3"

Визначено протоколи, які необхідно заборонити або обмежити; CM-07_ODP[05] визначено програмне забезпечення, яке необхідно заборонити або обмежити

No: 11

Name: cm_7_odp_06

Type: string

Default: nil

Визначено служби, які необхідно заборонити або обмежити

5.7.1. ПЕРІОДИЧНИЙ ПЕРЕГЛЯД (СМ-7(1))

No: 1

Name: cm_7_1_a

Type: string

Default: "TLS 1.3"

Система переглядається частота для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг

No: 2

Name: cm_7_1_b_01

Type: string

Default: nil

Функції, які вважаються непотрібними та/або незахищеними, вимкнено

No: 3

Name: cm_7_1_b_02

Type: string

Default: nil

Порти, які вважаються непотрібними та/або незахищеними, вимкнено

No: 4

Name: cm_7_1_b_03

Type: string

Default: "TLS 1.3"

Протоколи, які вважаються непотрібними та/або незахищеними, вимкнено

No: 5

Name: cm_7_1_b_04

Type: string

Default: nil

Послуги, які вважаються непотрібними та/або незахищеними, вимкнено

No: 6

Name: cm_7_1_odp_01

Type: string

Default: "TLS 1.3"

Визначено частоту, з якою слід переглядати систему для виявлення непотрібних та/або незахищених функцій, портів, протоколів і послуг

No: 7

Name: cm_7_1_odp_02

Type: string

Default: nil

Визначено функції, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними; CM-07(01)_ODP[03] визначено порти, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними

No: 8

Name: cm_7_1_odp_04

Type: string

Default: "TLS 1.3"

Визначено протоколи, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними

No: 9

Name: cm_7_1_odp_05

Type: string

Default: nil

Визначено послуги, які слід вимкнути, якщо вони вважаються непотрібними або незахищеними

5.7.2. ЗАБОРОНА ВИКОНАННЯ ПРОГРАМИ (CM-7(2))

Заборонити виконання програми відповідно до [Вибір (один або кілька): [Призначення: визначеної організацією політики, правил поведінки та/або угод про доступ щодо використання програмного забезпечення та обмежень]; правил, що встановлюють терміни та умови використання програмного забезпечення].

No: 1

Name: cm_7_2_odp_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {політики, правил поведінки та/або угод про доступ щодо використання програмного забезпечення та обмежень; правила, що встановлюють терміни та умови використання програмного забезпечення}

No: 2

Name: cm_7_2_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначені політики, правил поведінки та/або угод про доступ щодо використання програмного забезпечення та обмежень (якщо вибрано)

5.7.3. ВІДПОВІДНІСТЬ РЕЄСТРАЦІЇ (CM-7(3))

Забезпечити відповідність [Призначення: визначеним організацією вимогам до реєстрації для функцій, портів, протоколів і послуг].

No: 1
 Name: cm_7_3_01
 Type: string
 Default: nil

Вимоги до реєстрації дотримано

No: 2
 Name: cm_7_3_odp
 Type: string
 Default: "TLS 1.3"

Визначено вимоги до реєстрації функцій, портів, протоколів та сервісів

5.7.4. НЕАВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ - ЧОРНИЙ СПИСОК (СМ-7(4))

(а) Визначити [Призначення: визначені організацією програмне забезпечення, що не має дозволу виконуватися в системі]. (b) Впровадити політику «дозволу всього, за винятком деяких» для заборони виконання неавторизованих програм у системі (с) Переглядати та оновлювати список неавторизованих програм [Призначення: з визначеною організацією частотою].

No: 1
 Name: cm_7_4_a
 Type: string
 Default: nil

Визначено програмне забезпечення

No: 2
 Name: cm_7_4_b
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Політика "дозволу всього, за винятком деяких" застосовується для заборони виконання неавторизованих програм у системі

No: 3
 Name: cm_7_4_c
 Type: list
 Default: []

Переглядається та оновлюється список неавторизованих програм частота

No: 4
 Name: cm_7_4_odp_01
 Type: string
 Default: nil

Визначено програмне забезпечення, яке не має дозволу на виконання в системі

No: 5
 Name: cm_7_4_odp_02
 Type: list
 Default: []

Визначено частоту, з якою слід переглядати та оновлювати список неавторизованих програм

5.7.5. АВТОРИЗОВАНЕ ПРОГРАМНЕ ЗАБЕЗПЕЧЕННЯ – БІЛИЙ СПИСОК (СМ-7(5))

(а) Визначити [Призначення: визначені організацією програмне забезпечення, яке авторизовано виконується в системі] (b) Впровадити політику «заборони всього, за винятком деяких», щоб дозволити виконання авторизованих програм у системі. (с) Переглядати та оновлювати список авторизованих програм [Призначення: з визначеною організацією частотою].

No: 1

Name: cm_7_5_a

Type: string

Default: nil

Визначено програмне забезпечення

No: 2

Name: cm_7_5_b

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Політика "заборонити все, дозволити за винятком" застосовується, щоб дозволити виконання авторизованих програм у системі

No: 3

Name: cm_7_5_c

Type: list

Default: []

Переглядається та оновлюється список авторизованих програм частота

No: 4

Name: cm_7_5_odp_01

Type: string

Default: nil

Визначено програмне забезпечення, яке авторизовано для виконання в системі

No: 5

Name: cm_7_5_odp_02

Type: integer

Default: 30

Визначено частоту перегляду та оновлення списку авторизованих програм

5.7.6. ЗАМКНУТІ СЕРЕДОВИЩА З ОБМЕЖЕНИМИ ПРИВІЛЕЯМИ (СМ-7(6))

Вимагайте, щоб визначене програмне забезпечення, встановлене користувачем, виконувалося в обмеженому середовищі фізичної або віртуальної машини з обмеженими привілеями: [Призначення: програмне забезпечення, встановлене користувачем, визначене організацією]

No: 1

Name: cm_7_6_01

Type: string

Default: nil

Програмне забезпечення, встановлене користувачем має виконуватися в обмеженому середовищі фізичної або віртуальної машини з обмеженими привілеями

No: 2

Name: cm_7_6_odp

Type: string

Default: nil

Визначено встановлене користувачем програмне забезпечення, яке потрібно виконувати в обмеженому середовищі

5.7.7. ВИКОНУВАНИЙ КОД У ЗАХИЩЕНОМУ СЕРЕДОВИЩІ (СМ-7(7))

Дозволити виконання двійкового або машинно-виконуваного коду лише в обмеженому фізичному або віртуальному машинному середовищі та за явного дозволу [Призначення: персонал або ролі, визначені організацією], якщо такий код: а) Отримано з джерел з обмеженою гарантією або без неї; та/або б) Без надання вихідного коду.

No: 1

Name: cm_7_7_01

Type: string

Default: nil

Виконання двійкового або машинного коду дозволено лише в обмеженому середовищі фізичної або віртуальної машини

No: 2

Name: cm_7_7_a

Type: list

Default: ["admin", "security_officer"]

Виконання двійкового або машинного коду, отриманого з джерел з обмеженою гарантією або без неї, дозволяється лише з явного дозволу персонал або ролі

No: 3

Name: cm_7_7_b

Type: list

Default: ["admin", "security_officer"]

Виконання двійкового або машинного коду без надання вихідного коду дозволяється лише з явного дозволу персонал або ролі

No: 4

Name: cm_7_7_odp

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі для явного дозволу на виконання двійкового або машинно-виконуваного коду

5.7.8. БІНАРНИЙ АБО МАШИННИЙ ВИКОНУВАНИЙ КОД (СМ-7(8))

а) Заборонити використання двійкового або машинно-виконуваного коду з джерел з обмеженою гарантією або без неї або без надання вихідного коду; і б) Дозволяти винятки лише для обов'язкових місій або оперативних вимог і за погодженням з уповноваженою посадовою особою.

No: 1

Name: cm_7_8_a

Type: string

Default: nil

Використання двійкового або машинного коду заборонено, якщо він походить з джерел з обмеженою гарантією або без неї, або без надання вихідного коду

No: 2

Name: cm_7_8_b_01

Type: string

Default: nil

Винятки із заборони на використання двійкового або машинного коду з джерел з обмеженою гарантією або без неї, або без надання вихідного коду допускаються лише для обов'язкових місій або оперативних вимог

No: 3

Name: cm_7_8_b_02

Type: list

Default: ["admin", "security_officer"]

Винятки із заборони на використання двійкового або машинного коду з джерел з обмеженою гарантією або без неї, або без надання вихідного коду допускаються лише у разі погодження з уповноваженою посадовою особою

5.7.9. ЗАБОРОНА ВИКОРИСТАННЯ НЕАВТОРИЗОВАНОГО ОБЛАДНАННЯ (СМ-7(9))

а. б. с. - ЗАБОРОНА Визначити [Призначення: апаратні компоненти, визначені організацією, авторизовані для використання в системі]; Заборонити використання або підключення неавторизованих апаратних компонентів; Перегляд та оновлення списку авторизованих апаратних компонентів [Призначення: частота, визначена організацією].

No: 1

Name: cm_7_9_a

Type: string

Default: nil

Ідентифіковано апаратні компоненти

No: 2

Name: cm_7_9_b

Type: string

Default: nil

Використання або підключення несанкціонованих апаратних компонентів заборонено

No: 3

Name: cm_7_9_c

Type: list

Default: []

Список дозволених апаратних компонентів переглядається та оновлюється з частотою;

No: 4

Name: cm_7_9_odp_01

Type: list

Default: []

Визначено апаратні компоненти, дозволені для використання в системі; СМ-07(09)_ODP[02 визначено періодичність перегляду та оновлення переліку дозволених апаратних компонентів

5.8. ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ (СМ-8)

a. b. Розробити та задокументувати процес інвентаризації компонентів системи, який: 1. точно описує поточну систему; 2. охоплює всі компоненти в межах акредитації системи; 3. не включає повторний облік компонентів або компонентів, будь-якої іншої системи; 4. визначає рівень деталізації, який є необхідним для відстеження та звітування; 5. включає інформацію для досягнення підзвітності компонентів системи: [Призначення: визначена організацією інформація, необхідна для досягнення ефективної підзвітності компонентів системи]. Переглядати та оновлювати опис компонентів системи з [Призначення: визначеною організацією частотою].

No: 1

Name: cm_8_a_01

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який точно описує поточну систему

No: 2

Name: cm_8_a_02

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який охоплює всі компоненти в межах акредитації системи

No: 3

Name: cm_8_a_03

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який не включає повторний облік компонентів або компонентів, будь-якої іншої системи

No: 4

Name: cm_8_a_04

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який визначає рівень деталізації, який є необхідним для відстеження та звітування

No: 5

Name: cm_8_a_05

Type: string

Default: nil

Розроблено та задокументовано процес інвентаризації компонентів системи, який включає інформацію

No: 6

Name: cm_8_b

Type: string

Default: "щорічно"

Переглядається та оновлюється опис компонентів системи частота

No: 7

Name: cm_8_odp_01

Type: string

Default: nil

Визначено інформацію, яка вважається необхідною для досягнення ефективної підзвітності компонентів системи

No: 8

Name: cm_8_odp_02

Type: integer

Default: 30

Визначено частоту перегляду та оновлення опису компонентів системи

5.8.1. ОНОВЛЕННЯ ПІД ЧАС ВСТАНОВЛЕННЯ ТА ВИДАЛЕННЯ (СМ-8(1))

No: 1

Name: cm_8_1_01

Type: string

Default: nil

Інвентаризація компонентів системи оновлюється в рамках інсталяцій компонентів системи

No: 2

Name: cm_8_1_02

Type: string

Default: nil

Інвентаризація компонентів системи оновлюється в рамках видалення компонентів системи

No: 3

Name: cm_8_1_03

Type: string

Default: nil

Інвентаризація компонентів системи оновлюється в рамках оновлення компонентів системи

5.8.2. АВТОМАТИЗОВАНА ПІДТРИМКА (СМ-8(2))

No: 1

Name: cm_8_2_01

Type: string

Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для підтримки актуальності інвентаризації компонентів системи

No: 2

Name: cm_8_2_02

Type: string

Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для підтримки повноти інвентаризації компонентів системи

No: 3

Name: cm_8_2_03

Type: string

Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для підтримки точності інвентаризації компонентів системи

No: 4

Name: cm_8_2_04

Type: string

Default: "автоматизований засіб моніторингу"

Автоматизовані механізми використовуються для підтримки доступності інвентаризації компонентів системи

No: 5

Name: cm_8_2_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми підтримки актуальності інвентаризації компонентів системи

No: 6

Name: cm_8_2_odp_02

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми підтримки повноти інвентаризації компонентів системи

No: 7

Name: cm_8_2_odp_03

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми підтримки точності інвентаризації компонентів системи

No: 8

Name: cm_8_2_odp_04

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми підтримки доступності інвентаризації компонентів системи

5.8.3. АВТОМАТИЗОВАНЕ ВИЯВЛЕННЯ НЕАВТОРИЗОВАНИХ КОМПОНЕНТІВ (СМ-8(3))

No: 1

Name: cm_8_3_a_01

Type: string

Default: "щорічно"

Наявність несанкціонованого обладнання в системі виявляється за допомогою автоматизованих механізмів частота

No: 2

Name: cm_8_3_a_02

Type: string

Default: "щорічно"

Наявність несанкціонованого програмного забезпечення в системі виявляється за допомогою автоматизованих механізмів частота

No: 3

Name: cm_8_3_a_03

Type: string

Default: "щорічно"

Наявність несанкціонованих мікропрограмних компонентів в системі виявляється за допомогою автоматизованих механізмів частота

No: 4

Name: cm_8_3_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для виявлення наявності несанкціонованого обладнання в системі

No: 5

Name: cm_8_3_odp_02

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для виявлення наявності несанкціонованого програмного забезпечення в системі

No: 6

Name: cm_8_3_odp_03

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для виявлення наявності несанкціонованих мікро-програмних компонентів в системі

No: 7

Name: cm_8_3_odp_04

Type: integer

Default: 30

Визначено частоту, з якою використовуються автоматизовані механізми для виявлення присутності несанкціонованих компонентів системи в системі

No: 8

Name: cm_8_3_odp_05

Type: list

Default: ["admin", "security_officer"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {відключення доступу до мережі такими компонентами; ізолювати компоненти; повідомити персонал або ролі}

No: 9

Name: cm_8_3_odp_06

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які мають бути повідомлені при виявленні несанкціонованих компонентів (якщо вибрано)

5.8.4. ІНФОРМАЦІЯ ПРО ПІДЗВІТНІСТЬ (СМ-8(4))

No: 1

Name: cm_8_4_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {ім'я; позиція; роль}

5.8.5. ІНВЕНТАРИЗАЦІЯ КОМПОНЕНТІВ СИСТЕМИ ДУБЛЮВАННЯ КОМПОНЕНТІВ ОБЛІКУ (СМ-8(5))

Немає параметрів для цього контролю.

5.8.6. ПЕРЕВІРЕНІ НАЛАШТУВАННЯ ТА ЗАТВЕРДЖЕНІ ВІДХИЛЕННЯ (СМ-8(6))

No: 1

Name: cm_8_6_01

Type: string

Default: nil

Включено перевірені налаштування компонентів до поточних розгорнутих конфігурацій в інвентаризаційний облік компонентів системи

No: 2

Name: cm_8_6_02

Type: string

Default: nil

Включено будь-які затверджені відхилення до поточних розгорнутих конфігурацій в інвентаризаційний облік компонентів системи

5.8.7. ЦЕНТРАЛІЗОВАНЕ СХОВИЩЕ (СМ-8(7))

Впровадити централізоване компонентів системи. сховище СИСТЕМИ для - ЦЕНТРАЛІЗОВАНЕ інвентаризаційного обліку

No: 1

Name: cm_8_7_01

Type: string

Default: nil

Впроваджено централізоване сховище для інвентаризаційного обліку компонентів системи

5.8.8. АВТОМАТИЗОВАНЕ ВІДСТЕЖЕННЯ МІСЦЯ РОЗТАШУВАННЯ (СМ-8(8))

No: 1

Name: cm_8_8_01

Type: string

Default: "автоматизований засіб моніторингу"

Використовуються автоматизовані механізми для підтримки відстеження компонентів системи за географічним розташуванням

No: 2

Name: cm_8_8_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми відстеження компонентів

5.8.9. ПРИЗНАЧЕННЯ КОМПОНЕНТІВ СИСТЕМАМ (СМ-8(9))

No: 1

Name: cm_8_9_a

Type: string

Default: nil

Компоненти системи призначаються системі

No: 2
 Name: cm_8_9_b
 Type: list
 Default: ["admin", "security_officer"]

Отримано підтвердження призначення компонента від персонал або ролі

No: 3
 Name: cm_8_9_odp
 Type: list
 Default: ["admin", "security_officer"]

Визначено персонал або ролі, від яких слід отримувати підтвердження

5.9. РОЗТАШУВАННЯ ІНФОРМАЦІЇ (СМ-12)

No: 1
 Name: cm_12_a_01
 Type: string
 Default: nil

Місцезнаходження інформація визначено та задокументовано

No: 2
 Name: cm_12_a_02
 Type: string
 Default: nil

Визначено та задокументовано конкретні компоненти системи, на яких обробляється інформація

No: 3
 Name: cm_12_a_03
 Type: string
 Default: nil

Визначено та задокументовано конкретні компоненти системи, на яких зберігається інформація

No: 4
 Name: cm_12_b_01
 Type: string
 Default: nil

Визначено та задокументовано користувачів, які мають доступ до системи та компонентів системи, де обробляється інформація

No: 5
 Name: cm_12_b_02
 Type: string
 Default: nil

Визначено та задокументовано користувачів, які мають доступ до системи та компонентів системи, де зберігається інформація; СМ-12(с)[01] задокументовано зміни розташування (наприклад, системи або компонентів системи), де обробляється інформація

No: 6
 Name: cm_12_c_02
 Type: string
 Default: nil

Задокументовано зміни розташування (наприклад, системи або компонентів системи), де зберігається інформація

No: 7
 Name: cm_12_odp
 Type: string
 Default: nil

Визначено інформацію, місцезнаходження якої має бути визначено та задокументовано

5.9.1. АВТОМАТИЗОВАНІ ІНСТРУМЕНТИ ПІДТРИМКИ РОЗТАШУВАННЯ ІНФОРМАЦІЇ (СМ-12(1))

No: 1
 Name: cm_12_1_01
 Type: list
 Default: ["admin", "security_officer"]

Автоматизовані інструменти використовуються для ідентифікації інформації за типом на компонентах системи, щоб забезпечити впровадження належних заходів захисту щодо інформації про організацію і персональних даних

No: 2
 Name: cm_12_1_odp_01
 Type: string
 Default: nil

Інформація визначена за типом

No: 3
 Name: cm_12_1_odp_02
 Type: string
 Default: nil

Визначено компоненти системи, де знаходиться інформація

6. СР

Клас заходів захисту СР — ПЛАНУВАННЯ БЕЗПЕРЕРВНОЇ РОБОТИ

6.1. РЕЗЕРВНЕ КОПІЮВАННЯ (СР-9)

No: 1
 Name: cp_9_01
 Type: string
 Default: nil

РЕЗЕРВНЕ КОПІЮВАННЯ МЕТА ОЦІНКИ: Визначити, чи:

No: 2
 Name: cp_9_a
 Type: string
 Default: "щорічно"

Резервне копіювання інформації користувача, що міститься в компонентах системи, здійснюється частота

No: 3
 Name: cp_9_b
 Type: string
 Default: "щорічно"

Виконується резервне копіювання інформації системи, що міститься в системі частота; СР-09(с) створюються резервні копії документації системи, включаючи документацію, пов'язану з безпекою та конфіденційністю частота

No: 4
 Name: cp_9_d_01
 Type: string
 Default: nil

Конфіденційність резервних копій інформації захищена

No: 5
 Name: cp_9_d_02
 Type: string
 Default: nil

Цілісність резервних копій інформації захищена

No: 6
 Name: cp_9_d_03
 Type: string
 Default: nil

Доступність резервних копій інформації захищена

No: 7
 Name: cp_9_odp_01
 Type: string
 Default: nil

Визначено компоненти системи, для яких необхідно проводити резервне копіювання інформації користувачів

No: 8
 Name: cp_9_odp_02
 Type: integer
 Default: 30

Визначено частоту, з якою слід проводити резервне копіювання інформації користувача відповідно до часу відновлення та цілей відновлення

No: 9
 Name: cp_9_odp_03
 Type: integer
 Default: 30

Визначено частоту проведення резервного копіювання інформації системи, що відповідає завдань відновлення і встановлених цілей відновлення

No: 10
 Name: cp_9_odp_04
 Type: integer
 Default: 30

Визначено частоту, з якою слід проводити резервне копіювання документації системи відповідно до часу відновлення та цілей точки відновлення

6.1.1. ВИПРОБУВАННЯ НА НАДІЙНІСТЬ ТА ЦІЛІСНІСТЬ (СР-9(1))

No: 1

Name: cp_9_1_01

Type: string

Default: "щорічно"

Носії резервних копій інформації тестується 09(01)_ODP[01] частота> для перевірки надійності; <СР-

No: 2

Name: cp_9_1_02

Type: string

Default: "щорічно"

Носії резервних копій інформації тестується 09(01)_ODP[02] частота> для перевірки цілісності; <СР-

No: 3

Name: cp_9_1_odp_01

Type: integer

Default: 30

Визначено частоту тестування на надійність носіїв резервних копій інформації

No: 4

Name: cp_9_1_odp_02

Type: integer

Default: 30

Визначено частоту тестування на цілісність носіїв резервних копій інформації

6.1.2. ТЕСТУВАННЯ ВІДНОВЛЕННЯ З ВИКОРИСТАННЯМ ЗРАЗКІВ (СР-9(2))

No: 1

Name: cp_9_2_01

Type: integer

Default: 30

Використовується зразок резервної копії інформації при відновленні вибраних функцій системи як частину тестування плану забезпечення безперервної роботи та відновлення функціонування

6.1.3. ВІДОКРЕМЛЕНЕ СХОВИЩЕ КРИТИЧНОЇ ІНФОРМАЦІЇ (СР-9(3))

No: 1

Name: cp_9_3_01

Type: string

Default: nil

Резервні копії критичного системного програмного забезпечення та іншої інформації, пов'язаної з безпекою зберігаються в окремому сховищі або у вогнетривкому контейнері, не пов'язаному з системою

No: 2

Name: cp_9_3_odp

Type: string

Default: nil

Визначено критичного системного програмного забезпечення та іншої інформації, пов'язаної з безпекою яке має зберігатися в окремому сховищі або у вогнетривкому контейнері

6.1.4. ПЕРЕДАЧА НА АЛЬТЕРНАТИВНЕ СХОВИЩЕ ЗБЕРІГАННЯ (CP-9(5))

No: 1

Name: cp_9_5_01

Type: integer

Default: 30

Інформація резервної копії системи передається до альтернативного сховища протягом періоду часу; CP-09(05)[02] інформація резервної копії системи передається до альтернативного сховища з швидкість передачі

No: 2

Name: cp_9_5_odp_01

Type: integer

Default: 30

Визначено період часу, що відповідає часу відновлення та цілям відновлення

No: 3

Name: cp_9_5_odp_02

Type: integer

Default: 30

Визначено швидкість передачі даних, що відповідає часу відновлення та цілям відновлення

6.1.5. НАДЛИШКОВА ВТОРИННА СИСТЕМА (CP-9(6))

No: 1

Name: cp_9_6_01

Type: string

Default: nil

Резервне копіювання системи здійснюється шляхом підтримки надлишкової вторинної системи, яка не пов'язана з первинною системою

No: 2

Name: cp_9_6_02

Type: string

Default: nil

Резервне копіювання системи здійснюється шляхом підтримки резервної вторинної системи, яка може бути активована без втрати інформації або порушення роботи

6.1.6. ПОДВІЙНА АВТОРИЗАЦІЯ (CP-9(7))

No: 1

Name: cp_9_7_01

Type: string

Default: nil

Застосовано подвійну авторизацію для видалення або знищення резервної інформації

No: 2

Name: cp_9_7_odp

Type: string

Default: nil

Визначено резервну інформацію, для якої необхідно застосувати подвійну авторизацію з метою видалення або знищення

6.1.7. КРИПТОГРАФІЧНИЙ ЗАХИСТ (CP-9(8))

No: 1

Name: cp_9_8_01

Type: string

Default: "AES-256-GCM"

Реалізовано криптографічні механізми для запобігання несанкціонованому розкриттю та зміні резервної інформації

No: 2

Name: cp_9_8_odp

Type: string

Default: nil

Визначено резервні копії інформації для захисту від несанкціонованого розкриття та змін

7. ІА

Клас заходів захисту ІА — ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ

7.1. Політика та процедури ідентифікації та автентифікації (ІА-1)

No: 1

Name: ia_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику ідентифікації та автентифікації

No: 2

Name: ia_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика ідентифікації та автентифікації поширюється на персонал або ролі

No: 3

Name: ia_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблені та задокументовані процедури ідентифікації та автентифікації, що сприяють впровадженню політики ідентифікації та автентифікації, а також відповідні заходи ідентифікації та перевірки автентичності

No: 4

Name: ia_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління політикою та процедурами ідентифікації та автентифікації;
 IA-01(c)[01][01] переглядається та оновлюється поточна політика ідентифікації та автентифікації частота;
 IA-01(c)[01][02] переглядається та оновлюється поточна політика ідентифікації та автентифікації після подій;
 IA-01(c)[02][01] переглядаються та оновлюються поточні процедури ідентифікації та автентифікації частота;
 IA-01(c)[02][02] переглядаються та оновлюються поточні процедури ідентифікації та автентифікації після подій

No: 5

Name: ia_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюється політика ідентифікації та автентифікації

No: 6

Name: ia_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури ідентифікації та автентифікації

No: 7

Name: ia_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесів; рівень системи}

No: 8

Name: ia_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка управляє політикою та процедурами ідентифікації та автентифікації

No: 9

Name: ia_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика ідентифікації та автентифікації

No: 10

Name: ia_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, які потребують перегляду та оновлення поточної політики ідентифікації та автентифікації

No: 11

Name: ia_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури ідентифікації та автентифікації

No: 12

Name: ia_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення процедур ідентифікації та автентифікації

7.2. ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ КОРИСТУВАЧІВ (ІА-2)

No: 1

Name: ia_2_01

Type: string

Default: nil

ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: ia_2_02

Type: string

Default: nil

Процеси що діють від імені користувачів унікально ідентифіковані та автентифіковані

7.2.1. БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ ПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (ІА-2(1))

No: 1

Name: ia_2_1_01

Type: string

Default: nil

Реалізовано багатофакторну автентифікацію для доступу до привілейованих облікових записів

7.2.2. БАГАТОФАКТОРНА АВТЕНТИФІКАЦІЯ НЕПРИВІЛЕЙОВАНИХ (ІА-2(2))

No: 1

Name: ia_2_2_01

Type: string

Default: nil

Реалізовано багатофакторну автентифікацію для доступу до непривілейованих облікових записів

7.2.3. ЛОКАЛЬНИЙ ДОСТУП ДО ПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (ІА-2(3))

No: 1

Name: ia_2_3_01

Type: string

Default: nil

ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - ЛОКАЛЬНИЙ ДОСТУП ДО ПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ [Вилучено: Включено до ІА-02(01)]

7.2.4. ЛОКАЛЬНИЙ ДОСТУП ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ (IA-2(4))

No: 1
 Name: ia_2_4_01
 Type: string
 Default: nil

ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - ЛОКАЛЬНИЙ ДОСТУП ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ [Вилучено: Включено до IA-02(02)]

7.2.5. ІНДИВІДУАЛЬНА АВТЕНТИФІКАЦІЯ З ГРУПОВОЮ АВТЕНТИФІКАЦІЄЮ (IA-2(5))

No: 1
 Name: ia_2_5_01
 Type: string
 Default: nil

Користувачі повинні пройти індивідуальну автентифікацію перед наданням доступу до спільних облікових записів або ресурсів, якщо використовуються спільні облікові записи або автентифікатори

7.2.6. МЕРЕЖЕВИЙ ДОСТУП ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ – ОКРЕМИЙ ПРИСТРІЙ (IA-2(7))

No: 1
 Name: ia_2_7_01
 Type: string
 Default: nil

ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - МЕРЕЖЕВИЙ ДОСТУП ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ – ОКРЕМИЙ ПРИСТРІЙ [Вилучено: Включено до IA-02(01)]

7.2.7. Доступ до облікових записів — стійкість до відтворення (IA-2(8))

No: 1
 Name: ia_2_8_odp
 Type: string
 Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {привілейовані облікові записи; непривілейовані облікові записи}

7.2.8. ДОСТУП ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ – СТІЙКІСТЬ ДО ВІДТВОРЕННЯ (IA-2(9))

No: 1
 Name: ia_2_9_01
 Type: string
 Default: nil

ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - ДОСТУП ДО НЕПРИВІЛЕЙОВАНИХ ОБЛІКОВИХ ЗАПИСІВ – СТІЙКІСТЬ ДО ВІДТВОРЕННЯ [Вилучено: Включено до ІА-02(08)].
ІА-02(10) ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - ЄДИНА ТОЧКА ВХОДУ

7.2.9. ЄДИНА ТОЧКА ВХОДУ (ІА-2(10))

No: 1
Name: ia_2_10_odp
Type: string
Default: nil

Визначено облікові записи та послуги системи, для яких має бути забезпечена можливість єдиного входу; забезпечено можливість єдиного входу для облікових записів і послуг системи

7.2.10. ВІДДАЛЕНИЙ ДОСТУП - ОКРЕМИЙ ПРИСТРІЙ (ІА-2(11))

No: 1
Name: ia_2_11_01
Type: string
Default: nil

ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ (КОРИСТУВАЧІВ ОРГАНІЗАЦІЇ) - ВІДДАЛЕНИЙ ДОСТУП - ОКРЕМИЙ ПРИСТРІЙ [Вилучено: Включено до ІА-02(06)]

7.2.11. ПРИЙНЯТТЯ ПОВНОВАЖЕНЬ ДЛЯ ВЕРИФІКАЦІЇ ОСОБИСТОЇ ІНФОРМАЦІЇ (PIV CREDENTIALS) (ІА-2(12))

No: 1
Name: ia_2_12_01
Type: list
Default: ["admin", "security_officer"]

Приймаються та електронним шляхом підтверджуються повноваження облікових даних особистої ідентифікації

7.2.12. АВТЕНТИФІКАЦІЯ ПО ЗОВНІШНЬОМУ КАНАЛУ (ІА-2(13))

No: 1
Name: ia_2_13_01
Type: string
Default: "автоматизований засіб моніторингу"

Механізми зовнішньої автентифікації застосовано за умов

No: 2
Name: ia_2_13_odp_01
Type: string
Default: "автоматизований засіб моніторингу"

Визначено механізми зовнішньої автентифікації

No: 3
Name: ia_2_13_odp_02

Type: list

Default: []

Визначено умови, за яких має бути реалізована зовнішня автентифікація

7.3. ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ ПРИСТРОЇВ (ІА-3)

No: 1

Name: ia_3_odp_01

Type: string

Default: nil

Визначені пристрої та/або типи пристроїв, які повинні бути унікально ідентифіковані та автентифіковані перед установкою підключення

No: 2

Name: ia_3_odp_02

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {локальний; віддалений; мережевий}

7.3.1. КРИПТОГРАФІЧНА ДВОБІЧНА АВТЕНТИФІКАЦІЯ (ІА-3(1))

No: 1

Name: ia_3_1_odp_01

Type: string

Default: "AES-256-GCM"

Визначено пристрої та/або типи пристроїв, які потребують використання двобічної автентифікації яка заснована на криптографічних механізмах для автентифікації перед встановленням підключення

No: 2

Name: ia_3_1_odp_02

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {локальний; віддалений; мережевий}

7.3.2. КРИПТОГРАФІЧНИЙ ДВОБІЧНА МЕРЕЖА АВТЕНТИФІКАЦІЯ [Виключено: включено до ІА-03(01)]. (ІА-3(2))

Немає параметрів для цього контролю.

7.3.3. ДИНАМІЧНИЙ РОЗПОДІЛ АДРЕСИ (ІА-3(3))

No: 1

Name: ia_3_3_a_01

Type: string

Default: nil

Інформація про оренду динамічного розподілу адрес, що призначається пристроям з динамічним розподілом адрес, стандартизована відповідно до інформація про оренду

No: 2

Name: ia_3_3_a_02

Type: string

Default: nil

Тривалість оренди динамічного виділення адреси, що призначається пристроям з динамічним виділенням адреси, стандартизовано відповідно до тривалість оренди

No: 3

Name: ia_3_3_b

Type: string

Default: nil

Інформація про оренду перевіряється, коли її призначено пристрою

No: 4

Name: ia_3_3_odp_01

Type: string

Default: nil

Визначено інформацію про оренду, яку буде використано для стандартизації динамічного розподілу адрес для пристроїв

No: 5

Name: ia_3_3_odp_02

Type: string

Default: nil

Визначено тривалість оренди, яка буде використовуватися для стандартизації динамічного виділення адрес для пристроїв

7.3.4. ІДЕНТИФІКАЦІЯ ТА АВТЕНТИФІКАЦІЯ ПРИСТРОЮ ВИКОНУЄТЬСЯ НА ОСНОВІ АТЕСТАЦІЇ ЗА ДОПОМОГОЮ (IA-3(4))

No: 1

Name: ia_3_4_01

Type: string

Default: nil

Ідентифікація та автентифікація пристрою виконується на основі атестації за допомогою процес управління конфігурацією

No: 2

Name: ia_3_4_odp

Type: string

Default: nil

Визначено процес управління конфігурацією, який буде використовуватися для ідентифікації та автентифікації пристроїв на основі атестації

7.4. УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ (IA-4)

No: 1

Name: ia_4_a

Type: list

Default: ["admin", "security_officer"]

Управління ідентифікаторами здійснюється шляхом отримання дозволу від персоналу або ролей на призначення ідентифікатора особи, групі, ролі або пристрою

No: 2

Name: ia_4_b

Type: list

Default: ["admin", "security_officer"]

Управління ідентифікаторами здійснюється шляхом вибору ідентифікатора, який ідентифікує окрему особу, групу, ролі або пристрій

No: 3

Name: ia_4_c

Type: list

Default: ["admin", "security_officer"]

Управління ідентифікаторами здійснюється шляхом призначення ідентифікатора особи, групі, ролі або пристрою; IA-04(d) ідентифікатори управляються шляхом запобігання повторному використанню ідентифікаторів впродовж період часу

No: 4

Name: ia_4_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, від яких необхідно отримати дозвіл на призначення ідентифікатора

No: 5

Name: ia_4_odp_02

Type: integer

Default: 30

Визначено період часу для запобігання повторному використанню ідентифікаторів

7.4.1. ЗАБОРОНА ВИКОРИСТАННЯ ІДЕНТИФІКАТОРІВ ОБЛІКОВИХ ЗАПИСІВ ТАКИ САМИХ, ЯК Й ПУБЛІЧНІ ІДЕНТИФІКАТОРИ (IA-4(1))

No: 1

Name: ia_4_1_01

Type: string

Default: nil

Заборонено використання ідентифікаторів облікових записів системи, які збігаються із загальнодоступними ідентифікаторами для індивідуальних облікових записів

7.4.2. АВТОРИЗАЦІЯ СУПЕРВАЙЗЕРА [Виключено: Включено до IA-12(01)]. (IA-4(2))

No: 1

Name: ia_4_2_01

Type: string

Default: nil

УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ - АВТОРИЗАЦІЯ СУПЕРВАЙЗЕРА [Виключено: Включено до IA-12(01)]

7.4.3. МНОЖИННІ ФОРМИ СЕРТИФІКАЦІЇ (IA-4(3))

No: 1
 Name: ia_4_3_01
 Type: string
 Default: nil

УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ - МНОЖИННІ ФОРМИ СЕРТИФІКАЦІЇ [Виключено: Включено до IA-12(02)]

7.4.4. ІДЕНТИФІКАЦІЯ СТАТУСУ КОРИСТУВАЧА (IA-4(4))

No: 1
 Name: ia_4_4_01
 Type: string
 Default: nil

Управління індивідуальними ідентифікаторами, однозначно ідентифікуючи кожного індивідуума ознака, що ідентифікує індивідуальний статус

No: 2
 Name: ia_4_4_odp
 Type: string
 Default: nil

Визначено ознаку, що ідентифікує індивідуальний статус

7.4.5. ДИНАМІЧНЕ УПРАВЛІННЯ (IA-4(5))

No: 1
 Name: ia_4_5_01
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Індивідуальні ідентифікатори динамічно управляються відповідно до політика динамічних ідентифікаторів

No: 2
 Name: ia_4_5_odp
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Визначено політику динамічних ідентифікаторів управління індивідуальними ідентифікаторами

7.4.6. КРОС-ОРГАНІЗАЦІЙНЕ УПРАВЛІННЯ (IA-4(6))

No: 1
 Name: ia_4_6_odp
 Type: string
 Default: nil

Визначено зовнішні організації з якими необхідно здійснювати координацію для крос-організаційного управління ідентифікаторами; здійснюється координація з зовнішні організації для крос-організаційного управління ідентифікаторами

7.4.7. ОСОБИСТА РЕЄСТРАЦІЯ [Виключено: Включено до ІА-12(04)]. (ІА-4(7))

No: 1

Name: ia_4_7_01

Type: list

Default: ["admin", "security_officer"]

УПРАВЛІННЯ ІДЕНТИФІКАЦІЄЮ - ОСОБИСТА РЕЄСТРАЦІЯ [Виключено: Включено до ІА-12(04)]

7.4.8. ПОПАРНІ ПСЕВДОНІМНІ ІДЕНТИФІКАТОРИ (ІА-4(8))

No: 1

Name: ia_4_8_01

Type: string

Default: nil

Створено попарні псевдонімні ідентифікатори

7.4.9. ПОПАРНІ ПСЕВДОНІМНІ ІДЕНТИФІКАТОРИ (ІА-4(9))

No: 1

Name: ia_4_9_odp

Type: list

Default: ["admin", "security_officer"]

Визначено захищене центральне сховище, яке використовується для зберігання атрибутів для кожної унікально ідентифікованої особи, пристрою або служби; атрибути для кожної унікально ідентифікованої особи, пристрою або служби зберігаються у захищеному центральному сховищі

7.5. АВТЕНТИФІКАТОР УПРАВЛІННЯ

No: 1

Name: ia_5_a

Type: list

Default: ["admin", "security_officer"]

Управління системними автентифікаторами здійснюється шляхом перевірки, як частини початкового розподілу автентифікатора, особи, групи, ролі або пристрою, який отримує автентифікатор

No: 2

Name: ia_5_b

Type: string

Default: nil

Управління системними автентифікаторами здійснюється шляхом створення вихідного вмісту автентифікатора для будь-яких автентифікаторів, виданих організацією

No: 3

Name: ia_5_c

Type: string

Default: nil

Управління системними автентифікаторами здійснюється шляхом забезпечення того, щоб автентифікатори мали достатню стійкість механізму для їх використання за призначенням; ІА-05(d) управління системними

автентифікаторами здійснюється шляхом створення та реалізація адміністративних процедур для первинного розповсюдження автентифікаторів, для втрачених/скомпрометованих або пошкоджених автентифікаторів, а також для відкликання автентифікаторів

No: 4
Name: ia_5_e
Type: string
Default: nil

Управління системними автентифікаторами здійснюється шляхом зміни типових автентифікаторів перед першим використанням

No: 5
Name: ia_5_f
Type: list
Default: ["login", "logout", "failed_attempt"]

Управління системними автентифікаторами здійснюється шляхом зміни/оновлення автентифікаторів у встановлений період часу або коли відбуваються події

No: 6
Name: ia_5_g
Type: string
Default: nil

Управління системними автентифікаторами здійснюється шляхом захисту вмісту автентифікатора від несанкціонованого розкриття та модифікацій

No: 7
Name: ia_5_h
Type: string
Default: nil

Управління системними автентифікаторами здійснюється шляхом вимоги до осіб, які використовують пристрої, використовувати спеціальні заходи безпеки для захисту автентифікаторів

No: 8
Name: ia_5_i
Type: string
Default: nil

Управління системними автентифікаторами здійснюється шляхом вимоги змінювати автентифікатори для облікових записів груп/ролей при зміні членства в цих облікових записах

No: 9
Name: ia_5_odp_01
Type: integer
Default: 30

Визначено період часу для зміни або оновлення автентифікаторів за типом автентифікатора

7.5.1. АВТЕНТИФІКАЦІЯ НА ОСНОВІ ПАРОЛЯ (IA-5(1))

No: 1
Name: ia_5_1_a
Type: list
Default: ["admin", "security_officer"]

Для автентифікації на основі паролів підтримується та оновлюється список часто використовуваних, очікуваних або скомпрометованих паролів частота, а також коли є підозра, що паролі організації були скомпрометовані прямо чи опосередковано

No: 2

Name: ia_5_1_b

Type: list

Default: ["admin", "security_officer"]

Для автентифікації на основі паролів, коли паролі створюються або оновлюються користувачами, паролі перевіряються на відсутність у списку загальноновживаних, очікуваних або скомпрометованих паролів в ІА-05(01)(a)

No: 3

Name: ia_5_1_c

Type: list

Default: ["admin", "security_officer"]

Для автентифікації на основі паролів, паролі передаються лише криптографічно захищеними каналами

No: 4

Name: ia_5_1_d

Type: list

Default: ["admin", "security_officer"]

Для автентифікації на основі паролів паролі зберігаються за допомогою затвердженого алгоритму ґешування, переважно використовуючи ключову ґеш-функцію

No: 5

Name: ia_5_1_e

Type: string

Default: nil

Для автентифікації на основі пароля після відновлення облікового запису потрібно негайно вибрати новий пароль

No: 6

Name: ia_5_1_f

Type: list

Default: ["admin", "security_officer"]

Для автентифікації на основі пароля дозволяється вибір користувачем довгих паролів і фраз, що включають пробіли та всі друковані символи

No: 7

Name: ia_5_1_g

Type: list

Default: ["admin", "security_officer"]

Для автентифікації на основі пароля використовуються автоматизовані інструменти, які допомагають користувачеві у виборі надійних автентифікаторів паролів

No: 8

Name: ia_5_1_h

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Для автентифікації на основі пароля застосовуються склад та правила складності

No: 9

Name: ia_5_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено частоту оновлення списку часто використовуваних, очікуваних або скомпрометованих паролів

No: 10

Name: ia_5_1_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено склад та правила складності автентифікатора

7.5.2. АВТЕНТИФІКАЦІЯ НА ОСНОВІ ВІДКРИТОГО КЛЮЧА (IA-5(2))

Немає параметрів для цього контролю.

7.5.3. ОСОБИСТА АБО ДОВІРЧА АВТЕНТИФІКАЦІЯ ЗОВНІШНЬОЇ СТОРОНИ [Виключено: Включено до IA-12(04)]. (IA-5(3))

No: 1

Name: ia_5_3_01

Type: list

Default: ["admin", "security_officer"]

УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - ОСОБИСТА АБО ДОВІРЧА АВТЕНТИФІКАЦІЯ ЗОВНІШНЬОЇ СТОРОНИ [Виключено: Включено до IA-12(04)]

7.5.4. АВТОМАТИЗОВАНА ПІДТРИМКА ДЛЯ ВИЗНАЧЕННЯ МІЦНОСТІ ПАРОЛЯ [Виключено: Включено до IA-05(01)]. (IA-5(4))

No: 1

Name: ia_5_4_01

Type: string

Default: nil

УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - АВТОМАТИЗОВАНА ПІДТРИМКА ДЛЯ ВИЗНАЧЕННЯ МІЦНОСТІ ПАРОЛЯ [Виключено: Включено до IA-05(01)]

7.5.5. ЗМІНА АВТЕНТИФІКАТОРІВ ДО ДОСТАВКИ (IA-5(5))

No: 1

Name: ia_5_5_01

Type: string

Default: nil

Розробники та інсталятори компонентів системи зобов'язані надавати унікальні автентифікатори або змінювати автентифікатори за замовчуванням до доставки та встановлення

7.5.6. ЗАХИСТ АВТЕНТИФІКАТОРІВ (IA-5(6))

No: 1

Name: ia_5_6_01

Type: string

Default: nil

Автентифікатори захищені відповідно до категорії безпеки інформації, до якої дозволяє доступ використання автентифікатора

7.5.7. ВІДСУТНІСТЬ ВБУДОВАНИХ НЕЗАШИФРОВАНИХ СТАТИЧНИХ АВТЕНТИФІКАТОРІВ (IA-5(7))

No: 1

Name: ia_5_7_01

Type: string

Default: nil

Незашифровані статичні автентифікатори не вбудовуються в застосунки або сценарії доступу та не збережені на функціональній клавіші

7.5.8. БАГАТОСИСТЕМНІ ОБЛІКОВІ ЗАПИСИ (IA-5(8))

No: 1

Name: ia_5_8_01

Type: string

Default: nil

Заходи захисту впроваджені для управління ризиком компрометації через наявність облікових записів у декількох системах

No: 2

Name: ia_5_8_odp

Type: string

Default: nil

Визначено заходи захисту, впроваджені для управління ризиком компрометації через те, що користувачі мають облікові записи в декількох системах

7.5.9. УПРАВЛІННЯ ОБ'ЄДНАННЯМ АВТЕНТИФІКАТОРІВ (IA-5(9))

No: 1

Name: ia_5_9_01

Type: string

Default: nil

Зовнішні організації використовуються для об'єднання автентифікаторів

No: 2

Name: ia_5_9_odp

Type: string

Default: nil

Визначено зовнішні організації, які будуть використовуватися для об'єднання автентифікаторів

7.5.10. ДИНАМІЧНЕ ЗВ'ЯЗУВАННЯ МАНДАТІВ (IA-5(10))

No: 1

Name: ia_5_10_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Ідентифікатори та автентифікатори динамічно зв'язуються за допомогою правила для динамічного зв'язування

No: 2

Name: ia_5_10_odp

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено правила для динамічного зв'язування ідентифікаторів та автентифікаторів

7.5.11. АВТЕНТИФІКАЦІЯ НА ОСНОВІ АПАРАТНИХ ТОКЕНІВ (IA-5(11))

No: 1

Name: ia_5_11_01

Type: string

Default: nil

УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - АВТЕНТИФІКАЦІЯ НА ОСНОВІ АПАРАТНИХ ТОКЕНІВ [Вилучено: Включено до IA-02(01), IA-02(02)]

7.5.12. ЕФЕКТИВНІСТЬ БІОМЕТРИЧНОЇ АВТЕНТИФІКАЦІЇ (IA-5(12))

No: 1

Name: ia_5_12_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено вимоги до якості біометрії; для біометричної автентифікації використовувати механізми, які задовольняють вимоги

7.5.13. ЗАКІНЧЕННЯ ТЕРМІНУ ШУВАННЯ АВТЕНТИФІКАТОРІВ (IA-5(13))

No: 1

Name: ia_5_13_odp

Type: integer

Default: 30

Визначено періоду часу після якого необхідно заборонити використання кешованих автентифікаторів забороняється використання кешованих автентифікаторів після періоду часу

7.5.14. УПРАВЛІННЯ ЗМІСТОМ ДОВІРЧИХ СХОВИЩ ІНФРАСТРУКТУРИ ВІДКРИТИХ КЛЮЧІВ (IA-5(14))

No: 1

Name: ia_5_14_01

Type: string

Default: nil

Для автентифікації на основі інфраструктури з відкритим ключем використовується загальноорганізаційна методологія управління змістом довірених сховищ інфраструктури відкритого ключа, встановлених на всіх платформах, включно з мережами, операційними системами, браузерами та застосунками

7.5.15. ПРОДУКТИ ТА ПОСЛУГИ, ЗАТВЕРДЖЕНІ УПОВНОВАЖЕНИМ ОРГАНОМ (IA-5(15))

No: 1
 Name: ia_5_15_01
 Type: string
 Default: nil

Використовуються лише схвалені та затверджені уповноваженим органом продукти та послуги

7.5.16. ПЕРЕДАЧА ОСОБИСТОЇ АБО ДОВІРЧОЇ АВТЕНТИФІКАЦІЇ ЗОВНІШНЬОЇ СТОРОНИ (IA-5(16))

No: 1
 Name: ia_5_16_01
 Type: list
 Default: ["admin", "security_officer"]

УПРАВЛІННЯ АВТЕНТИФІКАТОРОМ - ПЕРЕДАЧА ОСОБИСТОЇ АБО ДОВІРЧОЇ АВТЕНТИФІКАЦІЇ ЗОВНІШНЬОЇ СТОРОНИ МЕТА ОЦІНКИ: Визначити, чи:

No: 2
 Name: ia_5_16_odp_01
 Type: string
 Default: nil

Визначено типи та/або конкретні автентифікатори, які будуть передаватися

No: 3
 Name: ia_5_16_odp_02
 Type: list
 Default: ["admin", "security_officer"]

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {особисто; довіреною зовнішньою стороною}

No: 4
 Name: ia_5_16_odp_03
 Type: string
 Default: nil

Визначено зареєстрований орган, який приймає автентифікатори

No: 5
 Name: ia_5_16_odp_04
 Type: list
 Default: ["admin", "security_officer"]

Визначено персонал або ролі, які уповноважують передачу автентифікаторів

7.5.17. АВТОМАТИЗОВАНІ ЗАСОБИ ВИЯВЛЕННЯ АТАК ІЗ ВИКОРИСТАННЯМ БІОМЕТРИЧНИХ АВТЕНТИФІКАТОРІВ (IA-5(17))

No: 1
 Name: ia_5_17_01
 Type: string
 Default: "автоматизований засіб моніторингу"

Використовуються механізми виявлення атак із використанням штучно виготовлених артефактів для біометричних автентифікаторів

7.5.18. МЕНЕДЖЕР ПАРОЛІВ (ІА-5(18))

No: 1

Name: ia_5_18_a

Type: list

Default: ["admin", "security_officer"]

Менеджери паролів використовуються для створення та керування паролями

No: 2

Name: ia_5_18_b

Type: list

Default: ["admin", "security_officer"]

Паролі захищені за допомогою елементи керування

No: 3

Name: ia_5_18_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено менеджери паролів, які використовуються для створення та керування паролями

No: 4

Name: ia_5_18_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено елементи керування для захисту паролів

7.6. ПРИХОВУВАННЯ ЗВОРОТНОГО ЗВ'ЯЗКУ АВТЕНТИФІКАТОРА

No: 1

Name: ia_6_01

Type: list

Default: ["admin", "security_officer"]

Забезпечено приховану зворотню передачу інформації автентифікації в процесі автентифікації для забезпечення захисту інформації від можливої експлуатації та використання неавторизованими особами

7.7. ПОВТОРНА АВТЕНТИФІКАЦІЯ (ІА-11)

No: 1

Name: ia_11_01

Type: string

Default: nil

Користувачі повинні повторно автентифікуватися, коли обставини або ситуації

No: 2

Name: ia_11_odp

Type: string

Default: nil

Визначено обставини або ситуації, що вимагають повторної автентифікації

8. IR

Клас заходів захисту IR — РЕАГУВАННЯ НА ІНЦИДЕНТИ

8.1. Політика та процедури реагування на інциденти (IR-1)

No: 1

Name: ir_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику реагування на інциденти

No: 2

Name: ir_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика реагування на інциденти поширюється серед персоналу або ролей

No: 3

Name: ir_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблені та задокументовані процедури реагування на інциденти, що сприяють впровадженню політики реагування на інциденти та пов'язаних з нею заходів захисту з реагування на інциденти

No: 4

Name: ir_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур реагування на інциденти; IR-01(c)[01][01] переглядається та оновлюється поточна політика реагування на інциденти частота; IR-01(c)[01][02] поточна політика реагування на інциденти переглядається та оновлюється після подій; IR-01(c)[02][01] переглядаються та оновлюються поточні процедури реагування на інциденти частота; IR-01(c)[02][02] поточні процедури реагування на інциденти переглядаються та оновлюються після подій

No: 5

Name: ir_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких має бути доведена політика реагування на інциденти

No: 6

Name: ir_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких мають бути доведені процедури реагування на інциденти

No: 7

Name: ir_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: ir_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами реагування на інциденти

No: 9

Name: ir_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика реагування на інциденти

No: 10

Name: ir_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначаються події, які потребують перегляду та оновлення поточної політики реагування на інциденти

No: 11

Name: ir_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури реагування на інциденти

No: 12

Name: ir_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення процедур реагування на інциденти

8.2. НАВЧАННЯ З РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-2)

No: 1

Name: ir_2_a_01

Type: list

Default: ["admin", "security_officer"]

Навчання з реагування на інциденти надається користувачам системи відповідно до призначених ролей та обов'язків протягом періоду часу з моменту прийняття на себе ролі або обов'язків з реагування на інциденти або отримання доступу до системи

No: 2
 Name: ir_2_a_02
 Type: string
 Default: nil

Навчання з реагування на інциденти надається користувачам системи відповідно до призначених ролей та обов'язків, коли цього вимагають зміни в системі

No: 3
 Name: ir_2_a_03
 Type: string
 Default: "щорічно"

Користувачам системи надається навчання з реагування на інциденти відповідно до призначених ролей та обов'язків частота

No: 4
 Name: ir_2_b_01
 Type: string
 Default: "щорічно"

Зміст навчання з реагування на інциденти переглядається та оновлюється частота

No: 5
 Name: ir_2_b_02
 Type: string
 Default: nil

Зміст навчання з реагування на інциденти переглядається та оновлюється після подій

No: 6
 Name: ir_2_odp_02
 Type: integer
 Default: 30

Визначено частоту, з якою користувачі повинні проходити навчання з реагування на інциденти

No: 7
 Name: ir_2_odp_03
 Type: integer
 Default: 30

Визначено частоту перегляду та оновлення змісту навчання з реагування на інциденти

No: 8
 Name: ir_2_odp_04
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Визначено події, які ініціюють перегляд змісту навчання з реагування на інциденти

8.2.1. МОДЕЛЮВАННЯ ПОДІЙ (IR-2(1))

Немає параметрів для цього контролю.

8.2.2. ЗЛАМ (IR-2(3))

No: 1
 Name: ir_2_3_01

Type: string

Default: nil

Проводиться навчання з реагування на інциденти щодо виявлення та реагу IR-02(03)[02] проводиться навчання з реагування на інциденти щодо процесу повідомлення п

8.3. ПЕРЕВІРКА РЕАГУВАНЬ НА ІНЦИДЕНТИ (IR-3)

No: 1

Name: ir_3_01

Type: string

Default: "щорічно"

Ефективність реагування системи на інциденти перевіряється частота за допомогою тестів

No: 2

Name: ir_3_odp_01

Type: integer

Default: 30

Визначено частоту, з якою необхідно перевіряти ефективність реагування системи на інциденти

No: 3

Name: ir_3_odp_02

Type: string

Default: nil

Визначено тести, що використовуються для перевірки ефективності реагування на інциденти в системі

8.3.1. КООРДИНАЦІЯ З ПОВ'ЯЗАНИМИ ПЛАНАМИ (IR-3(2))

No: 1

Name: ir_3_2_01

Type: string

Default: nil

Тестування реагування на інциденти координується з елементами організації, відповідальними за пов'язані плани

8.3.2. ПОСТІЙНЕ ПОКРАЩЕННЯ (IR-3(3))

No: 1

Name: ir_3_3_a_01

Type: string

Default: nil

Якісні дані тестування використовуються для визначення ефективності процесів реагування на інциденти; IR-03(03)(a)[02] кількісні дані тестування використовуються для визначення ефективності процесів реагування на інциденти

No: 2

Name: ir_3_3_b_01

Type: string

Default: nil

Якісні дані тестування використовуються для постійного вдосконалення процесів реагування на інциденти

No: 3
 Name: ir_3_3_b_02
 Type: string
 Default: nil

Кількісні дані тестування використовуються для постійного вдосконалення процесів реагування на інциденти

No: 4
 Name: ir_3_3_c_01
 Type: string
 Default: nil

Якісні дані, отримані за результатами тестування , використовуються для забезпечення точних показників та метрик реагування на інциденти

No: 5
 Name: ir_3_3_c_02
 Type: string
 Default: nil

Кількісні дані, отримані за результатами тестування , використовуються для забезпечення точних показників та метрик реагування на інциденти

No: 6
 Name: ir_3_3_c_03
 Type: string
 Default: nil

Якісні дані, отримані за результатами тестування , використовуються для забезпечення послідовності показників та метрик реагування на інциденти

No: 7
 Name: ir_3_3_c_04
 Type: string
 Default: nil

Кількісні дані, отримані за результатами тестування , використовуються для забезпечення послідовності показників та метрик реагування на інциденти

No: 8
 Name: ir_3_3_c_05
 Type: string
 Default: nil

Якісні дані, отримані за результатами тестування , використовуються для забезпечення відтворюваності показників та метрик реагування на інциденти

No: 9
 Name: ir_3_3_c_06
 Type: string
 Default: nil

Кількісні дані, отримані за результатами тестування , використовуються для забезпечення відтворюваності показників та метрик реагування на інциденти

8.4. Обробка інциденту (IR-4)

No: 1
 Name: ir_4_a_02

Type: string

Default: nil

Впроваджено можливість обробки інцидентів безпеки включно з виявленням

No: 2

Name: ir_4_a_03

Type: string

Default: nil

Впроваджено можливість обробки інцидентів безпеки включно з аналізом

No: 3

Name: ir_4_a_04

Type: string

Default: nil

Впроваджено можливість обробки інцидентів безпеки включно з локалізацією

No: 4

Name: ir_4_a_05

Type: string

Default: nil

Впроваджено можливість обробки інцидентів безпеки включно з ліквідацією

No: 5

Name: ir_4_a_06

Type: string

Default: nil

Впроваджено можливість обробки інцидентів безпеки включно з відновленням

No: 6

Name: ir_4_b

Type: string

Default: nil

Діяльність з обробки інцидентів координується із заходами із забезпечення безперервності функціонування

No: 7

Name: ir_4_c_01

Type: string

Default: nil

Уроки, отримані з поточних дій з обробки інцидентів, включаються в процедури реагування на інциденти, навчання та тестування

No: 8

Name: ir_4_c_02

Type: string

Default: nil

Зміни, що впливають відповідним чином

No: 9

Name: ir_4_d_01

Type: string

Default: nil

Строгість заходів з обробки інцидентів передбачуваною в межах всієї організації

No: 10

Name: ir_4_d_02

Type: string

Default: nil

Інтенсивність заходів з обробки інцидентів є порівнянною та передбачуваною в межах всієї організації

No: 11

Name: ir_4_d_03

Type: string

Default: nil

Обсяг заходів з обробки інцидентів є порівнянною та передбачуваною в межах всієї організації

No: 12

Name: ir_4_d_04

Type: string

Default: nil

Результати діяльності заходів з обробки інцидентів є порівнянною та передбачуваною в межах всієї організації; з отриманих уроків, є впроваджуються порівнянною

8.4.1. ДИНАМІЧНА РЕКОНФІГУРАЦІЯ (IR-4(2))

No: 1

Name: ir_4_2_01

Type: integer

Default: 30

Типи динамічної реконфігурації для компонентів системи включені як частина здатності реагування на інциденти

No: 2

Name: ir_4_2_odp_01

Type: string

Default: nil

Визначено типи динамічної реконфігурації для компонентів системи

No: 3

Name: ir_4_2_odp_02

Type: string

Default: nil

Визначено компоненти системи, які потребують динамічної реконфігурації

8.4.2. БЕЗПЕРЕРВНІСТЬ ОПЕРАЦІЙ (IR-4(3))

No: 1

Name: ir_4_3_01

Type: string

Default: nil

Ідентифіковано класи інцидентів

No: 2

Name: ir_4_3_02

Type: list

Default: ["login", "logout", "failed_attempt"]

Дії вживаються у відповідь на ці інциденти (визначені в IR-04(03)_ODP[01]) для забезпечення продовження виконання завдань та функцій організації

No: 3
 Name: ir_4_3_odp_01
 Type: string
 Default: nil

Визначено класи інцидентів, що вимагають вживання дій, визначених організацією (визначених в IR04(03)_ODP[02])

No: 4
 Name: ir_4_3_odp_02
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Визначено дії, які необхідно вжити у відповідь на визначені організацією класи інцидентів

8.4.3. ІНФОРМАЦІЙНА КОРЕЛЯЦІЯ (IR-4(4))

No: 1
 Name: ir_4_4_01
 Type: string
 Default: nil

Інформація про інциденти та індивідуальне реагування на інциденти зіставляється з метою досягнення загальноорганізаційного бачення на обізнаність про інциденти та реагування на них

8.4.4. ВНУТРІШНІ ЗАГРОЗИ - ОСОБЛИВІ МОЖЛИВОСТІ (IR-4(6))

No: 1
 Name: ir_4_6_01
 Type: string
 Default: nil

Реалізовано можливість обробки інцидентів, пов'язаних з внутрішніми загрозами

8.4.5. КООРДИНАЦІЯ З ЗОВНІШНІМИ ОРГАНІЗАЦІЯМИ (IR-4(8))

No: 1
 Name: ir_4_8_01
 Type: string
 Default: nil

Здійснюється координація з зовнішніми організаціями для кореляції та обміну інформацією про інциденти для досягнення міжорганізаційного бачення щодо обізнаності про інциденти та більш ефективного реагування на інциденти

No: 2
 Name: ir_4_8_odp_01
 Type: string
 Default: nil

Визначено зовнішні організації, з якими необхідно координувати та обмінюватися інформацією про інциденти в організації

No: 3
 Name: ir_4_8_odp_02
 Type: string

Default: nil

Визначено інформацію про інциденти, яку необхідно зіставляти та поширювати із зовнішніми організаціями

8.4.6. ЗДАТНІСТЬ ДИНАМІЧНОГО РЕАГУВАННЯ (IR-4(9))

No: 1

Name: ir_4_9_odp

Type: string

Default: nil

Визначено можливості динамічного реагування для ефективного реагування на інциденти безпеки. використовуються можливості динамічного реагування для ефективного реагування на інциденти безпеки

8.4.7. КООРДИНАЦІЯ ЛАНЦЮГА ПОСТАЧАННЯ (IR-4(10))

No: 1

Name: ir_4_10_01

Type: integer

Default: 30

Координується діяльність з обробки інцидентів, пов'язана з подіями ланцюжка постачання, з іншими організаціями, що беруть участь у ланцюжку постачання

8.4.8. ІНТЕГРОВАНА ГРУПА РЕАГУВАННЯ НА ІНЦЕДЕНТИ (IR-4(11))

No: 1

Name: ir_4_11_01

Type: string

Default: nil

Створена та підтримується інтегрована група реагування на інциденти

No: 2

Name: ir_4_11_02

Type: integer

Default: 30

Інтегрована група реагування на інциденти може бути розгорнута в будь-якому місці, визначеному організацією протягом часового періоду

No: 3

Name: ir_4_11_odp

Type: integer

Default: 30

Визначено період часу, протягом якого може бути розгорнута інтегрована група реагування на інцидент

8.4.9. ЗЛОВМИСНИЙ КОД ТА КРИМІНАЛІСТИЧНИЙ АНАЛІЗ (IR-4(12))

No: 1

Name: ir_4_12_01

Type: string

Default: nil

Шкідливий код, що залишився в системі, аналізується після інциденту

No: 2

Name: ir_4_12_02

Type: string

Default: nil

Інші залишкові артефакти, що залишилися в системі (якщо такі є), аналізуються після інциденту. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

8.4.10. АНАЛІЗ ПОВЕДІНКИ (IR-4(13))

No: 1

Name: ir_4_13_01

Type: string

Default: nil

Аналізується аномальна або підозрювана ворожа поведінка в середовищах або ресурсах або пов'язана з ними

No: 2

Name: ir_4_13_odp

Type: string

Default: nil

Визначаються середовища або ресурси, які можуть містити або можуть бути пов'язані з аномальною або підозрілою ворожою поведінкою

8.4.11. ЦЕНТР БЕЗПЕКИ (IR-4(14))

No: 1

Name: ir_4_14_01

Type: string

Default: nil

Створено оперативний центр безпеки

No: 2

Name: ir_4_14_02

Type: string

Default: nil

Підтримується оперативний центр безпеки

8.4.12. ЗВ'ЯЗКИ З ГРОМАДКІСТЮ ТА ВІДНОВЛЕННЯ РЕПУ- ТАЦІЇ (IR-4(15))

Немає параметрів для цього контролю.

8.5. Моніторинг інциденту (IR-5)

No: 1

Name: ir_5_01

Type: string

Default: nil

Відстежуються інциденти безпеки та приватності

No: 2

Name: ir_5_02

Type: string

Default: nil

Документуються інциденти безпеки та приватності. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

8.5.1. АВТОМАТИЗОВАНЕ ВІДСТЕЖЕННЯ, ЗБІР ДАНИХ І АНАЛІЗ (IR-5(1))

No: 1

Name: ir_5_1_01

Type: string

Default: nil

Інциденти відстежуються за допомогою 05(01)_ODP[01] автоматизованих механізмів>

No: 2

Name: ir_5_1_02

Type: string

Default: nil

Інформація про інциденти збирається за допомогою автоматизованих механізмів

No: 3

Name: ir_5_1_03

Type: string

Default: nil

Інформація про інциденти аналізується за допомогою автоматизованих механізмів. <IR-

No: 4

Name: ir_5_1_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми відстеження інцидентів

No: 5

Name: ir_5_1_odp_02

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми збору інформації про інциденти

No: 6

Name: ir_5_1_odp_03

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми аналізу інформації про інциденти

8.6. ЗВІТНІСТЬ ПРО ІНЦИДЕНТИ (IR-6)

No: 1

Name: ir_6_a

Type: list
 Default: ["admin", "security_officer"]

Персонал зобов'язаний повідомляти про підозрілі інциденти протягом періоду часу

No: 2
 Name: ir_6_b
 Type: string
 Default: nil

Інформацію про інцидент повідомляється органам

No: 3
 Name: ir_6_odp_01
 Type: list
 Default: ["admin", "security_officer"]

Визначено період часу, протягом якого персонал повинен повідомляти про підозрілі інциденти до уповноваженого органу

No: 4
 Name: ir_6_odp_02
 Type: string
 Default: nil

Визначені органи, до яких слід повідомляти інформацію про інцидент

8.6.1. АВТОМАТИЧНЕ ЗВІТУВАННЯ (IR-6(1))

No: 1
 Name: ir_6_1_01
 Type: string
 Default: "автоматизований засіб моніторингу"

Використовуються автоматичні механізми звітування про інциденти

No: 2
 Name: ir_6_1_odp
 Type: string
 Default: "автоматизований засіб моніторингу"

Визначені автоматичні механізми звітування про інциденти

8.6.2. КООРДИНАЦІЯ ЛАНЦЮЖКА ПОСТАЧАННЯ (IR-6(3))

No: 1
 Name: ir_6_3_01
 Type: integer
 Default: 30

Інформація про інцидент надається постачальнику продукту або послуги та іншим організаціям, які беруть участь у ланцюжку постачання систем або компонентів системи, пов'язаних з інцидентом

8.7. ПІДТРИМКА РЕАГУВАННЯ НА ІНЦИДЕНТИ (IR-7)

No: 1
Name: ir_7_01
Type: string
Default: nil

Ресурс підтримки реагування на інциденти містить поради та допомогу користувачам системи для обробки та формування звітності про інциденти

8.7.1. АВТОМАТИЗАЦІЯ ПІДТРИМКИ ДЛЯ ЗАБЕЗПЕЧЕННЯ ДОСТУПНОСТІ ІНФОРМАЦІЇ ТА ПІДТРИМКИ (IR-7(1))

No: 1
Name: ir_7_1_01
Type: string
Default: nil

Підвищено доступність інформації та підтримки реагування на інциденти з використанням автоматизованих механізмів

No: 2
Name: ir_7_1_odp
Type: string
Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для збільшення доступності інформації та підтримки при реагуванні на інциденти

8.7.2. КООРДИНАЦІЯ З ЗОВНІШНІМИ ПОСТАЧАЛЬНИКАМИ (IR-7(2))

No: 1
Name: ir_7_2_a
Type: string
Default: nil

Встановлено прямі відносини кооперації між здатністю реагування на інциденти та зовнішніми постачальниками можливостей захисту системи

No: 2
Name: ir_7_2_b
Type: string
Default: nil

Визначено членів команди реагування на інциденти в організації для зовнішніх постачальників послуг

8.8. План реагування на інциденти (IR-8)

No: 1
Name: ir_8_a_01
Type: string

Default: nil

Розроблено план реагування на інциденти, який надає організації дорожню карту для впровадження її можливостей реагування на інциденти

No: 2

Name: ir_8_a_02

Type: string

Default: nil

Розроблено план реагування на інциденти, який описує структуру та організацію спроможності реагування на інциденти

No: 3

Name: ir_8_a_03

Type: string

Default: nil

Розроблено план реагування на інциденти, який надає високорівневий підхід до того, як здатність реагування на інциденти вписується в загальну практику організації

No: 4

Name: ir_8_a_04

Type: string

Default: nil

Розроблено план реагування на інциденти, який відповідає унікальним вимогам організації, які пов'язані із завданнями, розміром, структурою і функціями

No: 5

Name: ir_8_a_05

Type: string

Default: nil

Розроблено план реагування на інциденти, який визначає підзвітні інциденти

No: 6

Name: ir_8_a_06

Type: string

Default: nil

Розроблено план реагування на інциденти, який надає показники для вимірювання можливостей реагування на інциденти всередині організації

No: 7

Name: ir_8_a_07

Type: string

Default: nil

Розроблено план реагування на інциденти, який визначає ресурси та управлінську підтримку, необхідну для ефективної підтримки та розвитку можливостей реагування на інциденти

No: 8

Name: ir_8_a_08

Type: string

Default: nil

Розроблено план реагування на інциденти, який вирішує питання обміну інформацією про інциденти

No: 9

Name: ir_8_a_09

Type: list

Default: ["admin", "security_officer"]

Розроблено план реагування на інцидент, який розглядається та затверджується персоналом або ролями частота

No: 10

Name: ir_8_a_10

Type: list

Default: ["admin", "security_officer"]

Розроблено план реагування на інциденти, в якому чітко визначено відповідальність за реагування на інциденти для організацій, персоналу або ролей

No: 11

Name: ir_8_b_01

Type: list

Default: ["admin", "security_officer"]

Копії плану реагування на інцидент розповсюджуються серед <IR- 08_ODP[04] персоналу з реагування на інциденти>

No: 12

Name: ir_8_b_02

Type: string

Default: nil

Копії плану реагування на інцидент розповсюджуються серед елементів організації

No: 13

Name: ir_8_c

Type: integer

Default: 30

План реагування на інциденти оновлюється з урахуванням змін у системі та організації або проблем, що виникають під час впровадження, виконання або тестування плану

No: 14

Name: ir_8_d_01

Type: list

Default: ["admin", "security_officer"]

Зміни в плані реагування на інцидент повідомляються персоналу з реагування на інциденти

No: 15

Name: ir_8_d_02

Type: string

Default: nil

Зміни в плані реагування на інциденти надсилаються до елементів організації

No: 16

Name: ir_8_e_01

Type: string

Default: nil

План реагування на інциденти захищений від несанкціонованого розкриття

No: 17

Name: ir_8_e_02

Type: string

Default: nil

План реагування на інциденти захищений від несанкціонованої модифікації

No: 18

Name: ir_8_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які переглядають та затверджують план реагування на інциденти

No: 19

Name: ir_8_odp_02

Type: string

Default: "щорічно"

Визначено періодичність перегляду та затвердження плану реагування на інциденти

No: 20

Name: ir_8_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначені організації, персонал або ролі, які несуть відповідальність за реагування на інциденти; IR-08_ODP[04] визначено персонал з реагування на інцидент (ідентифікований за іменами та/або за ролями), якому мають бути роздані копії плану реагування на інцидент

No: 21

Name: ir_8_odp_05

Type: string

Default: nil

Визначено елементи організації, серед яких мають розповсюджені копії плану реагування на інцидент; бути

No: 22

Name: ir_8_odp_06

Type: list

Default: ["admin", "security_officer"]

Визначено персонал з реагування на інцидент (ідентифікований за іменами та/або ролями), якому повідомляються зміни до плану реагування на інцидент

No: 23

Name: ir_8_odp_07

Type: string

Default: nil

Визначено елементи організації, яким повідомляється про зміни в плані реагування на інцидент

8.8.1. ОБРОБКА ПЕРСОНАЛЬНИХ ДАНИХ (IR-8(1))

No: 1

Name: ir_8_1_a

Type: list

Default: ["admin", "security_officer"]

План реагування на інциденти для інцидентів, пов'язаних з персональними даними, включає процес визначення доцільності повідомлення наглядових організацій і надання такого повідомлення, якщо це доречно

No: 2

Name: ir_8_1_b

Type: list

Default: ["admin", "security_officer"]

План реагування на інциденти для інцидентів, пов'язаних з персональними даними, включає процес оцінювання для визначення ступеня шкоди, труднощів, незручностей або несправедливості щодо постраждалих осіб та будь-які механізми пом'якшення такої шкоди

No: 3

Name: ir_8_1_c

Type: list

Default: ["admin", "security_officer"]

План реагування на інциденти для інцидентів, пов'язаних з персональними даними, включає ідентифікацію застосовних вимог щодо конфіденційності. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

9. МА

Клас заходів захисту МА — ТЕХНІЧНЕ ОБСЛУГОВУВАННЯ

9.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ТЕХНІЧНОГО ОБСЛУГОВУВАННЯ (МА-1)

а. Планувати, документувати та переглядати записи з технічного обслуговування, ремонту або заміни компонентів системи відповідно до вимог виробника та постачальників та/або вимог організації. б. Затвердити та здійснювати моніторинг усіх заходів з технічного обслуговування, незалежно від того, виконуються вони на місці або віддалено, а також чи обслуговуються системи або системні компоненти на місці, чи переміщуються в інше місце. с. Вимагати, щоб [Призначення: визначені організацією персонал чи ролі] явно схвалили видалення системи або компоненту системи з організаційного обладнання для технічного обслуговування, ремонту чи заміни поза об'єктами експлуатації. d. Очищати обладнання з погляду видалення всієї інформації з носіїв до вилучення обладнання організації для технічного обслуговування, ремонту чи заміни поза об'єктами експлуатації. е. Перевірити всі потенційно порушені заходи захисту, щоб переконатися, що вони, як і раніше, працюють належним чином після дій з обслуговування, ремонту або заміни. f. Вносити [Призначення: визначену організацією інформацію, пов'язану з технічним обслуговуванням] до записів з технічного обслуговування.

No: 1

Name: ma_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику технічного обслуговування

No: 2

Name: ma_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика технічного обслуговування поширюється на персонал або ролі

No: 3

Name: ma_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблені та задокументовані процедури технічного обслуговування, що сприяють впровадженню політики технічного обслуговування та пов'язаних з нею заходів технічного обслуговування

No: 4

Name: ma_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур технічного обслуговування; МА-01(с)[01][01] переглядається та оновлюється поточна політика обслуговування частота; МА-01(с)[01][02] переглядається та оновлюється поточна політика обслуговування після подій; МА-01(с)[02][01] переглядаються та оновлюються поточні процедури технічного обслуговування частота; МА-01(с)[02][02] переглядаються та оновлюються поточні процедури технічного обслуговування після подій

No: 5

Name: ma_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюється політика технічного обслуговування

No: 6

Name: ma_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури технічного обслуговування

No: 7

Name: ma_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: ma_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами технічного обслуговування

No: 9

Name: ma_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика технічного обслуговування

No: 10

Name: ma_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, які потребують перегляду та оновлення поточної політики технічного обслуговування

No: 11

Name: ma_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури технічного обслуговування

No: 12

Name: ma_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення процедур технічного обслуговування

9.2. ІНСТРУМЕНТИ ДЛЯ ОБСЛУГОВУВАННЯ (МА-3)

а. Затвердити, контролювати та відстежувати використання засобів технічного обслуговування. б. Переглядати раніше затверджені інструменти технічного [Призначення: з частотою, визначеною організацією]. обслуговування

No: 1

Name: ma_3_a_01

Type: string

Default: nil

Використання засобів технічного обслуговування затверджено

No: 2

Name: ma_3_a_02

Type: string

Default: nil

Використання засобів технічного обслуговування контролюється

No: 3

Name: ma_3_a_03

Type: string

Default: nil

Використання засобів технічного обслуговування відстажуються

No: 4

Name: ma_3_b

Type: string

Default: "щорічно"

Переглядаються раніше затверджені інструменти технічного обслуговування частота

No: 5

Name: ma_3_odp

Type: integer

Default: 30

Визначено частоту, з якою слід переглядати раніше затверджені інструменти технічного обслуговування

9.2.1. ПЕРЕВІРКА ІНСТРУМЕНТІВ (МА-3(1))

No: 1

Name: ma_3_1_01

Type: list

Default: ["admin", "security_officer"]

Оглядаються інструменти для технічного обслуговування, які доставлені на об'єкт обслуговуючим персоналом, на предмет неправильних або несанкціонованих модифікацій

9.2.2. ПЕРЕВІРКА НОСІЇВ ІНФОРМАЦІЇ (МА-3(2))

Перед використанням носіїв у системі перевірити носії, що містять діагностичні та тестові програми на наявність шкідливого коду.

No: 1

Name: ma_3_2_01

Type: string

Default: nil

Перед використанням носіїв у системі перевіряються носії, що містять діагностичні та тестові програми на наявність шкідливого коду

9.2.3. ЗАПОБІГАННЯ НЕСАНКЦІОНОВАНОМУ ПЕРЕМІЩЕННЮ (МА-3(3))

Запобігти переміщенню обладнання для технічного обслуговування, що містить організаційну інформацію, шляхом: (а) перевірки відсутності організаційної інформації, розміщеної на обладнанні; (b) очищення або знищення обладнання; (с) утримання обладнання на об'єкті; (d) отримання дозволу від [Призначення: визначених організацією персоналу чи ролей], які явно дозволяють переміщення обладнання з об'єкта.

No: 1

Name: ma_3_3_a

Type: string

Default: nil

Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом перевірки того, що на обладнанні не міститься ніякої інформації організації; або

No: 2

Name: ma_3_3_b

Type: string

Default: nil

Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом очищення або знищення обладнання; або

No: 3

Name: ma_3_3_c

Type: string

Default: nil

Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом утримання обладнання на об'єкті; або

No: 4

Name: ma_3_3_d

Type: list

Default: ["admin", "security_officer"]

Переміщення обладнання для технічного обслуговування, що містить інформацію організації, запобігається шляхом отримання дозволу від персоналу або ролі

No: 5

Name: ma_3_3_odp

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які можуть надавати дозвіл на переміщення обладнання з об'єкту

9.2.4. ОБМЕЖЕННЯ ВИКОРИСТАННЯ ІНСТРУМЕНТА (МА-3(4))

Обмежити використання інструментів авторизованим персоналом. - технічного ОБМЕЖЕННЯ обслуговування лише

No: 1

Name: ma_3_4_01

Type: list

Default: ["admin", "security_officer"]

Обмежено використання інструментів технічного обслуговування лише авторизованим персоналом

9.2.5. ПРИВІЛЕЙОВАНЕ ВИКОНАННЯ (МА-3(5))

(a) вимагати схвалення кожного віддаленого сеансу технічного обслуговування [Призначення: персоналом або роллю, що визначила організація]; (b) повідомити [Призначення: персонал або ролі, що визначила організація] про дату та час запланованого віддаленого обслуговування.

No: 1

Name: ma_3_5_01

Type: string

Default: nil

Відстежується використання інструментів обслуговування, які виконуються з підвищеними привілеями

9.2.6. ОНОВЛЕННЯ ПРОГРАМ- (МА-3(6))

Запровадити криптографічні механізми для захисту цілісності та конфіденційності віддаленого обслуговування та діагностичних комунікацій.

No: 1

Name: ma_3_6_01

Type: string

Default: nil

Інструменти технічного обслуговування перевіряються, щоб переконатися, що встановлені найновіші оновлення програмного забезпечення та патчі

9.3. ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ (МА-4)

No: 1

Name: ma_4_a_01

Type: list

Default: ["login", "logout", "failed_attempt"]

Впроваджено віддалені дії з обслуговування та діагностики

No: 2

Name: ma_4_a_02

Type: list

Default: ["login", "logout", "failed_attempt"]

Відстежуються віддалені дії з обслуговування та діагностики

No: 3
 Name: ma_4_b_01
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Використання віддалених засобів технічного обслуговування та діагностики дозволено лише відповідно до політики організації

No: 4
 Name: ma_4_b_02
 Type: string
 Default: nil

Використання віддалених засобів технічного обслуговування та діагностики задокументовано в плані захисту інформації

No: 5
 Name: ma_4_c
 Type: string
 Default: nil

Надійна автентифікація використовується при встановленні віддалених технічних та діагностичних сеансів

No: 6
 Name: ma_4_d
 Type: string
 Default: nil

Ведеться облік віддалених дій з обслуговування та діагностики

No: 7
 Name: ma_4_e_01
 Type: string
 Default: nil

Сесія припиняється, коли завершено віддалене обслуговування

No: 8
 Name: ma_4_e_02
 Type: string
 Default: nil

Мережеве з'єднання припиняється, коли завершено віддалене обслуговування

9.3.1. АУДИТ ТА ОГЛЯД (МА-4(1))

No: 1
 Name: ma_4_1_a_01
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Події аудиту журналюються для віддалених сеансів обслуговування

No: 2
 Name: ma_4_1_a_02
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Події аудиту журналюються для віддалених сеансів діагностики

No: 3
 Name: ma_4_1_b_01

Type: string

Default: nil

Здійснюється огляд записів про сеанси віддаленого обслуговування

No: 4

Name: ma_4_1_b_02

Type: string

Default: nil

Здійснюється огляд записів про сеанси віддаленої діагностики

No: 5

Name: ma_4_1_odp_01

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події аудиту, які слід журналювати для віддалених сеансів обслуговування

No: 6

Name: ma_4_1_odp_02

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події аудиту, які слід журналювати для віддалених сеансів діагностики

9.3.2. ДОКУМЕНТУВАННЯ ВІДДАЛЕНОГО ОБСЛУГОВУВАННЯ (МА-4(2))

No: 1

Name: ma_4_2_01

Type: string

Default: nil

ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ - ДОКУМЕНТУВАННЯ ВІДДАЛЕНОГО ОБСЛУГОВУВАННЯ [Вилучено: включено до МА-01 та МА-04]

9.3.3. ПОРІВНЯЛЬНА БЕЗПЕКА І ОЧИЩЕННЯ (МА-4(3))

No: 1

Name: ma_4_3_a_01

Type: string

Default: nil

Віддалені послуги з технічного обслуговування повинні виконуватися з системи, яка реалізує заходи захисту, співставні з заходами захисту, реалізованими в системі, що обслуговується

No: 2

Name: ma_4_3_a_02

Type: string

Default: nil

Віддалені послуги з діагностики повинні виконуватися з системи, яка реалізує заходи захисту, співставні з заходами захисту, реалізованими в системі, що обслуговується

No: 3

Name: ma_4_3_b_01

Type: string

Default: nil

Компонент, що підлягає обслуговуванню, видаляється з системи перед проведенням віддаленого технічного обслуговування або діагностики

No: 4

Name: ma_4_3_b_02

Type: string

Default: nil

Компонент, що підлягає обслуговуванню, пройшов процедуру очищення (від інформації організації)

No: 5

Name: ma_4_3_b_03

Type: string

Default: nil

Компонент перевіряється та очищується (на наявність потенційно шкідливого програмного забезпечення) після виконання послуги та перед повторним підключенням компонента до системи

9.3.4. СХВАЛЕННЯ ТА ПОВІДОМЛЕННЯ (МА-4(5))

No: 1

Name: ma_4_5_a

Type: list

Default: ["admin", "security_officer"]

Схвалення кожного віддаленого сеансу обслуговування від персоналу або ролі

No: 2

Name: ma_4_5_b

Type: list

Default: ["admin", "security_officer"]

Персонал і ролі повідомлено про дату і час запланованого віддаленого технічного обслуговування

No: 3

Name: ma_4_5_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, необхідні для затвердження кожного віддаленого сеансу технічного обслуговування; МА-04(05)_ODP[02] визначено персонал та ролі, які мають бути повідомлені про дату та час запланованого віддаленого технічного обслуговування

9.3.5. ВІДДАЛЕНЕ ОБСЛУГОВУВАННЯ РОЗ'ЄДНАННЯ (МА-4(7))

No: 1

Name: ma_4_7_01

Type: string

Default: nil

Реалізовано перевірку роз'єднання у разі припинення віддалених сеансів обслуговування

No: 2

Name: ma_4_7_02

Type: string

Default: nil

Реалізовано перевірку роз'єднання у разі припинення віддалених сеансів діагностики

9.4. ТЕХНІЧНИЙ ПЕРСОНАЛ (МА-5)

а. Встановити процедуру авторизації технічного персоналу та вести перелік авторизованих організацій технічного обслуговування або персоналу. б. Перевіряти, що персонал, який не супроводжується та виконує технічне обслуговування в системі, має необхідні дозволи на доступ. с. Визначити персонал організації з необхідними повноваженнями щодо доступу та технічною компетенцією для нагляду за персоналом з технічного обслуговування, який не має необхідних дозволів на доступ.

No: 1

Name: ma_5_a_01

Type: list

Default: ["admin", "security_officer"]

Запроваджено процес авторизації технічного персоналу

No: 2

Name: ma_5_a_02

Type: list

Default: ["admin", "security_officer"]

Ведеться перелік авторизованих організацій або персоналу з технічного обслуговування

No: 3

Name: ma_5_b

Type: list

Default: ["admin", "security_officer"]

Персонал без супроводу, який виконує технічне обслуговування системи, має необхідні дозволи на доступ

No: 4

Name: ma_5_c

Type: list

Default: ["admin", "security_officer"]

Персонал організації з необхідними повноваженнями доступу та технічною компетентністю призначений/призначені для нагляду за діяльністю з технічного обслуговування персоналу, який не має необхідних дозволів на доступ

9.4.1. ОСОБИ БЕЗ НАЛЕЖНОГО ДОСТУПУ (МА-5(1))

No: 1

Name: ma_5_1_a_01

Type: list

Default: ["admin", "security_officer"]

Впроваджені процедури залучення персоналу з технічного обслуговування, який не має відповідних дозволів (допуску) або не є громадянами України, містять вимогу: обслуговуючий персонал, що не має необхідних прав доступу, рівня допуску, або офіційного затвердженого доступу, повинен супроводжуватися та бути під наглядом уповноваженого організацією персоналу, з необхідним рівнем допуску, а також мати відповідну технічну кваліфікацію для виконання технічного обслуговування та діагностичних заходів у системі

No: 2

Name: ma_5_1_a_02

Type: list

Default: ["admin", "security_officer"]

Впроваджені процедури залучення персоналу з технічного обслуговування, який не має відповідних дозволів (допуску) або не є громадянами України, містять вимогу: перед тим, як розпочати технічне обслуговування або діагностику персоналом, який не має необхідних прав допуску, рівня допуску або офіційного затвердженого

доступу, упевнитися, що всі компоненти енергонезалежного зберігання інформації в системі очищуються, а всі енергонезалежні носії видаляються або фізично відключаються від системи та надійно захищаються

No: 3

Name: ma_5_1_b

Type: string

Default: nil

Альтернативні заходи захисту розробляються і впроваджуються у випадку, якщо систему неможливо очистити, вилучити або відключити від системи

No: 4

Name: ma_5_1_odp

Type: string

Default: nil

Визначені альтернативні заходи захисту, які мають бути розроблені та впроваджені на випадок, якщо компонент системи не може бути очищений, вилучений або відключений від системи

9.4.2. ОФОРМЛЕННЯ ДОПУСКУ ДЛЯ СИСТЕМ, ЩО ОБРОБЛЯЮТЬ ІНФОРМАЦІЮ З ОБМЕЖЕНИМ ДОСТУПОМ (МА-5(2))

Переконаватися, що персонал, який виконує технічне обслуговування та діагностику в системі, що обробляє, зберігає або передає інформацію з обмеженим доступом, має рівень допуску та офіційне схвалення на доступ для найвищого рівня секретності та для всієї інформації в системі.

No: 1

Name: ma_5_2_01

Type: list

Default: ["admin", "security_officer"]

Персонал, який виконує роботи з технічного обслуговування та діагностики в системі, що обробляє, зберігає або передає інформацію з обмеженим доступом, має відповідний рівень допуску

No: 2

Name: ma_5_2_02

Type: list

Default: ["admin", "security_officer"]

Персонал, який виконує роботи з технічного обслуговування та діагностики в системі, що обробляє, зберігає або передає інформацію з обмеженим доступом, має офіційне схвалення на допуск

9.4.3. ВИМОГИ ДО ГРОМАДЯНСТВА (МА-5(3))

Переконаватися, що працівники, які виконують технічне обслуговування та діагностичні заходи з обробки, зберігання або передачі таємної інформації, є громадянами України.

No: 1

Name: ma_5_3_01

Type: string

Default: nil

Працівники, які виконують технічне обслуговування та діагностичні заходи з обробки, зберігання або передачі інформації з обмеженим доступом, є громадянами України

9.4.4. ІНОЗЕМНІ ГРОМАДЯНИ (МА-5(4))

Переконайтеся, що: (a) іноземні громадяни з відповідним рівнем допуску залучаються для проведення технічного обслуговування та діагностичних робіт у системах, що обробляють інформацію з обмеженим доступом тільки тоді, коли ці системи спільно належать і експлуатуються урядами України та закордонних союзників, або належать та експлуатуються виключно іноземними союзними урядами; (b) схвалення, згоди та додаткові умови експлуатації, що стосуються залучення іноземних громадян для проведення робіт з технічного обслуговування та діагностики систем, що обробляють інформацію з обмеженим доступом, повністю задокументовані в Меморандумі про угоду.

No: 1

Name: ma_5_4_a

Type: string

Default: nil

Іноземні громадяни з відповідним рівнем допуску залучаються для проведення технічного обслуговування та діагностичних робіт у системах, що обробляють інформацію з обмеженим доступом тільки тоді, коли ці системи спільно належать і експлуатуються урядами України та закордонних союзників, або належать та експлуатуються виключно іноземними союзними урядами

No: 2

Name: ma_5_4_b_01

Type: string

Default: nil

Схвалення, що стосуються залучення іноземних громадян для проведення робіт з технічного обслуговування та діагностики систем, що обробляють інформацію з обмеженим доступом, повністю задокументовані в Меморандумі про угоду

No: 3

Name: ma_5_4_b_02

Type: string

Default: nil

Згоди, що стосуються залучення іноземних громадян для проведення робіт з технічного обслуговування та діагностики систем, що обробляють інформацію з обмеженим доступом, повністю задокументовані в Меморандумі про угоду

No: 4

Name: ma_5_4_b_03

Type: list

Default: []

Додаткові умови експлуатації, що стосуються залучення іноземних громадян для проведення робіт з технічного обслуговування та діагностики систем, що обробляють інформацію з обмеженим доступом, повністю задокументовані в Меморандумі про угоду

9.4.5. НЕСИСТЕМНЕ ОБСЛУГОВУВАННЯ (МА-5(5))

Переконайтеся, що персонал, який не супроводжується та здійснює ремонтні роботи, не пов'язаний безпосередньо із системою, але перебуває фізично близько від системи, має необхідні дозволи на доступ.

No: 1

Name: ma_5_5_01

Type: list

Default: ["admin", "security_officer"]

Персонал, який не супроводжується, що здійснює ремонтні роботи, не пов'язаний безпосередньо з системою, але знаходиться фізично близько від системи, має необхідні дозволи на доступ

10. МР

Клас заходів захисту МР — ЗАХИСТ НОСІЇВ ІНФОРМАЦІЇ

10.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ЩОДО ЗАХИСТУ НОСІЇВ ІНФОРМАЦІЇ (МР-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посад]: 1. 2. політику захисту носіїв інформації, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам; процедури, які сприяють здійсненню політики та заходів захисту носіїв інформації. б. Призначити [Призначення: визначену організацією посадову особу] для управління розробкою, документування, та розповсюдження політики та процедурами захисту носіїв інформації. с. Переглядати та оновлювати чинну систему захисту носіїв інформації: 1. поточну політику захисту носіїв інформації [Призначення: з визначеною організацією частотою]; 2. поточні процедури захисту носіїв інформації [Призначення: з визначеною організацією частотою].

No: 1

Name: mp_1_a_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику захисту носіїв інформації

No: 2

Name: mp_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика захисту носіїв інформації поширюється на персонал або ролі

No: 3

Name: mp_1_a_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано процедури захисту носіїв інформації, що сприятимуть реалізації політики захисту носіїв інформації та заходів захисту носіїв інформації

No: 4

Name: mp_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур захисту носіїв інформації. МР-01(с)[01][01] переглядається та оновлюється поточна політика захисту носіїв інформації частота; МР-01(с)[01][02] переглядається та оновлюється поточна політика захисту носіїв інформації після подій; МР-01(с)[02][01] переглядаються та оновлюються поточні процедури захисту

носіїв інформації частота; MP-01(c)[02][02] переглядаються та оновлюються поточні процедури захисту носіїв інформації після подій

No: 5

Name: mp_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, серед яких має бути поширена політика захисту носіїв інформації

No: 6

Name: mp_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, серед яких мають бути поширені процедури захисту носіїв інформації

No: 7

Name: mp_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 8

Name: mp_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами захисту носіїв інформації

No: 9

Name: mp_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика захисту носіїв інформації

No: 10

Name: mp_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, які потребують перегляду та оновлення чинної політики захисту носіїв інформації

No: 11

Name: mp_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються чинні процедури захисту носіїв інформації

No: 12

Name: mp_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення процедур захисту носіїв інформації

10.2. ДОСТУП ДО НОСІЇВ ІНФОРМАЦІЇ (МР-2)

Обмежити доступ до [Призначення: визначених організацією типів цифрових та/або нецифрових носіїв інформації] [Призначення: визначеним організацією персоналом або ролями].

No: 1

Name: mp_2_01

Type: list

Default: ["admin", "security_officer"]

Доступ до типів цифрових носіїв інформації обмежено для персоналу або ролей

No: 2

Name: mp_2_02

Type: list

Default: ["admin", "security_officer"]

Доступ до типів нецифрових носіїв інформації обмежено для персоналу або ролей

No: 3

Name: mp_2_odp_01

Type: string

Default: nil

Визначено типи цифрових носіїв інформації, доступ до яких обмежено

No: 4

Name: mp_2_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, уповноважені на доступ до цифрових носіїв інформації

No: 5

Name: mp_2_odp_03

Type: string

Default: nil

Визначено типи нецифрових носіїв інформації, доступ до яких обмежено

No: 6

Name: mp_2_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, уповноважені на доступ до нецифрових носіїв інформації

10.2.1. АВТОМАТИЗОВАНИЙ ОБМЕЖЕННИЙ ДОСТУП (МР-2(1))

No: 1

Name: mp_2_1_01

Type: string

Default: nil

ДОСТУП ДО НОСІЇВ ІНФОРМАЦІЇ - АВТОМАТИЗОВАНИЙ ОБМЕЖЕННИЙ ДОСТУП [Вилучено: Включено до МР-04(02)]

10.2.2. КРИПТОГРАФІЧНИЙ ЗАХИСТ (МР-2(2))

No: 1
 Name: mp_2_2_01
 Type: string
 Default: "AES-256-GCM"

ДОСТУП ДО НОСІЇВ ІНФОРМАЦІЇ - КРИПТОГРАФІЧНИЙ ЗАХИСТ [Вилучено: Включено до SC-28(01)]

10.3. МАРКУВАННЯ НОСІЇВ ІНФОРМАЦІЇ (МР-3)

а. Наносити на носії інформації маркування, що вказують на обмеження поширення, обробки, а також застереження та відповідні мітки безпеки (якщо такі є) інформації. б. Звільнити [Призначення: визначені організацією типи носіїв системи] від маркування, якщо носії залишаються в межах [Призначення: визначених організацією контрольованих зон].

No: 1
 Name: mp_3_01
 Type: string
 Default: nil

МАРКУВАННЯ НОСІЇВ ІНФОРМАЦІЇ МЕТА ОЦІНКИ: Визначити, чи:

No: 2
 Name: mp_3_a
 Type: string
 Default: nil

Носії інформації маркуються, щоб вказати на обмеження поширення, обробки, а також застереження та відповідні мітки безпеки (якщо такі є) інформації

No: 3
 Name: mp_3_b
 Type: string
 Default: nil

Типи носіїв інформації залишаються в межах контрольованих зон

No: 4
 Name: mp_3_odp_01
 Type: integer
 Default: 30

Визначено типи носіїв інформації, які звільняються від маркування під час перебування на контрольованих зонах

No: 5
 Name: mp_3_odp_02
 Type: string
 Default: nil

Визначено контрольовані зони, де носії інформації звільняються від маркування

10.4. ЗБЕРІГАННЯ НОСІЇВ ІНФОРМАЦІЇ (МР-4)

а. Фізично контролювати та безпечно зберігати [Призначення: визначені організацією типи цифрових та/або нецифрових носіїв інформації] в межах [Призначення: визначених організа-

цією контрольованих зон]. б. Захищати системні носії, які визначені в МР-4 до того часу, як носії знищуються або очищаються, з використанням затвердженого обладнання, методів та процедур.

No: 1

Name: mp_4_a_01

Type: string

Default: nil

Типи цифрових носіїв контролюються фізично

No: 2

Name: mp_4_a_02

Type: string

Default: nil

Типи нецифрових носіїв контролюються фізично

No: 3

Name: mp_4_a_03

Type: string

Default: nil

Типи цифрових носіїв безпечно зберігаються в контрольованих зонах

No: 4

Name: mp_4_a_04

Type: string

Default: nil

Типи нецифрових носіїв безпечно зберігаються в контрольованих зонах

No: 5

Name: mp_4_b

Type: string

Default: nil

Типи носіїв інформації (визначені в МР-04_ODP[01], МР04_ODP[02], МР-04_ODP[03], МР-04_ODP[04]) захищені доти, доки носії інформації не будуть знищені або очищені за допомогою визначеного обладнання, методик та процедур

No: 6

Name: mp_4_odp_01

Type: string

Default: nil

Визначено типи цифрових носіїв інформації, які підлягають фізичному контролю (якщо вибрано)

No: 7

Name: mp_4_odp_02

Type: string

Default: nil

Визначено типи нецифрових носіїв інформації, які підлягають фізичному контролю (якщо вибрано)

No: 8

Name: mp_4_odp_03

Type: string

Default: nil

Визначено типи цифрових носіїв інформації для безпечного зберігання (якщо вибрано)

No: 9

Name: mp_4_odp_04

Type: string

Default: nil

Визначено типи нецифрових носіїв інформації для безпечного зберігання (якщо вибрано)

No: 10

Name: mp_4_odp_05

Type: string

Default: nil

Визначено контрольовані зони, в яких можна безпечно зберігати цифрові носії інформації; MP-04_ODP[06]
визначено контрольовані зони, в яких можна безпечно зберігати нецифрові носії інформації

10.4.1. КРИПТОГРАФІЧНИЙ ЗАХИСТ (MP-4(1))

No: 1

Name: mp_4_1_01

Type: string

Default: "AES-256-GCM"

ЗБЕРІГАННЯ НОСІЇВ ІНФОРМАЦІЇ - КРИПТОГРАФІЧНИЙ ЗАХИСТ [Вилучено: Включено до SC-28(01)]

10.4.2. АВТОМАТИЗОВАНИЙ ОБМЕЖЕНИЙ ДОСТУП (MP-4(2))

No: 1

Name: mp_4_2_01

Type: string

Default: nil

Доступ до зон зберігання носіїв інформації обмежено за допомогою автоматизованих механізмів

No: 2

Name: mp_4_2_02

Type: integer

Default: 3

Спроби доступу до зон зберігання носіїв інформації реєструються за допомогою автоматизованих механізмів

No: 3

Name: mp_4_2_03

Type: string

Default: nil

Доступ, наданий до зон зберігання носіїв, реєструється за допомогою автоматизованих механізмів

No: 4

Name: mp_4_2_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми обмеження доступу до зон зберігання носіїв інформації

No: 5

Name: mp_4_2_odp_02

Type: integer

Default: 3

Визначено автоматизовані механізми реєстрації спроб доступу до зон зберігання носіїв інформації; MP-04(02)_ODP[03] визначено автоматизовані механізми реєстрації доступу, наданого до зон зберігання носіїв інформації

10.5. Транспортування носіїв інформації (МР-5)

а. Захищати та контролювати [Призначення: визначені організацією типи носіїв системи] під час транспортування за межами контрольованих зон, використовуючи [Призначення: визначені організацією заходи безпеки]. б. Вести облік носіїв системи інформації під час транспортування за межами контрольованих зон. с. Документувати дії, пов'язані з транспортуванням носіїв системи. д. Обмежити діяльність уповноваженого персоналу, пов'язану з транспортуванням носіїв системи.

No: 1

Name: mp_5_a_01

Type: integer

Default: 30

Типи носіїв інформації системи захищаються під час транспортування за межі контрольованих зон за допомогою заходів безпеки

No: 2

Name: mp_5_a_02

Type: integer

Default: 30

Типи носіїв інформації системи контролюються під час транспортування за межі контрольованих зон за допомогою заходів безпеки

No: 3

Name: mp_5_b

Type: integer

Default: 30

Під час транспортування за межі контрольованих зон ведеться облік носіїв інформації системи

No: 4

Name: mp_5_c

Type: string

Default: nil

Діяльність, пов'язана з транспортуванням носіїв інформації системи, задокументована

No: 5

Name: mp_5_d_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал, уповноважений здійснювати діяльність з транспортування носіїв інформації

No: 6

Name: mp_5_d_02

Type: list

Default: ["admin", "security_officer"]

Діяльність, пов'язана з транспортуванням носіїв інформації системи, обмежується визначеним уповноваженим персоналом

No: 7

Name: mp_5_odp_01

Type: integer

Default: 30

Визначено типи носіїв інформації системи для захисту та контролю під час транспортування за межі контрольованих зон

No: 8
Name: mp_5_odp_02
Type: string
Default: nil

Визначено заходи безпеки, що використовуються для захисту носіїв інформації системи поза контрольованими зонами

No: 9
Name: mp_5_odp_03
Type: string
Default: nil

Визначено заходи безпеки, що використовуються для контролю носіїв інформації системи за межами контрольованих зон

10.5.1. ЗАХИСТ ПОЗА КОНТРОЛЬОВАНИМИ ЗОНАМИ (МР-5(1))

No: 1
Name: mp_5_1_01
Type: string
Default: nil

ТРАНСПОРТУВАННЯ НОСІЇВ ІНФОРМАЦІЇ - ЗАХИСТ ПОЗА КОНТРОЛЬОВАНИМИ ЗОНАМИ [Вилучено: Включено до МР-05]

10.5.2. ДОКУМЕНТУВАННЯ ДІЙ (МР-5(2))

No: 1
Name: mp_5_2_01
Type: string
Default: nil

ТРАНСПОРТУВАННЯ НОСІЇВ ІНФОРМАЦІЇ - ДОКУМЕНТУВАННЯ ДІЙ [Вилучено: Включено до МР-05]

10.5.3. ЗБЕРІГАЧІ (МР-5(3))

No: 1
Name: mp_5_3_01
Type: integer
Default: 30

Визначено зберігачів інформації під час транспортування носіїв інформації системи за межі контрольованих зон

No: 2
Name: mp_5_3_02
Type: integer
Default: 30

Залучено визначених зберігачів інформації під час транспортування носіїв інформації системи за межі контрольованих зон

10.5.4. КРИПТОГРАФІЧНИЙ ЗАХИСТ (МР-5(4))

No: 1

Name: mp_5_4_01

Type: string

Default: "AES-256-GCM"

ТРАНСПОРТУВАННЯ НОСІВ ІНФОРМАЦІЇ - КРИПТОГРАФІЧНИЙ ЗАХИСТ [Вилучено: Включено до SC-28(01)]

10.6. ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ (МР-6)

а. Очищувати [Призначення: визначені організацією системні носії] перед утилізацією, випуском за межі організаційного контролю, або перед повторним використанням [Призначення: методами та процедурами очищення, визначеними організацією]. б. Використовувати механізми очищення зі стійкістю та цілісністю, що відповідає категорії безпеки або рівню секретності інформації.

No: 1

Name: mp_6_a_01

Type: string

Default: nil

Носії інформації системи перед утилізацією піддаються очищенню за допомогою методів та процедур очищення

No: 2

Name: mp_6_a_02

Type: string

Default: nil

Носії інформації системи очищаються за допомогою методів та процедур очищення перед випуском за межі контрольованої зони

No: 3

Name: mp_6_a_03

Type: string

Default: nil

Носії інформації системи очищуються за допомогою методів і процедур очищення перед повторним використанням

No: 4

Name: mp_6_b

Type: string

Default: "автоматизований засіб моніторингу"

Застосовуються механізми очищення, надійність і цілісність яких відповідає категорії безпеки або рівню секретності інформації

No: 5

Name: mp_6_odp_01

Type: string

Default: nil

Визначено носії інформації системи, які підлягають очищенню перед утилізацією

No: 6

Name: mp_6_odp_02

Type: string

Default: nil

Визначено носії інформації системи, які підлягають очищенню перед випуском за межі контрольованої зони

No: 7

Name: mp_6_odp_03

Type: string

Default: nil

Визначені носії інформації системи, що підлягають очищенню перед повторним використанням

No: 8

Name: mp_6_odp_04

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед утилізацією

No: 9

Name: mp_6_odp_05

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед випуском за межі контрольованої зони

No: 10

Name: mp_6_odp_06

Type: string

Default: nil

Визначено методи та процедури очищення, які слід використовувати для очищення перед повторним використанням

10.6.1. ПЕРЕГЛЯДАТИ, ЗАТВЕРДЖЕННЯ, ВІДСТЕЖЕННЯ, ДОКУМЕНТУВАННЯ ТА ПЕРЕВІРКА (MP-6(1))

No: 1

Name: mp_6_1_01

Type: string

Default: nil

Переглядаються заходи з очищення та утилізації носіїв інформації

No: 2

Name: mp_6_1_02

Type: string

Default: nil

Затверджуються заходи з очищення та утилізації носіїв інформації

No: 3

Name: mp_6_1_03

Type: string

Default: nil

Відстежуються заходи з очищення та утилізації носіїв інформації

No: 4
 Name: mp_6_1_04
 Type: string
 Default: nil

Документуються заходи з очищення та утилізації носіїв інформації

No: 5
 Name: mp_6_1_05
 Type: string
 Default: nil

Перевіряються заходи з очищення та утилізації носіїв інформації

10.6.2. ПЕРЕВІРКА ОБЛАДНАННЯ (МР-6(2))

No: 1
 Name: mp_6_2_01
 Type: string
 Default: "щорічно"

Обладнання для очищення тестується частота, щоб переконатися в досягненні запланованого очищення

No: 2
 Name: mp_6_2_02
 Type: string
 Default: "щорічно"

Процедури санітарної обробки тестуються частота, щоб переконатися в досягненні запланованого очищення

No: 3
 Name: mp_6_2_odp_01
 Type: string
 Default: "щорічно"

Визначена частота, з якою проводиться перевірка обладнання для очищення

No: 4
 Name: mp_6_2_odp_02
 Type: integer
 Default: 30

Визначено частоту, з якою потрібно перевіряти процедури очищення

10.6.3. НЕРУЙНІВНІ МЕТОДИ (МР-6(3))

No: 1
 Name: mp_6_3_01
 Type: string
 Default: nil

Застосовуються методи неруйнівного очищення до зовнішніх носіїв інформації перед підключенням таких пристроїв до системи при умовах, що вимагають очищення зовнішніх носіїв інформації

No: 2
 Name: mp_6_3_odp
 Type: list
 Default: []

Визначено умови, які вимагають очищення зовнішніх носіїв інформації

10.6.4. КЕРОВАНА НЕСЕКРЕТНА ІНФОРМАЦІЯ (МР-6(4))

No: 1

Name: mp_6_4_01

Type: string

Default: nil

ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ - КЕРОВАНА НЕСЕКРЕТНА ІНФОРМАЦІЯ
[Вилучено: Включено до МР-06]

10.6.5. СЕКРЕТНА ІНФОРМАЦІЯ (МР-6(5))

No: 1

Name: mp_6_5_01

Type: string

Default: nil

ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ - СЕКРЕТНА ІНФОРМАЦІЯ [Вилучено: Включено до МР-06]

10.6.6. ЗНИЩЕННЯ НОСІЇВ ІНФОРМАЦІЇ (МР-6(6))

No: 1

Name: mp_6_6_01

Type: string

Default: nil

ЗНИЩЕННЯ ІНФОРМАЦІЇ НА НОСІЯХ ІНФОРМАЦІЇ - ЗНИЩЕННЯ НОСІЇВ ІНФОРМАЦІЇ [Вилучено: Включено до МР-06]

10.6.7. ПОДВІЙНА АВТОРИЗАЦІЯ (МР-6(7))

No: 1

Name: mp_6_7_01

Type: string

Default: nil

Здійснюється подвійна авторизація для очищення носії інформації

No: 2

Name: mp_6_7_odp

Type: string

Default: nil

Визначено носії інформації для яких необхідно здійснювати подвійну авторизацію для очищення

10.6.8. ВІДДАЛЕНЕ ОЧИЩЕННЯ АБО СТИРАННЯ ІНФОРМАЦІЇ (МР-6(8))

No: 1

Name: mp_6_8_odp_01

Type: string

Default: nil

Визначено системи або компоненти системи для очищення або стирання інформації віддалено або за певних умов

No: 2

Name: mp_6_8_odp_02

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {віддалено; за умов }

No: 3

Name: mp_6_8_odp_03

Type: list

Default: []

Визначаються умови, за яких інформація підлягає очищенню або стиранню (якщо вибрано)

10.7. ВИКОРИСТАННЯ НОСІЇВ ІНФОРМАЦІЇ (МР-7)

а. [Вибір: обмежити; заборонити] використання [Призначення: визначених організацією типів носіїв системи] на [Призначення: визначені організацією системи або компоненти системи], використовуючи [Призначення: визначені організацією заходи безпеки]. б. Заборонити використання портативних пристроїв зберігання даних в системах організації, якщо такі пристрої не мають визначеного власника.

No: 1

Name: mp_7_01

Type: string

Default: nil

ВИКОРИСТАННЯ НОСІЇВ ІНФОРМАЦІЇ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: mp_7_b

Type: string

Default: nil

Використання зовнішніх носіїв інформації в системах організації заборонено, якщо такі пристрої не мають власника, якого можна ідентифікувати

No: 3

Name: mp_7_odp_01

Type: string

Default: nil

Визначено типи носіїв інформації, які мають бути обмежені або заборонені до використання в системі або компонентах системи

No: 4

Name: mp_7_odp_02

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРА: {обмежити; заборонити}

No: 5

Name: mp_7_odp_03

Type: string

Default: nil

Системи або компоненти системи, для яких визначено використання певних типів носіїв інформації, що підлягають обмеженню або забороні

No: 6
 Name: mp_7_odp_04
 Type: string
 Default: nil

Визначено заходи безпеки для обмеження або заборони використання певних типів носіїв інформації в системах або компонентах системи

10.7.1. ЗАБОРОНА ВИКОРИСТАННЯ БЕЗ ВИЗНАЧЕНОГО ВЛА- СНИКА (МР-7(1))

No: 1
 Name: mp_7_1_01
 Type: string
 Default: nil

ВИКОРИСТАННЯ НОСІЇВ ІНФОРМАЦІЇ - ЗАБОРОНА ВИКОРИСТАННЯ БЕЗ ВИЗНАЧЕНОГО ВЛА-
СНИКА [Вилучено: Включено до МР-07]

10.7.2. ЗАБОРОНА ВИКОРИСТАННЯ (МР-7(2))

No: 1
 Name: mp_7_2_01
 Type: string
 Default: nil

Ідентифіковано стійкі до очищення носії інформації

No: 2
 Name: mp_7_2_02
 Type: string
 Default: nil

Використання стійких до очищення носіїв інформації в системах організації заборонено

11. РЕ

Клас заходів захисту РЕ — ФІЗИЧНИЙ ЗАХИСТ І ЗАХИСТ РОБОЧОГО

11.1. РЕ-1 фізичного захисту та захисту робочого сере- довища Авторизація фізичного (РЕ-1)

No: 1
 Name: pe_1_a_01
 Type: list
 Default: ["default_deny_rule", "abac_rule_1"]

Розроблено та задокументовано політику фізичного захисту та захисту робочого середовища

No: 2
 Name: pe_1_a_02

Type: list

Default: ["admin", "security_officer"]

Політика фізичного захисту та захисту робочого середовища розповсюджується серед персоналу або ролей

No: 3

Name: pe_1_b

Type: list

Default: ["admin", "security_officer"]

Посадова особа призначається для управління розробкою, документуванням та розповсюдженням політики та процедур фізичного захисту та захисту робочого середовища; PE-01(c)[01][01] переглядається та оновлюється поточна політика фізичного захисту та захисту робочого середовища частота; PE-01(c)[01][02] поточна політика фізичного захисту та захисту робочого середовища переглядається та оновлюється після подій; PE-01(c)[02][01] переглядаються та оновлюються поточні процедури фізичного захисту та захисту робочого середовища частота; поточні процедури фізичного та екологічного захисту переглядаються та оновлюються після подій. PE-01(c)[02][02]

No: 4

Name: pe_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких має бути доведена політика фізичного захисту та захисту робочого середовища

No: 5

Name: pe_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури фізичного захисту та захисту робочого середовища

No: 6

Name: pe_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнес-процесу; рівень системи}

No: 7

Name: pe_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами фізичного захисту та захисту робочого середовища

No: 8

Name: pe_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено частоту, з якою переглядається та оновлюється поточна політика фізичного захисту та захисту робочого середовища

No: 9

Name: pe_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено події, які потребують перегляду та оновлення поточної політики фізичного захисту та захисту робочого середовища

No: 10

Name: pe_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури фізичного захисту та захисту робочого середовища

No: 11

Name: pe_1_odp_08

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено події, які потребують перегляду та оновлення процедур фізичного захисту та захисту робочого середовища

11.2. PE-2 доступу (PE-2)

No: 1

Name: pe_2_a_01

Type: list

Default: []

Розроблено перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система

No: 2

Name: pe_2_a_02

Type: list

Default: []

Затверджено перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система

No: 3

Name: pe_2_a_03

Type: list

Default: []

Ведеться перелік осіб, які мають право авторизованого доступу до об'єкта, де перебуває система

No: 4

Name: pe_2_b

Type: string

Default: nil

Для доступу до об'єкта надаються повноваження

No: 5

Name: pe_2_c

Type: list

Default: ["admin", "security_officer"]

Переглядається список доступу, у якому закріплений перелік персоналу або ролей, яким дозволений санкціонований доступ до об'єкта частота

No: 6

Name: pe_2_d

Type: list

Default: ["admin", "security_officer"]

Особи видаляються зі списку доступу до об'єкта, коли доступ більше не потрібен

No: 7

Name: pe_2_odp

Type: list

Default: ["admin", "security_officer"]

Визначено періодичність перегляду списку доступу, у якому закріплений перелік персоналу або ролей, яким дозволений санкціонований доступ до об'єкта

11.3. ФІЗИЧНИЙ ДОСТУП ДО СИСТЕМИ

No: 1

Name: pe_3_a_01

Type: string

Default: nil

Авторизація фізичного доступу забезпечується в пунктах входу і виходу шляхом перевірки індивідуальних дозволів доступу

No: 2

Name: pe_3_b

Type: string

Default: nil

Журнали контролю фізичного доступу ведуться для 03_ODP[04] точок входу або виходу>

No: 3

Name: pe_3_c

Type: string

Default: nil

Доступ в зони всередині об'єкту, визначені як загальнодоступні, підтримується шляхом впровадження заходів захисту

No: 4

Name: pe_3_d_01

Type: string

Default: nil

Відвідувачів супроводжують

No: 5

Name: pe_3_d_02

Type: list

Default: []

Активність відвідувачів контролюється умови

No: 6

Name: pe_3_e_01

Type: string

Default: nil

Ключі захищені

No: 7

Name: pe_3_e_02

Type: string

Default: nil

Коди доступу захищені

No: 8

Name: pe_3_e_03

Type: string

Default: nil

Інші пристрої фізичного доступу захищені

No: 9

Name: pe_3_f

Type: string

Default: "щорічно"

Пристрої фізичного доступу інвентаризуються частота

No: 10

Name: pe_3_g_01

Type: list

Default: ["admin", "security_officer"]

Коди доступу змінюється частота, коли код скомпрометовано, або коли особи, які володіють кодом, переводяться або звільняються; <PE- PE-03(g)[02] ключі змінюються частота, коли ключі втрачено, або коли особи, що володіють ключами, переводяться або звільняються

No: 11

Name: pe_3_odp_01

Type: string

Default: nil

Визначено точки входу та виходу в об'єкт, в якому знаходиться система

No: 12

Name: pe_3_odp_02

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {системи або пристрої; охоронці}

No: 13

Name: pe_3_odp_03

Type: string

Default: nil

Визначено фізичні системи або пристрої контролю доступу, що використовуються для контролю входу та виходу на об'єкт (якщо вибрано); PE-03_ODP[04] визначено точки входу або виходу, для яких ведуться журнали контролю фізичного доступу

No: 14

Name: pe_3_odp_05

Type: string

Default: nil

Визначено заходи захисту для контролю доступу в зони всередині об'єкту, позначені як загальнодоступні

No: 15

Name: pe_3_odp_06

Type: list

Default: []

Визначено умови, що вимагають супроводу відвідувачів та моніторингу активності відвідувачів

No: 16

Name: pe_3_odp_07

Type: string

Default: nil

Визначені пристрої фізичного доступу, що підлягають інвентаризації

No: 17

Name: pe_3_odp_08

Type: integer

Default: 30

Визначено частоту проведення інвентаризації пристроїв фізичного доступу

No: 18

Name: pe_3_odp_09

Type: integer

Default: 30

Визначено частоту, з якою потрібно змінювати коди доступу

No: 19

Name: pe_3_odp_10

Type: integer

Default: 30

Визначено частоту, з якою потрібно змінювати ключі

11.3.1. Керування фізичним доступом — Захист від злому (PE-3(5))

No: 1

Name: pe_3_5_odp_01

Type: string

Default: nil

Визначено заходи захисту від фізичної підробки або підміни

No: 2

Name: pe_3_5_odp_02

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {виявлення; запобігання}

No: 3

Name: pe_3_5_odp_03

Type: string

Default: nil

Визначено апаратні компоненти, які мають захищені від фізичної підробки або підміни

11.4. PE-4 ліній електроживлення (PE-4)

No: 1

Name: pe_4_01

Type: string

Default: nil

Фізичний доступ до систем розподілу та постачання живлення в межах об'єктів організації контролюється за допомогою заходів захисту

No: 2
Name: pe_4_odp_01
Type: string
Default: nil

Визначені системи розподілу та постачання живлення, які потребують фізичного контролю доступу

No: 3
Name: pe_4_odp_02
Type: string
Default: nil

Визначено заходи захисту, які необхідно впровадити для контролю фізичного доступу до систем розподілу та постачання живлення в межах об'єкту організації

11.5. КОНТРОЛЬ ДОСТУПУ В ПРИМІЩЕННЯ ДЛЯ ВІДОБРАЖЕННЯ ІНФОРМАЦІЇ

No: 1
Name: pe_5_odp
Type: string
Default: nil

Визначено пристрої для виведення інформації над якими необхідний контроль над фізичним доступом до вихідних даних

11.6. МОНІТОРИНГ ФІЗИЧНОГО ДОСТУПУ

No: 1
Name: pe_6_a
Type: string
Default: nil

Фізичний доступ до об'єкту, де знаходиться система, моніториться з метою виявлення та реагування на інциденти фізичної безпеки

No: 2
Name: pe_6_b_01
Type: string
Default: "щорічно"

Переглядаються журнали фізичного доступу частота

No: 3
Name: pe_6_b_02
Type: string
Default: nil

Журнали фізичного доступу переглядаються при виникненні подій

No: 4
Name: pe_6_c_01
Type: string
Default: nil

Результати переглядів узгоджуються з можливостями організації щодо реагування на інциденти

No: 5
 Name: pe_6_c_02
 Type: string
 Default: nil

Результати розслідувань узгоджуються з можливостями організації щодо реагування на інциденти

No: 6
 Name: pe_6_odp_01
 Type: integer
 Default: 30

Визначено частоту перегляду журналів фізичного доступу

No: 7
 Name: pe_6_odp_02
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Визначено події або потенційні ознаки подій, що вимагають перегляду журналів фізичного доступу

11.6.1. Моніторинг фізичного доступу — Автоматичні розпізнавання вторгнень і відповідна реакція (PE-6(2))

No: 1
 Name: pe_6_2_01
 Type: string
 Default: nil

Розпізнаються класи або типи вторгнень

No: 2
 Name: pe_6_2_02
 Type: string
 Default: nil

Реакції ініціюються за допомогою автоматизованих механізмів

No: 3
 Name: pe_6_2_odp_01
 Type: string
 Default: nil

Визначено класи або типи вторгнень, які мають розпізнаватися автоматизованими механізмами

No: 4
 Name: pe_6_2_odp_02
 Type: string
 Default: nil

Визначено реакції, які мають ініціюватися автоматизованими механізмами при розпізнаванні визначених організацією класів або типів вторгнень

No: 5
 Name: pe_6_2_odp_03
 Type: string
 Default: "автоматизований засіб моніторингу"

Визначено автоматизовані механізми, що використовуються для розпізнавання класів або типів вторгнень та ініціювання дій реагування (визначені в PE06(02)_ODP)

11.7. АЛЬТЕРНАТИВНЕ РОБОЧЕ МІСЦЕ (PE-17)

No: 1

Name: pe_17_odp_01

Type: string

Default: nil

Визначені альтернативні робочі місця, дозволені для використання працівниками

No: 2

Name: pe_17_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначаються заходи захисту, які будуть застосовуватися на альтернативних робочих місцях; PE-17(a) альтернативні робочі місця визначені та задокументовані; PE-17(b) заходи захисту впроваджені на альтернативних робочих місцях; PE-17(c) оцінюється ефективність заходів захисту на альтернативних робочих місцях; PE-17(d) працівникам надаються засоби комунікації з персоналом служби інформаційної безпеки на випадок інцидентів

12. PL

Клас заходів захисту PL — ПЛАНУВАННЯ БЕЗПЕКИ

12.1. ПОЛІТИКИ ТА ПРОЦЕДУРИ ПЛАНУВАННЯ БЕЗПЕКИ (PL-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або ролей]: 1. 2. [вибір (один або декілька): рівень організації; рівень місії/бізнес процесу; рівень системи] політику планування, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та системою контролю (compliance); (b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам; процедури, що полегшують здійснення планування політики безпеки та приватності й пов'язані з ними заходи. б. Призначити [Призначення: визначену організацією посадову особу] для управління політикою та процедурами планування політики безпеки та приватності. с. Переглядати та оновлювати поточне планування: 1. політики планування безпеки та приватності [Призначення: з визначеною організацією частотою] та наступні [Призначення: визначені організацією події]; 2. поточні процедури планування політики [Призначення: з визначеною організацією частотою] та наступні [Призначення: визначені організацією події]. безпеки та приватності частотою] та наступні

No: 1

Name: pl_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких має бути доведена політика планування безпеки

No: 2

Name: pl_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюватимуться процедури планування безпеки

No: 3

Name: pl_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: pl_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами планування безпеки

No: 5

Name: pl_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено періодичність перегляду та оновлення поточної політики планування безпеки

No: 6

Name: pl_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Є події, які потребують перегляду та оновлення поточної політики планування безпеки

No: 7

Name: pl_1_odp_07

Type: string

Default: "щорічно"

Визначена частота, з якою переглядаються та оновлюються поточні процедури планування безпеки

12.2. ПЛАНИ ЗАХИСТУ ІНФОРМАЦІЇ ТА ПЕРСОНАЛЬНИХ ДАНИХ (PL-2)

а. Розробити план захисту інформації та персональних даних для інформаційної системи, який: 1. узгоджується з архітектурою підприємства організації; 2. чітко визначає складові компоненти системи; 3. описує оперативний контекст інформаційної системи з точки зору завдань та процесів; 4. визначає осіб, які виконують системні ролі та обов'язки; 5. визначає тип інформації, яка обробляється, зберігається та передається системою; 6. надає огляд вимог безпеки та приватності інформаційної системи; 7. описує будь які конкретні загрози системи, які викликають стурбованість організації; 8. надає результати оцінки ризику конфіденційності для систем, в яких обробляються персональні дані; 9. описує робоче середовище інформаційної системи та будь які залежності від систем або компонентів систем або підключень до таких систем та їх компонентів; 10. надає огляд вимог безпеки та конфіденційності системи; 11. визначає будь які відповідні контрольні базові рівні або накладання, якщо вони застосовуються; 12. описує чинні або заплановані заходи щодо забезпечення безпеки та приватності, включно з обґрунтуванням рішень щодо налаштування 13. включає виявлення ризиків для архітектури безпеки і приватності, а також проектних рішень; 14. включає дії, пов'язані з безпекою та конфіденційністю, які впливають на систему, виконання яких вимагає планування та координацію з [Призначення: визначені організацією окремі особи або групи]; 15. розглядається та затверджується уповноваженою посадовою особою або призначеним представником до початку реалізації плану. б. Поширити копії планів захисту інформації та персональних

даних і повідомляти про подальші зміни планів серед [Призначення:визначеного організацією персоналу або ролей]. с. Переглядати плани захисту інформації та персональних даних [Призначення: з визначеною організацією частотою]. d. Оновлювати плани захисту інформації та персональних даних для врахування змін в інформаційній системі й робочому середовищі або проблем, виявлених у ході реалізації або оцінювання заходів безпеки та приватності. e. забезпечити захист планів захисту інформації та персональних даних від несанкціонованого розголошення та змін.

No: 1

Name: pl_2_odp_01

Type: list

Default: ["admin", "security_officer"]

Призначені особи або групи, з якими пов'язана діяльність з безпекою та конфіденційністю, що впливає на систему, яка потребує планування та координації

No: 2

Name: pl_2_odp_02

Type: list

Default: ["admin", "security_officer"]

Призначено персонал або ролі для отримання розповсюджуваних копій планів захисту інформації та конфіденційності системи

No: 3

Name: pl_2_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначено періодичність перегляду інформації та конфіденційності системи; планів захисту PL-02a.01[01] розроблено план захисту інформації, архітектурі підприємства організації; який відповідає PL-02a.01[02] розроблено план конфіденційності для системи, відповідає архітектурі підприємства організації; який PL-02a.02[01] розроблено план захисту інформації, який чітко визначає складові компоненти системи; PL-02a.02[02] розроблено для системи план забезпечення конфіденційності, який чітко визначає складові компоненти системи; PL-02a.03[01] розроблено план захисту інформації системи, який описує операційний контекст системи з точки зору місії та бізнеспроцесів; PL-02a.03[02] розроблено для системи план забезпечення конфіденційності, який описує операційний контекст системи з точки зору місії та бізнес-процесів; PL-02a.04[01] розроблено план захисту інформації, який визначає осіб, що виконують системні ролі та обов'язки; PL-02a.04[02] розроблено для системи план забезпечення конфіденційності, який визначає осіб, що виконують ролі та обов'язки в системі; PL-02a.05[01] розроблено план захисту інформації, який визначає типи інформації, що обробляється, зберігається та передається системою; PL-02a.05[02] розроблено план конфіденційності для системи, який визначає типи інформації, що обробляється, зберігається та передається системою; PL-02a.06[01] розроблено план захисту інформації, який передбачає категоризацію безпеки системи, включаючи відповідне обґрунтування; PL-02a.06[02] розроблено для системи план забезпечення конфіденційності, який передбачає категоризацію системи за рівнем безпеки, включаючи обґрунтування; PL-02a.07[01] розроблено план захисту інформації, який описує будь-які конкретні загрози для системи, що викликають потенційні ризики для організації; PL-02a.07[02] розроблено план конфіденційності для системи, який описує будь-які конкретні загрози для системи, що викликають потенційні ризики для організації; PL-02a.08[01] розроблено план захисту інформації, який містить результати оцінки ризиків конфіденційності для систем, що обробляють інформацію, яка ідентифікує особу; PL-02a.08[02] розроблено для системи план забезпечення конфіденційності, який містить результати оцінки ризиків конфіденційності для систем, що обробляють інформацію, яка ідентифікує особу; PL-02a.09[01] розроблено план захисту інформації, який описує операційне середовище системи та будь-які залежності або зв'язки з іншими системами чи компонентами системи; PL-02a.09[02] розроблено для системи план забезпечення конфіденційності, який описує робоче середовище системи та будь-які залежності або зв'язки з іншими системами чи компонентами системи; PL-02a.10[01] розроблено план захисту інформації, який містить огляд вимог до безпеки системи; PL-02a.10[02] розроблено для системи план забезпечення конфіденційності, який містить огляд вимог до конфіденційності системи; PL-02a.11[01] розроблено план захисту інформації, який визначає будь-які відповідні базові рівні контролю або обмеження, якщо такі є; PL-02a.11[02] розроблено для

системи план забезпечення конфіденційності, який визначає будь-які відповідні базові рівні контролю або обмеження, якщо такі є; PL-02a.12[01] розроблено план захисту інформації, який описує наявні або заплановані засоби контролю для виконання вимог безпеки, включаючи обґрунтування будь-яких рішень щодо адаптації; PL-02a.12[02] розроблено для системи план забезпечення конфіденційності, який описує наявні або заплановані засоби контролю для виконання вимог щодо конфіденційності, включаючи обґрунтування будь-яких рішень, пов'язаних з адаптацією; PL-02a.13[01] розроблено план захисту інформації, який включає визначення ризиків для архітектури безпеки та проектних рішень; PL-02a.13[02] розроблено план забезпечення конфіденційності для системи, який включає визначення ризиків для архітектури конфіденційності та проектних рішень; PL-02a.14[01] розроблено захисту інформації, який включає діяльність, пов'язану з безпекою, що впливає на систему і потребує планування та координації з окремими особами або групами; PL-02a.14[02] розроблено для системи план забезпечення конфіденційності, який включає діяльність, пов'язану з конфіденційністю, що впливає на систему і потребує планування та координації з окремими особами або групами; PL-02a.15[01] розроблено план захисту інформації, який розглядається та затверджується уповноваженою посадовою особою або призначеним представником до початку реалізації плану; PL-02a.15[02] розроблено план забезпечення конфіденційності для системи, який перевіряється та затверджується уповноваженою посадовою особою або призначеним представником перед впровадженням плану. PL-02b.[01] розповсюджуються копії персонал або ролі>; PL-02b.[02] повідомляються наступні зміни до планів персонал або ролі; PL-02c. переглядаються плани частота; планів серед <PL-02 _ODP[02] PL-02d.[01] оновлюються плани відповідно до змін у системі та середовищі діяльності; PL-02d.[02] оновлюються плани для вирішення проблем, виявлених під час реалізації плану; PL-02d.[03] оновлюються плани для вирішення проблем, виявлених під час контрольних оцінок; PL-02e.[01] захищені плани від несанкціонованого розголошення; PL-02e.[02] захищені плани від несанкціонованої модифікації

12.2.1. КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ДИВЕРСИФІКАЦІЯ ПОСТАЧАЛЬНИКІВ (PL-2(1))

No: 1
Name: pl_2_1_01
Type: string
Default: nil

КЕРУВАННЯ РИЗИКАМИ ЛАНЦЮГА ДИВЕРСИФІКАЦІЯ ПОСТАЧАЛЬНИКІВ [Вилучено: включено до PL-7]

12.2.2. ПЛАНИ ЗАХИСТУ ІНФОРМАЦІЇ ФУНКЦІОНАЛЬНА АРХІТЕКТУРА (PL-2(2))

No: 1
Name: pl_2_2_01
Type: string
Default: nil

ПЛАНИ ЗАХИСТУ ІНФОРМАЦІЇ ФУНКЦІОНАЛЬНА АРХІТЕКТУРА [Вилучено: включено до PL-8]

12.3. ПРАВИЛА ПОВЕДІНКИ (PL-4)

а. Створити та надати особам, що потребують доступу до інформаційної системи, правила, які описують їхні обов'язки й очікувану поведінку щодо інформації та використання інформаційної системи, безпеки та приватності. б. Отримати документальне підтвердження від таких осіб про те, що вони прочитали, зрозуміли та погодилися дотримуватися правил поведінки, перш ніж дозволяти доступ до інформації та інформаційної системи. с. Переглядати й оновлювати правила поведінки [Призначення: з визначеною організацією частотою]. д. Вимагати від осіб, які підписали попередню версію правил поведінки, перечитати та повторно підписати правила

[Вибір (один або декілька): [Призначення: з визначеною організацією частотою]; коли правила переглядаються чи оновлюються].

No: 1

Name: pl_4_odp_01

Type: string

Default: "щорічно"

Визначено періодичність перегляду та оновлення правил поведінки

No: 2

Name: pl_4_odp_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРА:{частота; коли правила переглядаються або оновлюються}

No: 3

Name: pl_4_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначена періодичність перегляду та повторного підтвердження правил поведінки (якщо вибрано); PL-04a.[01] встановлені правила, які описують обов'язки та очікувану поведінку щодо використання інформації та системи, безпеки та конфіденційності для осіб, яким потрібен доступ до системи; PL-04a.[02] надаються правила, які описують обов'язки та очікувану поведінку щодо використання інформації та системи, безпеки та конфіденційності, особам, які отримують доступ до системи; PL-04b. отримано перед наданням доступу до інформації та системи задокументоване підтвердження від таких осіб про те, що вони прочитали, зрозуміли та згодні дотримуватися правил поведінки; PL-04c. переглядаються та оновлюються правила поведінки частота; PL-04d. потрібно особам, які визнали попередню версію правил поведінки, прочитати та повторно визнати ЗНАЧЕННЯ ВИБРАНОВОГО ПАРАМЕТРА(ів)

12.3.1. ОБМЕЖЕННЯ НА СОЦІАЛЬНІ МЕДІА ТА МЕРЕЖУ (PL-4(1))

No: 1

Name: pl_4_1_a

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Включають правила поведінки обмеження на використання соціальних медіа, соціальних мереж та зовнішніх сайтів/додатків

No: 2

Name: pl_4_1_b

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Включають правила поведінки обмеження на розміщення інформації про організацію на публічних веб-сайтах

No: 3

Name: pl_4_1_c

Type: list

Default: ["admin", "security_officer"]

Включають правила поведінки обмеження на використання наданих організацією ідентифікаторів (наприклад, адрес електронної пошти) та секретів автентифікації (наприклад, паролів) для створення облікових записів на зовнішніх сайтах/додатках. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

13. PS

Клас заходів захисту PS — КАДРОВА БЕЗПЕКА

13.1. Політика та процедури кадрової безпеки (PS-1)

No: 1

Name: ps_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюється політика кадрової безпеки

No: 2

Name: ps_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури кадрової безпеки

No: 3

Name: ps_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: ps_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами кадрової безпеки

No: 5

Name: ps_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначена періодичність перегляду та оновлення поточної політики кадрової безпеки

No: 6

Name: ps_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Є події, які вимагають перегляду та оновлення поточної політики кадрової безпеки

No: 7

Name: ps_1_odp_07

Type: string

Default: "щорічно"

Визначено періодичність перегляду та оновлення поточних процедур кадрової безпеки

13.2. Перевірка персоналу (PS-3)

No: 1

Name: ps_3_odp_01

Type: list

Default: []

Визначені умови, що вимагають повторної перевірки осіб

No: 2

Name: ps_3_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначена частота повторної перевірки осіб, для яких це показано; PS-03a. проходять особи перевірку перед тим, як надати їм доступ до системи; PS-03b.[01] проходять особи повторну перевірку відповідно до умови, що вимагають повторної перевірки; PS-03b.[02] проводиться повторна перевірка у випадках, коли це зазначено, частота

13.3. Звільнення персоналу (PS-4)

No: 1

Name: ps_4_odp_01

Type: integer

Default: 30

Визначено період часу, протягом якого забороняється доступ до системи

No: 2

Name: ps_4_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначені теми інформаційної безпеки для обговорення під час проведення співбесід; PS-04a. при звільненні працівника доступ до системи вимикається протягом часового періоду; PS-04b. припиняють дію або анулюють будь-які автентифікатори та облікові дані після припинення трудових відносин з окремими особами; PS-04c. проводяться при звільненні окремих працівників співбесіди, які включають обговорення питань інформаційної безпеки; PS-04d. отримується після звільнення особи все майно, пов'язане з безпекою організаційної системи; PS-04e. зберігається доступ до організаційної інформації та систем, які раніше перебували під контролем особи, що звільняється, після припинення нею трудових відносин

13.4. Переведення персоналу (PS-5)

No: 1

Name: ps_5_odp_01

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначені дії, які мають бути ініційовані після переведення або перепризначення

No: 2

Name: ps_5_odp_02

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначено період часу, протягом якого мають бути здійснені дії з переведення або перепризначення після переведення або перепризначення

No: 3

Name: ps_5_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, про які необхідно повідомляти, коли осіб призначають на інші посади або переводять на інші посади в організації

No: 4

Name: ps_5_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено період часу, протягом якого необхідно повідомляти визначений організацією персонал або ролі, коли осіб перепризначають або переводять на інші посади в межах організації; PS-05a. переглядаються та підтверджуються поточні потреби в логічних та фізичних дозволах на доступ до систем та об'єктів при перепризначенні або переведенні осіб на інші посади в організації; PS-05b. були ініційовані дії з переведення або перепризначення протягом періоду часу після формальної дії з переведення; PS-05c. змінюється авторизація доступу за необхідності, щоб відповідати будь-яким змінам в оперативних потребах у зв'язку з перепризначенням або переведенням; PS-05d. було повідомлено персонал або ролі протягом часового періоду

14. RA

Клас заходів захисту RA — ОЦІНЮВАННЯ РИЗИКУ

14.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ОЦІНЮВАННЯ РИЗИКУ (RA-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посадових осіб]: 1. 2. Політику оцінювання ризику, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (b) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам і керівним принципам. Процедури, що сприяють здійсненню політики оцінювання ризику та пов'язаних з ними заходів оцінювання ризику. б. Призначити [Призначення: визначена організацією посадову особу] для управління політикою та процедурами оцінювання ризику. с. Переглядати й оновлювати: 1. Поточну політику оцінювання організацією частотою]. ризику [Призначення: з визначеною 2. Поточні процедури оцінювання ризику [Призначення: з визначеною організацією частотою].

No: 1

Name: ra_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюється політика оцінювання ризику

No: 2

Name: ra_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури, що сприяють здійсненню політики оцінювання ризику

No: 3

Name: ra_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: ra_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначена посадова особа, відповідальна за управління політикою та процедурами оцінювання ризику

No: 5

Name: ra_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначена періодичність перегляду та оновлення поточної політики оцінювання ризику

No: 6

Name: ra_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Є події, які вимагають перегляду та оновлення поточної політики оцінювання ризику

No: 7

Name: ra_1_odp_07

Type: string

Default: "щорічно"

Визначено періодичність перегляду поточних процедур оцінювання ризику

14.2. ОЦІНЮВАННЯ РИЗИКУ (RA-3)

No: 1

Name: ra_3_odp_01

Type: string

Default: nil

Вибрано одне з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {плани безпеки та приватності; звіт про оцінювання ризику; документ}

No: 2

Name: ra_3_odp_02

Type: string

Default: nil

Визначено документ, в якому мають бути задокументовані результати оцінювання ризику (якщо вони не задокументовані в планах безпеки та приватності або в звіті про оцінювання ризику) (якщо вибрано)

No: 3

Name: ra_3_odp_03

Type: string
Default: "щорічно"

Визначено періодичність оцінювання ризику

No: 4
Name: ra_3_odp_04
Type: list
Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких мають бути доведені результати оцінювання ризику

No: 5
Name: ra_3_odp_05
Type: list
Default: ["admin", "security_officer"]

Визначена періодичність оновлення оцінювання ризику; перегляду результатів RA-03a.01 проводиться оцінювання ризику для виявлення загроз і вразливостей у системі; RA-03a.02 проводиться оцінювання ризику для визначення ймовірності та розміру шкоди від несанкціонованого доступу, використання, розкриття, порушення, модифікації або знищення системи; інформації, яку вона обробляє, зберігає або передає; а також будь-якої пов'язаної з нею інформації; RA-03a.03 проводиться оцінювання ризику для визначення ймовірності та впливу несприятливих наслідків для фізичних осіб, що виникають у зв'язку з обробкою інформації, яка ідентифікує особу; RA-03b. інтегровані результати оцінювання ризику та рішення з управління ризиками з точки зору організації та місії або бізнес-процесів з оцінкою ризиків на системному рівні; RA-03c. результати оцінювання ризику задокументовані в ЗНАЧЕННЯ ВИБРАНОГО ПАРАМЕТРА; RA-03d. переглядаються результати 03_ODP[03] частота>; RA-03e. поширюються результати оцінювання ризику серед персоналу або ролей; RA-03f. оновлюється оцінювання ризику частота або коли відбуваються значні зміни в системі, середовищі її функціонування або інших умовах, які можуть вплинути на стан безпеки або приватності системи оцінювання ризику <RA-

14.2.1. ОЦІНЮВАННЯ ПОСТАЧАННЯ (RA-3(1))

No: 1
Name: ra_3_1_a
Type: string
Default: nil

Оцінювання ризику ланцюга постачання, пов'язані з системами, системними компонентами та системними послугами

No: 2
Name: ra_3_1_b
Type: string
Default: nil

Потрібно оновлювати оцінювання ризику ланцюга постачання, коли відбуваються значні зміни у відповідному ланцюгу постачання, або коли зміни в системі, середовищі функціонування чи інших умовах можуть вимагати змін у ланцюгу постачання

14.2.2. ВИКОРИСТАННЯ ІНФОРМАЦІЇ З УСІХ ДОСТУПНИХ ДЖЕРЕЛ (RA-3(2))

No: 1
Name: ra_3_2_01
Type: string
Default: nil

Використовується інформація з усіх доступних джерел для аналізу ризиків

14.2.3. УСВІДОМЛЕННЯ ДИНАМІЧНИХ ЗАГРОЗ (РА-3(3))

No: 1

Name: ra_3_3_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначається поточне середовище кіберзагроз на постійній основі за допомогою засоби

No: 2

Name: ra_3_3_odp

Type: string

Default: "автоматизований засіб моніторингу"

Є засоби для постійного визначення поточного стану кіберзагроз

14.2.4. ПРОГНОСТИЧНА КІБЕРАНАЛІТИКА (РА-3(4))

No: 1

Name: ra_3_4_01

Type: string

Default: nil

Використовуються розширені можливості автоматизації для прогнозування та виявлення ризику для систем або компонентів системи

No: 2

Name: ra_3_4_02

Type: string

Default: nil

Застосовуються розширені аналітичні можливості для прогнозування та виявлення ризику для систем або компонентів системи. аналітики

14.3. СКАНУВАННЯ ВРАЗЛИВОСТЕЙ (РА-5)

Використовувати заходи ПДТР за [Призначення: визначені організацією місця] [Вибір (один або кілька): [Призначення: з визначеною організацією частотою]; [Призначення: за визначеними організацією подіями або показниками]].

No: 1

Name: ra_5_odp_01

Type: string

Default: nil

Визначена необхідність моніторингу систем та розміщених застосунків на наявність вразливостей

No: 2

Name: ra_5_odp_02

Type: string

Default: "щорічно"

Визначена періодичність перевірки систем та розміщених на них застосунків на наявність вразливостей

No: 3

Name: ra_5_odp_03

Type: integer

Default: 30

Визначено час реагування на усунення законних вразливостей відповідно до організаційної оцінки ризику

No: 4

Name: ra_5_odp_04

Type: list

Default: ["admin", "security_officer"]

Потрібно ділитися інформацією, отриманою в процесі сканування вразливостей та оцінок контролю, з персоналом або ролями, з якими потрібно ділитися; RA-05a.[01] здійснюється моніторинг систем та розміщених застосунків на наявність вразливостей частота та/або випадковість відповідно до визначеного організацією процесу, а також коли виявляються та повідомляються нові вразливості, що потенційно можуть вплинути на систему; RA-05a.[02] перевіряються системи та розміщені застосунки на наявність вразливостей частота та/або випадковим чином відповідно до визначеного організацією процесу, а також коли виявляються та повідомляються нові вразливості, що потенційно можуть вплинути на систему; RA-05b. застосовуються інструменти та методи моніторингу вразливостей для забезпечення сумісності між інструментами; RA-05b.01 застосовуються інструменти та методи моніторингу вразливостей для автоматизації частини процесу управління вразливостями, використовуючи стандарти для переліку платформ, недоліків програмного забезпечення та неправильних конфігурацій; RA-05b.02 застосовуються інструменти та методи моніторингу вразливостей для полегшення взаємодії між інструментами та автоматизації частини процесу управління вразливостями шляхом використання стандартів для формування контрольних списків та процедур тестування; RA-05b.03 застосовуються інструменти та методи моніторингу вразливостей для полегшення взаємодії між інструментами та автоматизації частин процесу управління вразливостями шляхом використання стандартів для вимірювання впливу вразливостей; RA-05c. аналізуються звіти про сканування вразливостей та результати моніторингу вразливостей; RA-05d. усуваються легітимні вразливості час реагування відповідно до організаційної оцінки ризиків; RA-05e. надається інформація, отримана в процесі моніторингу вразливостей та оцінки контролю, персонал або ролі, щоб допомогти усунути подібні вразливості в інших системах; RA-05f. використовуються інструменти моніторингу вразливостей, які передбачають можливість швидкого оновлення вразливостей, що підлягають скануванню

14.3.1. СКАНУВАННЯ ВРАЗЛИВОСТЕЙ ІНСТРУМЕНТІВ (RA-5(1))

No: 1

Name: ra_5_1_01

Type: string

Default: nil

СКАНУВАННЯ ВРАЗЛИВОСТЕЙ ІНСТРУМЕНТІВ [Вилучено: включено до RA-5]

14.3.2. ОНОВЛЕННЯ ЗА ЧАСТОТОЮ, ПЕРЕД НОВИМ СКАНУВАННЯМ АБО ПРИ ІДЕНТИФІКАЦІЇ (RA-5(2))

No: 1

Name: ra_5_2_01

Type: integer

Default: 30

Визначено час реагування на усунення законних вразливостей відповідно до організаційної оцінки ризику

14.3.3. ШИРОТА ТА ГЛИБИНА ПОКРИТТЯ (RA-5(3))

No: 1

Name: ra_5_3_01

Type: string

Default: nil

Визначено ширину вразливостей. та глибину охоплення сканування

14.3.4. ВИЯВНА ІНФОРМАЦІЯ (RA-5(4))

No: 1

Name: ra_5_4_01

Type: list

Default: ["login", "logout", "failed_attempt"]

Є інформація про систему відкритою; RA-05(04)[02] вживаються коригувальні дії, коли інформація про систему підтверджується як така, що може бути виявлена

No: 2

Name: ra_5_4_odp

Type: list

Default: ["login", "logout", "failed_attempt"]

Визначені коригувальні дії, які необхідно вжити, якщо інформація про систему буде виявлена

14.3.5. ПРИВІЛЕЙОВАНИЙ ДОСТУП (RA-5(5))

No: 1

Name: ra_5_5_01

Type: string

Default: nil

Реалізовано авторизацію привілейованого доступу до компоненти системи для діяльності зі сканування вразливостей

14.3.6. СКАНУВАННЯ ТЕНДЕНЦІЙ (RA-5(6))

No: 1

Name: ra_5_6_01

Type: string

Default: "автоматизований засіб моніторингу"

Порівнюються результати багаторазового сканування вразливостей за допомогою автоматизовані механізми

No: 2

Name: ra_5_6_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначені автоматизовані механізми для порівняння результатів багаторазового сканування вразливостей

14.3.7. АВТОМАТИЗОВАНЕ ВИЯВЛЕННЯ ТА СПОВІЩЕННЯ ПРО НЕАВТОРИЗОВАНІ КОМПОНЕНТИ (RA-5(7))

No: 1

Name: ra_5_7_01

Type: string

Default: nil

СКАНУВАННЯ ВРАЗЛИВОСТЕЙ - АВТОМАТИЗОВАНЕ ВИЯВЛЕННЯ ТА СПОВІЩЕННЯ ПРО НЕАВТОРИЗОВАНІ КОМПОНЕНТИ [Вилучено: включено до СМ-8]

14.3.8. ОГЛЯД ЖУРНАЛІВ АУДИТУ ЗА МИНУЛІ ПЕРІОДИ (RA-5(8))

Немає параметрів для цього контролю.

14.3.9. СКАНУВАННЯ ВРАЗЛИВОСТЕЙ ПРОНИКНЕННЯ (RA-5(9))

No: 1

Name: ra_5_9_01

Type: string

Default: nil

СКАНУВАННЯ ВРАЗЛИВОСТЕЙ ПРОНИКНЕННЯ [Вилучено: включено до СА-8] RA5(10) СКАНУВАННЯ ВРАЗЛИВОСТЕЙ - ЗІСТАВЛЕННЯ ІНФОРМАЦІЇ ПРО СКАНУВАННЯ - ТЕСТУВАННЯ ТА АНАЛІЗ

14.4. РЕАГУВАННЯ НА РИЗИК (RA-7)

Реагувати на результати оцінювання, моніторингу й аудиту безпеки та приватності.

No: 1

Name: ra_7_01

Type: string

Default: nil

Вживаються заходи реагування на результати оцінок безпеки відповідно до організаційної толерантності до ризиків

No: 2

Name: ra_7_02

Type: string

Default: nil

Вживаються заходи реагування на результати оцінювання приватності відповідно до організаційної толерантності до ризиків

No: 3

Name: ra_7_03

Type: string

Default: nil

Вживаються заходи реагування на результати моніторингу відповідно до організаційної толерантності до ризиків

No: 4

Name: ra_7_04

Type: string

Default: nil

Вживаються заходи реагування на висновки аудиту відповідно до організаційної толерантності до ризиків

15. SA

Клас заходів захисту SA — ПРИДБАННЯ СИСТЕМИ ТА ПОСЛУГ

15.1. ПОЛІТИКИ ТА ПРОЦЕДУРИ ПРИДБАННЯ СИСТЕМ ТА ПОСЛУГ (SA-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або ролей]: 1. 2. б. [Вибір (один або декілька): рівень організації; рівень місії/бізнес-процесу; рівень системи] політики придбання систем і послуг, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю (compliance); (б) відповідає чинному законодавству, виходячи з наказів, директив, норм, політик, стандартів і рекомендацій. Процедури, що полегшують впровадження політики та заходів придбання систем і послуг. Призначити [Призначення: визначену організацією посадову особу] для управління політикою та процедурами придбання системи та послуг. с. Переглядати й оновлювати поточні політику та процедури придбання систем та послуг: 1. Поточну політику придбання системи та послуг [Призначення: з визначеною організацією частотою]. 2. Поточні процедури придбання системи та послуг [Призначення: з визначеною організацією частотою] та наступні [Призначення: події, визначені організацією].

No: 1

Name: sa_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюватиметься політика придбання систем і послуг

No: 2

Name: sa_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури придбання систем і послуг

No: 3

Name: sa_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: sa_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами придбання систем і послуг

No: 5

Name: sa_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначено періодичність перегляду та оновлення поточної політики придбання систем і послуг

No: 6

Name: sa_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Є події, які вимагають перегляду та оновлення поточної політики придбання систем і послуг

No: 7

Name: sa_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні процедури придбання систем і послуг

15.2. БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ІНЖИНІРИНГУ (SA-8)

Застосовувати [Призначення: визначені організацією принципи інжинірингу безпеки та конфіденційності системи] в специфікації, проектуванні, розробці, впровадженні та зміні системи й компонентів системи.

No: 1

Name: sa_8_01

Type: string

Default: nil

Застосовуються принципи інжинірингу безпеки систем у специфікації системи та компонентів системи

No: 2

Name: sa_8_02

Type: string

Default: nil

Застосовуються принципи інжинірингу безпеки систем при розробці системи та її компонентів

No: 3

Name: sa_8_03

Type: string

Default: nil

Були застосовані принципи інжинірингу безпеки систем при розробці системи та компонентів систем

No: 4

Name: sa_8_04

Type: string

Default: nil

Застосовуються принципи інжинірингу безпеки систем при реалізації системи та компонентів систем

No: 5

Name: sa_8_05

Type: string

Default: nil

Застосовуються принципи інжинірингу безпеки систем при модифікації системи та компонентів систем

No: 6

Name: sa_8_06

Type: string

Default: nil

Застосовуються принципи інжинірингу конфіденційності у специфікації системи та компонентів систем; принципи інжинірингу конфіденційності SA-08[07] застосовуються принципи інжинірингу конфіденційності при розробці системи та компонентів систем

No: 7
Name: sa_8_08
Type: string
Default: nil

Застосовуються принципи інжинірингу конфіденційності при розробці системи та компонентів систем

No: 8
Name: sa_8_09
Type: string
Default: nil

Застосовуються принципи інжинірингу конфіденційності при реалізації системи та компонентів систем

No: 9
Name: sa_8_10
Type: string
Default: nil

Застосовуються принципи інжинірингу конфіденційності при модифікації системи та компонентів систем

No: 10
Name: sa_8_odp_01
Type: string
Default: nil

Визначені принципи інжинірингу безпеки систем

No: 11
Name: sa_8_odp_02
Type: string
Default: nil

Визначені системи

15.2.1. ЧІТКА АБСТРАКЦІЯ (SA-8(1))

No: 1
Name: sa_8_1_01
Type: string
Default: nil

Реалізовано принцип проектування безпеки чітких абстракцій

15.2.2. БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ НАЙМЕНШ ПОШИРЕНИЙ МЕХАНІЗМ (SA-8(2))

No: 1
Name: sa_8_2_01
Type: string
Default: nil

Реалізують системи або компоненти системи принцип побудови безпеки за принципом найменш поширеного механізму

No: 2
Name: sa_8_2_odp
Type: string
Default: nil

Реалізовано абстракцій. принцип проектування безпеки чітких

15.2.3. БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ МОДУЛЬНІСТЬ І БАГАТОРІВНЕВІСТЬ (SA-8(3))

No: 1
Name: sa_8_3_01
Type: string
Default: nil

БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ МОДУЛЬНІСТЬ І БАГАТОРІВНЕВІСТЬ ІНЖИНІРИНГУ - МЕТА ОЦІНКИ: Визначити, чи: SA08(03)_ODP[01] визначені системи або компоненти системи, реалізують принцип модульності дизайну безпеки; які SA08(03)_ODP[02] визначені системи або компоненти реалізують принцип багаторівневого безпеки

No: 2
Name: sa_8_3_02
Type: string
Default: nil

Системи або компоненти системи реалізують принцип багаторівневого проектування безпеки. системи, які проектування

15.2.4. БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ЧАСТКОВО ВПОРЯДКОВАНІ ЗАЛЕЖНОСТІ (SA-8(4))

No: 1
Name: sa_8_4_01
Type: integer
Default: 30

Системи або компоненти системи реалізують принцип проектування безпеки частково впорядкованих залежностей

No: 2
Name: sa_8_4_odp
Type: integer
Default: 30

Визначені системи або компоненти системи, які реалізують принцип проектування безпеки частково впорядкованих залежностей

15.2.5. БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ЕФЕКТИВНИЙ ОПОСЕРЕДКОВАНИЙ ДОСТУП (SA-8(5))

No: 1
Name: sa_8_5_01
Type: string
Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки ефективного опосередкованого доступу

No: 2

Name: sa_8_5_odp

Type: string

Default: nil

Визначені системи або її компоненти, які реалізують принцип проектування безпеки ефективного опосередкованого доступу

15.2.6. БЕЗПЕКА ТА ПРИВАТНІСТЬ МІНІМІЗОВАНИЙ ОБМІН (SA-8(6))

No: 1

Name: sa_8_6_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип побудови безпеки за принципом мінімізації спільного використання

No: 2

Name: sa_8_6_odp

Type: string

Default: nil

Визначені системи або компоненти системи, які реалізують принцип проектування безпеки, що полягає в мінімізації спільного використання

15.2.7. ЗНИЖЕНА СКЛАДНІСТЬ (SA-8(7))

No: 1

Name: sa_8_7_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки за принципом зниженої складності. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

No: 2

Name: sa_8_7_odp

Type: string

Default: nil

Визначені системи або компоненти системи, які реалізують принцип проектування безпеки за принципом зниженої складності

15.2.8. БЕЗПЕКА ТА ПРИВАТНІСТЬ ПРИНЦИПІВ ЕВОЛЮЦІЯ БЕЗПЕКИ В СИСТЕМІ (SA-8(8))

No: 1

Name: sa_8_8_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип безпечного проектування безпечної еволюційності

No: 2
Name: sa_8_8_odp
Type: string
Default: nil

Визначені системи або компоненти системи, які реалізують принцип безпечного проектування безпечної еволюційності

15.2.9. ДОВІРЕНІ КОМПОНЕНТИ СИСТЕМИ (SA-8(9))

No: 1
Name: sa_8_9_01
Type: string
Default: nil

Системи або компоненти реалізують принцип побудови безпеки компонентів. системи довірених

No: 2
Name: sa_8_9_odp
Type: string
Default: nil

Визначені системи або компоненти системи, які реалізують принцип побудови безпеки довірених компонентів

15.2.10. РЕАЛІЗУЮТЬ ПРИНЦИП ІЄРАРХІЧНОЇ ДОВІРИ В ДИЗАЙНІ БЕЗПЕКИ (SA-8(10))

No: 1
Name: sa_8_10_01
Type: string
Default: nil

Системи або компоненти системи реалізують принцип ієрархічної довіри в дизайні безпеки. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

No: 2
Name: sa_8_10_odp
Type: string
Default: nil

Визначені системи або компоненти системи, які реалізують принцип ієрархічної довіри при проектуванні безпеки

15.2.11. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ ЗВОРОТНОГО ПОРОГУ МОДИФІКАЦІЇ (SA-8(11))

No: 1
Name: sa_8_11_01
Type: string
Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки зворотного порогу модифікації

No: 2
Name: sa_8_11_odp
Type: string
Default: nil

Визначені системи або компоненти системи, які реалізують принцип ієрархічної довіри при проектуванні безпеки

15.2.12. РЕАЛІЗУЮТЬ ПРИНЦИП ПОБУДОВИ ІЄРАРХІЧНОГО ЗАХИСТУ (SA-8(12))

No: 1

Name: sa_8_12_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип побудови ієрархічного захисту

No: 2

Name: sa_8_12_odp

Type: string

Default: nil

Визначені системи або компоненти системи, реалізують принцип ієрархічного дизайну безпеки; які

15.2.13. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ З МІНІМІЗАЦІЄЮ ЕЛЕМЕНТІВ БЕЗПЕКИ (SA-8(13))

No: 1

Name: sa_8_13_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки з мінімізацією елементів безпеки. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

No: 2

Name: sa_8_13_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип проектування безпеки за принципом мінімізації елементів безпеки

15.2.14. РЕАЛІЗУЮТЬ ПРИНЦИП ПОБУДОВИ БЕЗПЕКИ ЗА ПРИНЦИПОМ НАЙМЕНШИХ ПРИВІЛЕЇВ (SA-8(14))

No: 1

Name: sa_8_14_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип побудови безпеки за принципом найменших привілеїв

No: 2

Name: sa_8_14_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип побудови безпеки за принципом найменших привілеїв

15.2.15. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ ПОПЕРЕДНЬОГО ДОЗВОЛУ (SA-8(15))

No: 1

Name: sa_8_15_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки попереднього дозволу

No: 2

Name: sa_8_15_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип проектування безпеки попереднього дозволу

15.2.16. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ САМОДОСТАТНЬОЇ НАДІЙНОСТІ (SA-8(16))

No: 1

Name: sa_8_16_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки самодостатньої надійності. ПО-ТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

No: 2

Name: sa_8_16_odp

Type: string

Default: nil

Визначено системи або компоненти реалізують принцип проектування ґрунтується на самодостатній надійності; системи, безпеки, які що

15.2.17. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ ЗАХИЩЕНОГО РОЗПОДІЛЕНОГО ВМІСТУ (SA-8(17))

No: 1

Name: sa_8_17_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки захищеного розподіленого вмісту

No: 2

Name: sa_8_17_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип безпечного проектування захищеного розподіленого вмісту

15.2.18. РЕАЛІЗУЮТЬ ПРИНЦИП ПОБУДОВИ БЕЗПЕКИ ДОВІРЕНИХ КАНАЛІВ ЗВ'ЯЗКУ (SA-8(18))

No: 1

Name: sa_8_18_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип побудови безпеки довірених каналів зв'язку

No: 2

Name: sa_8_18_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип побудови безпеки довірених каналів зв'язку

15.2.19. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ ДОВГОТРИВАЛОГО (SA-8(19))

No: 1

Name: sa_8_19_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки довготривалого захисту

No: 2

Name: sa_8_19_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які втілюють принцип проектування безпеки довготривалого захисту

15.2.20. РЕАЛІЗУЮТЬ ПРИНЦИП БЕЗПЕЧНОГО УПРАВЛІННЯ МЕТАДАНИМИ (SA-8(20))

No: 1

Name: sa_8_20_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип безпечного управління метаданими

No: 2

Name: sa_8_20_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип безпечного управління метаданими

15.2.21. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕКИ НА ОСНОВІ САМОАНАЛІЗУ (SA-8(21))

No: 1

Name: sa_8_21_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип проектування безпеки на основі самоаналізу

No: 2

Name: sa_8_21_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип самоаналізу при проектуванні безпеки

15.2.22. РЕАЛІЗУЮТЬ ПРИНЦИП ПРОЕКТУВАННЯ БЕЗПЕЧНИХ НАЛАШТУВАНЬ ЗА ЗАМОВЧУВАННЯМ (SA-8(23))

No: 1

Name: sa_8_23_odp

Type: string

Default: nil

Визначено системи або компоненти системи, реалізують принцип безпечних налаштувань за замовчуванням; які за SA-08(23) системи або компоненти системи реалізують принцип проектування безпечних налаштувань за замовчуванням

15.2.23. <SA-08(25)_ODP системи або компоненти реалізують принцип безпеки економіки. (SA-8(25))

No: 1

Name: sa_8_25_01

Type: string

Default: nil

Системи або компоненти реалізують принцип безпеки економіки. які системи

No: 2

Name: sa_8_25_odp

Type: string

Default: nil

Визначено системи або компоненти реалізують принцип безпеки економіки; системи,

15.2.24. <SA-08(26)_ODP системи або компоненти реалізують принцип безпеки продуктивності. (SA-8(26))

No: 1

Name: sa_8_26_01

Type: string

Default: nil

Системи або компоненти реалізують принцип безпеки продуктивності. які системи

No: 2

Name: sa_8_26_odp

Type: string

Default: nil

Визначено системи або компоненти системи, реалізують принцип безпеки продуктивності

15.2.25. РЕАЛІЗУЮТЬ ПРИНЦИП БЕЗПЕКИ З УРАХУВАННЯМ ЛЮДСЬКОГО ФАКТОРУ (SA-8(27))

No: 1

Name: sa_8_27_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип безпеки з урахуванням людського фактору

No: 2

Name: sa_8_27_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип безпеки з урахуванням людського фактору

15.2.26. <SA-08(28)_ODP системи або компоненти реалізують принцип прийнятного рівня безпеки. (SA-8(28))

No: 1

Name: sa_8_28_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип повторюваних та задокументованих процедур

No: 2

Name: sa_8_28_odp

Type: string

Default: nil

Визначено системи або компоненти системи, реалізують принцип прийнятного рівня безпеки

15.2.27. РЕАЛІЗУЮТЬ ПРИНЦИП БЕЗПЕЧНОЇ МОДИФІКАЦІЇ СИСТЕМ (SA-8(31))

No: 1

Name: sa_8_31_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип безпечної модифікації систем

No: 2

Name: sa_8_31_odp

Type: string

Default: nil

Визначено системи або компоненти системи, реалізують принцип безпечної модифікації систем; які

15.2.28. РЕАЛІЗУЮТЬ ПРИНЦИП ДОСТАТНЬОЇ ДОПУСКНОЇ ДОКУМЕНТАЦІЇ (SA-8(32))

No: 1

Name: sa_8_32_01

Type: string

Default: nil

Системи або компоненти системи реалізують принцип достатньої допускної документації

No: 2

Name: sa_8_32_odp

Type: string

Default: nil

Визначено системи або компоненти системи, які реалізують принцип достатньої допускної документації

15.2.29. <SA-08(33)_ODP системи або компоненти реалізують принцип мінімізації конфіденційності. (SA-8(33))

No: 1

Name: sa_8_33_odp

Type: string

Default: nil

Визначено системи або компоненти системи, реалізують принцип мінімізації конфіденційності; які SA-08(33) системи або компоненти реалізують принцип мінімізації конфіденційності. системи

15.3. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ (SA-9)

а. Вимагати, щоб постачальники зовнішніх послуг для системи відповідали вимогам безпеки та приватності в організації та застосовували такі заходи захисту [Призначення: встановлені організацією заходи безпеки та приватності]. б. Визначити та задокументувати нагляд організаціїповноваження та обов'язки користувачів щодо зовнішніх послуг для системи. с. Використовувати наступні процеси, методи та техніки для постійного моніторингу дотримання контролю зовнішніми постачальниками послуг: [Призначення: визначені організацією процеси, методи та техніки].

No: 1

Name: sa_9_odp_01

Type: string

Default: "автоматизований засіб моніторингу"

Визначені засоби контролю, які будуть застосовуватися зовнішніми постачальниками системних послуг

No: 2

Name: sa_9_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначені процеси, методи та техніки, що застосовуються для моніторингу дотримання вимог контролю зовнішніми постачальниками послуг; SA-09a.[01] дотримуються постачальники зовнішніх системних послуг вимог організаційної безпеки; SA-09a.[02] дотримуються постачальники зовнішніх системних послуг вимог

приватності організації; SA-09a.[03] використовують постачальники зовнішніх системних послуг елементи керування; SA-09b.[01] визначено та задокументовано організаційний нагляд за зовнішніми системними послугами; SA-09b.[02] визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних сервісів; SA-09c. визначені та задокументовані ролі та обов'язки користувачів щодо зовнішніх системних послуг

15.3.1. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- ОЦІНЮВАННЯ РИЗИКІВ ТА ОРГАНІЗАЦІЙНІ ПОГОДЖЕННЯ (SA-9(1))

(а) Проводити організаційне оцінювання ризиків перед придбанням або переданням послуг інформаційної безпеки служб інформаційної безпеки. (b) Переконатися, що придбання або передача спеціалізованих служб інформаційної безпеки погоджені [Призначення: визначеним організацією персоналом або посадовими особами].

No: 1

Name: sa_9_1_a

Type: string

Default: nil

Проводиться організаційна оцінка ризиків перед придбанням або передачею послуг з інформаційної безпеки

No: 2

Name: sa_9_1_b

Type: list

Default: ["admin", "security_officer"]

Схвалюють персонал або ролі придбання або передачу спеціальних послуг з інформаційної безпеки

No: 3

Name: sa_9_1_odp

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, які схвалюють придбання або передачу спеціальних послуг з інформаційної безпеки

15.3.2. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- ВИЗНАЧЕННЯ ФУНКЦІЙ, ПОРТІВ, ПРОТОКОЛІВ ТА СЛУЖБ (SA-9(2))

Вимагати від постачальників наведених нижче зовнішніх послуг для системи [Призначення: визначених організацією зовнішніх послуг для системи] визначити функції, порти, протоколи та інші служби, необхідні для використання таких служб.

No: 1

Name: sa_9_2_01

Type: string

Default: "TLS 1.3"

Необхідно постачальникам зовнішніх системних послуг ідентифікувати функції, порти, протоколи та інші послуги, необхідні для використання таких послуг

No: 2

Name: sa_9_2_odp

Type: string

Default: "TLS 1.3"

Визначені зовнішні системні сервіси, які потребують ідентифікації функцій, портів, протоколів та інших сервісів

15.3.3. СТВОРЕННЯ ТА ПІДТРИМКА ДОВІРЧИХ ВІДНОСИН З ПОСТАЧАЛЬНИКАМИ (SA-9(3))

Створити, задокументувати та підтримувати довірчі відносини із зовнішніми постачальниками послуг на основі таких вимог, властивостей, факторів або умов: [Призначення: визначених організацією вимог, властивостей, факторів або умов щодо безпеки та приватності, що визначають прийнятні довірчі відносини].

No: 1

Name: sa_9_3_01

Type: string

Default: nil

Встановлені та задокументовані довірчі відносини з зовнішніми постачальниками послуг на основі вимог, властивостей, факторів або умов безпеки

No: 2

Name: sa_9_3_02

Type: string

Default: nil

Підтримуються довірчі відносини з зовнішніми постачальниками послуг на основі вимог, властивостей, факторів або умов безпеки

No: 3

Name: sa_9_3_03

Type: string

Default: nil

Встановлені та задокументовані довірчі відносини із зовнішніми постачальниками послуг на основі вимог, властивостей, факторів або умов конфіденційності

No: 4

Name: sa_9_3_04

Type: string

Default: nil

Підтримуються довірчі відносини із зовнішніми постачальниками послуг на основі вимог, властивостей, факторів або умов конфіденційності

15.3.4. ЗОВНІШНІ СИСТЕМНІ СЛУЖБИ СПОЖИВАЧІВ І ПОСТАЧАЛЬНИКІВ (SA-9(4))

Виконайте такі дії, щоб переконатися, що інтереси [Призначення: визначених організацією зовнішніх постачальників послуг] узгоджуються з інтересами організації та відображають їх: [Призначення: дії, визначені організацією].

No: 1

Name: sa_9_4_01

Type: list

Default: ["login", "logout", "failed_attempt"]

Вживаються дії для перевірки того, що інтереси зовнішніх постачальників послуг узгоджуються з інтересами організації та відображають їх

15.3.5. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- МІСЦЕ ОБРОБКИ, ЗБЕРІГАННЯ ТА ОБСЛУГОВУВАННЯ (SA-9(5))

Обмежити розташування [Вибір (один або більше): обробка інформації; інформація або дані; системні служби] до [Призначення: визначені організацією місця] на основі [Призначення: визначених організацією вимог або умов].

Немає параметрів для цього контролю.

15.3.6. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- КРИПТОГРАФІЧНІ КЛЮЧІ, КЕРОВАНІ ОРГАНІЗАЦІЄЮ (SA-9(6))

Зберігати контроль над криптографічними ключами для зашифрованої інформації, яка зберігається або передається через зовнішню систему.

No: 1

Name: sa_9_6_01

Type: string

Default: "AES-256-GCM"

Зберігається ексклюзивний контроль над криптографічними ключами для зашифрованих матеріалів, що зберігаються або передаються через зовнішню систему

15.3.7. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИ- ПЕРЕВІРКА ЦІЛІСНОСТІ, ЩО КОНТРОЛЮЄТЬСЯ ОРГАНІЗАЦІЄЮ (SA-9(7))

Забезпечити можливість перевірки цілісності інформації в організації під час її перебування в зовнішній системі.

No: 1

Name: sa_9_7_01

Type: integer

Default: 30

Передбачена можливість перевірки цілісності інформації під час її перебування у зовнішній системі

15.3.8. ЗОВНІШНІ ПОСЛУГИ ДЛЯ СИСТЕМИЗБЕРІГАННЯ – ЮРИСДИКЦІЯ УКРАЇНИ (SA-9(8))

Обмежити географічне розміщення обробки та зберігання даних об'єктами, розташованими в межах юридичної юрисдикції України.

No: 1

Name: sa_9_8_01

Type: string

Default: nil

Обмежується географічне розміщення обробки інформації та зберігання даних об'єктами, розташованими в межах юридичної юрисдикції України

15.4. КОМПОНЕНТИ СИСТЕМИ, ЩО НЕ ПІДТРИМУЮТЬСЯ (SA-22)

а. Замінювати компоненти системи, якщо підтримка компонентів більше не доступна розробнику, постачальнику або виробнику. б. Надавати такі варіанти альтернативних джерел для подальшої підтримки непідтримуваних компонентів [Вибір (один або більше): внутрішня підтримка; [Призначення: підтримка, визначена організацією від зовнішніх постачальників]].

No: 1

Name: sa_22_odp_01

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {внутрішня підтримка; підтримка від зовнішніх постачальників}

16. SC

Клас заходів захисту SC — ЗАХИСТ ІНФОРМАЦІЙНОЇ СИСТЕМИ ТА

16.1. ПОЛІТИКА ТА ПРОЦЕДУРИ ЗАХИСТУ СИСТЕМИ ТА КОМУНІКАЦІЙ (SC-1)

а. Розробити, задокументувати та поширити серед [Призначення: визначеного організацією персоналу або посадових осіб]: 1. 2. Політику захисту системи та комунікацій, яка: (а) містить мету, сферу застосування, ролі, обов'язки, відповідальність керівництва, координацію між організаційними підрозділами та систему контролю відповідності (compliance); (б) відповідає чинному законодавству, виконавчим наказам, директивам, нормам, політикам, стандартам та керівним принципам. Процедури для сприяння впровадженню політики в області захисту систем і комунікацій, а також пов'язаних з ними систем і засобів захисту зв'язку. б. Призначити [Призначення: визначена організацією посадову особу] для управління політикою та процедурами захисту системи та комунікацій. с. Переглядати та оновлювати: 1. поточну політику захисту системи та комунікацій [Призначення: визначена організацією частота]; 2. поточні процедури захисту системи та комунікацій [Призначення: визначена організацією частота].

No: 1

Name: sc_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких має бути доведена політика захисту системи та комунікацій

No: 2

Name: sc_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури захисту системи та комунікацій

No: 3

Name: sc_1_odp_03

Type: string

Default: nil

Вибрано жодне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4

Name: sc_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено посадову особу, яка керуватиме політикою та процедурами захисту системи та комунікацій

No: 5

Name: sc_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначена періодичність перегляду та оновлення поточної політики захисту системи та комунікацій

No: 6

Name: sc_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Є події, які вимагають перегляду та оновлення поточної політики захисту системи та комунікацій

No: 7

Name: sc_1_odp_07

Type: string

Default: "щорічно"

Визначена періодичність перегляду та оновлення поточних процедур захисту системи та засобів зв'язку

16.2. ІНФОРМАЦІЯ В ЗАГАЛЬНИХ СИСТЕМНИХ РЕСУРСАХ (SC-4)

Запобігати несанкціонованій та ненавмисній передачі інформації через спільні системні ресурси.

No: 1

Name: sc_4_01

Type: string

Default: nil

Запобігається несанкціонована передача інформації через спільні системні ресурси

No: 2

Name: sc_4_02

Type: string

Default: nil

Запобігається ненавмисна передача інформації через спільні системні ресурси. ПОТЕНЦІЙНІ МЕТОДИ ТА ОБ'ЄКТИ ОЦІНКИ:

16.2.1. РІВНІ БЕЗПЕКИ (SC-4(1))

No: 1
 Name: sc_4_1_01
 Type: string
 Default: nil

ІНФОРМАЦІЯ В ЗАГАЛЬНИХ СИСТЕМНИХ РЕСУРСАХ - РІВНІ БЕЗПЕКИ [Вилучено: включено до SC-4]

16.2.2. ІНФОРМАЦІЯ В ЗАГАЛЬНИХ СИСТЕМНИХ БАГАТО-РІВНЕВА АБО ПЕРІОДИЧНА ОБРОБКА (SC-4(2))

No: 1
 Name: sc_4_2_01
 Type: string
 Default: nil

Запобігається несанкціонована передача інформації через спільні ресурси відповідно до процедур, коли системна обробка явно перемикається між різними рівнями класифікації інформації або категоріями безпеки

No: 2
 Name: sc_4_2_odp
 Type: string
 Default: nil

Визначені процедури для запобігання несанкціонованій передачі інформації через спільні ресурси

16.3. ДОСТУПНІСТЬ РЕСУРСІВ (SC-7)

а. Контролювати та управляти зв'язком на зовнішньому периметрі системи та на ключових внутрішніх периметрах всередині системи. b. Реалізувати підмережі для загальнодоступних компонентів системи, які є [Вибір: фізично; логічно] відділені від внутрішніх мереж організації. с. Підключатися до зовнішніх мереж або систем тільки через керовані інтерфейси, що складаються з пристроїв захисту периметру, і розташованих відповідно до архітектури безпеки та приватності організації.

Немає параметрів для цього контролю.

16.3.1. ФІЗИЧНО ВІДДІЛЕНІ ПІДМЕРЕЖІ (SC-7(1))

No: 1
 Name: sc_7_1_01
 Type: string
 Default: nil

ЗАХИСТ ПЕРИМЕТРА - ФІЗИЧНО ВІДДІЛЕНІ ПІДМЕРЕЖІ [Вилучено: включено до SC-7]

16.3.2. ПУБЛІЧНИЙ ДОСТУП (SC-7(2))

No: 1
 Name: sc_7_2_01
 Type: string
 Default: nil

ЗАХИСТ ПЕРИМЕТРА - ПУБЛІЧНИЙ ДОСТУП [Вилучено: включено до SC-7]]

16.3.3. ТОЧКИ ДОСТУПУ (SC-7(3))

No: 1
Name: sc_7_3_01
Type: integer
Default: 3

Обмежена кількість зовнішніх мережевих підключень до системи

16.3.4. ЗОВНІШНІ КОМУНІКАЦІЙНІ СЛУЖБИ (SC-7(4))

No: 1
Name: sc_7_4_a
Type: string
Default: nil

Реалізовано керований інтерфейс для кожної зовнішньої телекомунікаційної послуги

No: 2
Name: sc_7_4_b
Type: list
Default: ["default_deny_rule", "abac_rule_1"]

Встановлена політика потоку трафіку для кожного керованого інтерфейсу

No: 3
Name: sc_7_4_c_01
Type: string
Default: nil

Захищена конфіденційність інформації, що передається через кожен інтерфейс

No: 4
Name: sc_7_4_c_02
Type: string
Default: nil

Захищена цілісність інформації, що передається через кожен інтерфейс

No: 5
Name: sc_7_4_d
Type: list
Default: ["default_deny_rule", "abac_rule_1"]

Задokumentовано кожен виняток з політики управління трафіком з обґрунтуванням місії або бізнес-потреби, а також тривалості такої потреби

No: 6
Name: sc_7_4_e_01
Type: list
Default: ["default_deny_rule", "abac_rule_1"]

Переглядаються винятки з політики потоку трафіку частота

No: 7
Name: sc_7_4_e_02
Type: list
Default: ["default_deny_rule", "abac_rule_1"]

Потрібно видалити винятки з політики потоку трафіку, які більше не підтримуються чітко визначеною місією або бізнеспотребою

No: 8
Name: sc_7_4_f
Type: string
Default: nil

Запобігається несанкціонований обмін управління із зовнішніми мережами

No: 9
Name: sc_7_4_g
Type: string
Default: nil

Публікується інформація, яка дозволяє віддаленим мережам виявляти несанкціонований трафік площини керування з внутрішніх мереж

No: 10
Name: sc_7_4_h
Type: string
Default: nil

Фільтрується несанкціонований трафік з зовнішніх мереж. трафіком плану

No: 11
Name: sc_7_4_odp
Type: list
Default: ["default_deny_rule", "abac_rule_1"]

Визначено періодичність перегляду винятків з політики управління інформаційними потоками

16.3.5. ВІДМОВА ЗА ЗАМОВЧУВАННЯМ - ДОЗВІЛ ЗА ВИНЯТКОМ (SC-7(5))

Немає параметрів для цього контролю.

16.3.6. ВІДПОВІДЬ НА РОЗПІЗНАНІ ПОМИЛКИ (SC-7(6))

No: 1
Name: sc_7_6_01
Type: string
Default: nil

ЗАХИСТ ПЕРИМЕТРА - ВІДПОВІДЬ НА РОЗПІЗНАНІ ПОМИЛКИ [Вилучено: включено до SC-7(18)]

16.3.7. ЗАПОБІГАННЯ ПОДІЛУ ТУНЕЛЮВАННЯ ДЛЯ ВІДДАЛЕНИХ ПРИСТРОЇВ (SC-7(7))

No: 1
Name: sc_7_7_01
Type: string
Default: "автоматизований засіб моніторингу"

Запобігається розділеному тунелюванню для віддалених пристроїв, що підключаються до систем організації, якщо розділене тунелюванню не захищено за допомогою засоби захисту

No: 2
 Name: sc_7_7_odp
 Type: string
 Default: nil

Визначені гарантії безпечного прокладання розділеному тунелюванню

16.3.8. ЗАХИСТ ПЕРИМЕТРА -МАРШРУТИЗАЦІЯ АВТЕНТИФІКОВАНИХ ПРОКСІ-СЕРВЕРІВ (SC-7(8))

No: 1
 Name: sc_7_8_01
 Type: string
 Default: nil

SC-07(08) _ODP[01] внутрішній комунікаційний трафік> спрямовується до <SC-07(08) _ODP[02] зовнішніх мереж> через автентифіковані проксі-сервери на керованих інтерфейсах

16.3.9. ЗАХИСТ (SC-7(9))

No: 1
 Name: sc_7_9_a_01
 Type: string
 Default: nil

Виявлено вихідний комунікаційний трафік, що становить загрозу для зовнішніх систем

No: 2
 Name: sc_7_9_a_02
 Type: string
 Default: nil

Заборонено вихідний комунікаційний трафік, що становить загрозу для зовнішніх систем

No: 3
 Name: sc_7_9_b
 Type: string
 Default: nil

Перевіряється ідентичність внутрішніх пов'язаних з відмовою у зв'язку користувачів,

16.3.10. ІЗОЛЬОВАНІ ВІД ІНШИХ ВНУТРІШНІХ КОМПОНЕНТІВ СИСТЕМИ ШЛЯХОМ ВПРОВАДЖЕННЯ ФІЗИЧНО ВІДОКРЕМЛЕНИХ ПІДМЕРЕЖ З КЕРОВАНИМИ ІНТЕРФЕЙСАМИ ДО ІНШИХ КОМПОНЕНТІВ СИСТЕМИ (SC-7(13))

No: 1
 Name: sc_7_13_01
 Type: string
 Default: "автоматизований засіб моніторингу"

Ізольовані засоби, механізми та компоненти підтримки інформаційної безпеки від інших внутрішніх компонентів системи шляхом впровадження фізично відокремлених підмереж з керованими інтерфейсами до інших компонентів системи

No: 2

Name: sc_7_13_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначені інструменти, механізми та компоненти підтримки інформаційної безпеки, які мають бути ізольовані від інших внутрішніх компонентів системи

16.4. КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ ПЕРЕДАЧІ (SC-8)

Забезпечити [Вибір (один або кілька): конфіденційність; цілісність] інформації, що передається.

Немає параметрів для цього контролю.

16.4.1. КОНФІДЕНЦІЙНІСТЬ ТА КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-8(1))

No: 1

Name: sc_8_1_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {запобігти несанкціонованому розголошенню інформації; виявити зміни в інформації}

16.4.2. ПОПЕРЕДНЯ І ПОСТОБРОВКА (SC-8(2))

No: 1

Name: sc_8_2_01

Type: string

Default: nil

КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ ПЕРЕДАЧІ - ПОПЕРЕДНЯ І ПОСТОБРОВКА МЕТА ОЦІНКИ:
Визначити, чи:

No: 2

Name: sc_8_2_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {конфіденційність; цілісність}

16.4.3. КОНФІДЕНЦІЙНІСТЬ ТА ЦІЛІСНІСТЬ КРИПТОГРАФІЧНИЙ ЗАХИСТ ПОВІДОМЛЕНЬ (SC-8(3))

No: 1

Name: sc_8_3_01

Type: string

Default: "AES-256-GCM"

Впроваджено криптографічні механізми для захисту зовнішніх повідомлень, якщо інше не захищено альтерна-

тивні фізичні засоби контролю

No: 2

Name: sc_8_3_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначено альтернативні фізичні засоби контролю для захисту зовнішніх повідомлень

16.4.4. ПРИХОВУВАННЯ АБО РАНДОМІЗАЦІЯ КОМУНІКАЦІЇ (SC-8(4))

No: 1

Name: sc_8_4_01

Type: string

Default: "AES-256-GCM"

Застосовуються криптографічні механізми для приховування або рандомізації шаблонів комунікації, якщо інше не захищено альтернативні фізичні засоби контролю

No: 2

Name: sc_8_4_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначені альтернативні фізичні засоби контролю для захисту від несанкціонованого розкриття шаблонів комунікації

16.4.5. КОНФІДЕНЦІЙНІСТЬ ТА СИСТЕМА РОЗПОДІЛУ (SC-8(5))

Немає параметрів для цього контролю.

16.5. ВІДКЛЮЧЕННЯ МЕРЕЖІ (SC-10)

Завершити з'єднання з мережею, яке пов'язане із сеансом зв'язку в кінці сеансу або після [Призначення: визначений організацією період часу] бездіяльності.

No: 1

Name: sc_10_odp

Type: integer

Default: 30

Визначено період бездіяльності, після якого система розриває мережеве з'єднання, пов'язане з сеансом зв'язку; SC08(05)_ODP[02] мережеве з'єднання, пов'язане з сеансом зв'язку, розірвано в кінці сеансу або після період часу бездіяльності

16.6. ВСТАНОВЛЕННЯ КЛЮЧАМИ (SC-12)

Встановити та управляти криптографічними ключами для криптографічних засобів, які використовуються в системі відповідно до [Призначення: визначені організацією вимоги до генерації, поширення, зберігання, доступу та знищення ключів].

No: 1

Name: sc_12_01

Type: string

Default: "AES-256-GCM"

Встановлюються криптографічні ключі, коли в системі використовується криптографія відповідно до < SC-12_ODP вимог >

No: 2

Name: sc_12_02

Type: string

Default: "AES-256-GCM"

Здійснюється управління криптографічними ключами, коли в системі використовується криптографія, відповідно до вимог

No: 3

Name: sc_12_odp

Type: string

Default: nil

Визначені вимоги до генерації, розповсюдження, зберігання, доступу та знищення ключів

16.7. КРИПТОГРАФІЧНИЙ ЗАХИСТ (SC-13)

- a. Визначити [Призначення: використання криптографічних засобів, визначених організацією];
- b. Впровадити [Завдання: визначені організацією види криптографії для кожного визначеного криптографічного використання].

No: 1

Name: sc_13_01

Type: string

Default: "AES-256-GCM"

КРИПТОГРАФІЧНИЙ ЗАХИСТ МЕТА ОЦІНКИ: Визначити, чи:

No: 2

Name: sc_13_odp_01

Type: string

Default: "AES-256-GCM"

Визначено використання криптографічних засобів

No: 3

Name: sc_13_odp_02

Type: string

Default: "AES-256-GCM"

Визначено типи криптографії для кожного вказаного криптографічного використання; SC-13a. ідентифіковано використання>; SC-13b. реалізовано типи криптографії для кожного вказаного криптографічного використання (визначеного в SC-13_ODP[01]). криптографічне <SC-13_ODP[01]

16.8. СПІЛЬНІ ОБЧИСЛЮВАЛЬНІ ПРИСТРОЇ ТА ЗАСТОСУНКИ (SC-15)

- a. Заборонити віддалену активацію спільних обчислювальних пристроїв (хмар) та застосунків з такими виключеннями: [Призначення: визначені організацією виключення, у яких дозволена

віддалена активація]. б. Надати явну вказівку щодо використання користувачами фізично присутніми пристроями.

Немає параметрів для цього контролю.

16.9. МОБІЛЬНИЙ КОД (SC-18)

а. Визначати прийнятні та неприйнятні мобільні коди та технології мобільних кодів. б. Проводити авторизацію, відстежувати та контролювати використання мобільного коду всередині системи.

Немає параметрів для цього контролю.

16.10. АВТЕНТИФІКАЦІЯ СЕСІЇ (SC-23)

Забезпечити автентифікацію сеансів зв'язку.

No: 1

Name: sc_23_01

Type: string

Default: nil

Захищено автентифікацію сеансів зв'язку

16.11. ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ (SC-28)

Забезпечити [Вибір (один або кілька): конфіденційність; цілісність] [Призначення: визначена організацією інформація] в стані спокою.

No: 1

Name: sc_28_odp

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {конфіденційність; цілісність}

No: 2

Name: sc_28_odp_02

Type: string

Default: nil

Є інформація в стані спокою, яка потребує захисту

16.11.1. ЗАХИСТ ІНФОРМАЦІЇ В СТАНІ СПОКОЮ | КРИПТОГРАФІЧНИЙ ЗАХИСТ

No: 1

Name: sc_28_1_01

Type: string
Default: "AES-256-GCM"

Реалізовані криптографічні механізми для запобігання несанкціонованому розкриттю інформації, що знаходиться в стані спокою на системних компонентах або носіях

No: 2
Name: sc_28_1_02
Type: string
Default: "AES-256-GCM"

Реалізовані криптографічні механізми для запобігання несанкціонованій модифікації інформації, що знаходиться в стані спокою на системних компонентах або носіях

17. SI

Клас заходів захисту SI — ЦІЛІСНІСТЬ СИСТЕМИ ТА ІНФОРМАЦІЇ

17.1. ПОЛІТИКА І ПРОЦЕДУРИ ЦІЛІСНОСТІ ІНФОРМАЦІЇ (SI-1)

No: 1
Name: si_1_odp_01
Type: list
Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких має бути доведена політика цілісності системи та інформації

No: 2
Name: si_1_odp_02
Type: list
Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури цілісності системи та інформації

No: 3
Name: si_1_odp_03
Type: string
Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень місії/бізнеспроцесу; рівень системи}

No: 4
Name: si_1_odp_04
Type: list
Default: ["admin", "security_officer"]

Визначено посадову особу, відповідальну за управління системою та політикою і процедурами цілісності інформації

No: 5
Name: si_1_odp_05
Type: list
Default: ["default_deny_rule", "abac_rule_1"]

Визначено періодичність перегляду та оновлення поточної політики цілісності системи та інформації

No: 6

Name: si_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Є події, які вимагають перегляду та оновлення поточної політики цілісності системи та інформації

No: 7

Name: si_1_odp_07

Type: integer

Default: 30

Визначено частоту, з якою переглядаються та оновлюються поточні цілісності системи та інформації

17.2. ВИПРАВЛЕННЯ ДЕФЕКТІВ (SI-2)

No: 1

Name: si_2_odp

Type: integer

Default: 30

Визначено період часу, протягом якого необхідно встановити оновлення програмного забезпечення, пов'язані з безпекою, після виходу оновлень; SI-02a.[01] виявлено недоліки системи; SI-02a.[02] повідомляється про недоліки системи; SI-02a.[03] виправлені недоліки системи; SI-02b.[01] перевіряються оновлення програмного забезпечення, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[02] перевіряються оновлення програмного забезпечення, пов'язані з виправленням дефектів, на наявність потенційних побічних ефектів перед встановленням; SI-02b.[03] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на ефективність перед встановленням; SI-02b.[04] перевіряються оновлення прошивки, пов'язані з усуненням недоліків, на наявність потенційних побічних ефектів перед встановленням; SI-02c.[01] встановлено оновлення програмного забезпечення, що стосуються безпеки, протягом часовий проміжок з моменту випуску оновлень; SI-02c.[02] встановлено оновлення мікропрограми, що стосуються безпеки, протягом часового періоду з моменту випуску оновлень; SI-02d. включено відновлення порушених прав у процес управління організаційною конфігурацією

17.2.1. ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ (SI-2(1))

No: 1

Name: si_2_1_01

Type: string

Default: nil

ВИПРАВЛЕННЯ ДЕФЕКТІВ - ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ [Вилучено: перенесено до PL-09]

17.2.2. АВТОМАТИЗОВАНЕ ВИПРАВЛЕННЯ ДЕФЕКТІВ (SI-2(2))

No: 1

Name: si_2_2_01

Type: integer

Default: 30

Встановлені на компонентах системи відповідні оновлення програмного забезпечення та мікропрограми, що стосуються безпеки, з частотою за допомогою автоматизованих механізмів

17.2.3. ЧАС ДЛЯ УСУНЕННЯ ДЕФЕКТІВ ТА ОРІЄНТИРИ ДЛЯ КОРИГУВАЛЬНИХ ДІЙ (SI-2(3))

No: 1

Name: si_2_3_a

Type: integer

Default: 30

Вимірюється час між виявленням дефекту та його усуненням; SI-02(03)(b) були встановлені орієнтири для вжиття коригувальних дій

No: 2

Name: si_2_3_odp

Type: string

Default: nil

Визначені контрольні коригувальних заходів; показники для вжиття

17.2.4. АВТОМАТИЧНІ ЗАСОБИ УПРАВЛІННЯ ВИПРАВЛЕННЯМИ (SI-2(4))

No: 1

Name: si_2_4_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначені компоненти системи, які потребують автоматизованих інструментів управління виправленнями для полегшення усунення дефектів; SI-02(04)] застосовуються автоматизовані засоби управління виправленнями для полегшення виправлення недоліків у компонентах

17.2.5. ВИПРАВЛЕННЯ ДЕФЕКТІВ АВТОМАТИЧНЕ ОНОВЛЕННЯ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ВБУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ (SI-2(5))

No: 1

Name: si_2_5_01

Type: string

Default: nil

SI-02(05) _ODP[01] оновлення програмного забезпечення та мікропрограми, що стосуються безпеки>, встановлено автоматично до <SI-02(05) _ODP[02] компонентів системи>

17.2.6. ВИДАЛЕННЯ ПОПЕРЕДНІХ ВЕРСІЙ ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ ТА ВБУДОВАНОГО ПРОГРАМНОГО ЗАБЕЗПЕЧЕННЯ (SI-2(6))

No: 1

Name: si_2_6_01

Type: string

Default: nil

Видаляються попередні версії програмне забезпечення та компоненти мікропрограми після встановлення оновлених версій

No: 2
 Name: si_2_6_odp
 Type: string
 Default: nil

Потрібно видаляти компоненти програмного забезпечення та мікропрограми після встановлення оновлених версій

17.3. ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ (SI-3)

No: 1
 Name: si_3_odp_01
 Type: string
 Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {підписаний; непідписаний}

No: 2
 Name: si_3_odp_02
 Type: integer
 Default: 30

Визначено частоту, з якою механізми шкідливого коду виконують сканування

No: 3
 Name: si_3_odp_03
 Type: string
 Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {кінцева точка; точки входу та виходу з мережі}

No: 4
 Name: si_3_odp_04
 Type: string
 Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {block malicious code; quarantitne malicious code; take action}

No: 5
 Name: si_3_odp_05
 Type: list
 Default: ["login", "logout", "failed_attempt"]

Визначено дії, яких слід вжити у відповідь на виявлення шкідливого коду (якщо вибрано)

17.3.1. ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ (SI-3(1))

No: 1
 Name: si_3_1_01
 Type: string
 Default: nil

ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ - ЦЕНТРАЛІЗОВАНЕ УПРАВЛІННЯ [Вилучено: включено до PL-9]

17.3.2. АВТОМАТИЧНІ ОНОВЛЕННЯ (SI-3(2))

No: 1
Name: si_3_2_01
Type: string
Default: nil

ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ - АВТОМАТИЧНІ ОНОВЛЕННЯ [Вилучено: включено до SI-03]

17.3.3. ЗАХИСТ ВІД ШКІДЛИВОГО КОРИСТУВАЧІ (SI-3(3))

No: 1
Name: si_3_3_01
Type: string
Default: nil

ЗАХИСТ ВІД ШКІДЛИВОГО КОРИСТУВАЧІ [Вилучено: включено до АС-6(10)]. КОДУ - НЕПРИВІЛЕЙОВАНІ SI-3(4) ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ ПРИВІЛЕЙОВАНИМИ КОРИСТУВАЧАМИ ОНОВЛЕННЯ ТІЛЬКИ

17.3.4. ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ ПРИВІЛЕЙОВАНИМИ КОРИСТУВАЧАМИ (SI-3(4))

No: 1
Name: si_3_4_01
Type: string
Default: "автоматизований засіб моніторингу"

Оновлюються механізми захисту від шкідливого коду лише за вказівкою привілейованого користувача

17.3.5. ЗАХИСТ ВІД ШКІДЛИВОГО ЗБЕРІГАННЯ ДАНИХ (SI-3(5))

No: 1
Name: si_3_5_01
Type: string
Default: nil

ЗАХИСТ ВІД ШКІДЛИВОГО ЗБЕРІГАННЯ ДАНИХ [Вилучено: включено до МР-7]. КОДУ

17.3.6. ТЕСТУВАННЯ ТА ВЕРИФІКАЦІЯ (SI-3(6))

No: 1
Name: si_3_6_a
Type: string
Default: "щорічно"

Перевіряються механізми захисту від шкідливого коду частота шляхом введення в систему відомого доброякісного коду

No: 2
Name: si_3_6_b_01
Type: string
Default: nil

Відбувається виявлення (доброякісний тест) коду

No: 3

Name: si_3_6_b_02

Type: string

Default: nil

Відбувається відповідне звітування про інцидент

No: 4

Name: si_3_6_odp

Type: string

Default: "щорічно"

Визначено періодичність тестування механізмів захисту від зловмисного коду

17.3.7. ВИЯВЛЕННЯ БЕЗ ПІДПISУ (SI-3(7))

No: 1

Name: si_3_7_01

Type: string

Default: nil

ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ - ВИЯВЛЕННЯ БЕЗ ПІДПISУ [Вилучено: включено до SI-3]

17.3.8. ВИЯВЛЕННЯ НЕАВТОРИЗОВАНИХ КОМАНД (SI-3(8))

No: 1

Name: si_3_8_a

Type: string

Default: nil

Виявлено <SI-03(08) _ODP[01] неавторизовані команди операційної системи> через інтерфейс прикладного програмування ядра на <SI-03(08) _ODP[02] апаратних компонентах системи>

17.3.9. АВТЕНТИФІКАЦІЯ ВІДДАЛЕНИХ КОМАНД (SI-3(9))

No: 1

Name: si_3_9_01

Type: string

Default: nil

ЗАХИСТ ВІД ШКІДЛИВОГО КОДУ - АВТЕНТИФІКАЦІЯ ВІДДАЛЕНИХ КОМАНД [Вилучено: включено до AC-17(10)]

17.3.10. АНАЛІЗ ШКІДЛИВОГО КОДУ (SI-3(10))

No: 1

Name: si_3_10_a

Type: string

Default: nil

Використовуються інструменти та методи для аналізу характеристик та поведінки шкідливого коду

No: 2

Name: si_3_10_b_01

Type: string

Default: nil

Включені результати аналізу шкідливого коду в організаційні процеси реагування на інциденти

No: 3

Name: si_3_10_b_02

Type: string

Default: nil

Включені результати аналізу шкідливого коду в організаційні процеси виправлення недоліків

No: 4

Name: si_3_10_odp

Type: string

Default: nil

Визначені інструменти та методи, які будуть використовуватися для аналізу характеристик та поведінки шкідливого коду

17.4. МОНІТОРИНГ СИСТЕМИ (SI-4)

No: 1

Name: si_4_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначені методи та способи, що використовуються для виявлення несанкціонованого використання системи

No: 2

Name: si_4_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначена інформація про моніторинг системи, яка повинна надаватися персоналу або ролям

No: 3

Name: si_4_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, яким має надаватися інформація про моніторинг системи

No: 4

Name: si_4_odp_05

Type: string

Default: "щорічно"

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {за потребою; частота}

17.4.1. МОНІТОРИНГ СИСТЕМИ ВИЯВЛЕННЯ ВТОРГНЕНЬ (IDS) (SI-4(1))

No: 1

Name: si_4_1_01

Type: string

Default: "автоматизований засіб моніторингу"

Підключені окремі засоби виявлення вторгнень загальносистемної системи виявлення вторгнень; до

No: 2

Name: si_4_1_02

Type: string

Default: nil

Об'єднані окремі інструменти виявлення вторгнень загальносистемну систему виявлення вторгнень. у

17.4.2. АВТОМАТИЗОВАНІ МЕХАНІЗМИ АНАЛІЗУ В РЕАЛЬНОМУ ЧАСІ (SI-4(2))

Немає параметрів для цього контролю.

17.4.3. МОНІТОРИНГ СИСТЕМИ МЕХАНІЗМИ ІНТЕГРАЦІЇ (SI-4(3))

No: 1

Name: si_4_3_01

Type: string

Default: "автоматизований засіб моніторингу"

Використовуються автоматизовані інструменти та механізми для інтеграції інструментів та механізмів виявлення вторгнень у механізми контролю доступу

No: 2

Name: si_4_3_02

Type: string

Default: "автоматизований засіб моніторингу"

Використовуються автоматизовані інструменти та механізми для інтеграції інструментів та механізмів виявлення вторгнень у механізми контролю потоків

17.4.4. МОНІТОРИНГ СИСТЕМИ КОМУНІКАЦІЙ (SI-4(4))

No: 1

Name: si_4_4_a_01

Type: list

Default: []

Визначені критерії незвичної або несанкціонованої діяльності або умови для вхідного трафіку зв'язку

No: 2

Name: si_4_4_a_02

Type: list

Default: []

Визначені критерії незвичайної або несанкціонованої діяльності або умови для вихідного трафіку зв'язку

No: 3

Name: si_4_4_b_01

Type: string

Default: "щорічно"

Здійснюється моніторинг вхідного комунікаційного трафіку частота на предмет незвичних або несанкціонованих дій або умов

No: 4

Name: si_4_4_b_02

Type: string

Default: "щорічно"

Контролюється вихідний трафік зв'язку частота на предмет незвичних або несанкціонованих дій або умов. вихідного виявлення

17.4.5. СИСТЕМНІ СПОВІЩЕННЯ (SI-4(5))

No: 1

Name: si_4_5_01

Type: list

Default: ["admin", "security_officer"]

Відбувається оповіщення <SI-04(05) _ODP[01] персоналу або ролей> при виникненні згенерованих системою <SI-04(05) _ODP[02] індикаторів компрометації>

17.4.6. ЗАБОРОНА ДЛЯ НЕПРИВІЛЕЙОВАНИХ КОРИСТУВАЧІВ (SI-4(6))

No: 1

Name: si_4_6_01

Type: string

Default: nil

МОНІТОРИНГ СИСТЕМИ - ЗАБОРОНА ДЛЯ НЕПРИВІЛЕЙОВАНИХ КОРИСТУВАЧІВ [Вилучено: включено до AC-6(10)]

17.4.7. МОНІТОРИНГ СИСТЕМИ ПІДОЗРІЛІ ПОДІЇ (SI-4(7))

No: 1

Name: si_4_7_a

Type: list

Default: ["admin", "security_officer"]

Повідомляється персонал з реагування на інциденти про виявлені підозрілі події

No: 2

Name: si_4_7_b

Type: list

Default: ["login", "logout", "failed_attempt"]

Вживаються найменш руйнівні дії при виявленні підозрілих подій

17.4.8. ЗАХИСТ ІНФОРМАЦІЇ МОНІТОРИНГУ (SI-4(8))

No: 1

Name: si_4_8_01

Type: string

Default: nil

МОНІТОРИНГ СИСТЕМИ - ЗАХИСТ ІНФОРМАЦІЇ МОНІТОРИНГУ [Вилучено: включено до SI-4]

17.4.9. ТЕСТУВАННЯ ЗАСОБІВ І МЕХАНІЗМІВ МОНІТОРИНГУ (SI-4(9))

No: 1

Name: si_4_9_01

Type: string
Default: "щорічно"

Тестуються інструменти та механізми моніторингу вторгнень <SI-04(09)_ ODP періодичність>

No: 2
Name: si_4_9_odp
Type: string
Default: "щорічно"

Визначена періодичність тестування механізмів моніторингу вторгнень; інструментів і

17.4.10. МОНІТОРИНГ КОМУНІКАЦІЙ (SI-4(10))

No: 1
Name: si_4_10_01
Type: string
Default: nil

Передбачено, щоб <SI-04(10)_ ODP[01] зашифрований трафік зв'язку> був видимим для <SI-04(10)_ ODP[02] засобів та механізмів моніторингу системи>

17.4.11. МОНІТОРИНГ СИСТЕМИ КОМУНІКАЦІЙ (SI-4(11))

No: 1
Name: si_4_11_01
Type: string
Default: nil

Аналізується вихідний комунікаційний трафік на зовнішніх інтерфейсах системи для виявлення аномалій

No: 2
Name: si_4_11_02
Type: string
Default: nil

Аналізується вихідний трафік зв'язку в внутрішніх точках для виявлення аномалій

No: 3
Name: si_4_11_odp
Type: string
Default: nil

Визначені внутрішні точки в системі, в яких необхідно аналізувати комунікаційний трафік

17.4.12. МОНІТОРИНГ СИСТЕМИ АВТОМАТИЗОВАНІ СПОВІЩЕННЯ (SI-4(12))

No: 1
Name: si_4_12_01
Type: list
Default: ["admin", "security_officer"]

Оповіщається <SI-04(12)_ ODP[01] персонал або ролі> за допомогою <SI-04(12)_ ODP[02] автоматизованих механізмів>, коли <SI-04(12)_ ODP[03] дії, що викликають оповіщення> вказують на невідповідну або незвичну викликають оповіщення персоналу, або діяльність, що має вплив на безпеку або приватне життя

17.4.13. АНАЛІЗ ТРАФІКУ ТА ШАБЛОНІВ ПОДІЙ (SI-4(13))

No: 1

Name: si_4_13_a_01

Type: string

Default: nil

Аналізується трафік для системи

No: 2

Name: si_4_13_a_02

Type: string

Default: nil

Проаналізовано патерни подій для системи

No: 3

Name: si_4_13_b_01

Type: string

Default: nil

Розроблені профілі, що представляють загальний трафік

No: 4

Name: si_4_13_b_02

Type: string

Default: nil

Розроблені профілі, що представляють патерни подій

No: 5

Name: si_4_13_c_01

Type: string

Default: nil

Використовуються профілі трафіку пристроїв системного моніторингу

No: 6

Name: si_4_13_c_02

Type: string

Default: nil

Використовуються профілі подій при налаштуванні пристроїв системного моніторингу при налаштуванні

17.4.14. МОНІТОРИНГ ВТОРГНЕННЯ (SI-4(14))

No: 1

Name: si_4_14_01

Type: string

Default: nil

Використовується система виявлення бездротових вторгнень для виявлення несанкціонованих бездротових пристроїв

No: 2

Name: si_4_14_02

Type: integer

Default: 3

Використовується бездротова система виявлення вторгнень для виявлення спроб атак на систему

No: 3
Name: si_4_14_03
Type: string
Default: nil

Використовується бездротова система виявлення вторгнень для виявлення потенційних компрометації або порушень в системі

17.4.15. ПЕРЕХІД ВІД БЕЗДРОТОВОГО ЗВ'ЯЗКУ ДО ПРОВІДНИХ МЕРЕЖ (SI-4(15))

Немає параметрів для цього контролю.

17.4.16. МОНІТОРИНГ МОНІТОРИНГУ (SI-4(16))

No: 1
Name: si_4_16_01
Type: string
Default: nil

Співвідноситься інформація з інструментів моніторингу та механізмів, що застосовуються в системі

17.4.17. МОНІТОРИНГ ОБІЗНАНІСТЬ (SI-4(17))

No: 1
Name: si_4_17_01
Type: string
Default: nil

Співвідноситься інформація, отримана в результаті моніторингу фізичної, кібернетичної діяльності та діяльності ланцюга поставок, з метою досягнення інтегрованої, загальноорганізаційної ситуаційної обізнаності

17.4.18. АНАЛІЗ ТРАФІКУ ТА ПРИХОВАНОЇ ЕКСФІЛЬТРАЦІЇ (SI-4(18))

No: 1
Name: si_4_18_01
Type: string
Default: nil

Аналізується вихідний комунікаційний трафік на зовнішніх по відношенню до системи інтерфейсах для виявлення прихованого витоку інформації

No: 2
Name: si_4_18_02
Type: string
Default: nil

Аналізується вихідний трафік зв'язку в внутрішніх точках для виявлення прихованого витоку інформації

No: 3
Name: si_4_18_odp
Type: string
Default: nil

Визначені внутрішні точки в системі, в яких необхідно аналізувати комунікаційний трафік

17.4.19. ОСОБИ, ЯКІ ПРЕДСТАВЛЯЮТЬ БІЛЬШИЙ РИЗИК (SI-4(19))

No: 1

Name: si_4_19_01

Type: string

Default: nil

Здійснюється <SI-04(19) _ODP[01] додатковий моніторинг> щодо осіб, які були ідентифіковані джерелами <SI-04(19) _ODP[02] як такі, що становлять підвищений рівень ризику>

17.4.20. ПРИВІЛЕЙОВАНІ КОРИСТУВАЧІ (SI-4(20))

No: 1

Name: si_4_20_01

Type: string

Default: nil

Реалізовано привілейованих користувачів. привілейованих додатковий моніторинг

No: 2

Name: si_4_20_odp

Type: string

Default: nil

Визначено додатковий користувачів; моніторинг

17.4.21. ВИПРОБУВАЛЬНІ ТЕРМІНИ (SI-4(21))

No: 1

Name: si_4_21_01

Type: integer

Default: 30

Здійснюється <SI-04(21) _ODP[01] додатковий моніторинг> осіб під час <SI-04(21) _ODP[02] випробувального терміну>

17.4.22. НЕСАНКЦІОНОВАНІ ПОСЛУГИ МЕРЕЖІ (SI-4(22))

No: 1

Name: si_4_22_a

Type: string

Default: nil

Виявлено послуги мережі, які не було авторизовано або схвалено відповідно до процесів авторизації або схвалення

17.4.23. ПРИСТРОЇ НА ОСНОВІ ХОСТА (SI-4(23))

No: 1

Name: si_4_23_01

Type: string

Default: "автоматизований засіб моніторингу"

Реалізовано <SI-04(23) _ ODP[01] механізми моніторингу на основі хостів> на <SI-04(23) _ ODP[02] компоненти системи>

17.4.24. ІНДИКАТОРИ КОМПРОМЕТАЦІЇ (SI-4(24))

No: 1

Name: si_4_24_01

Type: string

Default: nil

Виявлено індикатори компрометації, 04(24)_ODP[01] джерелами>

No: 2

Name: si_4_24_02

Type: string

Default: nil

Збираються індикатори компрометації, що надаються джерелами

No: 3

Name: si_4_24_03

Type: list

Default: ["admin", "security_officer"]

Індикатори компрометації, надані <SI-04(24) джерелами>, поширюються на <SI-04(24) персонал або ролі>. надані <SI- _ ODP[01] _ ODP[02]

17.4.25. АНАЛІЗ МЕРЕЖЕВОГО ТРАФІКУ (SI-4(25))

No: 1

Name: si_4_25_01

Type: string

Default: nil

Забезпечується видимість мережевого трафіку на зовнішніх системних інтерфейсах для оптимізації ефективності пристроїв моніторингу

No: 2

Name: si_4_25_02

Type: string

Default: nil

Забезпечено видимість мережевого трафіку на ключових внутрішніх інтерфейсах системи для оптимізації ефективності пристроїв моніторингу

17.5. ПОПЕРЕДЖЕННЯ, РЕКОМЕНДАЦІЇ ТА ДИРЕКТИВИ З БЕЗПЕКИ (SI-5)

No: 1

Name: si_5_odp_01

Type: string

Default: nil

Визначені зовнішні організації, від яких необхідно постійно отримувати оповіщення, поради та директиви щодо безпеки системи

No: 2

Name: si_5_odp_02

Type: list

Default: ["admin", "security_officer"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {персонал або ролі; елементи; зовнішні організації}

No: 3

Name: si_5_odp_03

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, до яких мають бути доведені попередження, поради та директиви з безпеки (якщо визначено)

No: 4

Name: si_5_odp_04

Type: string

Default: nil

Визначені елементи в організації, до яких мають надсилатися оповіщення, поради та директиви з безпеки (якщо вони були обрані)

17.5.1. ПОПЕРЕДЖЕННЯ, РЕКОМЕНДАЦІЇ ТА ДИРЕКТИВИ З БЕЗПЕКИ АВТОМАТИЧНІ ПОПЕРЕДЖЕННЯ ТА РЕ- КОМЕНДАЦІЇ (SI-5(1))

No: 1

Name: si_5_1_01

Type: string

Default: "автоматизований засіб моніторингу"

Використовуються автоматизовані механізми для трансляції попередження та рекомендації інформації з питань безпеки по всій організації

No: 2

Name: si_5_1_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначені автоматизовані механізми, які використовуються для трансляції попередження та рекомендації інформації про безпеку в організації

17.6. УПРАВЛІННЯ ТА ЗБЕРЕЖЕННЯ ІНФОРМАЦІЇ (SI-12)

Управляти та зберігати інформацію всередині системи та виводити інформацію із системи відповідно до чинного законодавства, виконавчих наказів, директив, правил, політик, стандартів, керівних принципів та експлуатаційних вимог.

No: 1

Name: si_12_01

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Здійснюється управління інформацією в системі відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог

No: 2

Name: si_12_02

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Зберігається інформація в системі відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог

No: 3

Name: si_12_03

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Управління інформацією, що виводиться з системи, здійснюється відповідно до чинних законів, указів Президента, директив, положень, політик, стандартів, інструкцій та операційних вимог

No: 4

Name: si_12_04

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Зберігається інформація, що виводиться з системи, відповідно до чинних законів, наказів, директив, положень, політик, стандартів, інструкцій та експлуатаційних вимог

17.6.1. УПРАВЛІННЯ ТА ЗБЕРЕЖЕННЯ ІНФОРМАЦІЇ ЕЛЕМЕНТІВ ПЕРСОНАЛЬНИХ ДАНИХ (SI-12(1))

No: 1

Name: si_12_1_01

Type: list

Default: ["admin", "security_officer"]

Обмежується обробка персональних даних у життєвому циклі інформації в життєвому циклі інформації, елементами інформації, що ідентифікує особу

No: 2

Name: si_12_1_odp

Type: list

Default: ["admin", "security_officer"]

Визначені елементи персональних даних у життєвому циклі інформації

17.6.2. МІНІМІЗАЦІЯ ВИКОРИСТАННЯ ПЕРСОНАЛЬНИХ ДАНИХ ПІД ЧАС ТЕСТУВАННЯ, НАВЧАННЯ ТА ДОСЛІДЖЕННЯ (SI-12(2))

No: 1

Name: si_12_2_01

Type: list

Default: ["admin", "security_officer"]

Використовуються методи для мінімізації використання персональних даних для досліджень; SI-12(02)[02] використовуються методи для мінімізації використання персональних даних для тестування

No: 2

Name: si_12_2_03

Type: list
 Default: ["admin", "security_officer"]

Застосовуються методи для мінімізації використання персональних даних для навчання

17.6.3. УПРАВЛІННЯ ІНФОРМАЦІЇ (SI-12(3))

No: 1
 Name: si_12_3_01
 Type: string
 Default: nil

Використовуються методи для знищення інформації після закінчення терміну зберігання

No: 2
 Name: si_12_3_02
 Type: string
 Default: nil

Використовуються методи для знищення інформації після закінчення терміну зберігання

No: 3
 Name: si_12_3_03
 Type: integer
 Default: 30

Використовуються методи для стирання інформації після закінчення періоду зберігання

18. SR

Клас заходів захисту SR — УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА

18.1. ПОЛІТИКА ТА ПРОЦЕДУРИ УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-1)

а. Розробіть, задокументуйте та поширте [Призначення: персонал або ролі, визначені організацією]: 1. [Вибір (один або декілька): Рівень організації; Рівень місії/бізнес-процесу; рівень системи] політика управління ризиками ланцюга постачання, яка: а) Розглядає мету, сферу діяльності, ролі, відповідальність, зобов'язання керівництва, координацію між організаційними підрозділами та відповідність; б) Відповідає чинним законам, виконавчим наказам, директивам, положенням, політикам, стандартам і вказівкам; 2. Процедури для сприяння впровадженню політики управління ризиками ланцюга постачання та відповідних засобів контролю управління ризиками ланцюга постачання; б. Призначити [Призначення: посадова особа, визначена організацією] для управління розробкою, документуванням і розповсюдженням політики та процедур управління ризиками ланцюга постачання; с. Перегляньте та оновіть поточне управління ризиками ланцюга постачання: 1. Політика [Призначення: частота, визначена організацією] та наступне [Призначення: події, визначені організацією]; 2. Процедури [Призначення: частота, визначена організацією] та наступні [Призначення: події, визначені організацією].

No: 1
 Name: sr_1_odp_01

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюється політика управління ризиками ланцюга постачання

No: 2

Name: sr_1_odp_02

Type: list

Default: ["admin", "security_officer"]

Визначено персонал або ролі, на які поширюються процедури управління ризиками ланцюга постачання

No: 3

Name: sr_1_odp_03

Type: string

Default: nil

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРІВ: {рівень організації; рівень завдань/бізнеспроцесу; рівень системи}

No: 4

Name: sr_1_odp_04

Type: list

Default: ["admin", "security_officer"]

Визначена посадова особа, відповідальна за розробку, документування та розповсюдження політики та процедур управління ризиками ланцюга постачання

No: 5

Name: sr_1_odp_05

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Визначена періодичність перегляду та оновлення поточної політики управління ризиками ланцюга постачання

No: 6

Name: sr_1_odp_06

Type: list

Default: ["default_deny_rule", "abac_rule_1"]

Є події, які вимагають перегляду та оновлення поточної політики управління ризиками ланцюга постачання

No: 7

Name: sr_1_odp_07

Type: string

Default: "щорічно"

Визначена періодичність перегляду та оновлення поточної процедури управління ризиками ланцюга постачання

18.2. ПЛАН УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ (SR-2)

а. Розробіть план управління ризиками ланцюга постачання, пов'язаними з дослідженнями та розробкою, проектуванням, виробництвом, придбанням, доставкою, інтеграцією, експлуатацією та обслуговуванням, а також утилізацією таких систем, компонентів системи або послуг для системи: [Призначення: системи, визначені організацією, системні компоненти або системні служби]; б. Перегляньте та оновіть план управління ризиками ланцюга постачання [Призначення: частота, визначена організацією] або за потреби для усунення загроз; с. Захистіть план управління ризиками ланцюга постачання від несанкціонованого розголошення та модифікації.

No: 1
 Name: sr_2_odp_01
 Type: string
 Default: nil

Визначені системи, компоненти системи або системні послуги, для яких розробляється план управління ризиками ланцюга постачання

18.2.1. СТВОРЕННЯ КОМАНДИ ПОСТАЧАННЯ (SR-2(1))

No: 1
 Name: sr_2_1_01
 Type: list
 Default: ["admin", "security_officer"]

Створена команда з управління ризиками ланцюга постачання, що складається з персонал, ролі та обов'язки для керівництва та підтримки діяльності з управління ризиками ланцюга постачання

18.3. КОНТРОЛЬ ЛАНЦЮГА ПОСТАЧАННЯ І ПРОЦЕСІВ (SR-3)

а. Встановлення процесу або процесів для виявлення та усунення слабких місць або недоліків в елементах і процесах ланцюга постачання [Призначення: визначена організацією система або компонент системи] у координації з [Завдання: персонал ланцюга постачання, визначений організацією]; б. Використовуйте такі заходи захисту, щоб захистити систему, компонент системи або системну службу від ризиків ланцюга постачання та обмежити шкоду чи наслідки від подій, пов'язаних із ланцюгом постачання: [Призначення: заходи захисту ланцюга постачання, визначені організацією]; с. Задokumentуйте обрані та впроваджені процеси та заходи захисту ланцюгом постачання у [Вибір: плани безпеки та приватності; план управління ризиками ланцюга постачання; [Призначення: документ, визначений організацією]].

No: 1
 Name: sr_3_odp_01
 Type: string
 Default: nil

Визначено систему або компонент системи, який потребує процесу або процесів для виявлення та усунення слабких місць або недоліків

No: 2
 Name: sr_3_odp_02
 Type: list
 Default: ["admin", "security_officer"]

Визначено персонал ланцюга поставок, з яким необхідно координувати процес або процеси виявлення та усунення слабких місць або недоліків в елементах і процесах ланцюга постачання

No: 3
 Name: sr_3_odp_03
 Type: string
 Default: "автоматизований засіб моніторингу"

Визначені засоби контролю ланцюга постачання, що застосовуються для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання

No: 4

Name: sr_3_odp_04

Type: list

Default: ["admin", "security_officer"]

Вибрано одне або декілька з наступних ЗНАЧЕНЬ ПАРАМЕТРИВ: {плани безпеки та конфіденційності; план управління ризиками ланцюга постачання; документ}; SR-03_ODP[05] визначено документ, що ідентифікує обрані та впроваджені процеси та засоби контролю ланцюга постачання (якщо обрано); SR-03a.[01] запроваджено процес або процеси для виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання; SR-03a.[02] процес або процеси виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання системи або компонента системи координується/координуються з персоналом ланцюга постачання; SR-03b. застосовуються засоби контролю ланцюга постачання для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання; SR-03c. задокументовані обрані та впроваджені процеси та засоби контролю ланцюга постачання в ЗНАЧЕННЯ ВИБІРКОВОГО ПАРАМЕТРА(iv)

No: 5

Name: sr_3_odp_05

Type: list

Default: ["admin", "security_officer"]

Визначено документ, що ідентифікує обрані та впроваджені процеси та засоби контролю ланцюга постачання (якщо обрано); SR-03a.[01] запроваджено процес або процеси для виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання; SR-03a.[02] процес або процеси виявлення та усунення слабких місць або недоліків в елементах та процесах ланцюга постачання системи або компонента системи координується/координуються з персоналом ланцюга постачання; SR-03b. застосовуються засоби контролю ланцюга постачання для захисту від ризиків ланцюга постачання для системи, системного компонента або системної послуги, а також для обмеження шкоди або наслідків від подій, пов'язаних з ланцюгом постачання; SR-03c. задокументовані обрані та впроваджені процеси та засоби контролю ланцюга постачання в ЗНАЧЕННЯ ВИБІРКОВОГО ПАРАМЕТРА(iv)

18.3.1. РІЗНІ БАЗИ ПОСТАЧАННЯ (SR-3(1))

Немає параметрів для цього контролю.

18.3.2. ОБМЕЖЕННЯ ШКОДИ (SR-3(2))

No: 1

Name: sr_3_2_odp

Type: string

Default: "автоматизований засіб моніторингу"

Визначені засоби контролю для обмеження шкоди від потенційних супротивників ланцюга постачання; SR-03(02) застосовуються контроль для обмеження шкоди від потенційних супротивників, які ідентифікують та націлюються на ланцюг постачання організації

18.3.3. ПЕРЕНЕСЕННЯ ЗАХОДІВ ЗАХИСТУ УПРАВЛІННЯ РИЗИКАМИ ЛАНЦЮГА ПОСТАЧАННЯ ДО СУБПІДРІДНИКІВ (SR-3(3))

No: 1

Name: sr_3_3_01

Type: string

Default: "автоматизований засіб моніторингу"

Включені засоби контролю, передбачені в контрактах з основними підрядниками, також і в контрактах з субпідрядниками

18.4. СТРАТЕГІЇ ПРИДБАННЯ, ІНСТРУМЕНТИ І МЕТОДИ (SR-5)

Використовуйте наступні стратегії придбання, контрактні інструменти та методи закупівель, щоб захистити від ризиків ланцюга постачання, визначити та пом'якшити їх: [Призначення: визначені організацією стратегії придбання, контрактні інструменти та методи закупівель].

No: 1

Name: sr_5_01

Type: string

Default: nil

Застосовуються стратегії, інструменти та методи для захисту від ризиків ланцюга постачання

No: 2

Name: sr_5_02

Type: string

Default: nil

Застосовуються стратегії, інструменти та методи для виявлення ризиків ланцюга постачання

No: 3

Name: sr_5_03

Type: string

Default: nil

Застосовуються стратегії, інструменти та методи для зменшення ризиків ланцюга постачання

No: 4

Name: sr_5_odp

Type: string

Default: nil

Визначені стратегії закупівель, контрактні інструменти та методи закупівель для захисту, виявлення та пом'якшення ризиків ланцюга постачання

18.4.1. НАЛЕЖНЕ ПОСТАЧАННЯ (SR-5(1))

No: 1

Name: sr_5_1_01

Type: string

Default: "автоматизований засіб моніторингу"

Застосовуються засоби контролю для забезпечення адекватного постачання критично важливих компонентів системи

18.4.2. ОЦІНКА ПЕРЕД ВІДБОРОМ, ПРИЙНЯТТЯ, МОДИФІКАЦІЯ ЧИ ОНОВЛЕННЯ (SR-5(2))

No: 1

Name: sr_5_2_01

Type: string

Default: nil

Оцінюється система, компонент системи або послуги системи перед відбором

No: 2

Name: sr_5_2_02

Type: string

Default: nil

Оцінюється система, компонент системи або послуги системи перед прийняттям

No: 3

Name: sr_5_2_03

Type: string

Default: nil

Оцінюється система, компонент системи або послуги системи перед модифікацією

No: 4

Name: sr_5_2_04

Type: string

Default: nil

Оцінюється система, компонент системи або послуги системи перед оновленням

18.5. ОЦІНКА ПОСТАЧАЛЬНИКІВ (SR-6)

Оцініть і перегляньте ризики ланцюга постачання, пов'язані з постачальниками або підрядниками, системою, системним компонентом або системною послугою, яку вони надають [Призначення: частота, визначена організацією].

No: 1

Name: sr_6_01

Type: string

Default: "щорічно"

Оцінюються та аналізуються ризики, пов'язані з ланцюгом постачання, які стосуються постачальників або підрядників та систем, компонентів системи або системних послуг, які вони надають < SR-06_ODP частота >

No: 2

Name: sr_6_odp

Type: string

Default: "щорічно"

Визначена періодичність оцінки та аналізу ризиків, пов'язаних з ланцюгом постачання, що стосуються постачальників або підрядників, а також систем, компонентів системи або системних послуг, які вони надають

18.5.1. ТЕСТУВАННЯ ТА АНАЛІЗ (SR-6(1))

Немає параметрів для цього контролю.